MODULE 00 · EXAM STRATEGY - ALL DOMAINS

AWS Certified CloudOps Engineer

SOA-C03. Thirty-five modules, four practice exams, and every fact checked against a live source.

EXAM **SOA-C03** MODULES **35 + 4 exams** RUNTIME **About 9 hours**

admin@sthithapragna.com

A course built for this version of the exam, with every fact checked against a live AWS source rather than inherited from older material.

The exam, precisely

- **SOA-C03 is the AWS Certified CloudOps Engineer - Associate**, renamed from SysOps Administrator with this version. Both names describe this exam.
- **65 questions in 130 minutes.** 50 are scored and 15 are unscored and unmarked. Multiple choice and multiple response only.
- **There is no hands-on lab section.** Labs belonged to SOA-C02 and were suspended in March 2023.
- **150 US dollars.** Pass mark 720 on a 100 to 1000 scale, with **compensatory scoring**, so there is no minimum per domain.

> ON THE EXAM
>
> These figures are widely misreported. At least one prominent site states $300, 180 minutes and a lab section. All three are wrong.

The five domains

DOMAIN	WEIGHT
1. Monitoring, Logging, Analysis, Remediation and Performance Optimization	22%
2. Reliability and Business Continuity	22%
3. Deployment, Provisioning and Automation	22%
4. Security and Compliance	16%
5. Networking and Content Delivery	18%

ON THE EXAM

SOA-C02 had six domains. The old cost and performance optimisation domain was folded into Task 1.3, which is why performance modules sit in Domain 1 here.

The course map

MODULES	WHAT THEY COVER
01 to 11	Domain 1. CloudWatch, logs, CloudTrail, EventBridge, Systems Manager, performance
12 to 17	Domain 2. Auto Scaling, load balancing, Multi-AZ, scaling data, backup, DR
18 to 23	Domain 3. CloudFormation, CDK and Terraform, containers, deployment, event-driven
24 to 27	Domain 4. IAM, multi-account, encryption, compliance and detection
28 to 32	Domain 5. VPC, security groups, hybrid connectivity, Route 53, CloudFront
33 to 35	Cross-cutting. What changed, confusion pairs, exam mechanics
Practice exams 1 to 4	Twenty questions each, worked in full

ON THE EXAM

Module count per domain follows exam weight. Domain 1 has eleven modules and Domain 4 has four, in proportion to 22 and 16 per cent.

How every module is built

- **One core idea** up front. A single sentence that makes the rest of the module make sense, rather than a list of objectives.
- **Teaching slides** with an "on the exam" note on each, saying what the exam actually does with the fact.
- **Four to nine worked scenarios**, in the exam's own format, with every wrong option explained rather than just marked wrong.
- **Five things to carry forward** at the end. If you remember nothing else from a module, remember those.

> ON THE EXAM
>
> There are 172 worked scenarios across the course. Explaining why a wrong answer is wrong is where most of the learning happens.

How to use the scenarios

- Each scenario slide ends with **pause and decide**. Actually pause it. Reading the answer is worth a fraction of choosing one.
- The following slide works it, marking the correct option and explaining **why each wrong option is wrong**.
- Many wrong options **genuinely work**. They are wrong because they cost more, solve half the requirement, or are no longer AWS's recommendation.
- **Pay most attention to the ones you got right by luck.** Those are the ones that will not repeat on the day.

> ON THE EXAM
>
> The next two slides are a scenario, so you can see the format before the teaching starts.

> A team enables detailed monitoring on their EC2 instances to diagnose a memory leak. After an hour, CloudWatch still shows no memory metrics for the instances, and the team suspects a permissions problem.
>
> The instances are running and reporting CPU metrics normally.

What is the cause?

A. An IAM permissions problem preventing metric publication

B. Memory is not an EC2 metric. It requires the CloudWatch agent, because the hypervisor cannot see inside the guest

C. Detailed monitoring takes up to 24 hours to begin reporting

D. The instances need to be restarted after enabling detailed monitoring

◆ PAUSE AND DECIDE

What is the cause?

A **IAM permissions**

CPU metrics are arriving, which proves publication works. The team's own theory is stated so that you can test it and discard it.

B **Memory needs the agent**

EC2 metrics come from the hypervisor, which sees CPU, network and disk activity but cannot see inside the guest operating system. Memory and disk usage need the agent.

C **24-hour delay**

Invented behaviour. Detailed monitoring changes the interval from five minutes to one, and takes effect within minutes.

D **Restart required**

Detailed monitoring is a setting change with no restart. It also would not create a metric that does not exist.

THE SIGNAL

That is the format. Notice that the team's stated theory was wrong, and that one detail in the scenario - CPU metrics arriving - was there to eliminate it.

What you will be able to do

- **Read a failure and name the cause.** A 503 with a running application, a stair-step throttling graph, a connection that establishes then hangs.
- **Choose between services that look alike**, using the one property that separates them rather than recalling a feature list.
- **Recognise a dated recommendation**, including in your own team's runbooks, and know when AWS changed the answer.
- **Read an exam question properly**: find the qualifier, count the requirements, and spot the clause that eliminates three options.

> ON THE EXAM
>
> The first two are what the exam tests. The second two are what makes the difference between knowing the material and passing comfortably.

What is different about this course

- **Every fact checked against a live AWS source**, not inherited. The verification log runs to several hundred entries.
- **Currency is treated as content.** Module 33 lists what other material teaches wrongly, with the dates things changed.
- **Containers, CDK, Terraform and Git are covered**, because they are new scope in C03 and absent from C02-era material.
- **Wrong options are explained.** Knowing why an attractive answer fails is more durable than knowing which one is right.

> ON THE EXAM
>
> Where AWS has changed something recently, the module says so and gives the date, so you can judge how much to trust older material you meet.

What this course assumes

- You have **used AWS**: launched an instance, made a bucket, edited a security group. This is an associate-level exam, not an entry point.
- You are comfortable reading **JSON and YAML**. You will not be asked to write CloudFormation from scratch.
- You understand **basic networking**: IP addresses, subnets, ports, DNS. Module 28 builds on that rather than starting from it.
- You do **not** need to be a developer, a Kubernetes engineer, or to have passed any other AWS certification first.

> ON THE EXAM
>
> AWS suggests about a year of operational AWS experience. That is a guide rather than a requirement, and the scenarios assume you have seen things go wrong.

How to work through it

- **In order, at least the first time.** Later modules reference earlier ones deliberately, and the cross-references are part of the teaching.
- **One or two modules a sitting.** Each is around thirteen minutes, and the scenarios need attention rather than background listening.
- **Take the practice exams timed**, and only after finishing the teaching modules. They are diagnostic, not revision.
- **In the final week**, re-watch module 33 and drill module 34. Those two carry the highest value per minute at that stage.

> ON THE EXAM
>
> About nine hours of material. Spread over three weeks with the practice exams at the end is a realistic and comfortable schedule.

The four practice exams

- **Twenty questions each**, written in the exam's format and difficulty, and **worked in full** with every wrong option explained.
- They are **weighted by domain** in the same proportions as the real exam, so your score is a meaningful signal.
- **Take them after the teaching modules, under time.** Twenty questions in forty minutes matches the real pace.
- **They are diagnostic, not revision.** The value is in what they reveal you do not know, not in the score.

> ON THE EXAM
>
> Eighty questions across four exams, on top of 172 worked scenarios in the modules. That is more worked examples than most courses contain in total.

What this course does not do

- **It is not hands-on.** There are no click-through labs, and you should build things alongside it in your own account.
- **It does not cover every service AWS offers**, only what the exam guide names as in scope, plus what recent changes make necessary.
- **It is not a substitute for experience.** The scenarios are written to feel like real incidents because that is what the exam tests.
- **It is focused on passing.** Where a topic is fascinating and unexamined, it is left out deliberately.

> ON THE EXAM
>
> The AWS free tier is enough to build most of what this course describes. An hour in the console after a module is worth more than watching it twice.

A warning about names

- **Several services have been renamed recently**, and the exam guide still uses some older names while the console shows newer ones.
- For example: **RDS Performance Insights is now CloudWatch Database Insights**, and **Aurora Serverless v2 is now just Aurora serverless**.
- Each module flags the rename where it arises, and **module 33 lists all of them together** with dates.
- The rule throughout: **learn the capability, recognise both names**, and answer with the exam guide's terminology.

> ON THE EXAM
>
> This is the most disorienting thing you will meet. Opening the console and not finding a service you just learned about is confusing, and usually just a rename.

A note on dates

- Every fact in this course was verified against a live AWS source in **September 2026**, against **exam guide version 1.1** of 1 June 2026.
- **AWS will keep changing things.** Where a fact is recent or a service is being renamed, the module says so explicitly and gives the date.
- That means you can judge for yourself how much to trust anything older you meet, rather than having to take this course's word for it.
- If something here contradicts material you have seen elsewhere, **module 33 probably explains why**, with the date it changed.

> ON THE EXAM
>
> Dates are given throughout for the same reason. A fact with a date attached can be re-checked; a fact without one cannot.

You are ready to begin

- **Module 1 starts with CloudWatch metrics**, and specifically with why memory is not one of them.
- **Pause on every scenario.** That single habit is worth more than anything else in this introduction.
- **Build alongside it** where you can. Ten minutes in the console after a module beats watching it twice.
- **Trust the cross-references.** When a module says "as module 9 covered", that connection is usually examinable.

> ON THE EXAM
>
> About nine hours of material, 172 worked scenarios, and four practice exams. Good luck.

MODULE 01 · DOMAIN 1 - MONITORING, LOGGING, ANALYSIS, REMEDIATION, AND PERFORMANCE OPTIMIZATION

The CloudWatch Metric Model

Namespaces, dimensions, resolution and statistics. Get this wrong and every alarm you build is wrong quietly.

DOMAIN 1 of 5 EXAM WEIGHT 22% MODULE 1 of 35

admin@sthithapragna.com

A metric is not a name. It is a **coordinate**. Change any part of it and you have a different metric, not a different reading.

What identifies a metric

- **Namespace.** The container. AWS services use **AWS/EC2**, **AWS/RDS**, **AWS/Lambda**. Yours cannot start with AWS slash.
- **Metric name.** CPUUtilization, Duration, FreeStorageSpace.
- **Dimensions.** Up to **30** name and value pairs. They are part of the identity, not a filter applied afterwards.
- **Region.** Metrics never leave the Region they were published in.

> ON THE EXAM
>
> Namespace plus name plus the exact set of dimensions. All four must match or it is a different metric.

Why dimensions catch people out

- **You cannot aggregate across a dimension you invented.** If a service does not publish a rolled-up version, there is nothing to graph.
- Adding one dimension to an existing custom metric **starts a new series from zero**. The old history stays where it was.
- AWS services publish the **same metric at several dimension combinations** deliberately, so both views exist.
- High-cardinality dimensions such as request ID or customer ID **multiply your bill**, because each combination is a billable custom metric.

> ON THE EXAM
>
> Design dimensions for the questions you will ask. Retrofitting one splits your history in two.

EC2 metrics are collected from **outside** the instance. That is why there is no memory metric.

In the box by default, and not

MEASUREMENT	AVAILABLE WITHOUT AN AGENT?
CPUUtilization	Yes. Hypervisor-visible
NetworkIn / NetworkOut	Yes. Counted on the virtual NIC
EBS read and write ops	Yes. Counted at the volume
StatusCheckFailed	Yes. Instance, system and attached EBS checks
Memory used, available	NO. Needs the CloudWatch agent
Disk space used on a filesystem	NO. Needs the CloudWatch agent
Page file or swap usage	NO. Needs the CloudWatch agent

ON THE EXAM

If the question says memory or disk space, the answer involves the CloudWatch agent. Every time.

Basic or detailed monitoring?

BASIC - THE DEFAULT

Five-minute periods

- Free, on by default for EC2
- Data points every 300 seconds
- Fine for capacity trends and slow-moving alarms
- An alarm cannot react faster than the data arrives

DETAILED - OPT IN

One-minute periods

- Charged per instance per month
- Data points every 60 seconds
- Needed for responsive scaling and incident response
- Enable per instance, or in the launch template

THE TIEBREAKER

An alarm evaluating a 60-second period against a metric published every 300 seconds spends most of its life in INSUFFICIENT_DATA.

Two related traps

- **Auto Scaling group metrics are off by default** and are separate from instance metrics. GroupInServiceInstances and friends must be enabled.
- **ASG group metrics are always one-minute** and free. Detailed monitoring on the instances is a different setting.
- **Detailed monitoring is set in the launch template** for scaled instances. Setting it on one instance by hand does not survive a scale event.
- Metrics with no new data points for **two weeks stop appearing** in the console. The data is still there for the full retention.

> ON THE EXAM
>
> "The dashboard is empty for the auto scaling group" is almost always disabled group metrics, not a permissions problem.

Standard or high resolution?

STANDARD RESOLUTION

One-minute granularity

- Everything AWS publishes, always
- Alarm periods are multiples of 60 seconds
- The default for your custom metrics

HIGH RESOLUTION

One-second granularity

- Custom metrics only, StorageResolution set to 1
- Alarm periods of 10 or 30 seconds become available
- Retrievable at 1, 5, 10, 30 seconds or multiples of 60
- Costs more, and only survives 3 hours

THE TIEBREAKER

High resolution is a property of the data you publish. You cannot make an AWS service metric high resolution.

Retention, and what rollup actually does

PERIOD OF THE DATA POINT	HOW LONG YOU CAN RETRIEVE IT
Under 60 seconds (high resolution)	3 hours
60 seconds (1 minute)	15 days
300 seconds (5 minutes)	63 days
3600 seconds (1 hour)	455 days, about 15 months

ON THE EXAM

Nothing is deleted at 15 days. It is aggregated. Your data survives 15 months, just not at the resolution you wrote it.

Timestamps and the awkward edges

- A data point's timestamp can be **up to two weeks in the past and two hours in the future**. Outside that it is rejected.
- Backfilling a metric older than two weeks is **not possible**. This kills a lot of migration plans.
- Omit the timestamp and CloudWatch stamps it on receipt, which hides clock skew on the sender.
- CloudWatch aggregates to a floor of **one second** even if you send finer timestamps.

> ON THE EXAM
>
> "We want to import last quarter's metrics into CloudWatch" cannot be done. The two-week window is hard.

Statistics: the number you choose changes the answer

- **Average, Sum, Minimum, Maximum, SampleCount** are the basic five.
- **Percentiles** such as p90, p95, p99 need raw data points, so they do not work on pre-aggregated statistic sets.
- Percentiles are **unavailable if any value is negative**.
- **Trimmed mean** and trimmed count discard outliers at the ends, useful when a few extreme values distort the mean.

> ON THE EXAM
>
> The statistic is chosen at read time, not at write time. The same stored data answers all of them.

Average or percentile?

AVERAGE TELLS YOU

How the system is doing

- Good for capacity and cost
- Good for CPU-driven scaling
- Hides a slow minority completely
- One request in a hundred taking 30 seconds barely moves it

P99 TELLS YOU

How your worst users are doing

- Good for latency and user experience
- Good for SLA and SLO alarms
- Catches the tail the average buries
- Noisy on low-traffic metrics with few samples

THE TIEBREAKER

The average customer experience is nobody's experience. If a scenario mentions some users, complaints, or an SLA, it wants a percentile.

Querying metrics: three tools, three jobs

- **Metric math** combines existing metrics: rates, sums across resources, error percentages. Alarms can watch a math expression.
- **Search expressions** match metrics by pattern, so a dashboard picks up new instances **without being edited**.
- **Metrics Insights** is a SQL-like query over metrics, with GROUP BY and ORDER BY, for high-cardinality exploration.
- An alarm on a search expression **needs metric math to collapse it** to a single series first.

> ON THE EXAM
>
> "The dashboard must include instances added later" is a search expression. Nothing else does that.

Publishing your own: two doors

PUTMETRICDATA

An explicit API call

- Direct, synchronous, easy to reason about
- Every call is charged
- Adds latency to the code path
- Fine for a few metrics on a schedule

EMBEDDED METRIC FORMAT

Structured JSON in a log line

- Write a log line, CloudWatch extracts metrics from it
- No API call, no added latency
- Keeps the full log context beside the metric
- The recommended path from Lambda

THE TIEBREAKER

High volume, or inside a Lambda function, or you also want the log line: EMF. Otherwise PutMetricData is fine.

One pane of glass: cross-account observability

- One **monitoring account** creates a **sink**. Each **source account** creates a **link** to it.
- Shares **metrics, logs and traces**. Search, graph, run Logs Insights and alarm across accounts.
- **No extra charge** for logs and metrics. Works with Organizations for bulk onboarding.
- It is **within a Region**. For cross-Region use centralization rules or a cross-account metric stream.

> ON THE EXAM
>
> Sink in the monitoring account, link in each source account. Getting the direction backwards is a classic distractor.

Getting metrics out: metric streams

- **Metric streams** push metrics continuously to **Amazon Data Firehose**, in near real time.
- From Firehose to S3 for a data lake, or to a third-party tool such as a partner monitoring product.
- The alternative is polling **GetMetricData** on a schedule, which is slower and costs API calls.
- Streams can be filtered by namespace, and can be **cross-account** from a monitoring account.

> ON THE EXAM
>
> "Continuously export CloudWatch metrics to a third party or a data lake" is a metric stream, not a Lambda on a schedule.

A CloudOps engineer runs a fleet of Linux web servers in an Auto Scaling group, and the instances are replaced regularly. An alarm is needed whenever any instance has less than 10 percent free space on its /var partition.

The engineer opens the CloudWatch console, filters to the AWS/EC2 namespace, and cannot find a disk space metric for any instance.

What should the engineer do?

A Enable detailed monitoring on the Auto Scaling group's launch template

B Install and configure the CloudWatch agent through the launch template's user data, publishing disk_used_percent

C Enable Auto Scaling group metrics collection on the group

D Create a metric math expression deriving free space from EBS read and write operations

◆ PAUSE AND DECIDE

What should the engineer do?

A. Enable detailed monitoring

Changes how often existing metrics arrive, from five minutes to one. It cannot create a metric that does not exist.

B. CloudWatch agent via the launch template

Filesystem usage is only visible inside the guest, so an agent is the only source. Putting it in the launch template means replaced instances still report.

C. Enable group metrics

Gives you instance counts by lifecycle state for the group. Says nothing about anything inside an instance.

D. Metric math from EBS ops

Read and write operations count activity, not occupancy. A full volume and an empty one can produce identical numbers.

THE SIGNAL

Two clauses decide it: disk space means agent, and replaced regularly means the launch template rather than a one-off install.

> An application publishes a custom metric named CheckoutLatency in the namespace Shop, with a single dimension of Environment set to production. A dashboard has graphed it for a year.
>
> A release adds a second dimension, Region, to every published data point. The next morning the dashboard shows a line that stops at the release time, and the on-call engineer reports that the latency alarm has been in INSUFFICIENT_DATA since the deployment.

Why did this happen?

A. The new dimension exceeded the 30-dimension limit, so the publish calls are failing

B. Adding a dimension creates a new metric, and the old dimension combination is no longer receiving data

C. Custom metrics are retained for 15 days, and the historical data has aged out

D. The metric became high resolution, so it is only retained for three hours

◆ PAUSE AND DECIDE

Why did this happen?

A. Exceeded the 30-dimension limit

Two dimensions is nowhere near thirty. And a rejected publish would show as errors in the application, not a tidy line ending.

B. The dimension set changed the metric's identity

Namespace plus name plus the exact dimension set is the identity. Environment alone and environment plus region are two different metrics.

C. Retention aged the data out

Fifteen days applies to one-minute resolution and then rolls up rather than deleting. It also would not coincide with a release.

D. It became high resolution

High resolution is set by StorageResolution, not by dimensions, and it would not affect the old series at all.

THE SIGNAL

The alarm still watches Environment=production alone. That coordinate exists and is empty, which is what INSUFFICIENT_DATA means.

A payments API is meeting its published target of a 250 millisecond response time when measured as the average over one-minute periods. Support is nonetheless receiving daily complaints from a small number of merchants about requests that hang for many seconds before completing.

The team wants an alarm that fires on the behaviour the merchants are describing, using the existing latency metric.

What should the team configure?

A Change the alarm to the Maximum statistic over the same period

B Change the alarm to the p99 statistic and set a threshold against the tail

C Enable high resolution on the metric so slow requests are not averaged away

D Shorten the alarm period to 10 seconds so short spikes are visible

◆ PAUSE AND DECIDE

What should the team configure?

A Maximum statistic

The genuinely tempting one. It does surface slow requests, but a single outlier fires it, so it alarms constantly and gets muted.

B p99 statistic

Measures the experience of the worst one per cent as a population, so it tracks a real degradation and ignores a lone straggler.

C High resolution

Changes how often data points exist, not how they are summarised. Averaging one-second data still buries the tail.

D 10-second period

Also a frequency change, and it needs a high-resolution metric to be legal at all. The average is still an average.

THE SIGNAL

A small number of users complaining while the average looks fine is the textbook percentile signal. Resolution and statistic are different axes.

A company runs 40 accounts under AWS Organizations. The central operations team must graph metrics, search log groups and alarm on resources in every account from one place, without engineers switching roles to investigate.

The team also needs the same metrics delivered continuously into an existing third-party monitoring product that the company is contractually committed to for another two years.

Which combination should the team implement?

A. Cross-account observability with a sink in the operations account, plus a metric stream to Amazon Data Firehose

B. A scheduled Lambda function in each account calling GetMetricData and writing to a central S3 bucket

C. Cross-account observability with a sink in each source account, plus CloudWatch dashboards shared by URL

D. An organization CloudTrail trail, with the third party reading the trail's S3 bucket

◆ PAUSE AND DECIDE

Which combination should the team implement?

A Sink in operations, plus a metric stream

Correct direction for the sink, and a stream is the managed continuous export. Both halves of the requirement, no code.

B Scheduled Lambda per account

Forty functions to maintain, polling rather than streaming, and it delivers files to a bucket rather than a searchable console view.

C Sink in each source account

The direction is backwards. One sink lives in the monitoring account; sources create links. Shared URLs also do not give you cross-account alarms.

D Organization CloudTrail trail

CloudTrail records API calls, not metrics. It answers who did what, which is not what either requirement asked for.

THE SIGNAL

Two requirements, two mechanisms. "From one place" is cross-account observability; "continuously, to a third party" is a metric stream.

The five things to carry forward

- **A metric is a coordinate:** namespace, name, exact dimension set, Region. Change one and it is a different metric.
- **Memory and disk space need the agent.** The hypervisor cannot see inside the guest, and no setting changes that.
- **Resolution and statistic are different axes.** Frequency of data versus how it is summarised.
- **Retention rolls up, it does not delete.** 3 hours, 15 days, 63 days, 455 days.
- **Sink in the monitoring account, links in the sources.** Streams push out to Firehose.

> ON THE EXAM
>
> Next: alarms. Everything here is the input to them, which is why they are in this order.

MODULE 02 · DOMAIN 1 - MONITORING, LOGGING, ANALYSIS, REMEDIATION, AND PERFORMANCE OPTIMIZATION

Alarms That Work

States, evaluation windows, missing data, composite alarms and mute rules. Most broken alarms are broken in the same four ways.

DOMAIN 1 of 5 EXAM WEIGHT 22% MODULE 2 of 35

admin@sthithapragna.com

An alarm is not a threshold check. It is a **state machine voting over a window**, and the window is where the surprises live.

Three states, and what each one means

- **OK.** The metric is inside the threshold for the evaluated window.
- **ALARM.** The metric is outside the threshold for enough of the window.
- **INSUFFICIENT_DATA.** Not enough data points to decide. Not a failure, and not a success.
- You can set actions on **all three transitions**, including recovery back to OK.

> ON THE EXAM
>
> A new alarm always starts in INSUFFICIENT_DATA. So does an alarm whose metric has gone quiet, which are two very different situations.

How an alarm actually decides

01

Period

How long one data point covers. 60 seconds, 300 seconds, and so on.

02

Evaluation periods

How many of those periods CloudWatch looks at. The N.

03

Datapoints to alarm

How many of those N must breach. The M.

04

Missing data rule

What to do about periods with no data at all.

05

State

OK, ALARM or INSUFFICIENT_DATA, then actions on transition.

ON THE EXAM

M out of N is the whole design. 3 of 3 is slow and steady; 2 of 5 tolerates a flapping metric without ignoring it.

Why an alarm can be OK while the latest data point is breaching

- The alarm needs **M breaching points out of N**. One bad point out of three changes nothing, by design.
- To fill gaps, CloudWatch looks back over an **evaluation range wider than N**, pulling in older points.
- So a fresh breach can be **outvoted by older healthy data** that is still inside the range.
- Want it to react to the newest point? Use **1 datapoint out of 1** and accept the noise that comes with it.

> ON THE EXAM
>
> "The graph is clearly over the line but the alarm says OK" is almost always M out of N, not a bug.

The four missing-data treatments

SETTING	WHAT CLOUDWATCH DOES WITH AN EMPTY PERIOD
`missing (the default)`	Judge on the data points that do exist. If none exist at all, go to INSUFFICIENT_DATA
`notBreaching`	Treat it as good. Pushes the alarm toward OK
`breaching`	Treat it as bad. Pushes the alarm toward ALARM
`ignore`	Do not re-evaluate. The alarm holds whatever state it already had

ON THE EXAM

Alarms on metrics in the AWS/DynamoDB namespace default to ignore, not missing. That exception is examinable.

Treat missing as breaching, or not breaching?

NOTBREACHING WHEN

Silence is normal

- The metric only publishes when something happens
- Error counts, throttles, queue depth on a quiet queue
- You want no news to mean good news

BREACHING WHEN

Silence is the failure

- A heartbeat metric published by a job that must run
- An agent that should always be reporting
- The absence of data is the symptom you care about

THE TIEBREAKER

Ask what silence means for this metric. If a stopped process stops publishing, silence is the outage and breaching is correct.

What an alarm can do when it fires

ACTION	NOTES THAT DECIDE QUESTIONS
Notify an SNS topic	The default. Fan out to email, chat, a pager, a queue, or Lambda
Invoke a Lambda function	Supported directly, no SNS topic in the middle
EC2 action	Stop, terminate, reboot or recover. Only on alarms watching EC2 metrics
Auto Scaling action	Runs a step or simple scaling policy on the group
Systems Manager	Create an OpsItem in OpsCenter, the recommended path. ALARM state only
EventBridge event	Every state change emits an event. This is the general-purpose hook

ON THE EXAM

Except for Auto Scaling actions, actions fire on the TRANSITION only. An alarm stuck in ALARM for two days notifies once.

EC2 status checks and the recover action

- **StatusCheckFailed_System** means the underlying host or its network is broken. **Recover** is the right response.
- **StatusCheckFailed_Instance** means the guest is broken. Reboot or replace it. Recovery will not help.
- Recover migrates to new hardware and **keeps the instance ID, private IP, Elastic IP and metadata**.
- **Instance store data is lost.** The instance is restarted on different hardware, not moved.

> ON THE EXAM
>
> System check means AWS's problem, recover. Instance check means your problem, reboot. Picking the wrong one is a favourite distractor.

Static threshold or anomaly detection?

STATIC THRESHOLD WHEN

You know the number

- An SLA, a quota, a disk that must not fill
- Behaviour is flat, or you genuinely have a limit
- Cheap, obvious, easy to explain in a review

ANOMALY DETECTION WHEN

Normal is a shape, not a number

- Traffic with daily and weekly cycles
- A fixed threshold would be wrong at 3am or wrong at noon
- Builds a band from up to two weeks of history

THE TIEBREAKER

If the scenario says the threshold is right on weekdays and wrong at weekends, it is describing seasonality. That is an anomaly detection band.

Composite alarms: one incident, one page

- A composite alarm has **no metric**. Its state comes from a rule over other alarms.
- Rule syntax uses **ALARM(name)**, **OK(name)**, **INSUFFICIENT_DATA(name)** with AND, OR and NOT.
- Put notifications on the composite and **remove them from the children**. Twenty alarms, one page.
- Composites can notify SNS and raise OpsItems or incidents. They **cannot do EC2 or Auto Scaling actions**.

> ON THE EXAM
>
> "One failure generates forty emails" is the composite alarm signal. Silence the children, alert on the parent.

Suppressing noise: two different tools

ACTIONS SUPPRESSOR

Driven by another alarm's state

- Set on a composite alarm
- While the suppressor is in ALARM, actions are held
- WaitPeriod and ExtensionPeriod cover lag
- For: network down, do not page about the app

ALARM MUTE RULES

Driven by the calendar

- Announced February 2026. One-time or recurring
- cron or at expressions, plus a duration and timezone
- Up to 100 alarms per rule
- For deployments, maintenance windows, off-hours

THE TIEBREAKER

Is the reason for the silence a condition, or a schedule? Condition means suppressor. Schedule means mute rule.

Mute rules: three details worth knowing

- **Alarms keep evaluating** and keep changing state. Only the actions are muted, so history stays intact.
- When a rule expires, **previously muted actions fire** if the alarm is still in the same state.
- Replaces the old workaround: a scheduled Lambda disabling and re-enabling alarm actions.
- Creating one needs **PutAlarmMuteRule on the rule and on every targeted alarm**.

> ON THE EXAM
>
> The old pattern left alarms disabled when the re-enable script failed. Mute rules expire on their own, which is the real argument for them.

Alarms on things that are not a plain metric

- **Metric math.** Alarm on an error percentage rather than on a raw error count. Far fewer false alarms at low traffic.
- **High-resolution alarms.** Periods of 10 or 30 seconds, only on high-resolution custom metrics.
- **Search expressions** must be collapsed with metric math first, because an alarm needs a single series.
- Cross-account alarms work, but **not ANOMALY_DETECTION_BAND, INSIGHT_RULE or SERVICE_QUOTA**, and not cross-account composites.

> ON THE EXAM
>
> Ten errors out of ten requests is an outage. Ten out of a million is Tuesday. Alarm on the ratio, not the count.

Six things an alarm can watch

DATA SOURCE	WHEN IT IS THE RIGHT CHOICE
A single metric	The default. One resource, one number
A metric math expression	Ratios, sums across a fleet, anomaly detection bands
A Metrics Insights query	A whole fleet at once, adjusting as resources come and go
A log group metric filter	A pattern in logs that you also want to graph
A Logs Insights query (log alarm)	A pattern in logs, with NO metric filter to maintain
A PromQL instant query	OpenTelemetry metrics sent to the CloudWatch OTLP endpoint

ON THE EXAM

A log alarm removes a whole step. You no longer need a metric filter just to alarm on something in a log.

One alarm for a whole fleet

- Alarm on a Metrics Insights query with **GROUP BY**, and each returned series becomes a **contributor**.
- The query re-runs at every evaluation, so the alarm **adapts as resources appear and disappear**. No alarm to create, none to clean up.
- Notifications name the breaching contributor, and **EC2 actions run at contributor level**, on the instance that actually breached.
- Limits: **100 contributors in ALARM**, only the last **3 hours** of data, 200 such alarms per account per Region by default.

> ON THE EXAM
>
> "Alarms must cover instances that do not exist yet, without a script" is a Metrics Insights alarm. A per-instance alarm cannot do it.

The INSUFFICIENT_DATA checklist

- **Is the period shorter than the publishing interval?** A 60-second period on basic monitoring data is the classic.
- **Did the dimension set change?** The alarm watches an exact coordinate. Module one covered this.
- **Does the metric only publish when something happens?** Then this is normal, and missing-data treatment is the fix.
- **Is the resource gone?** A terminated instance stops publishing, and its alarms sit there for ever.

> ON THE EXAM
>
> Work down the list in order. Three of the four are configuration, and only the last is a real incident.

> A nightly batch job publishes a custom metric called JobHeartbeat, with a value of 1, once at the end of each successful run. An alarm watches it with a period of one hour, one evaluation period, and a threshold of less than 1.
>
> The job failed to start for three consecutive nights. Nobody was notified. The alarm has been in INSUFFICIENT_DATA throughout, and the operations lead wants to know why it did not fire.

What change makes this alarm detect the failure?

A Set the missing data treatment to breaching

B Set the missing data treatment to notBreaching

C Increase evaluation periods to 3 so three nights are considered

D Add an INSUFFICIENT_DATA action pointing at the SNS topic

◆ PAUSE AND DECIDE

What change makes this alarm detect the failure?

A Missing data as breaching

Silence is the failure here. A job that does not run publishes nothing, so an empty period must count as bad.

B Missing data as notBreaching

Exactly backwards. It would guarantee the alarm never fires, because the failure mode produces no data at all.

C Three evaluation periods

Changes how many periods vote. It does not change the fact that every one of those periods is empty and cannot vote.

D INSUFFICIENT_DATA action

The genuinely tempting one. It would notify, but it also notifies for every hour of the twenty-three when no run is expected.

THE SIGNAL

The metric only exists on success, so absence is the signal. That is the definition of the breaching treatment.

> An RDS database instance fails. Within two minutes, 26 CloudWatch alarms move into ALARM: connection counts on six application services, latency on four load balancers, queue depth on three queues, and error rates across the rest.
>
> Every alarm notifies the same SNS topic, which pages the on-call engineer. The team wants one page per incident, while keeping every alarm's history for post-incident review.

What should the team implement?

A Delete the child alarms and keep only the database alarm

B Create a composite alarm over the children, move the SNS action to it, and remove the actions from the children

C Create an alarm mute rule covering the 26 alarms

D Raise the datapoints to alarm on every child so they take longer to fire

◆ PAUSE AND DECIDE

What should the team implement?

A Delete the child alarms

Solves the paging by destroying the evidence. The requirement explicitly asks to keep the history for review.

B Composite alarm, actions moved to the parent

Children keep evaluating and keep their history; only the composite pages. One incident, one notification.

C Alarm mute rule

Mute rules are scheduled. A database failure is not on the calendar, so there is no window to define.

D Raise datapoints to alarm

Delays twenty six pages rather than preventing them. It also slows genuine detection, making the system worse.

THE SIGNAL

Two requirements: one page, and keep the history. Only the composite pattern satisfies both, because muting actions is not the same as deleting alarms.

A retail platform alarms on request latency. The threshold is a static 400 milliseconds, with a five-minute period and three datapoints out of three. It pages reliably during the weekday morning peak, when latency naturally rises, and the team has learned to dismiss those pages.

During a quiet Sunday night, latency doubled from its usual 80 milliseconds to 160 milliseconds because of a failing cache node. The alarm never fired.

What should the team change?

A Lower the static threshold to 150 milliseconds

B Replace the static threshold with a CloudWatch anomaly detection band

C Change datapoints to alarm from 3 of 3 to 1 of 1

D Shorten the period from five minutes to one minute

◆ PAUSE AND DECIDE

What should the team change?

A. Lower the threshold to 150ms

Catches Sunday and turns the weekday peak into a permanent alarm. It moves the noise, it does not remove it.

B. Anomaly detection band

Learns the daily and weekly shape, so 160ms is anomalous on a Sunday night and unremarkable at 9am on a Tuesday.

C. 1 of 1 datapoints

Makes it more sensitive to spikes at any hour, which worsens the weekday false alarms and still misses 160ms overall.

D. One-minute period

A frequency change. The threshold is still a single number, so it is still wrong at one end of the day or the other.

THE SIGNAL

The same value is fine at 9am and alarming at 2am. One number cannot express that. Seasonality is the anomaly detection signal.

> An EC2 instance running a licensed legacy application cannot be replaced automatically, because its licence is bound to the instance ID and its private IP address is hard-coded in three partner firewalls.
>
> Twice this year the instance became unreachable. Both times the EC2 system status check failed while the instance status check stayed healthy, and an engineer manually stopped and started the instance to fix it.

What should the engineer configure?

A. An alarm on StatusCheckFailed_Instance with the reboot action

B. An alarm on StatusCheckFailed_System with the recover action

C. Put the instance in an Auto Scaling group of one, so a failed health check replaces it

D. An alarm on StatusCheckFailed_System with the terminate action

◆ PAUSE AND DECIDE

What should the engineer configure?

A Instance check, reboot

Watches the wrong check. The instance check was healthy both times, so this alarm would never have fired.

B System check, recover

System check failure means the host is broken. Recovery migrates to new hardware and keeps the instance ID and the private IP, which the constraints demand.

C Auto Scaling group of one

The architecturally fashionable answer, and it breaks both stated constraints. A replacement gets a new instance ID and a new private IP.

D System check, terminate

Right check, catastrophic action. It destroys the licensed instance rather than moving it.

THE SIGNAL

Two constraints in the first paragraph name the answer: keep the instance ID and keep the private IP. Recovery preserves both; replacement preserves neither.

The five things to carry forward

- **M out of N, over a window.** Not a tripwire. That explains most "why did it not fire" questions.
- **Ask what silence means.** Errors go notBreaching; heartbeats go breaching. DynamoDB defaults to ignore.
- **Actions fire on the transition**, not repeatedly. Auto Scaling actions are the exception.
- **System check means recover; instance check means reboot.** Recovery keeps the ID and the private IP.
- **Condition-based silence is a composite suppressor. Schedule-based silence is a mute rule.**

> ON THE EXAM
>
> Next: CloudWatch Logs and the unified agent, which is where the metrics you cannot get any other way come from.

MODULE 03 · DOMAIN 1 - MONITORING, LOGGING, ANALYSIS, REMEDIATION, AND PERFORMANCE OPTIMIZATION

CloudWatch Logs and the Unified Agent

Getting logs off EC2, ECS and EKS, and keeping the bill under control once they arrive.

DOMAIN 1 of 5 EXAM WEIGHT 22% MODULE 3 of 35

admin@sthithapragna.com

The agent configuration is a **deployment artefact**, not a file on a server. Treat it as a file and it drifts within a week.

The log data model

- **Log event.** One record with a timestamp. **Log stream.** A sequence from one source, usually one instance or container.
- **Log group.** The unit of everything that matters: retention, encryption, access, metric filters, subscriptions, log class.
- **Retention defaults to Never expire.** Nobody chooses this. It is what you get by not choosing.
- Up to **1,000,000 log groups** per Region per account, so the limit is your bill, not the service.

> ON THE EXAM
>
> Every setting you care about lives on the log group, not the stream. Streams are just where the lines land.

Retention, and the bill

SETTING	WHAT IT MEANS IN PRACTICE
`Never expire (the default)`	You pay storage on every line, for ever
`1 to 3653 days`	Fixed steps only: 1, 3, 5, 7, 14, 30, 60, 90 … up to 10 years
`Set on the log group`	Applies to every stream in it. Expired events are deleted automatically
`Ingestion vs storage`	Two separate charges. Retention only reduces the second one
`Export to S3`	For cheap long-term retention. S3 lifecycle rules then apply

ON THE EXAM

Retention is a fixed list, not any number you like. "Set retention to 45 days" is not a valid option, and the exam knows it.

What the unified agent actually is

- **One binary that does both jobs:** system metrics and log files. It replaced the old separate awslogs agent and collectd setup.
- Collects **memory, disk, swap, processes** - everything module one said the hypervisor cannot see.
- Runs on **EC2, on-premises servers and other clouds**. The same agent, with a different mode flag.
- Also accepts **StatsD and collectd** custom metrics, and OTLP metrics and traces.

> ON THE EXAM
>
> "Unified" means metrics and logs in one agent. If a scenario mentions two agents, it is describing something that was retired.

Deploying it so it stays deployed

01

Install

SSM Distributor, or bake it into the AMI.

02

Attach a role

CloudWatchAgentServerPolicy on the instance profile.

03

Store the config

Put the JSON in SSM Parameter Store, once.

04

Push it

Run Command to apply now, State Manager to keep it applied.

05

Verify

Check the log group appears and the agent's own log for errors.

ON THE EXAM

The config lives in Parameter Store and the agent fetches it with an ssm: prefix. That is the whole pattern, and the exam expects it.

Run Command or State Manager?

RUN COMMAND WHEN

Do it once, now

- A one-off change across a fleet
- You want the result immediately
- Applies to instances running at that moment
- Nothing re-applies it afterwards

STATE MANAGER WHEN

Keep it true

- A configuration that must not drift
- New instances get it automatically
- Re-applies on a schedule you set
- Someone editing the box by hand gets corrected

THE TIEBREAKER

"Instances launched later must also be configured" or "the setting keeps getting changed" both mean State Manager.

The agent is installed but nothing appears

- **Is there an instance profile** with CloudWatchAgentServerPolicy? The most common cause by a distance.
- **Can it reach the endpoints?** A private subnet with no NAT and no VPC endpoints for logs and monitoring will fail silently.
- **Is the config actually applied?** Installed is not configured. The agent starts with nothing to collect.
- **Read the agent's own log.** /opt/aws/amazon-cloudwatch-agent/logs on Linux. It says exactly what is wrong.

> ON THE EXAM
>
> All four failures look identical from the console: an empty log group, or no log group at all. Work the list in order.

Standard or Infrequent Access log class?

STANDARD WHEN

The logs do work

- Metric filters, subscription filters
- Live Tail, log anomaly detection
- Real-time alerting off log content
- Higher ingestion price per GB

INFREQUENT ACCESS WHEN

The logs are evidence

- Forensics, audit, occasional investigation
- Lower ingestion price per GB
- Logs Insights, export to S3, encryption
- March 2026: masking, OpenSearch PPL and SQL

THE TIEBREAKER

Only ingestion price differs. Storage and Logs Insights query charges are identical in both classes.

Log class rules worth memorising

- **The class cannot be changed after the log group is created.** Wrong choice means a new log group.
- Infrequent Access has **no metric filters, no subscription filters, no Live Tail, no anomaly detection**.
- It **does** have Logs Insights, export to S3, encryption and cross-account analytics.
- **Updated March 2026:** Infrequent Access gained **data protection masking** plus OpenSearch PPL and SQL queries.

> ON THE EXAM
>
> If a scenario needs an alarm on something in the log, the group must be Standard. Metric filters and subscription filters are the deciding capabilities.

ECS: awslogs driver or FireLens?

AWSLOGS DRIVER

Straight to CloudWatch Logs

- Set in the task definition's logConfiguration
- Simple, no extra container to run
- One destination: CloudWatch Logs
- The default answer for ECS container logs

FIRELENS

A log router as a sidecar

- Runs Fluent Bit or Fluentd beside your container
- Filter, parse and enrich before sending
- Fan out to several destinations at once
- Needed for third-party destinations or splitting streams

THE TIEBREAKER

One destination and no processing means awslogs. Several destinations, or filtering before it is charged for, means FireLens.

EKS: one add-on does most of it

- The **Amazon CloudWatch Observability EKS add-on** deploys the **CloudWatch agent as a DaemonSet** and **Fluent Bit** for container logs.
- Agent handles metrics and Container Insights. **Fluent Bit handles the log lines.** Two components, two jobs.
- Permissions come from **EKS Pod Identity** or IRSA, not from the node's instance profile.
- Windows nodes need add-on **version 1.5.0 or later**, and Application Signals is not supported on Windows there.

> ON THE EXAM
>
> DaemonSet means one agent per node. That is how you get node-level metrics that a per-pod sidecar could never see.

Where the logs come from, by compute type

COMPUTE	HOW LOG LINES REACH CLOUDWATCH LOGS
EC2	CloudWatch agent tailing files you name in its config
ECS on EC2	awslogs log driver, or FireLens sidecar
ECS on Fargate	Same: awslogs or FireLens. No host to install anything on
EKS	Fluent Bit, deployed by the Observability add-on
Lambda	Automatic. Nothing to install; stdout goes to a log group
VPC, ELB, Route 53 etc	Vended logs. Enable the feature; no agent involved

ON THE EXAM

On Fargate there is no host, so any answer involving installing an agent on the instance is wrong by construction.

Sensitive data: masking at ingest

- A **data protection policy** on the log group detects and masks sensitive fields as events arrive.
- Uses **managed data identifiers** for PII, PHI and financial data, so you do not write the patterns yourself.
- **It applies at ingest only.** Events already in the log group are not masked retroactively.
- Auditors can be granted **Unmask** permission separately, so the data is hidden rather than destroyed.

> ON THE EXAM
>
> "Card numbers appeared in the logs last month" cannot be fixed by a policy. The policy protects tomorrow, not yesterday.

Access, encryption and other accounts

- Log groups are encrypted at rest by default. Associate a **KMS customer managed key** when you need to control the key.
- The **key policy must allow the CloudWatch Logs service principal**, or association fails and ingestion stops.
- **Cross-account observability** from module one covers logs too: search and query other accounts' log groups from the monitoring account.
- A **resource policy** on the log group is what lets another service put events into it. One policy per log group.

> ON THE EXAM
>
> A KMS-related logging outage is almost always the key policy, not the IAM policy of whoever is writing.

Two features worth knowing by name

- **Live Tail.** A streaming view of log events as they arrive, with filtering. For watching a deployment, not for investigating history.
- **Log anomaly detection.** Learns the normal pattern of a log group and surfaces new or unusual message types.
- **Neither works on Infrequent Access log groups.** Both are Standard-class features.
- Anomaly detection catches **a new stack trace nobody wrote a filter for**, which is the whole point.

> ON THE EXAM
>
> Metric filters find what you predicted. Log anomaly detection finds what you did not.

Making logs cheaper and faster to query

- **Field indexes.** Index high-cardinality fields such as request ID or user ID. Logs Insights then skips events that cannot match.
- Lower query cost and faster results. Currently **one field index policy per log group**.
- **Transformers** parse and restructure log events **at ingest**, so downstream filters and queries work on real fields.
- Transformers can be set **account-wide**, and a log-group-level transformer overrides the account one. No extra charge on Standard ingestion.

> ON THE EXAM
>
> Transform once at ingest instead of parsing in every query. The parsing was going to happen either way; this way you pay for it once.

> A company runs 300 EC2 instances across six Auto Scaling groups. An engineer installed and configured the CloudWatch agent on each instance by hand over two weeks, using the configuration wizard.
>
> Three months later, memory metrics are missing from about 40 percent of instances, several instances report a different set of log files from the rest, and the newest instances report nothing at all.

What should the company implement?

A. Store one agent configuration in SSM Parameter Store and apply it with a State Manager association

B. Use Run Command to reapply the wizard-generated configuration to all 300 instances

C. Enable detailed monitoring on all six Auto Scaling groups

D. Write a Lambda function on an EventBridge schedule that SSHes to each instance and checks the agent

◆ PAUSE AND DECIDE

What should the company implement?

A Parameter Store plus State Manager

One configuration, re-applied on a schedule, and automatically applied to instances that launch later. Fixes drift and new instances together.

B Run Command to reapply

The best wrong answer. It fixes today's 300 instances and does nothing for tomorrow's, so the drift returns immediately.

C Detailed monitoring

Changes how often existing metrics publish. Memory is not an EC2 metric at all, so there is nothing to publish more often.

D Lambda that connects to each instance

Rebuilds State Manager badly, with SSH keys, network paths and 300 connections to maintain. Maximum operational overhead.

THE SIGNAL

Two symptoms, two requirements: drift on existing instances, and nothing at all on new ones. Only a desired-state mechanism fixes both.

A security team enables a data protection policy with the credit card managed data identifier on a payments application's log group. They confirm new log events show masked card numbers.

An auditor then reports that log events from the previous six weeks still contain full card numbers in plain text, and asks the team to explain why the control did not work.

What is the correct explanation and remedy?

A The policy needs the Unmask permission removed before it takes effect

B Masking applies at ingestion only; historical events must be deleted, and shortening retention or recreating the log group is the remedy

C The log group is in the Infrequent Access class, which does not support data protection

D A second data protection policy must be applied at the account level to cover historical data

◆ PAUSE AND DECIDE

What is the correct explanation and remedy?

A. Remove Unmask permission

Unmask controls who can view masked values. It has nothing to do with whether older events were ever masked.

B. Masking is at ingest; delete the history

Documented behaviour: events ingested before the policy existed are not masked. Only removing them clears the exposure.

C. Infrequent Access does not support it

Was true until March 2026. Infrequent Access now supports data protection, and the masking on new events proves the class is not the issue.

D. An account-level policy for history

Account-level policies exist and are useful, but they also apply at ingestion. Scope is not the same as time.

THE SIGNAL

The control worked exactly as designed. It protects everything ingested after it was created, and nothing before.

A CloudOps engineer moves an application's log group to the Infrequent Access log class to reduce ingestion cost. The application runs on ECS Fargate and uses the awslogs driver.

After the change, a metric filter that counted OutOfMemoryError occurrences stops producing data points, and the alarm built on it moves to INSUFFICIENT_DATA. Queries in Logs Insights still work normally.

Why did this happen, and what is the fix?

A Fargate does not support metric filters; move the workload to ECS on EC2

B Infrequent Access does not support metric filters. Create a new Standard log group and point the task definition at it

C Change the log group's class back to Standard in the console

D The alarm needs its missing data treatment set to breaching

◆ PAUSE AND DECIDE

Why did this happen, and what is the fix?

A. Fargate does not support metric filters

Invented limitation. Metric filters are a property of the log group and do not care what wrote to it.

B. New Standard log group, repoint the task

Metric filters are Standard-only, and the class cannot be changed after creation. A new log group is the only route.

C. Change the class back

The genuinely tempting one, and the trap. Log class is fixed at creation; there is no console option to change it.

D. Missing data as breaching

Would make the alarm fire constantly while the underlying metric no longer exists. It hides the fault rather than fixing it.

THE SIGNAL

Logs Insights still working is the clue that narrows it. Infrequent Access kept querying and lost metric filters, which is exactly the observed behaviour.

> A team runs microservices on Amazon EKS. They need node-level and pod-level metrics in Container Insights, container log lines in CloudWatch Logs, and they must not attach broad CloudWatch permissions to the node instance profile, because every pod on a node would inherit them.
>
> The cluster runs Linux nodes only. The team wants the least operational overhead.

What should the team deploy?

A. The Amazon CloudWatch Observability EKS add-on, with permissions granted through EKS Pod Identity

B. The CloudWatch agent as a sidecar container in every pod, using the node instance profile

C. The awslogs log driver on each pod specification, plus detailed monitoring on the nodes

D. A FireLens sidecar in every pod, with CloudWatchAgentServerPolicy on the node role

◆ PAUSE AND DECIDE

What should the team deploy?

A Observability add-on with Pod Identity

One managed add-on gives the agent DaemonSet and Fluent Bit. Pod Identity scopes permissions to the service account, not the node.

B Agent sidecar per pod, node profile

A sidecar in every pod cannot see node-level metrics, and it uses exactly the node-wide permissions the team ruled out.

C awslogs driver on pods

awslogs is an ECS task definition setting. It is not how Kubernetes pods ship logs, and it produces no Container Insights metrics.

D FireLens sidecar, node role policy

FireLens is ECS terminology, it moves only logs and no metrics, and it still puts the permissions on the node role.

THE SIGNAL

The permissions clause is the discriminator. Every option except A grants CloudWatch access to the whole node, which the scenario explicitly forbids.

The five things to carry forward

- **Config in Parameter Store, pushed by State Manager.** Run Command fixes today; State Manager keeps it true.
- **Retention defaults to never expire**, and the allowed values are a fixed list. Ingestion and storage bill separately.
- **Log class is fixed at creation.** Infrequent Access loses metric filters, subscription filters, Live Tail and anomaly detection.
- **ECS is awslogs or FireLens. EKS is the Observability add-on:** agent DaemonSet for metrics, Fluent Bit for logs.
- **Masking applies at ingest only.** It protects tomorrow, never yesterday.

> ON THE EXAM
>
> Next: reading logs at scale - metric filters, subscription filters and Logs Insights. This module got the logs in; that one gets answers out.

MODULE 04 · DOMAIN 1 - MONITORING, LOGGING, ANALYSIS, REMEDIATION, AND PERFORMANCE OPTIMIZATION

Reading Logs at Scale

Metric filters, subscription filters and Logs Insights. Three routes out of a log group, and the exam tests which one you pick.

DOMAIN 1 of 5 EXAM WEIGHT 22% MODULE 4 of 35

admin@sthithapragna.com

Ask what the log is **for**. Alarm on it, ship it somewhere, or interrogate it. Three questions, three mechanisms.

The three routes out of a log group

MECHANISM	WHAT IT GIVES YOU
Metric filter	A CloudWatch metric. Alarm on it, graph it, use it in metric math
Subscription filter	The events themselves, streamed in near real time, to another service
Logs Insights	Interactive queries. Answers, not automation
Export to S3	A batch copy for archive or Athena. Not real time
Live Tail	A streaming view for a human, right now. Nothing is stored

ON THE EXAM

Metric filters and subscription filters both need the Standard log class. Infrequent Access has neither.

Metric filters: text becomes a number

- A **pattern** plus a **metric transformation**: which metric to publish, what value, and what dimensions.
- Value can be a **literal 1** to count occurrences, or a **field from the log event** such as a duration or a byte count.
- **Not retroactive.** A filter created today never sees yesterday's events, no matter how long they are retained.
- **100 metric filters per log group**, and that limit cannot be raised.

> ON THE EXAM
>
> Filters run at ingestion, exactly like data protection policies. Anything already in the log group is out of reach.

The pattern syntax, in three shapes

- **Plain terms.** **ERROR** matches events containing it. **"ERROR" "Timeout"** requires both. **?ERROR ? WARN** matches either.
- **Exclusion** with a minus: **ERROR -Timeout** matches errors that are not timeouts.
- **JSON** events use dollar-dot notation: **{ $.statusCode = 500 }**. Numeric and string comparisons both work.
- **Space-delimited** events use bracket notation with positional names: **[ip, user, ..., status=404]**.

> ON THE EXAM
>
> Structured logs make filters simple. If you control the application, log JSON and the pattern becomes a field comparison.

The default value trap

- With **no default value set**, a period with no matching events publishes **nothing at all**.
- The alarm then sees missing data and goes to **INSUFFICIENT_DATA**, not OK. Everything is fine and the alarm looks broken.
- Set **default value 0** and the filter publishes a zero for quiet periods, so the alarm sits properly in OK.
- Or leave it unset and set the alarm's missing-data treatment to **notBreaching**. Either works. Doing neither is the bug.

> ON THE EXAM
>
> This is module two's missing-data lesson with a specific cause. "Our error alarm is always in INSUFFICIENT_DATA" is this, almost every time.

Metric filter or Logs Insights?

METRIC FILTER WHEN

You know what to look for

- You want an alarm, so you need a metric
- The pattern is known in advance
- Costs nothing extra at query time
- Only sees events after you created it

LOGS INSIGHTS WHEN

You are working it out

- Investigating, not automating
- Ad hoc questions you did not predict
- Can query the full retained history
- Charged per byte scanned, per query

THE TIEBREAKER

Filters look forward, queries look backward. That single sentence answers most questions in this area.

Subscription filters: events on the move

- Streams matching events in **near real time** to **Lambda**, **Kinesis Data Streams**, **Amazon Data Firehose** or **OpenSearch Service**.
- **Lambda** for custom processing and routing. **Firehose** for managed delivery to S3, OpenSearch or Redshift.
- **Kinesis Data Streams** when several independent consumers need the same events.
- The same filter pattern syntax applies, so you can stream only what matters instead of everything.

> ON THE EXAM
>
> Firehose buffers, so expect delivery in minutes. Lambda is the low-latency option when seconds matter.

Two limits that shape designs

- **Two subscription filters per log group.** Firm, and it cannot be raised.
- Need more destinations? **Fan out through Kinesis Data Streams** and attach consumers to that instead.
- Cross-account streaming uses a **destination** in the receiving account, with an access policy naming the sending accounts.
- The sending side needs an **IAM role CloudWatch Logs can assume** to write to the destination.

> ON THE EXAM
>
> "We already stream to a SIEM and now the security team wants a copy too" is a two-filter problem. The third destination goes behind Kinesis.

Subscription filter or export to S3?

SUBSCRIPTION FILTER WHEN

Continuous and current

- Near real time, event by event
- Feeds a SIEM, an index, or a processing pipeline
- Filter pattern selects what leaves
- Always running once configured

EXPORT TO S3 WHEN

A bulk copy, on request

- CreateExportTask, a batch job over a time range
- Can take up to 12 hours to finish
- For archive, Athena, or handing data to someone
- One export task at a time per account

THE TIEBREAKER

"Continuously", "as they occur" or "near real time" means subscription filter. "Archive" or "analyse in Athena" means export.

From a log line to a page

01
Event arrives
An application writes a line to the log group.

02
Transformer
Optional. Parses it into real fields at ingest.

03
Metric filter
Pattern matches, publishes a metric data point.

04
Alarm
M out of N over the metric, missing data handled.

05
SNS or action
Notify, invoke Lambda, raise an OpsItem.

ON THE EXAM

Five links, and a break in any one produces the same symptom: nobody was told. Troubleshoot along the chain, not at the ends.

Logs Insights: the commands you actually use

- **fields** chooses columns, **filter** narrows rows, **sort** and **limit** finish the job.
- **stats** aggregates: **stats count(*) by bin(5m)** is the single most useful query shape there is.
- **parse** pulls fields out of unstructured text. **dedup** collapses repeats.
- **JOIN and sub-query** arrived in April 2026, so correlating two log groups no longer needs OpenSearch SQL.

> ON THE EXAM
>
> stats … by bin() turns a wall of text into a shape over time. Learn that one query and half of incident triage gets faster.

Three query languages, one console

LANGUAGE	REACH FOR IT WHEN
Logs Insights QL	The default. Fewest commands, works with existing saved queries and dashboards
OpenSearch PPL	Pipe-and-search style. Familiar if the team already uses OpenSearch
OpenSearch SQL	Your team already writes SQL, or you are porting existing OpenSearch queries

ON THE EXAM

Since April 2026 Logs Insights QL has JOIN and sub-query too, so the languages differ mainly by familiarity rather than capability.

Current quotas, and the ones everyone still quotes

LIMIT	CURRENT VALUE
Concurrent Logs Insights QL queries	100 per account. Was 30 until March 2026
Concurrent OpenSearch SQL or PPL queries	15 per account
Log groups in one query	50 by name, or up to 10,000 via SOURCE with a prefix
Query timeout	60 minutes. The old 15-minute figure is long dead
Results returned	100,000 with LIMIT. Was 10,000 until May 2026
Query results kept	7 days

ON THE EXAM

Study guides written before 2026 say 20 log groups, 10 concurrent queries and 10,000 results. All three are wrong now.

What Logs Insights costs, and how to spend less

- You are charged for **bytes scanned**, so a narrow time range is the cheapest optimisation there is.
- **Field indexes** let the engine skip events that cannot match. Use **filterIndex** to query only indexed log groups.
- Put **filter** early in the pipeline, before **stats**. Reduce rows before you aggregate them.
- A dashboard widget running a Logs Insights query **re-runs and re-charges** every time the dashboard loads.

> ON THE EXAM
>
> The dashboard point surprises teams every month. A Logs Insights widget on a wall-mounted screen is a standing charge.

Two patterns the exam expects you to recognise

- **CloudTrail to CloudWatch Logs to metric filter to alarm.** The standard way to alert on API activity such as root account use.
- This is how CIS-style controls are implemented. CloudTrail alone **records**; it does not alert.
- **Contributor Insights** builds top-N rules over structured logs: the noisiest IP, the busiest tenant, the heaviest caller.
- Contributor Insights answers **who** is causing the load. A metric filter only tells you **how much** there is.

> ON THE EXAM
>
> "Alert when the root user signs in" is always CloudTrail into a log group, then a metric filter, then an alarm. Not CloudTrail on its own.

> A team creates a metric filter that counts the string PaymentDeclined in an application log group, publishing a value of 1 for each match. They build an alarm on it with a five-minute period and a threshold of more than 10.
>
> Declines are rare. The alarm has been in INSUFFICIENT_DATA almost continuously since it was created, and it did not fire during an incident last week when 40 declines occurred in ten minutes.

What explains both symptoms, and what is the fix?

A The metric filter is not retroactive, so it missed the incident. Recreate it

B No default value is set, so quiet periods publish nothing. Set the default value to 0

C The log group is in the Infrequent Access class. Recreate it as Standard

D The alarm period is shorter than the publishing interval. Increase it to 15 minutes

◆ PAUSE AND DECIDE

What explains both symptoms, and what is the fix?

A Not retroactive

True of metric filters, but irrelevant. The filter existed before the incident, so it did see those events.

B Set default value to 0

Explains the constant INSUFFICIENT_DATA, and that state is why the alarm could not evaluate normally during the burst.

C Infrequent Access class

Self-defeating. An IA log group cannot have a metric filter at all, so the filter would never have been created.

D Period too short

The module two trap, applied to the wrong cause. The metric does not publish on an interval; it publishes when something matches.

THE SIGNAL

One cause, both symptoms. A metric that only exists when something goes wrong leaves the alarm blind the rest of the time.

An application log group already has two subscription filters: one to a Lambda function that redacts and forwards events to a partner, and one to Amazon Data Firehose delivering to an S3 data lake.

The security team now needs the same events delivered to their SIEM in near real time. An engineer tries to add a third subscription filter and the request fails.

What should the engineer do?

A Request a service quota increase for subscription filters per log group

B Replace one filter with a Kinesis Data Streams destination and attach the existing consumer plus the SIEM to that stream

C Schedule a CreateExportTask to S3 every five minutes and have the SIEM read the bucket

D Create a second log group and configure the application to write every event to both

◆ PAUSE AND DECIDE

What should the engineer do?

A Request a quota increase

The two-filter limit is firm and not adjustable. A plausible-sounding action that AWS will not grant.

B Fan out through Kinesis Data Streams

One filter feeds a stream; any number of consumers read it independently. The documented answer to needing more than two destinations.

C Scheduled export to S3

Export is a batch task that can take hours and runs one at a time per account. It cannot be near real time.

D Duplicate log group

Doubles ingestion cost, needs an application change, and creates two versions of the truth that will drift.

THE SIGNAL

When a hard limit blocks you, the answer is a different topology, not a bigger number. Fan-out is that topology.

During an incident, a CloudOps engineer needs to find which API endpoints returned 5xx responses across 38 microservice log groups, and when the errors started. The log groups all share the name prefix /aws/apps/prod/.

The engineer has no metric filters for this and needs an answer in the next few minutes, covering the last six hours.

What is the fastest correct approach?

A Create a metric filter on each log group for 5xx responses and wait for the metrics to populate

B Run a Logs Insights query using SOURCE with the log group prefix, filtering on status and using stats count by bin

C Export all 38 log groups to S3 and query the results with Amazon Athena

D Open Live Tail on all 38 log groups and watch for 5xx responses

◆ PAUSE AND DECIDE

What is the fastest correct approach?

A. Create 38 metric filters

Filters are not retroactive. They would show nothing about the last six hours, which is the entire question.

B. Logs Insights with SOURCE prefix

Queries retained history immediately, SOURCE avoids naming 38 groups, and stats by bin shows when it started.

C. Export to S3, query in Athena

Correct eventually. Export can take hours and runs one task at a time, which is useless during an incident.

D. Live Tail everywhere

Live Tail shows events arriving now. It cannot look back six hours, and it cannot aggregate.

THE SIGNAL

"Looking backward" plus "right now" is always Logs Insights. Filters look forward and exports are slow.

> A compliance requirement states that the security team must be notified within minutes whenever the root user signs in to any of the company's accounts. CloudTrail is already enabled as an organization trail delivering to an S3 bucket in the security account.
>
> The security team argues that because CloudTrail is enabled, the requirement is already met.

What must still be implemented?

A Nothing. An organization trail already records root sign-ins

B Configure the trail to also deliver to CloudWatch Logs, add a metric filter for root sign-in, and alarm on it with an SNS action

C Enable S3 event notifications on the CloudTrail bucket to notify the security team

D Schedule an Athena query over the CloudTrail bucket every morning and email the results

◆ PAUSE AND DECIDE

What must still be implemented?

A. Nothing, CloudTrail records it

Recording is not alerting. The event is captured in a bucket nobody is watching, which satisfies audit and not notification.

B. Trail to CloudWatch Logs, metric filter, alarm

The standard chain. Log group makes the events filterable, the filter makes a metric, the alarm makes it a notification.

C. S3 event notifications

Fires when a log file object is written, which happens constantly. It says a file arrived, never what is inside it.

D. Daily Athena query

Right data, wrong latency. The requirement says within minutes and this answers within a day.

THE SIGNAL

Detective controls have two halves: capture and notify. CloudTrail is capture. Nothing in CloudTrail alone tells a human anything.

The five things to carry forward

- **Filters look forward, queries look backward.** Neither one substitutes for the other.
- **Set a default value of 0** on counting metric filters, or the alarm lives in INSUFFICIENT_DATA.
- **Two subscription filters per log group, firm.** Need more destinations, fan out through Kinesis Data Streams.
- **Subscription filter is continuous; export to S3 is a slow batch.** "Near real time" decides it.
- **CloudTrail records, it does not alert.** The chain is trail, log group, metric filter, alarm.

> ON THE EXAM
>
> Next: CloudTrail itself, and the difference between who did it, what it looked like, and how it is performing.

MODULE 05 · DOMAIN 1 - MONITORING, LOGGING, ANALYSIS, REMEDIATION, AND PERFORMANCE OPTIMIZATION

CloudTrail and the Audit Trail

Who did what, when, from where - and proving afterwards that nobody edited the answer.

DOMAIN 1 of 5 EXAM WEIGHT 22% MODULE 5 of 35

admin@sthithapragna.com

CloudTrail records **actions**, not state and not performance. Every question in this area starts by deciding which of those three you need.

Three questions, three services

THE QUESTION BEING ASKED	THE SERVICE THAT ANSWERS IT
Who deleted the bucket, and when?	CloudTrail. It records API calls and their callers
What did that security group look like on Tuesday?	AWS Config. It records configuration state over time
Are any buckets public right now?	AWS Config. Current state, queried
Is this instance running out of memory?	CloudWatch. Metrics and logs
Tell me when errors exceed a threshold	A CloudWatch alarm

ON THE EXAM

Who did it, what it looked like, how it is performing. Three questions, and the wording of a scenario always picks one.

Event history: what you get for nothing

- **90 days** of history, free, viewable and searchable in the console. On by default and it cannot be turned off.
- **Management events only.** No data events, and no Insights events.
- **Per account, per Region.** There is no single view across the organisation.
- Beyond 90 days, or for anything else on that list, you need a **trail**.

> ON THE EXAM
>
> "We do not need a trail because CloudTrail is already on" is the reasoning a scenario will hand you. It is wrong the moment the requirement exceeds 90 days.

Four event types

EVENT TYPE	WHAT IT CAPTURES, AND WHAT IT COSTS
Management	Control plane: create, delete, configure. ON by default. First copy free per Region
Data	Data plane: S3 object access, Lambda invoke, DynamoDB items. OFF by default. Charged from the first copy
Insights	Unusual API call rate or error rate. OFF by default. Charged per event analysed
Network activity	API calls traversing your VPC endpoints. OFF by default. Charged

ON THE EXAM

Only management events are on by default. Three of the four types are opt-in, and that is where both the marks and the bill live.

Data events, and how to afford them

- **Never on by default**, and there is no free first copy. Logging every object in a busy bucket is genuinely expensive.
- **Advanced event selectors** narrow by resource ARN, event name, read or write, and more.
- Log **write events on the sensitive bucket** rather than all events on all buckets. Same evidence, a fraction of the volume.
- Without data events, **a deleted object never appears in CloudTrail at all**. The management event only shows the bucket being configured.

> ON THE EXAM
>
> "Who deleted that object?" is unanswerable unless S3 data events were already enabled. Being able to say so is worth a mark.

Three ways the CloudTrail bill explodes

- **The second copy.** A multi-Region trail plus a single-Region trail means events are logged twice, and copy two is charged.
- **Data events left wide open.** All buckets, all objects, read and write. This is the big one.
- **SSE-KMS on a busy bucket.** Every object operation generates KMS management events, which are then logged.
- A well designed management-events-only multi-Region trail costs close to nothing in CloudTrail fees.

> ON THE EXAM
>
> Storage in S3 is a separate charge from CloudTrail itself. A scenario blaming CloudTrail for a bill may actually be describing S3.

Network activity events: the newer one

- Records **AWS API calls traversing your VPC endpoints**, generally available since February 2025.
- Filter on **vpcEndpointId**, **eventName**, and **errorCode** - where the only valid error code is **VpceAccessDenied**.
- Log **access denied only** and you get data-perimeter evidence at a tiny fraction of the volume.
- Since July 2026 you can also filter by **the calling IAM identity**, so trusted roles can be excluded.

> ON THE EXAM
>
> This answers "did anyone use credentials from outside our organisation at our endpoint?" without decrypting any traffic.

CloudTrail Insights

- Detects **unusual API call rate** and **unusual API error rate** against a learned baseline.
- **Prerequisites bite:** call rate needs Write management events logged; error rate needs Read or Write.
- Catches a runaway script, a misconfigured deployment loop, or credentials being probed.
- Charged per event analysed, per insight type. It is opt-in on the trail.

> ON THE EXAM
>
> Insights is anomaly detection for API activity, the same idea as CloudWatch anomaly detection but applied to who is calling what.

Organization trails

- Created **once** in the management account or a delegated administrator, and it covers **every account**, including ones created later.
- **Member accounts cannot alter or delete it.** They can see it exists and nothing more.
- The **management account always owns it**, whoever created it, so removing a delegated admin leaves the trail intact.
- Make it **multi-Region**. Global service events such as IAM and STS are recorded in us-east-1.

> ON THE EXAM
>
> A per-account trail is only as trustworthy as that account's administrator. That is the entire argument for an organization trail.

Proving nobody edited the evidence

- **Log file integrity validation** writes an hourly **digest file** containing hashes of every log file delivered in that hour.
- Log files are hashed with **SHA-256**; digests are signed with the private key of a CloudTrail key pair.
- Verify with **aws cloudtrail validate-logs**. It proves files are unmodified, and that none were deleted.
- **It is off by default.** An auditor asking for tamper evidence is asking for this switch.

> ON THE EXAM
>
> Digests chain to the previous hour, so deleting a whole log file is detectable too, not just editing one.

Protecting the bucket the trail writes to

- Put it in a **separate, tightly controlled account**, so an attacker in the workload account cannot reach it.
- **S3 Object Lock** in compliance mode makes objects undeletable for a retention period, even by the root user.
- **MFA delete** on the bucket, **versioning** on, and a bucket policy that denies deletes.
- Encrypt with **SSE-KMS** and control who can decrypt separately from who can read the bucket.

> ON THE EXAM
>
> Integrity validation detects tampering. Object Lock prevents it. Auditors usually want both, and questions often want the preventive one.

How an event travels

01

API call

Console, CLI, SDK or a service acting on your behalf.

›

02

CloudTrail

Records it as an event, if the type is enabled.

›

03

EventBridge

Management events reach the default bus in near real time.

›

04

S3

Log files delivered, typically within 15 minutes.

›

05

CloudWatch Logs

Optional. Enables metric filters and alarms.

ON THE EXAM

Two speeds. EventBridge is near real time; S3 delivery lags. Choose by how fast the scenario needs to react.

React fast, or investigate later?

EVENTBRIDGE WHEN

Seconds matter

- Rule on the default bus matching the API call
- Target a Lambda function or SSM Automation
- Near real time, no S3 delivery wait
- Management events only, without a data trail

S3 PLUS ATHENA WHEN

Depth matters

- Query months of history across accounts
- Joins, aggregation, arbitrary questions
- Minutes to hours behind live
- The forensic and compliance path

THE TIEBREAKER

Automatically revert an unauthorised change is EventBridge. Work out who has been doing this for six months is Athena over the bucket.

Reading an event record

- **userIdentity** is where investigations start. Type, ARN, and for assumed roles the **sessionContext**.
- An assumed-role event names the **role**. The human is in **sessionIssuer** and the session name, so name sessions after people.
- **eventSource** and **eventName** identify the call; **sourceIPAddress** and **userAgent** say where from.
- **errorCode** and **errorMessage** appear on failures. A denied call is still recorded, which is often the interesting one.

> ON THE EXAM
>
> Failed calls are logged too. "Nothing shows in CloudTrail" usually means the event type was off, not that nothing happened.

Honest limit: CloudTrail Lake is closed to new customers

- **Closed to new customers on 31 May 2026.** Existing customers continue as normal.
- It now receives **critical bug fixes and security updates only**. Do not design anything new around it.
- **CloudTrail itself is fully supported.** Only Lake changed. Trails, event history and all four event types are unaffected.
- AWS points customers toward **CloudWatch** for comparable capability. Athena over the trail bucket remains the classic route.

> ON THE EXAM
>
> Exam material may still present Lake as a normal option. Learn what it does, and know you would not choose it for a new build today.

> A finance team reports that a spreadsheet stored in S3 disappeared some time in the last week. The account has a multi-Region organization trail delivering management events to a central S3 bucket, with 400 days of retention.
>
> A CloudOps engineer searches CloudTrail Event history and the delivered log files, and finds no record of the object being deleted.

What is the most likely explanation?

A The event is older than the 90-day Event history window

B S3 data events were never enabled, so object-level operations were never recorded

C The organization trail does not cover the account that owns the bucket

D Log file integrity validation is disabled, so delete events were dropped

◆ PAUSE AND DECIDE

What is the most likely explanation?

A. Older than 90 days

The deletion happened in the last week, and the trail retains 400 days regardless. Both facts are stated to rule this out.

B. Data events were never enabled

Deleting an object is a data-plane operation. The trail logs management events only, so the deletion was never recorded anywhere.

C. Trail does not cover the account

An organization trail covers every account including new ones, and member accounts cannot exclude themselves.

D. Integrity validation disabled

Invented mechanism. Validation detects tampering after delivery; it never decides which events are captured.

THE SIGNAL

The scenario says "management events" once, quietly. That single word is the whole answer.

> An external auditor wants proof that two years of CloudTrail logs have not been modified or deleted by anyone. That includes administrators with full access to the logging account.
>
> The company has an organization trail delivering to a versioned S3 bucket in a dedicated logging account. A bucket policy denies s3:DeleteObject to everyone except the security team's role.

Which combination should the company implement?

A. Enable log file integrity validation, and apply S3 Object Lock in compliance mode to the bucket

B. Enable CloudTrail Insights and turn on MFA delete

C. Copy the log files nightly to a second bucket in another Region with a Lambda function

D. Enable S3 server access logging on the CloudTrail bucket

◆ PAUSE AND DECIDE

Which combination should the company implement?

A Integrity validation plus Object Lock

Validation proves nothing changed; compliance-mode Object Lock means nobody could have changed it, including root. Detective plus preventive.

B Insights plus MFA delete

Insights detects unusual API rates and is unrelated. MFA delete helps, but a determined administrator with the MFA device is not stopped.

C Nightly copy to another Region

Improves durability, not integrity. The same administrator can delete from both buckets, and a copy proves nothing about the original.

D S3 server access logging

Records who accessed the bucket. It is evidence about the evidence, and it is itself deletable by the same administrator.

THE SIGNAL

"Including administrators" rules out any control an administrator can undo. Compliance mode is the only option here that root cannot override.

> A security policy covers any change opening a security group to inbound traffic from 0.0.0.0/0 on port 22. Such a change must be automatically reverted within one minute, and the security team notified.
>
> The company has a multi-Region organization trail delivering to S3 and to a CloudWatch log group. An engineer proposes a nightly Athena query over the trail bucket to find such changes.

What should the company implement instead?

A Keep the Athena query but run it hourly instead of nightly

B An EventBridge rule on the default bus matching AuthorizeSecurityGroupIngress, targeting a Lambda function that reverts the rule and publishes to SNS

C A metric filter on the CloudWatch log group with an alarm that notifies the security team

D Enable CloudTrail Insights to detect the unusual API call

◆ PAUSE AND DECIDE

What should the company implement instead?

A Hourly Athena query

Still detection, still an hour late, and it does not revert anything. It answers neither half of the requirement.

B EventBridge rule to Lambda

Management events reach the default bus in near real time. Lambda both reverts the change and notifies, inside the one-minute window.

C Metric filter and alarm

The strongest wrong answer. It notifies, but it cannot revert, and trail delivery to the log group adds minutes before the filter even sees it.

D CloudTrail Insights

Detects unusual call volume, not a specific dangerous call. One deliberate change is not a rate anomaly.

THE SIGNAL

Two requirements: revert automatically, and within one minute. Option C fails the first; options A and C fail the second.

A company's CloudTrail costs rose from about $40 to over $3,000 a month. A project team had enabled data events for all S3 buckets, read and write, across a multi-Region trail. Auditors only require evidence of writes to one bucket holding regulated records.

The company also still has an old single-Region trail in eu-west-1 logging management events, created before the organization trail existed.

Which combination reduces the cost while meeting the audit requirement?

A. Switch the organization trail to the Infrequent Access log class

B. Use advanced event selectors to log write data events on the regulated bucket only, and delete the redundant single-Region trail

C. Disable data events entirely and rely on S3 server access logging for the regulated bucket

D. Reduce the S3 bucket lifecycle policy to move trail logs to Glacier after 30 days

◆ PAUSE AND DECIDE

Which combination reduces the cost while meeting the audit requirement?

A **Infrequent Access log class**

Log classes are a CloudWatch Logs feature. A trail delivering to S3 has no log class, so this is a category error.

B **Scoped selectors, drop the second trail**

Selectors cut the data-event volume to what auditors need, and removing the duplicate trail stops paying twice for management events.

C **Server access logging instead**

Best-effort delivery, no guaranteed completeness, and no integrity validation. Weak evidence for a regulated record.

D **Glacier lifecycle**

Reduces S3 storage, which is not where this bill came from. The charge is per event logged, not per byte stored.

THE SIGNAL

Both of this module's cost traps in one question: data events wide open, and a forgotten second copy of management events.

The five things to carry forward

- **Who did it, what it looked like, how it is performing.** CloudTrail, Config, CloudWatch.
- **Only management events are on by default.** No data events means a deleted object is simply unrecorded.
- **Integrity validation detects; Object Lock prevents.** "Including administrators" means you need the preventive one.
- **EventBridge in seconds, S3 in about 15 minutes.** The required reaction time picks the path.
- **CloudTrail Lake closed to new customers on 31 May 2026.** CloudTrail itself is unaffected.

> ON THE EXAM
>
> Next: EventBridge properly - buses, patterns, targets, and the many reasons a rule quietly does not fire.

MODULE 06 · DOMAIN 1 - MONITORING, LOGGING, ANALYSIS, REMEDIATION, AND PERFORMANCE OPTIMIZATION

EventBridge and Event Routing

Buses, patterns, targets - and the six reasons a rule quietly does not fire.

DOMAIN 1 of 5 EXAM WEIGHT 22% MODULE 6 of 35

admin@sthithapragna.com

EventBridge routes on the **shape** of an event. A rule that does not fire is nearly always a pattern that does not match, and nothing tells you.

The event envelope

- Every event has the same outer fields: **version, id, detail-type, source, account, time, region, resources, detail**.
- **source** identifies the producer: **aws.ec2**, **aws.s3**, or your own reverse-DNS style name.
- **detail** is the service-specific payload. Everything above it is standard, which is why one pattern language works for all events.
- It is **detail-type** with a hyphen, and matching is **case-sensitive**. Both catch people constantly.

> ON THE EXAM
>
> Maximum event size is 256 KB. Larger payloads go to S3 and the event carries a reference. That is the claim-check pattern.

Buses, and which one you are on

- **The default bus** receives every AWS service event in the account automatically. You do not subscribe to anything.
- **Custom buses** are for your own application events, giving separate rules, permissions and quotas.
- **Partner buses** receive events from SaaS providers such as payment or monitoring vendors.
- **Scheduled rules only work on the default bus.** Creating one on a custom bus does not run.

> ON THE EXAM
>
> AWS service events land on the default bus and nowhere else. A rule for them on a custom bus will never match anything.

Pattern matching, beyond exact values

OPERATOR	WHAT IT DOES
`Exact value`	"source": ["aws.ec2"] - an array of values means OR, not AND
`prefix / suffix`	Match the start or end of a string, such as a bucket name prefix
`anything-but`	Everything except the listed values. Useful for excluding a known-good case
`numeric`	Comparisons such as greater than or between, on numbers in the detail
`exists`	Whether a field is present at all, regardless of value
`cidr`	Match an IP address against a network range
`equals-ignore-case, wildcard`	Case-insensitive matching, and * within a string

ON THE EXAM

An array is OR. To require two conditions, put them in two different fields. There is no AND inside one field.

Four pattern rules that decide questions

- **The pattern must mirror the event's structure.** A nested field has to be nested identically in the pattern.
- **A field you omit is not filtered.** Leave out source and you match every source, which is usually not what you meant.
- **Matching is case-sensitive** unless you use equals-ignore-case.
- For an **array in the event**, the pattern matches if **any element** matches.

> ON THE EXAM
>
> Copy a real event from CloudTrail or the sandbox and build the pattern from it. Writing one from memory is how afternoons disappear.

Why a rule does not fire: configuration

- **Wrong bus.** AWS service events are on the default bus. Scheduled rules must be on the default bus.
- **Pattern does not match.** Test it against a real event with the sandbox before blaming anything else.
- **Wrong Region.** Rules are regional. Global service events such as IAM appear in us-east-1.
- **The event was never produced.** S3 object-level events need EventBridge notifications enabled on the bucket, or CloudTrail data events.

> ON THE EXAM
>
> Nothing is logged when a pattern fails to match. Silence is the normal outcome, not a symptom of a fault.

Why a rule does not fire: delivery

- **The rule is disabled.** Obvious, and worth ten seconds of checking before an hour of theorising.
- **The target rejects the invocation.** EventBridge needs permission: a resource policy on SQS, SNS or Lambda, or an IAM role for others.
- Here the rule **did** match, so **FailedInvocations** increments. That metric is how you tell the two halves apart.
- An **encrypted SQS queue** also needs the KMS key policy to allow EventBridge to Decrypt and GenerateDataKey.

> ON THE EXAM
>
> Matched but undelivered shows in FailedInvocations. Never matched shows nowhere. Check that metric first and you halve the search space.

Targets, and reshaping what they receive

- **Up to 5 targets per rule**, and that limit is firm. More consumers means more rules, or fan out through SNS.
- Targets include Lambda, Step Functions, SQS, SNS, ECS tasks, **SSM Automation and Run Command**, Kinesis, another event bus.
- The **input transformer** reshapes the event before it arrives, so the target gets the fields it expects.
- **API destinations** deliver to any HTTPS endpoint, with managed authentication and rate limiting.

> ON THE EXAM
>
> SSM Automation as a direct target means many remediations need no Lambda function at all. That matters for "least operational overhead".

When delivery fails

- Default retry policy: **24 hours and up to 185 attempts**, with exponential backoff and jitter.
- After that the event is **dropped silently** unless a dead-letter queue is configured.
- The DLQ is a **standard SQS queue**, set **per target**, and the message carries the error code and rule ARN.
- EventBridge retries **5xx and 429** responses. It does **not** retry other 4xx errors, because they will not improve.

> ON THE EXAM
>
> Watch FailedInvocations and InvocationsSentToDlq. Without a DLQ, a broken target loses events with nothing to show for it.

Archive and replay

- An **archive** stores events arriving on a bus, optionally filtered by pattern, for a retention period you choose.
- **Replay** re-sends archived events over a chosen time range to the bus, and rules process them again.
- Recovers from a bug in a downstream consumer, or a target that was broken for hours.
- Replay is **not** a dead-letter queue. It replays what the bus received, not what failed delivery.

> ON THE EXAM
>
> "Reprocess yesterday's events after fixing the consumer" is replay. "Recover the specific events that failed" is the DLQ.

Scheduled rule or EventBridge Scheduler?

SCHEDULED RULE

The original, now legacy

- cron or rate, on the default bus only
- UTC only, no time zone awareness
- Targets limited to EventBridge target types
- Fine for something you already have

EVENTBRIDGE SCHEDULER

What AWS now recommends

- Time zones and daylight saving handled
- One-time schedules as well as recurring
- Over 270 services as direct targets
- Flexible time windows to spread load

THE TIEBREAKER

AWS explicitly recommends Scheduler for new work. Time zones, one-time schedules or huge scale each decide it on their own.

EventBridge Pipes: point to point

- Connects **one source to one target**, with optional **filtering** and **enrichment** in between.
- Sources are polling sources: **DynamoDB Streams, Kinesis, SQS, Amazon MQ, MSK** and self-managed Kafka.
- Enrichment can call **Lambda, Step Functions, API Gateway or an API destination** to add context before delivery.
- A bus is **one to many** with rules. A pipe is **one to one**. That is the distinction the exam wants.

> ON THE EXAM
>
> Pipes exists to delete the glue Lambda that only polled a stream, reshaped a record and called something else.

EventBridge or SNS?

EVENTBRIDGE WHEN

Routing on content

- Rich filtering on the whole event body
- Hundreds of AWS services as native sources
- Archive, replay and schema registry
- Slightly higher latency, around half a second

SNS WHEN

Fan-out at speed

- Very high throughput, very low latency
- Filtering on message attributes, not full content
- Many subscribers of the same message
- SMS, email and mobile push endpoints

THE TIEBREAKER

They combine well. EventBridge routes and filters; SNS fans a single routed event out to many subscribers.

Across accounts and Regions

- Target **another account's event bus ARN** directly. Cross-Region works the same way, using the full ARN.
- The **receiving bus needs a resource policy** allowing events:PutEvents from the sending account or organisation.
- Centralise by having every account forward to a bus in a security or operations account.
- **Global endpoints** use a Route 53 health check to fail events over to a secondary Region automatically.

> ON THE EXAM
>
> Sending is a rule target; receiving is a resource policy. Forget the second and events vanish without an obvious error.

A CloudOps engineer creates a custom event bus named ops-events and adds a rule on it with the pattern {"source": ["aws.ec2"], "detail-type": ["EC2 Instance State-change Notification"]}, targeting a Lambda function that logs terminations.

Instances are terminated repeatedly over two days. The Lambda function is never invoked. CloudWatch shows no Invocations for the function and no FailedInvocations for the rule.

What is the cause?

A The Lambda function's resource policy does not allow EventBridge to invoke it

B AWS service events are delivered to the default event bus, not to custom buses

C The detail-type string is case-sensitive and does not match

D CloudTrail data events must be enabled for EC2 state changes to be published

◆ PAUSE AND DECIDE

What is the cause?

A **Lambda resource policy**

A permissions failure means the rule matched and delivery failed, which would increment FailedInvocations. The scenario says it is zero.

B **Service events go to the default bus**

The rule is on a custom bus, so no EC2 event ever reaches it. Nothing matches, nothing fails, and both metrics stay at zero.

C **Case-sensitive mismatch**

The string quoted is the correct one. Plausible in general, but this particular pattern is right.

D **CloudTrail data events**

EC2 state changes are native EventBridge events. They do not depend on CloudTrail at all.

THE SIGNAL

FailedInvocations at zero is the discriminator. It proves the rule never matched, which rules out every permissions answer.

> A rule on the default bus matches a nightly batch completion event and targets an SQS queue encrypted with a customer managed KMS key. The rule's FailedInvocations metric increments every night, and no messages arrive in the queue.
>
> The queue's resource policy already allows events.amazonaws.com to call sqs:SendMessage.

What is the most likely remaining cause?

A The rule needs a dead-letter queue configured before it can deliver

B The KMS key policy does not allow EventBridge to call Decrypt and GenerateDataKey

C The event pattern does not match, so nothing is delivered

D The rule has exceeded the limit of 5 targets

◆ PAUSE AND DECIDE

What is the most likely remaining cause?

A **Needs a DLQ first**

A DLQ catches events after retries are exhausted. It never enables delivery, and its absence causes no failure.

B **KMS key policy missing permissions**

Writing to an encrypted queue needs GenerateDataKey and Decrypt on the key, in addition to SendMessage on the queue.

C **Pattern does not match**

Ruled out by the evidence. FailedInvocations only increments when a rule matched and delivery then failed.

D **Too many targets**

Exceeding five targets is rejected when you configure the rule, not silently at delivery time each night.

THE SIGNAL

The mirror image of scenario 1. FailedInvocations incrementing proves the pattern is fine and the problem is downstream.

A company runs a compliance report every weekday at 07:00 in London local time, currently triggered by a scheduled EventBridge rule with a cron expression. Twice a year, when British Summer Time starts or ends, the report runs an hour early or an hour late for several days until someone notices.

The team also wants to add roughly 4,000 further schedules for per-customer report generation, spread across many time zones.

What should the team use?

A Keep scheduled rules and add a Lambda function that adjusts the cron expressions twice a year

B EventBridge Scheduler, with time zone aware schedules and flexible time windows

C An EventBridge Pipe with a Kinesis source triggered by a clock stream

D Scheduled rules on a custom event bus, one per customer time zone

◆ PAUSE AND DECIDE

What should the team use?

A. Lambda that rewrites cron twice a year

Rebuilds daylight saving by hand, in code nobody touches for six months. Maximum operational overhead, and it will fail quietly.

B. EventBridge Scheduler

Time zones and DST are native, it scales to millions of schedules, and flexible time windows stop 4,000 jobs firing on the same second.

C. Pipe with a Kinesis source

Pipes connects a source to a target. It is not a scheduler, and there is no clock stream to poll.

D. Scheduled rules on a custom bus

Doubly wrong: scheduled rules do not work on a custom bus at all, and this still does not solve daylight saving.

THE SIGNAL

Time zones, one-time schedules, or very large numbers of schedules. Any one of those three points at Scheduler on its own.

> An operations team must automatically restart a specific Windows service on any EC2 instance where a CloudWatch alarm reports the service has stopped. The instances are Systems Manager managed and an SSM Automation runbook already exists that performs the restart correctly.
>
> The team wants the least operational overhead and no code to maintain.

How should the team wire this up?

A. An EventBridge rule matching the alarm state change, targeting the SSM Automation runbook directly

B. An EventBridge rule targeting a Lambda function that calls StartAutomationExecution

C. An SNS topic subscribed to the alarm, with a Lambda subscriber that starts the runbook

D. An EventBridge Pipe with the alarm as the source and the runbook as the target

◆ PAUSE AND DECIDE

How should the team wire this up?

A Rule targets the runbook directly

SSM Automation is a native EventBridge target. No function, no code, no deployment pipeline for glue logic.

B Rule to Lambda to runbook

Works perfectly and is what most teams build first. The Lambda function does nothing EventBridge cannot do, and it still needs owning.

C SNS then Lambda

Adds a topic and a function. Two components to maintain where the requirement asked for the fewest.

D EventBridge Pipe

Pipes sources are polling sources such as queues and streams. An alarm state change is not one of them.

THE SIGNAL

"No code to maintain" is the phrase. When a native target exists, a Lambda function in the middle is a wrong answer that works.

The five things to carry forward

- **AWS service events and scheduled rules live on the default bus.** A custom bus is for your own events.
- **FailedInvocations tells you which failure you have.** Zero means it never matched; climbing means delivery failed.
- **An array in a pattern means OR.** An omitted field is not filtered at all.
- **24 hours, 185 retries, then dropped** unless a DLQ exists. Archive and replay is a different tool.
- **SSM Automation is a native target.** A Lambda function that only forwards is avoidable overhead.

> ON THE EXAM
>
> Next: Systems Manager itself – the agent, Session Manager, Run Command, Patch Manager and State Manager.

MODULE 07 · DOMAIN 1 - MONITORING, LOGGING, ANALYSIS, REMEDIATION, AND PERFORMANCE OPTIMIZATION

Systems Manager for Operations

One prerequisite, then a dozen tools. Get the prerequisite wrong and none of them work.

DOMAIN 1 of 5 EXAM WEIGHT 22% MODULE 7 of 35

admin@sthithapragna.com

Systems Manager is not one service. It is a dozen tools sharing **one prerequisite**: the node must be manageable.

What makes a node manageable

01

Agent

SSM Agent installed and running. Pre-installed on most modern AMIs.

02

Permissions

An instance profile, or account-level Default Host Management.

03

Network path

Reach ssm, ssmmessages and ec2messages endpoints.

04

Managed node

It appears in Fleet Manager, and every tool works.

ON THE EXAM

Agent, permissions, network. Three things. Every "it is not showing up" question is one of these three.

The modern way to grant permissions

- **Default Host Management Configuration** is an account and Region setting. Every eligible instance becomes managed, with no instance profile.
- AWS now **recommends this account-level approach** over attaching a profile to each instance.
- **It requires IMDSv2.** Instances still on IMDSv1 are not picked up, and there is no warning.
- It also needs **SSM Agent 3.2.582.0 or later**. Older agents are silently ignored.

> ON THE EXAM
>
> The classic answer is AmazonSSMManagedInstanceCore on an instance profile. That still works. DHMC is the account-wide version, and it has two hard prerequisites.

"My instance is not a managed node"

- **1. Is the agent running?** Check the service. Old AMIs may not have it at all.
- **2. Are there permissions?** An instance profile with AmazonSSMManagedInstanceCore, or DHMC enabled and IMDSv2 in use.
- **3. Is there a network path?** Private subnet with no NAT needs **interface endpoints for ssm, ssmmessages and ec2messages**.
- **4. Do the endpoint and subnet allow it?** Security group on the endpoint must permit 443 from the instance.

> ON THE EXAM
>
> Session Manager specifically needs ssmmessages. If Run Command works but sessions fail, that endpoint is the one to check.

Session Manager: what it removes

- **No bastion host.** No SSH keys to distribute, rotate or lose. No RDP.
- **No inbound ports at all.** The agent makes an outbound connection, so security groups need no inbound rules.
- Access is controlled by **IAM**, so joiners and leavers are handled where everything else already is.
- Works on instances in **private subnets with no internet access**, through interface endpoints.

> ON THE EXAM
>
> "Remove the bastion", "stop managing SSH keys" or "no inbound ports" all point at Session Manager. It is one of the most reliable signals on this exam.

Session Manager: the auditable parts

- **Session logs to CloudWatch Logs or S3**, capturing the commands typed and the output returned.
- Every session start and stop is a **CloudTrail event**, tied to the IAM identity.
- **KMS encryption** of session data in transit, above the TLS that is already there.
- **Port forwarding** reaches a database or web console on a private instance, with no tunnel host.

> ON THE EXAM
>
> A bastion tells you someone connected. Session Manager tells you who, when, under which role, and every keystroke.

Session Manager or EC2 Instance Connect?

SESSION MANAGER

Agent-based, no ports

- Needs SSM Agent and a managed node
- No inbound rules, works in private subnets
- Full session logging to S3 or CloudWatch
- Port forwarding and RunAs support

EC2 INSTANCE CONNECT

Pushes a temporary key

- Pushes a one-time SSH public key, valid 60 seconds
- Still an SSH connection on port 22
- Needs an inbound path, or the Endpoint variant
- Linux only, no session logging

THE TIEBREAKER

Both remove long-lived keys. Only Session Manager removes the inbound port and records the session.

Documents: the unit of work

DOCUMENT TYPE	WHAT IT DOES
Command	What Run Command and State Manager execute on a node
Automation	A multi-step workflow over AWS APIs
Session	Configures Session Manager behaviour, such as logging and shell profile
Policy	Used by State Manager, for example to collect Inventory
Package	A Distributor package: software to install on nodes

ON THE EXAM

Documents are versioned and can be shared across accounts, or publicly. AWS-owned ones start with AWS-, such as AWS-RunPatchBaseline.

Run Command: doing something now

- Runs a **document** against nodes chosen by **instance ID, tag, or resource group**. Tags are how you target a fleet.
- **Rate control**: concurrency as a number or percentage, and an **error threshold** that stops the rollout.
- Output goes to **S3 or CloudWatch Logs**. The console truncates at 2,500 characters.
- It is **one-shot**. Nothing re-runs, and instances launched afterwards are untouched.

> ON THE EXAM
>
> The error threshold is the safety feature. Stop after 5 failures and a bad command hits five instances, not five hundred.

Run Command or State Manager?

RUN COMMAND

Imperative, once

- Do this now, on these nodes
- Immediate result, immediate feedback
- Nothing re-applies it
- New instances are not covered

STATE MANAGER

Declarative, continuously

- An association: this is the desired state
- Re-applied on a schedule you choose
- New instances matching the tag are picked up
- Manual changes get corrected

THE TIEBREAKER

"Instances launched later must also be configured", or "the setting keeps drifting back". Both mean State Manager.

Automation runbooks

- A runbook orchestrates **multi-step workflows** across AWS APIs, not just commands inside an instance.
- Hundreds of **AWS-owned runbooks** exist already: restart an instance, create an AMI, resize a volume, remediate a bucket.
- A runbook is a **native EventBridge target**, so an alarm or an API event can trigger one with no Lambda function.
- Supports **approval steps**, rate control across accounts and Regions, and branching on results.

> ON THE EXAM
>
> Run Command acts inside the operating system. Automation acts on AWS resources. That is the cleanest way to separate them.

OpsCenter: one queue for operational work

- An **OpsItem** is a tracked piece of operational work, with status, severity, and the affected resource attached.
- CloudWatch alarms and EventBridge rules can **create OpsItems automatically**, and duplicates are deduplicated.
- Each OpsItem carries **investigation context** and can run an **Automation runbook** to resolve itself.
- Works **across accounts**, so one operations team sees the whole organisation's queue.

> ON THE EXAM
>
> This closes the loop from module two. An alarm's Systems Manager action creates an OpsItem here, and the runbook that fixes it is attached to it.

Patch Manager: baselines and approval

- A **patch baseline** defines which patches are approved. AWS provides a default baseline per operating system.
- **Approval rules** auto-approve by classification and severity, usually after a delay such as seven days.
- Explicit **approved and rejected lists** override the rules, for a patch you must have or must not have.
- Operations are **Scan** or **Install**. Scan reports compliance and changes nothing.

> ON THE EXAM
>
> The auto-approval delay is how you let a patch prove itself in the wild for a week before it reaches your fleet.

Patch policies: the recommended method now

- Configured in **Quick Setup**. One wizard covers scanning, installing, baselines and targets.
- Separate **scan and install schedules**: scan daily for compliance, install weekly to limit disruption.
- Applies across **an entire organisation, chosen OUs, or one account and Region**.
- **No patch groups needed.** The older tag-based patch group mechanism is no longer required.

> ON THE EXAM
>
> AWS documents patch policies as the recommended way to configure patching. Maintenance windows and patch groups are the older path.

Inventory, compliance and maintenance windows

- **Inventory** collects installed applications, packages, network config and more, on a schedule, via State Manager.
- **Compliance** reports patch and association status across the fleet, and feeds AWS Config and Security Hub.
- **Maintenance windows** define when disruptive work may run: a schedule, a duration, a cutoff, targets and tasks.
- The **cutoff** stops new tasks starting near the end of the window, so work does not overrun into business hours.

> ON THE EXAM
>
> "Which instances have that vulnerable library?" is Inventory. "Only patch between 2am and 4am on Sunday" is a maintenance window.

Parameter Store

- **Standard tier**: 10,000 parameters, 4 KB each, no charge. **Advanced**: 100,000, 8 KB, charged, plus parameter policies.
- **SecureString** encrypts with KMS. Reading it needs both the parameter permission and the key permission.
- **Hierarchical paths** such as /prod/app/db/host allow IAM policies and GetParametersByPath over a whole branch.
- **Public parameters** supply the latest AMI IDs, so a launch template never needs a hard-coded AMI.

> ON THE EXAM
>
> Parameter policies are Advanced tier only: expire a parameter, or notify before it expires. That is the usual reason to pay.

Parameter Store or Secrets Manager?

PARAMETER STORE WHEN

Configuration

- Endpoints, feature flags, AMI IDs, sizes
- Standard tier is free
- SecureString for the occasional secret
- No built-in rotation

SECRETS MANAGER WHEN

Credentials

- Database passwords, API keys, OAuth tokens
- Automatic rotation, including RDS integration
- Cross-account and cross-Region replication
- Charged per secret per month

THE TIEBREAKER

Does it need to rotate automatically? Yes means Secrets Manager. That single question resolves nearly every instance of this pair.

Beyond EC2: hybrid and multicloud

- **Hybrid activations** register on-premises servers, edge devices and VMs in other clouds as managed nodes.
- An activation has an **expiry** and a **registration limit**. Expiry only blocks new registrations; existing nodes keep working.
- Once registered, **every tool works identically**: Session Manager, Run Command, Patch Manager, Inventory.
- **Fleet Manager** gives a console view of every node: file system, registry, performance counters, RDP and shell.

> ON THE EXAM
>
> Hybrid activations are why "manage on-premises servers the same way" is nearly always a Systems Manager answer.

Four availability changes worth knowing

- **Incident Manager: closed to new customers 7 November 2025.** No new features. AWS recommends **OpsCenter** instead.
- **Change Manager: closed to new customers 7 November 2025.** Existing customers continue.
- **The Systems Manager CloudWatch Dashboard was removed after 30 April 2026.** Use the CloudWatch console.
- **The Advanced Instances Tier was removed on 30 June 2026.** Hybrid and multicloud nodes now register with no per-instance charge.

> ON THE EXAM
>
> From 30 September 2026, Session Manager and Run Command on hybrid nodes move to pay-as-you-go. Registration itself stays free.

A CloudOps engineer launches 20 instances from a current Amazon Linux AMI into a private subnet with no NAT gateway and no internet gateway route. Each instance has an instance profile carrying AmazonSSMManagedInstanceCore.

None of the instances appear in Fleet Manager. The agent is running on all of them. Other instances in a public subnet, with the same profile and AMI, appear normally.

What should the engineer do?

A Add the AmazonSSMFullAccess policy to the instance profile

B Create interface VPC endpoints for ssm, ssmmessages and ec2messages, reachable from the subnet

C Enable Default Host Management Configuration in the account and Region

D Add a NAT gateway so the instances can reach the internet

◆ PAUSE AND DECIDE

What should the engineer do?

A AmazonSSMFullAccess

Permissions are already proven correct: identical instances in a public subnet work with the same profile.

B Interface endpoints for the three services

The only difference between working and failing instances is the network path. Endpoints supply it without exposing the subnet.

C Enable DHMC

Another way to grant permissions, which are not the problem. It also needs the same network path, so nothing changes.

D Add a NAT gateway

Would work, and is the wrong instinct. It gives the whole subnet outbound internet access to solve a three-endpoint problem.

THE SIGNAL

The control group is the clue. Same AMI, same profile, different subnet, different result. Only the network differs.

> A security review requires the company to remove its two bastion hosts. Engineers must still get an interactive shell on Linux and Windows instances in private subnets, every session must be recorded, and access must be governed by existing IAM roles.
>
> The instances are already managed nodes. The team wants the least ongoing administration.

What should the team implement?

A EC2 Instance Connect, with SSH keys pushed on demand

B Session Manager, with session logging to CloudWatch Logs

C A single hardened bastion in a separate account, with CloudTrail enabled

D AWS Client VPN into the private subnets, with SSH and RDP from laptops

◆ PAUSE AND DECIDE

What should the team implement?

A EC2 Instance Connect

Linux only, so it fails the Windows requirement outright. It also has no session recording and still needs an inbound path.

B Session Manager with logging

Covers Linux and Windows, records every session, uses IAM for access, and needs no inbound ports or hosts to maintain.

C One hardened bastion elsewhere

The review said remove the bastions. Moving one to another account is still a host to patch, and CloudTrail does not record keystrokes.

D Client VPN plus SSH and RDP

Replaces two hosts with a VPN endpoint and per-laptop credentials, and records nothing about what was typed.

THE SIGNAL

Three requirements, and Windows quietly eliminates the closest competitor before recording or IAM are even considered.

A company must scan 900 instances daily for missing patches to keep compliance reporting current, but may only install patches during a two-hour window on Sunday mornings. The fleet spans 12 accounts and 3 Regions in an organisation.

The team currently maintains separate maintenance windows and patch groups in each account, and they frequently drift out of alignment.

What should the team implement?

A. A Quick Setup patch policy for the organisation, with a daily scan schedule and a weekly install schedule

B. A Run Command document invoking AWS-RunPatchBaseline, triggered by an EventBridge schedule in each account

C. One maintenance window per account running AWS-RunPatchBaseline in Install mode daily

D. A State Manager association per account running AWS-RunPatchBaseline in Scan mode hourly

◆ PAUSE AND DECIDE

What should the team implement?

A Organisation-wide patch policy

One configuration across all accounts and Regions, with separate scan and install schedules. It also removes the patch groups that keep drifting.

B Run Command on a schedule per account

Twelve accounts times three Regions of hand-built automation. It rebuilds the drift problem the scenario is complaining about.

C Daily install maintenance windows

Installs daily, which breaks the Sunday-only constraint outright, and keeps the per-account sprawl.

D Hourly scan association

Scans only, so nothing is ever patched. It also scans far more often than the requirement asks for.

THE SIGNAL

Two schedules from one configuration is precisely what patch policies added. The drift complaint is pointing at organisation-level setup.

A team stores an application's database password in Parameter Store as a SecureString and reads it at start-up. A new compliance rule requires the password to change every 30 days without downtime, and the application must always receive the current value.

A second requirement asks that the application's non-sensitive settings, such as the API endpoint and a feature flag, stay where they are at no additional cost.

What should the team do?

A Move the password to Secrets Manager with automatic rotation, and leave the settings in Parameter Store

B Upgrade Parameter Store to the Advanced tier and use a parameter policy to expire the password every 30 days

C Keep everything in Parameter Store and add a Lambda function on an EventBridge schedule to rotate the password

D Move all parameters, sensitive and not, to Secrets Manager for consistency

◆ PAUSE AND DECIDE

What should the team do?

A Password to Secrets Manager, settings stay

Rotation is the deciding requirement, and RDS integration changes the database and the secret together. Settings stay free in Parameter Store.

B Advanced tier expiry policy

The sharpest distractor. A parameter policy expires or notifies. It deletes the value; it never sets a new password anywhere.

C Lambda rotation function

Rebuilds Secrets Manager rotation by hand, including the risky part where the database and the stored value must change together.

D Everything to Secrets Manager

Charged per secret per month. The second requirement explicitly says the settings must not add cost.

THE SIGNAL

"Expire" and "rotate" are not the same verb. One removes a value; the other replaces it in two places at once.

A CloudWatch alarm on a critical queue's age-of-oldest-message currently notifies an SNS topic. The operations team wants each occurrence tracked as a work item with a status and severity, visible across all 14 accounts. Each item should have a runbook attached that can be run from the item itself.

Repeated firing of the same alarm must not create hundreds of separate items. The team is building this in 2026 and has never used Incident Manager.

What should the team use?

A Systems Manager Incident Manager, with a response plan triggered by the alarm

B Systems Manager OpsCenter, with the alarm configured to create OpsItems

C An EventBridge rule writing alarm events to a DynamoDB table used as a work queue

D Systems Manager Change Manager, with a change template per alarm

◆ PAUSE AND DECIDE

What should the team use?

A Incident Manager response plan

Closed to new customers since 7 November 2025. A team that has never used it cannot enable it, and AWS points them at OpsCenter.

B OpsCenter with OpsItems

Status, severity, cross-account view, attached runbooks and built-in deduplication. Every stated requirement, and it is AWS's recommended path.

C DynamoDB as a work queue

Builds a ticketing system from scratch: no deduplication, no console, no runbook integration, and a table to own for ever.

D Change Manager

Also closed to new customers, and it governs planned changes rather than tracking incidents. Wrong tool and unavailable.

THE SIGNAL

"Building this in 2026 and has never used Incident Manager" is not scene-setting. It is the clause that makes A impossible.

> An engineer runs a Run Command document across 800 instances to update a configuration file. A typo in the document corrupts the file, and the instances begin failing health checks. The engineer stops the command after noticing, but 800 instances are already affected.
>
> Management asks what configuration would have limited the damage, and what would keep the file correct from now on.

Which combination answers both questions?

A. Set an error threshold and concurrency limit on Run Command, and use a State Manager association to maintain the file

B. Run the command inside a maintenance window, and enable Inventory collection

C. Use Automation instead of Run Command, and enable Patch Manager compliance reporting

D. Target instances by instance ID rather than by tag, and enable Session Manager logging

◆ PAUSE AND DECIDE

Which combination answers both questions?

A Rate control, plus a State Manager association

Concurrency and an error threshold stop the rollout after a few failures. State Manager then holds the file at its correct content continuously.

B Maintenance window and Inventory

A window controls when it runs, not how many break. Inventory reports what is installed, and would not have caught a corrupted file's contents.

C Automation and patch compliance

Automation acts on AWS resources, not files inside the OS. Patch compliance has nothing to do with a configuration file.

D Target by instance ID

Listing 800 IDs by hand is worse operationally and would still have run on all of them. Session logging records shells, not Run Command.

THE SIGNAL

Rate control is the blast-radius answer; desired state is the drift answer. Two requirements, two different Systems Manager features.

The five things to carry forward

- **Agent, permissions, network.** Every "not a managed node" question is one of those three, and the network one needs three endpoints.
- **DHMC replaces per-instance profiles**, and needs IMDSv2 plus a recent agent.
- **No bastion, no keys, no inbound ports, session recorded.** All four phrases mean Session Manager.
- **Run Command acts inside the OS; Automation acts on AWS resources.** State Manager keeps either one true.
- **Rotation decides Parameter Store versus Secrets Manager.** Expiry is not rotation.

> ON THE EXAM
>
> Next: automated remediation and self-healing, which assembles modules 2 to 7 into systems that fix themselves.

MODULE 08 · DOMAIN 1 - MONITORING, LOGGING, ANALYSIS, REMEDIATION, AND PERFORMANCE OPTIMIZATION

Automated Remediation and Self-Healing

Wiring detection to action - and the newest tools in scope, AWS DevOps Agent and Kiro.

DOMAIN 1 of 5 EXAM WEIGHT 22% MODULE 8 of 35

admin@sthithapragna.com

Automate the fix you already understand. **Investigate** the one you do not. Confusing those two is how automation causes outages.

The remediation chain

01
Detect
An alarm, a Config rule, a CloudTrail event, a Health event.

›

02
Route
EventBridge, or the alarm action itself.

›

03
Decide
Guardrails: is this safe, is it in scope, has it already run?

›

04
Act
SSM Automation, Lambda, Step Functions, an EC2 action.

›

05
Record
An OpsItem, a notification, a CloudTrail entry.

ON THE EXAM

Most designs skip Decide and Record. Skipping Decide is how you get a remediation loop; skipping Record is how nobody learns anything.

Five paths from detection to action

PATH	RIGHT WHEN
Alarm with an EC2 action	Reboot, stop, terminate or recover one instance. No routing needed
Alarm with an Auto Scaling action	The fix is more capacity, or replacing an unhealthy instance
EventBridge to SSM Automation	A known multi-step fix on AWS resources. The workhorse
Config rule to SSM Automation	A resource has drifted from a compliance rule and must be put back
EventBridge to Step Functions	The fix needs waits, branching, or a human approval

ON THE EXAM

Lambda is missing on purpose. It is always available and rarely the best answer when a native path exists.

The simplest self-healing

- **StatusCheckFailed_System with the recover action.** Broken host, same instance, no code anywhere.
- **Auto Scaling health checks** replace an unhealthy instance automatically. EC2 checks by default, or ELB health checks.
- Turn on **ELB health checks in the group** so an instance that is running but not serving traffic is also replaced.
- These fix **symptoms, fast**. Neither one tells you why, so pair them with something that records the event.

> ON THE EXAM
>
> An Auto Scaling group with ELB health checks is self-healing with no automation to write. Reach for it before building anything.

EventBridge to SSM Automation: the workhorse

- The rule matches the event; the **runbook is a native target**. No Lambda function in between.
- Works from a **CloudWatch alarm state change**, a **CloudTrail API event**, or a **Health event**.
- Hundreds of **AWS-owned runbooks** already exist for common fixes, so often there is nothing to write.
- The runbook can carry **rate control and approval steps**, which a Lambda function would have to implement itself.

> ON THE EXAM
>
> "Automatically revert an unauthorised change" is a CloudTrail event to a runbook. This one pattern answers a lot of questions.

Config rules and remediation

- A **Config rule** evaluates resources against a desired configuration and marks them compliant or not.
- A **remediation action** attaches an SSM Automation runbook to the rule, set to **automatic** or **manual**.
- Automatic remediation supports **retries**, with a maximum attempt count over a time window.
- It needs a **remediation execution role** that the runbook assumes. A missing or under-scoped role is the usual failure.

> ON THE EXAM
>
> Config evaluates state, not events. It notices a resource is wrong even if the change that made it wrong was never seen.

Config remediation or EventBridge remediation?

CONFIG WHEN

State has drifted

- Continuous evaluation against a rule
- Catches resources that were already wrong
- Also catches changes made before the rule existed
- Slower: evaluation is periodic or change-triggered

EVENTBRIDGE WHEN

Something just happened

- Reacts to the API call itself
- Near real time, seconds not minutes
- Only sees events after the rule was created
- No compliance history or reporting

THE TIEBREAKER

Within one minute means EventBridge. Compliance reporting, or fixing what is already broken, means Config.

Prevention beats remediation

- **State Manager** re-applies desired state on a schedule, so drift is corrected before anyone notices it.
- **SCPs and IAM** stop the bad change from happening at all. Nothing to remediate.
- **CloudFormation drift detection** reports resources that no longer match their template.
- Remediation is a **detective control with an action attached**. It always runs after the damage.

> ON THE EXAM
>
> If a question offers a preventive option and a remediating one, and both meet the requirement, the preventive one is usually the answer.

Guardrails that keep automation safe

- **Idempotent.** Running the fix twice must be harmless, because it will run twice.
- **Bounded blast radius.** Rate control and error thresholds, so a bad fix stops after five resources rather than five hundred.
- **Approval steps** in a runbook for anything destructive or expensive.
- **Loop protection.** If the fix can re-trigger the detection, you have built a machine that bills you all weekend.

> ON THE EXAM
>
> The scariest failure is not the remediation that does not run. It is the one that runs correctly, repeatedly, against the wrong thing.

When not to automate

- **The root cause is unknown.** Restarting something that is failing for an unknown reason destroys the evidence.
- **The fix is destructive and irreversible.** Deleting data, terminating a stateful node, changing DNS.
- **The condition fires during deployments.** Automation that fights a deployment will win, and that is worse.
- In these cases automate the **investigation and the notification**, and leave the action to a human.

> ON THE EXAM
>
> Automating the gathering of evidence is nearly always safe. Automating the change is the part that needs judgement.

AWS Health Dashboard events

- Added to the in-scope service list in **exam guide v1.1, June 2026**.
- Publishes **scheduled changes, degradations and account notifications** as events on the default EventBridge bus.
- Examples: an **EC2 instance scheduled for retirement**, a certificate about to expire, an underlying host degradation.
- Organizational view aggregates health events for **every account** in the organisation.

> ON THE EXAM
>
> "Act before AWS retires the instance" is a Health event to a runbook. No alarm or metric will tell you that in advance.

AWS DevOps Agent: what it actually is

- An **autonomous operations agent**, generally available **31 March 2026**, built on **Amazon Bedrock AgentCore**.
- Three modes: **incident investigations**, **proactive reliability evaluations**, and **on-demand SRE tasks**.
- Triggered by a **webhook**: a CloudWatch alarm, or a third-party alert from PagerDuty, Datadog or ServiceNow.
- Investigates **AWS, Azure and on-premises** workloads. Non-AWS reach is through the Model Context Protocol.

> ON THE EXAM
>
> This is why Amazon Bedrock joined the in-scope list in v1.1. DevOps Agent is built on it, and the two arrived together.

How a DevOps Agent investigation runs

- It builds a **topology of your application** and correlates metrics, logs, traces, deployments and code changes.
- It forms **hypotheses**, tests each against telemetry, and narrows to a probable root cause with evidence.
- It produces a **mitigation plan for human approval**. It does not execute changes on its own.
- Every step is written to an **immutable audit journal** that the agent cannot edit, and it integrates with CloudTrail.

> ON THE EXAM
>
> The third point is the exam-relevant one. DevOps Agent shortens diagnosis, not approval. A human still decides.

Adopting DevOps Agent without losing control

- An **Agent Space** is the unit of setup. Admins configure it in the console; operators work in the DevOps Agent web app.
- Start in **recommendation-only mode**. The agent proposes and humans approve everything, so you can measure it before trusting it.
- Connects to **CloudWatch** plus third-party tools: Datadog, Dynatrace, New Relic, Splunk, GitHub, GitLab, ServiceNow, Slack.
- Billed **per second of agent working time**, not per seat. New customers get a free trial.

> ON THE EXAM
>
> The webhook is the integration point. A CloudWatch alarm action pointed at it starts an investigation automatically.

Runbook or DevOps Agent?

SSM AUTOMATION RUNBOOK

You know the answer

- Deterministic: this condition, that fix
- Runs in seconds, unattended
- Auditable and testable in advance
- Useless against a cause you did not anticipate

DEVOPS AGENT

You do not know the answer

- Correlates across tools to find a root cause
- Handles novel and multi-service failures
- Produces a plan, then waits for approval
- Diagnosis in minutes, not the fix itself

THE TIEBREAKER

Known failure, known fix, act now: runbook. Unknown cause, many services, need the reason: DevOps Agent.

Kiro, and being honest about where it fits

- An **agentic IDE**, generally available November 2025. Spec-driven: requirements, design and tasks as real files.
- **Agent hooks** run actions on events such as a file save or a commit. **Steering files** encode team standards persistently.
- For operations, it is where you **author** runbooks, IaC and Lambda functions - not where they run.
- The **Kiro Autonomous Agent** is still preview. Do not assume it in an answer.

> ON THE EXAM
>
> The exam guide lists Kiro under automating remediation. It builds the automation; SSM, EventBridge and Config run it.

Four AI services, and why they all arrived at once

SERVICE	WHAT IT IS FOR, IN ONE LINE
Amazon Bedrock	The foundation. DevOps Agent is built on Bedrock AgentCore
AWS DevOps Agent	Investigates incidents and proposes mitigations. Operations
Kiro	Agentic IDE where you author automation. Development
AWS Security Agent	Penetration testing and code scanning. Security. Being renamed to Continuum
Amazon Q Developer	Being retired. New sign-ups blocked 15 May 2026, IDE plugins end 30 April 2027

ON THE EXAM

Q Developer inside the AWS console and first-party experiences is NOT affected. Only the IDE plugins and paid subscriptions are retiring.

A compliance rule requires that every new EBS volume is encrypted. Several unencrypted volumes already exist from before the rule was written, and developers occasionally create more. The security team must be able to show auditors a compliance history for every volume.

Remediation should happen without a human, but the team accepts it may take a few minutes rather than seconds.

What should the team implement?

A An EventBridge rule on CreateVolume, targeting a Lambda function that checks and fixes encryption

B An AWS Config rule with an automatic SSM Automation remediation action

C A State Manager association running a Run Command document hourly

D An SCP denying ec2:CreateVolume when encryption is not specified

◆ PAUSE AND DECIDE

What should the team implement?

A EventBridge on CreateVolume plus Lambda

Only sees volumes created after the rule exists, so the pre-existing ones stay wrong. It also produces no compliance history.

B Config rule with automatic remediation

Evaluates state, so it finds the old volumes too, remediates without a human, and produces exactly the compliance history auditors want.

C State Manager association

State Manager acts on managed nodes through documents run on instances. It is not a mechanism for evaluating EBS volume properties.

D SCP denying unencrypted volumes

Genuinely good prevention, and it does nothing about the volumes that already exist. It also produces no compliance report.

THE SIGNAL

Two clauses decide it: existing resources must be fixed, and auditors need history. Only state-based evaluation gives you both.

> An application on EC2 becomes unresponsive roughly once a fortnight. Restarting the process always clears it. Nobody knows why it happens, and the team has been restarting it manually at whatever time it occurs.
>
> The engineering manager proposes an EventBridge rule that automatically restarts the process whenever the alarm fires, so nobody is woken up again.

What is the best response to this proposal?

A. Implement it as proposed. The fix is known and reliable

B. Automate evidence collection and notification first, and restart only after the root cause is understood

C. Replace the instance with an Auto Scaling group of one and let health checks handle it

D. Increase the alarm's datapoints to alarm so it fires less often

◆ PAUSE AND DECIDE

What is the best response to this proposal?

A Implement as proposed

The fix is known; the cause is not. An automatic restart destroys the state that would have explained a fortnightly failure.

B Collect evidence first, restart later

Capture a thread dump, memory and logs automatically, notify, then restart once the cause is understood. Nobody is woken and nothing is lost.

C Auto Scaling group of one

Automated restarting with extra steps. It hides the fault behind a replacement and still explains nothing.

D Raise datapoints to alarm

Makes detection slower and less sensitive. The application still hangs; you just hear about it later.

THE SIGNAL

"Nobody knows why it happens" is the clause. A reliable fix for an undiagnosed fault is a way of never diagnosing it.

> During a payment outage, four engineers spent three hours correlating CloudWatch metrics, RDS Performance Insights, application logs and a GitHub deployment history before finding that a schema migration had removed an index. Similar multi-service investigations happen most months.
>
> The company wants to shorten diagnosis. Compliance requires that a human approves every production change, and that the investigation is auditable.

What should the company adopt?

A. An SSM Automation runbook triggered by the payment latency alarm, which restarts the service

B. AWS DevOps Agent, triggered by the alarm, producing a root cause and a mitigation plan for approval

C. CloudWatch anomaly detection on every metric in the payment stack

D. Kiro, to generate remediation code for each failure as it occurs

◆ PAUSE AND DECIDE

What should the company adopt?

A Runbook that restarts the service

A deterministic fix for a cause nobody identified in advance. A restart would not have replaced a dropped index.

B DevOps Agent investigation

Correlates telemetry, logs and deployment history exactly as the engineers did, proposes a plan for approval, and journals every step immutably.

C Anomaly detection everywhere

Improves detection, which was never the problem. They knew within minutes that it was broken; they needed to know why.

D Kiro to generate remediation code

Kiro is a development environment. It writes automation ahead of time; it is not an incident response tool.

THE SIGNAL

Every clause fits: multi-tool correlation, novel causes, approval required, auditable. That is the DevOps Agent shape exactly.

AWS notifies an account that 30 EC2 instances are scheduled for retirement in 14 days because their underlying hardware is being decommissioned. The team only discovered this by chance, reading the console.

They want future notifications of this kind to automatically raise a tracked work item and start a runbook that stops and starts each affected instance during the next maintenance window.

What should the team configure?

A. A CloudWatch alarm on StatusCheckFailed_System with the recover action

B. An EventBridge rule on AWS Health events, targeting an SSM Automation runbook and creating an OpsItem

C. An AWS Config rule detecting instances scheduled for retirement

D. A daily Lambda function that calls DescribeInstanceStatus and emails the team

◆ PAUSE AND DECIDE

What should the team configure?

A. Status check alarm with recover

Fires when the host has already failed. Retirement is a scheduled future event, so nothing is failing yet and no alarm exists.

B. EventBridge on AWS Health events

Health publishes scheduled changes to the default bus. One rule gives both the tracked OpsItem and the runbook.

C. Config rule for retirement

Config evaluates resource configuration. A retirement notice is an AWS-side event, not a property of the instance.

D. Daily Lambda plus email

Polling rebuilt by hand, and an email is not a tracked work item or an automated fix. It answers neither requirement.

THE SIGNAL

Nothing is broken yet. That single observation eliminates every metric and alarm answer, because there is no metric for a future event.

The five things to carry forward

- **EventBridge to an SSM Automation runbook** is the default remediation pattern. No Lambda in the middle.
- **Config for drifted state, EventBridge for fresh events.** Existing resources or compliance history means Config.
- **Prefer prevention**, unless the scenario says resources are already wrong.
- **Unknown cause means investigate, not restart.** Automate evidence gathering; it is always safe.
- **DevOps Agent proposes, a human approves.** Runbooks act. AWS Health warns before anything breaks.

> ON THE EXAM
>
> Next: compute and EBS performance - instance families, burst credits, volume types and placement groups.

MODULE 09 · DOMAIN 1 - MONITORING, LOGGING, ANALYSIS, REMEDIATION, AND PERFORMANCE OPTIMIZATION

Compute and EBS Performance

Instance families, burst credits, volume types and the ceiling that is actually limiting you.

DOMAIN 1 of 5 EXAM WEIGHT 22% MODULE 9 of 35

admin@sthithapragna.com

Storage performance has **three ceilings**: the volume, the instance, and the file system. The lowest one wins, and it is usually not the one you configured.

Reading an instance type name

- **m7i.2xlarge**: family **m**, generation **7**, processor **i**, size **2xlarge**.
- Processor letters: **i** Intel, **a** AMD, **g** Graviton (AWS Arm). No letter means Intel on older generations.
- Extra letters: **n** higher network bandwidth, **d** local NVMe instance store, **e** extra memory or storage, **flex** lower cost for non-sustained load.
- A higher generation on the same family is almost always **cheaper per unit of work**, not just faster.

> ON THE EXAM
>
> Reading the name tells you most of what a question needs. m7i is general purpose, seventh generation, Intel. r7gd adds memory, Graviton and local NVMe.

Families, and what each is for

FAMILY	OPTIMISED FOR
T	Burstable. Low steady load with occasional spikes. Cheapest per hour
M	General purpose. Balanced CPU, memory and network. The default
C	Compute. High CPU per unit of memory: batch, encoding, HPC, web front ends
R, X, z	Memory. Databases, caches, in-memory analytics. X and z are extreme
I, D, H	Storage. Local NVMe or HDD, very high local IOPS: NoSQL, data warehouses
P, G, Inf, Trn	Accelerated. GPUs and AWS silicon for training and inference

ON THE EXAM

Questions rarely ask which family. They describe a workload and expect you to know that "in-memory cache" means R, not M.

Graviton, briefly

- AWS Arm-based processors. Generally **better price for the same performance** than comparable x86 instances.
- Well suited to **web servers, containers, microservices, caches and open-source databases**.
- It is a **different architecture**. Anything with compiled binaries or a licence tied to x86 needs checking first.
- Most managed services support it: RDS, ElastiCache, OpenSearch, Lambda, Fargate.

> ON THE EXAM
>
> "Reduce cost without reducing performance" on a Linux workload with no exotic dependencies is very often a Graviton answer.

How burstable instances work

- Each T instance has a **baseline CPU percentage**. Below it you **earn credits**; above it you **spend them**.
- One credit is **one vCPU running at 100 percent for one minute**.
- Baselines: **t3.micro 10%, t3.small and medium 20%, t3.large 30%, t3.xlarge and 2xlarge 40%.**
- **CPUCreditBalance** is the metric. When it reaches zero in standard mode, the instance is throttled to baseline.

> ON THE EXAM
>
> A T instance is a bet that your average load is below baseline. If the average is above it, you are on the wrong family.

Standard or unlimited mode?

STANDARD

Throttle when credits run out

- Performance drops to baseline, hard
- Never costs more than the hourly price
- T2 default. Recommended for Spot
- Predictable bill, unpredictable performance

UNLIMITED

Borrow, and maybe pay

- Bursts indefinitely using surplus credits
- Free if the 24-hour average is at or below baseline
- T3, T3a and T4g default
- Predictable performance, variable bill

THE TIEBREAKER

Unlimited averages over a rolling 24 hours. Sustained load above baseline is charged per vCPU-hour, and can cost more than a right-sized M instance.

Diagnosing a burstable instance

- **Application slow, CPU pinned at exactly the baseline?** Standard mode with an exhausted credit balance. Look at CPUCreditBalance.
- **Bill higher than expected on T3?** Unlimited mode paying for surplus. Look at CPUSurplusCreditBalance.
- **The fix is usually the family, not the mode.** Consistent load above baseline belongs on M or C.
- **T3 gets no launch credits.** Only T2 standard receives them, at 30 per vCPU.

> ON THE EXAM
>
> A CPU graph flat-lining at 20 percent is not a coincidence. That is a t3.medium at its baseline, throttled.

EBS volume types, current numbers

TYPE	KEY FIGURES
gp3	3,000 IOPS and 125 MiB/s baseline at any size. Up to 80,000 IOPS, 2,000 MiB/s, 64 TiB
gp2	3 IOPS per GiB, bursts to 3,000. Max 16,000 IOPS at 5,334 GiB, 16 TiB
io1	Up to 64,000 IOPS, 1,000 MiB/s. 50:1 IOPS per GiB
io2 Block Express	Up to 256,000 IOPS, 4,000 MiB/s, 64 TiB. 99.999% durability, sub-millisecond
st1	Throughput HDD. Up to 500 MiB/s but only 500 IOPS. Sequential only
sc1	Cold HDD. Up to 250 MiB/s, 250 IOPS. Cheapest per GiB

ON THE EXAM

HDD volumes cannot be boot volumes. Pair st1 or sc1 with a small gp3 root volume.

gp3 changed, and most study guides did not

- **Since September 2025:** gp3 supports up to **64 TiB**, **80,000 IOPS** and **2,000 MiB/s**.
- The widely published figures of **16 TiB, 16,000 IOPS and 1,000 MiB/s** are the old limits.
- The practical effect: workloads that used to require io1 or io2 now fit comfortably on **much cheaper gp3**.
- **gp3 has no burst.** What you provision is what you get, all the time. That is the point of it.

> ON THE EXAM
>
> If a question hinges on "gp3 cannot exceed 16,000 IOPS", that premise is out of date. Reach for io2 only above 80,000 IOPS or for the durability.

The ratio constraint nobody mentions

- **IOPS per GiB is capped by volume type**, so a small volume cannot be given large IOPS however much you pay.
- **gp3 is 500:1.** A 20 GiB volume tops out at 10,000 IOPS. Reaching 80,000 needs at least **160 GiB**.
- **io1 is 50:1.** Reaching 64,000 IOPS needs **1,280 GiB**. **io2 Block Express** needs **256 GiB** for 256,000.
- This is a **hard limit at provisioning time**, not a performance target you might miss.

> ON THE EXAM
>
> "We need 30,000 IOPS on a 40 GiB volume" is not a tuning problem. It is impossible, and the volume must be bigger.

gp2 or gp3?

GP2

Performance from size

- 3 IOPS per GiB, so you buy capacity to get speed
- Bursts to 3,000 IOPS using a credit bucket
- BurstBalance metric, and a cliff when it empties
- Previous generation

GP3

Performance you choose

- 3,000 IOPS and 125 MiB/s at any size, included
- Provision IOPS and throughput independently
- No burst and no credit cliff
- About 20 percent cheaper per GiB

THE TIEBREAKER

gp3 is cheaper and more predictable at almost every size. "Migrate gp2 to gp3" is a very common correct answer.

gp3 or io2 Block Express?

GP3 WHEN

Almost always

- Up to 80,000 IOPS and 2,000 MiB/s is enough
- 99.8 to 99.9 percent durability is acceptable
- Single-digit millisecond latency is fine
- Substantially cheaper

IO2 BLOCK EXPRESS WHEN

The exceptions

- Above 80,000 IOPS, or above 2,000 MiB/s
- Sub-millisecond latency: under 500 microseconds typical
- 99.999 percent durability required
- Multi-Attach across up to 16 instances

THE TIEBREAKER

Three specific triggers: extreme IOPS, sub-millisecond latency, or five-nines durability. Absent all three, gp3 is the answer.

When a hard disk is the right answer

- **st1 and sc1 are throughput devices.** Up to 500 and 250 MiB/s, but only 500 and 250 IOPS.
- Excellent for **large sequential reads and writes**: log processing, big data, Kafka segments, data warehouse scans.
- Terrible for anything random. Small scattered reads will crawl.
- **Neither can be a boot volume.** Pair them with a small gp3 root volume.

> ON THE EXAM
>
> About half the price of gp3 per GiB. At petabyte scale on sequential workloads, that difference is the entire argument.

The instance is often the real ceiling

- Every instance size has its own **EBS bandwidth and IOPS maximum**, independent of the volume attached.
- **Smaller sizes only burst to their headline number**, typically for about 30 minutes in 24 hours, then drop to roughly half.
- So a 4xlarge and an 8xlarge can quote the same maximum, and only the 8xlarge sustains it.
- Instance-level ceilings for gp3-attached storage reach about **260,000 IOPS and 12,500 MB/s** on the largest sizes.

> ON THE EXAM
>
> Provisioned 40,000 IOPS and seeing 20,000 after half an hour? That is the instance's EBS burst expiring, not the volume.

Instance store, and Elastic Volumes

- **Instance store** is local NVMe. The highest IOPS available, and **lost on stop or terminate**.
- Right for **caches, scratch, buffers and replicated data**. Never for anything you need to keep.
- **Elastic Volumes** change an EBS volume's size, type, IOPS or throughput **with no downtime and no detach**.
- You must wait about **6 hours** before modifying the same volume again. Volumes can grow but never shrink.

> ON THE EXAM
>
> "Change gp2 to gp3 without downtime" is Elastic Volumes. A snapshot and restore is the answer only if the volume must get smaller.

EBS metrics that tell you what is wrong

- **VolumeQueueLength.** Requests waiting. Persistently high means the volume cannot keep up.
- **BurstBalance.** gp2, st1 and sc1 only. Trending to zero predicts the performance cliff before it arrives.
- **VolumeThroughputPercentage** and **VolumeConsumedReadWriteOps** on provisioned IOPS volumes show how much you are using.
- **gp3 has no BurstBalance metric**, because it does not burst. Its absence is not a fault.

> ON THE EXAM
>
> Alarm on BurstBalance while you still have gp2 volumes. It is the only metric that warns you before the slowdown, rather than during it.

Placement groups

TYPE	WHAT IT DOES, AND WHEN
Cluster	Packs instances close together in one AZ. Lowest latency, highest throughput. HPC
Spread	Separate hardware, max 7 instances per AZ per group. Small critical sets
Partition	Groups on distinct racks, up to 7 partitions per AZ. HDFS, Cassandra, Kafka

ON THE EXAM

Cluster maximises performance and concentrates risk. Spread maximises isolation. Partition is the compromise for distributed data stores.

Network performance and right-sizing

- **ENA** is enhanced networking, standard on current instances. **EFA** adds OS-bypass for tightly coupled HPC and machine learning.
- **Compute Optimizer** analyses CloudWatch metrics and recommends instance types, EBS volumes, Auto Scaling groups and Lambda memory.
- It cannot see memory unless the **CloudWatch agent** is publishing it. Without that, recommendations are CPU and network only.
- Default lookback is **14 days**. Enhanced infrastructure metrics extends this to **3 months**, for a charge.

> ON THE EXAM
>
> Compute Optimizer and module one's memory lesson connect here. No agent means no memory metric, which means no memory-aware recommendation.

A reporting application on a t3.medium runs a nightly job. For the first 40 minutes it performs well, then slows dramatically and takes four more hours. CloudWatch shows CPUUtilization flat at exactly 20 percent for the rest of the run.

The instance is in standard credit mode. During the day the application is almost idle.

What is happening, and what is the best fix?

A. The EBS volume's BurstBalance is exhausted. Move to a larger gp2 volume

B. CPU credits are exhausted and the instance is throttled to baseline. Move the job to a compute-optimised instance

C. Switch the instance to unlimited mode and leave everything else unchanged

D. The instance's EBS burst has expired. Attach a second volume and stripe across both

◆ PAUSE AND DECIDE

What is happening, and what is the best fix?

A EBS BurstBalance exhausted

Would show as high VolumeQueueLength and slow I/O, not as CPU pinned at exactly the baseline figure.

B CPU credits exhausted; change family

20 percent is precisely t3.medium's baseline. A four-hour job above baseline is not a burstable workload.

C Switch to unlimited mode

The most tempting answer. It fixes the throttling and bills surplus credits for four hours every night, potentially above the cost of a right-sized instance.

D Instance EBS burst expired

Real behaviour, wrong symptom. That limits storage throughput and would not hold CPU flat at exactly 20 percent.

THE SIGNAL

"Flat at exactly 20 percent" is the giveaway. That is not a workload, it is a ceiling, and it is t3.medium's baseline.

> A database team requires 30,000 IOPS and sub-millisecond latency for a 40 GiB transactional volume. An engineer creates a gp3 volume of 40 GiB and attempts to provision 30,000 IOPS. The request is rejected.
>
> The team asks whether this is a quota that can be raised.

What should the engineer explain and recommend?

A. It is a soft quota. Request an increase for gp3 provisioned IOPS

B. gp3 is capped at 500 IOPS per GiB, so 40 GiB allows 20,000. Increase the volume size, and use io2 Block Express for sub-millisecond latency

C. gp3 cannot exceed 16,000 IOPS. Use io1 instead

D. Attach four 40 GiB gp3 volumes and stripe them with RAID 0

◆ PAUSE AND DECIDE

What should the engineer explain and recommend?

A Request a quota increase

The IOPS-per-GiB ratio is an architectural limit of the volume type, not an adjustable account quota. Support cannot raise it.

B Ratio limit; resize, and io2 for latency

Correct on both halves. 500:1 caps a 40 GiB gp3 at 20,000, and sub-millisecond latency is an io2 Block Express characteristic, not a gp3 one.

C gp3 cannot exceed 16,000

Out of date since September 2025. gp3 now reaches 80,000 IOPS, so the stated reason is wrong even though io1 would work.

D RAID 0 across four volumes

Would deliver the IOPS, and adds four failure domains, complexity and no latency guarantee. It also ignores why the request failed.

THE SIGNAL

Two requirements, and the latency one is decisive. gp3 is single-digit milliseconds; sub-millisecond is an io2 Block Express property.

> An analytics workload on an m6i.4xlarge reads large sequential files. Its 4 TiB gp3 volume is provisioned at 40,000 IOPS and 1,000 MiB/s. Throughput reaches about 1,000 MiB/s for the first half hour of each run, then settles at roughly half that for the remaining three hours.
>
> The volume's BurstBalance metric shows no data, and VolumeQueueLength is moderate throughout.

What is the most likely cause?

A. The gp3 volume's burst credits are exhausted

B. The instance's EBS bandwidth burst has expired, dropping it to its sustained baseline

C. The provisioned throughput setting is being throttled by the 500:1 IOPS ratio

D. The file system needs a larger block size

◆ PAUSE AND DECIDE

What is the most likely cause?

A gp3 burst credits exhausted

gp3 has no burst mechanism, which is exactly why BurstBalance shows no data. The absence of that metric disproves this option.

B Instance EBS burst expired

Smaller instance sizes hold their maximum EBS bandwidth for about 30 minutes in 24 hours, then drop to roughly half. The timing and the ratio both match.

C The 500:1 ratio

That ratio limits IOPS relative to capacity at provisioning time. A 4 TiB volume is nowhere near constrained, and it does not cause a mid-run drop.

D Larger block size

Might improve efficiency generally, but would not produce a clean halving exactly 30 minutes into every run.

THE SIGNAL

Half an hour, then half the throughput. Both numbers point at the instance, and the missing BurstBalance metric rules out the volume.

A finance team must reduce EC2 and EBS spend without reducing performance. The estate is 400 Linux instances running containerised Java microservices, plus 900 gp2 volumes, most of them under 200 GiB. There are no commercial software licences involved.

Compute Optimizer reports that most instances are over-provisioned on CPU, but reports no memory findings at all.

Which combination should the team implement?

A. Migrate the gp2 volumes to gp3, move suitable workloads to Graviton instances, and install the CloudWatch agent so memory recommendations become available

B. Migrate all volumes to io2 Block Express and buy Reserved Instances for the current sizes

C. Move all instances to T3 in unlimited mode and enlarge every gp2 volume

D. Enable enhanced infrastructure metrics and wait three months before acting

◆ PAUSE AND DECIDE

Which combination should the team implement?

A gp3, Graviton, and the agent

gp3 is cheaper and more predictable, containerised Linux Java is ideal for Graviton with no licence blockers, and the agent explains the missing memory findings.

B io2 Block Express plus RIs

io2 is far more expensive than gp2, so this increases storage cost. Reserving over-provisioned sizes locks in the waste for years.

C T3 unlimited everywhere

Microservices under steady load run above baseline continuously, so surplus credit charges apply constantly. Enlarging gp2 buys IOPS the expensive way.

D Wait three months

Delays every saving to improve data that is already conclusive on CPU. It is also the only option that changes nothing.

THE SIGNAL

"No memory findings at all" is not a Compute Optimizer failure. It is module one's lesson: no agent, no memory metric, nothing to analyse.

The five things to carry forward

- **Three ceilings: volume, instance, file system.** The instance is the one people forget, and it bursts for about 30 minutes.
- **gp3 now reaches 64 TiB, 80,000 IOPS and 2,000 MiB/s.** The old 16,000 figure is stale.
- **IOPS per GiB is a hard ratio.** A small volume cannot be given large IOPS at any price.
- **CPU flat at exactly the baseline means credits are gone.** The fix is usually the family, not the mode.
- **No CloudWatch agent means no memory recommendations** from Compute Optimizer.

> ON THE EXAM
>
> Next: storage and database performance - S3, EFS, FSx, S3 Files, RDS, DynamoDB and ElastiCache.

MODULE 10 · DOMAIN 1 - MONITORING, LOGGING, ANALYSIS, REMEDIATION, AND PERFORMANCE OPTIMIZATION

Storage and Database Performance

S3, EFS, FSx, S3 Files, RDS, Aurora, DynamoDB and ElastiCache - matching the shape of the workload.

DOMAIN 1 of 5 EXAM WEIGHT 22% MODULE 10 of 35

admin@sthithapragna.com

Every storage and database service has a **natural shape**. Matching the workload to the shape beats tuning the wrong service for months.

S3 request performance

- **5,500 GET or HEAD** and **3,500 PUT, COPY, POST or DELETE** per second, **per partitioned prefix**.
- There is **no limit on the number of prefixes**. Ten prefixes give you ten times the throughput.
- Spread keys across prefixes when you need scale, rather than requesting a quota increase. There is no quota to raise.
- A **date-first key pattern** such as 2026/09/05/ concentrates every write of the day into one prefix.

> ON THE EXAM
>
> S3 scales horizontally through prefixes, not vertically. The design decision is the key naming scheme, and it is hard to change later.

Moving large objects quickly

- **Multipart upload**: recommended above 100 MB, **required above 5 GB**. Up to 10,000 parts, 5 TB maximum object.
- Parts upload in parallel, and a failed part is retried alone rather than restarting the whole object.
- **Byte-range fetches** do the same in reverse, downloading ranges of one object in parallel.
- Incomplete multipart uploads **keep being billed**. A lifecycle rule to abort them after 7 days is standard practice.

> ON THE EXAM
>
> The abort-incomplete-multipart lifecycle rule is a genuine cost answer. Failed uploads leave parts that never appear in the object listing.

Transfer Acceleration or DataSync?

TRANSFER ACCELERATION

Long-distance uploads to S3

- Routes over the CloudFront edge network
- For clients geographically far from the bucket
- A property of the bucket, no agent needed
- Charged per GB transferred

DATASYNC

Bulk transfer between file systems

- On-premises NFS or SMB to S3, EFS or FSx
- Handles scheduling, verification and retries
- Agent-based for on-premises sources
- For migrations and recurring sync jobs

THE TIEBREAKER

One client uploading from far away: Transfer Acceleration. A file server's worth of data moving into AWS: DataSync.

S3 Express One Zone

- A storage class using **directory buckets**, in a **single Availability Zone** you choose, co-located with your compute.
- **Single-digit millisecond** first-byte latency, up to **10 times faster** than S3 Standard.
- Default **200,000 reads and 100,000 writes per second** per directory bucket, raisable to millions.
- **One AZ only.** Losing that AZ loses the data, so it is for hot working sets rather than the record copy.

> ON THE EXAM
>
> Higher storage price, much lower request price. It wins on workloads with huge numbers of small requests, not on quiet archives.

Shared file storage: which one

SERVICE	CHOOSE IT WHEN
Amazon EFS	Linux, NFS, many clients, elastic capacity. The default for Linux shared storage
Amazon S3 Files	You want an existing S3 bucket mounted as NFS, with S3 API access preserved
FSx for Windows File Server	SMB, Windows, Active Directory integration, NTFS ACLs
FSx for Lustre	HPC and machine learning at very high throughput, linked to an S3 bucket
FSx for NetApp ONTAP	Multi-protocol NFS and SMB, snapshots, dedup, existing ONTAP skills
FSx for OpenZFS	NFS with very low latency and ZFS snapshot semantics

ON THE EXAM

The protocol usually decides it. SMB and Active Directory means FSx for Windows. NFS on Linux means EFS unless something else is named.

Amazon S3 Files, added in exam guide v1.1

- Generally available **April 2026**. Mounts an S3 bucket as a shared **NFS v4.2** file system, and it is built on Amazon EFS.
- **Both access paths work at once.** The same data is reachable through the file system and through the S3 API.
- It **caches the active working set**; large reads of 1 MB and above stream from S3 at ordinary S3 GET cost.
- Named in **skill 1.3.4** alongside EFS and FSx, so it is explicitly examinable.

> ON THE EXAM
>
> "A legacy application needs a POSIX file path, but the data must stay in S3 for the analytics pipeline" is exactly this service.

EFS throughput and performance modes

- **Elastic throughput is the default**. It scales automatically and you pay for what you read and write. Best for spiky workloads.
- **Bursting** ties throughput to how much you store, using a credit balance. **Provisioned** fixes a rate you pay for regardless of use.
- **General Purpose** performance mode gives the lowest latency and is right roughly 90 percent of the time.
- **Max I/O is previous generation**, higher latency, and is **not supported with One Zone or with Elastic throughput**.

> ON THE EXAM
>
> Performance mode cannot be changed after creation. Throughput mode can. Getting the first one wrong means a new file system and a migration.

EFS storage classes and cost

- **Standard**, **Infrequent Access** and **Archive**. Lifecycle management moves files between them automatically.
- A typical policy: move to Infrequent Access after **30 days** without access, and to Archive after **90**.
- Reading from Infrequent Access or Archive incurs a **per-GB access charge**. Frequently read files should not be tiered down.
- **Regional** file systems span Availability Zones. **One Zone** is cheaper and loses data if that zone is lost.

> ON THE EXAM
>
> EFS lifecycle is the biggest single cost lever on a large file system, and the access charge is the reason not to set it too aggressively.

RDS monitoring: three separate layers

- **CloudWatch metrics** come from the hypervisor: CPU, connections, storage, IOPS. The outside view.
- **Enhanced Monitoring** runs an agent on the database host for **OS-level** metrics, as often as **1 second**. It writes to **CloudWatch Logs**.
- **CloudWatch Database Insights** shows **database load** by wait event and by SQL statement. The inside view.
- Enhanced Monitoring metrics are **not** ordinary CloudWatch metrics, so alarming on them means a metric filter first.

> ON THE EXAM
>
> "CPU is fine but the database is slow" needs the inside view. Only database load by wait event tells you what queries are waiting on.

Currency: Performance Insights has been replaced

- **RDS Performance Insights reached end of life in 2026** and the console now redirects to **CloudWatch Database Insights**.
- **Standard mode** preserves the old experience and pricing, with 7 days of detail included.
- **Advanced mode** adds **fleet-level monitoring, lock diagnostics and execution plan capture**, which Performance Insights never had.
- The **Performance Insights API still exists unchanged**, so CloudFormation and Terraform keep working.

> ON THE EXAM
>
> Every SOA course written before 2026 teaches "RDS Performance Insights". Learn the capability under both names, and expect Database Insights in the console.

RDS scaling levers

- **Storage autoscaling** grows the volume when free space runs low, up to a maximum you set. It never shrinks.
- **Modify the instance class** for CPU and memory. On Multi-AZ, the standby is done first, so downtime is one failover.
- **Parameter groups** tune the engine. **Static** parameters need a reboot; **dynamic** ones apply immediately.
- RDS storage is EBS underneath, so **gp3** and provisioned IOPS behave exactly as module nine described.

> ON THE EXAM
>
> Storage autoscaling prevents the storage-full outage. It does nothing for IOPS, which is a separate setting on the volume.

RDS Proxy

- A managed **connection pool** in front of RDS or Aurora. Applications connect to the proxy, not the database.
- Solves **connection exhaustion**, which is the classic Lambda-plus-RDS failure: thousands of functions, thousands of connections.
- Reduces **failover time** substantially, because the proxy holds client connections open while the database fails over.
- Integrates with **Secrets Manager** and supports **IAM authentication**, so credentials leave the application.

> ON THE EXAM
>
> "Too many connections" errors from a serverless front end is RDS Proxy. A bigger instance buys a few hundred more connections and delays the same failure.

Aurora, and Serverless v2

- Storage is a **shared cluster volume**, six copies across three AZs, growing automatically. Replicas read the same volume.
- Up to **15 read replicas** with typically sub-second replica lag, because there is no log shipping.
- **Serverless v2** scales in fine increments measured in **Aurora Capacity Units**, each roughly 2 GiB of memory.
- It can scale **down to zero ACUs** and pause, then resume on the next connection. That is the development-environment answer.

> ON THE EXAM
>
> Aurora replicas share one storage volume, so adding a replica adds no storage cost and almost no replication lag. RDS replicas each get their own copy.

DynamoDB: on-demand or provisioned?

ON-DEMAND WHEN

You cannot predict load

- New applications with no traffic history
- Spiky, seasonal or unpredictable patterns
- No capacity planning and no throttling from under-provisioning
- Higher price per request

PROVISIONED WHEN

Load is predictable

- Steady, well understood traffic
- Substantially cheaper per request at scale
- Pair with auto scaling for daily cycles
- Reserved capacity available for further savings

THE TIEBREAKER

You can switch between modes, but only once every 24 hours. That limit appears in questions about reacting to an unexpected event.

When DynamoDB throttles

- **A hot partition.** A partition supports about **3,000 read units and 1,000 write units** per second, whatever the table is provisioned for.
- **Adaptive capacity** shifts throughput toward busy partitions automatically, but it cannot fix a badly chosen partition key.
- **A throttled GSI throttles the base table's writes**, because writes must succeed on both.
- The fix is nearly always the **partition key design**: higher cardinality, or a write-sharding suffix.

> ON THE EXAM
>
> Throttling on a table that is well under its provisioned capacity is a hot partition. More capacity will not help; a better key will.

DAX or ElastiCache?

DAX WHEN

The database is DynamoDB

- Purpose-built DynamoDB cache, microsecond reads
- Write-through, so it is API-compatible
- Caches items and query results
- No application caching logic to write

ELASTICACHE WHEN

Anything else, or more control

- Caches RDS, Aurora, computed results, sessions
- Valkey and Redis, or Memcached
- You control eviction, TTL and structure
- Application code manages the cache

THE TIEBREAKER

DAX only accelerates DynamoDB, and needs almost no code change. ElastiCache works with anything, and needs code.

ElastiCache: which engine

- **Valkey and Redis**: rich data structures, persistence, replication, cluster mode, pub/sub, sorted sets. Valkey is the open-source continuation.
- **Memcached**: simple key-value, multi-threaded, no persistence and no replication.
- **Cluster mode enabled** shards data across node groups, which is how you scale writes as well as reads.
- Needing **persistence, replicas, failover or anything beyond strings** rules Memcached out immediately.

> ON THE EXAM
>
> Memcached is the answer only when the requirement is a simple, disposable cache that scales by adding identical nodes.

A legacy reporting application must read data files from a POSIX file path. The same files are already in an S3 bucket and are read continuously by an analytics pipeline that uses the S3 API. Copying the data would create two versions that drift.

The application runs on Linux EC2 instances and cannot be modified.

What should the team use?

A Amazon S3 Files, mounting the existing bucket as an NFS file system

B DataSync on a schedule, copying the bucket into an EFS file system

C FSx for Lustre linked to the bucket, with the application mounting Lustre

D Mountpoint for Amazon S3 on each instance

◆ PAUSE AND DECIDE

What should the team use?

A Amazon S3 Files

Purpose-built for this: one copy of the data, reachable through NFS and the S3 API at the same time. No drift and no application change.

B DataSync into EFS

Creates the second copy the requirement rules out. Scheduled sync means the two versions are different between runs.

C FSx for Lustre

Genuinely links to S3 and is built for HPC throughput, at HPC cost. It is heavy machinery for a reporting application.

D Mountpoint for S3

The strongest alternative, and it is not fully POSIX. Random writes and some file operations are unsupported, which is a risk for unmodifiable legacy code.

THE SIGNAL

"Copying would create two versions that drift" is the clause. Only simultaneous dual access to one copy satisfies it.

> A DynamoDB table is provisioned at 20,000 write capacity units and averages 6,000. Users report intermittent failures, and CloudWatch shows WriteThrottleEvents throughout the day. The partition key is a country code, and roughly 80 percent of traffic is from one country.
>
> The team has already tried increasing provisioned capacity to 30,000, which did not help.

What is the correct fix?

A. Switch the table to on-demand capacity mode

B. Redesign the partition key for higher cardinality, for example by adding a shard suffix

C. Add a DAX cluster in front of the table

D. Enable DynamoDB auto scaling with a higher maximum

◆ PAUSE AND DECIDE

What is the correct fix?

A **Switch to on-demand**

On-demand removes provisioning, not per-partition limits. One partition still caps at about 1,000 write units per second.

B **Redesign the partition key**

The traffic is concentrated on one partition key value. Only spreading writes across more partitions raises the effective ceiling.

C **Add DAX**

DAX caches reads. The throttling here is on writes, which pass straight through to the table.

D **Auto scaling with a higher maximum**

The same mistake the team already made, automated. More table capacity does not raise the per-partition limit.

THE SIGNAL

The scenario states the experiment and its result: more capacity did not help. That is the evidence that the limit is not table-level.

A serverless API on Lambda connects to an Aurora PostgreSQL cluster. Under load the functions return "too many connections" errors, although the database's CPU and memory are barely used. Scaling the writer to a larger instance class helped for a fortnight, then the errors returned.

A failover last month also caused eight minutes of errors while connections re-established.

What should the team implement?

A RDS Proxy in front of the Aurora cluster

B A larger instance class again, with storage autoscaling enabled

C Aurora Serverless v2 with a higher maximum ACU setting

D ElastiCache in front of the database to reduce query volume

◆ PAUSE AND DECIDE

What should the team implement?

A RDS Proxy

Pools connections so thousands of Lambda executions share a few, and holds client connections open through a failover. It answers both symptoms.

B Bigger instance again

The scenario already ran this experiment. A larger class raises the connection limit somewhat and delays the same failure.

C Serverless v2 with higher ACUs

Scales compute, and the database is not short of compute. CPU and memory are stated as barely used.

D ElastiCache

Reduces query volume, which helps a busy database. It does not change how many connections Lambda opens.

THE SIGNAL

Two symptoms, one cause. Connection exhaustion with idle CPU, plus slow failover recovery, are both what a connection proxy exists to fix.

> An ingestion pipeline writes about 4,000 small objects per second into an S3 bucket. Keys are formatted as logs/2026/09/05/HH-MM-SS-uuid.json. The team sees 503 Slow Down responses and rising retry rates, and has asked AWS Support to raise the bucket's request quota.
>
> Reads are performed later by a batch analytics job.

What should the team do?

A. Wait for the quota increase, since 4,000 writes per second exceeds the bucket limit

B. Change the key scheme so writes spread across many prefixes, for example by leading with a hash or a shard identifier

C. Enable S3 Transfer Acceleration on the bucket

D. Switch the bucket to the S3 Express One Zone storage class

◆ PAUSE AND DECIDE

What should the team do?

A Wait for a quota increase

There is no per-bucket request quota to raise. The 3,500 writes per second figure is per prefix, and prefixes are unlimited.

B Spread writes across prefixes

A date-first key puts every write of the day in one prefix. Leading with a hash or shard spreads them, and throughput scales with prefix count.

C Transfer Acceleration

Improves long-distance transfer speed. It does nothing about request rate, and the pipeline is presumably already in-Region.

D S3 Express One Zone

Would raise the ceiling substantially, at higher storage cost and single-AZ durability. It also does not fix a key design that will concentrate load anywhere.

THE SIGNAL

The team's support request is the distractor. Knowing which limits are per-prefix rather than per-bucket is what turns this from a quota problem into a design one.

The five things to carry forward

- **S3 scales by prefix, not by quota.** A date-first key scheme is a self-inflicted throughput cap.
- **Protocol picks the file service.** SMB means FSx for Windows; S3 Files mounts a bucket as NFS without copying it.
- **Performance Insights is now CloudWatch Database Insights.** Learn the capability under both names.
- **Connection errors with idle CPU means RDS Proxy.** A bigger instance delays the same failure.
- **Throttling below provisioned capacity is a hot partition.** Fix the key, not the capacity.

> ON THE EXAM
>
> Next: observability beyond CloudWatch - X-Ray, Managed Prometheus, Managed Grafana and the Health Dashboard.

MODULE 11 · DOMAIN 1 - MONITORING, LOGGING, ANALYSIS, REMEDIATION, AND PERFORMANCE OPTIMIZATION

Observability Beyond CloudWatch

X-Ray, OpenTelemetry, Application Signals, Managed Prometheus, Managed Grafana and the Health Dashboard.

DOMAIN 1 of 5 EXAM WEIGHT 22% MODULE 11 of 35

admin@sthithapragna.com

Three pillars, one question each. **Metrics**: is it healthy? **Logs**: what happened? **Traces**: where did the time go?

AWS X-Ray

- Follows one request across services using a **trace ID**, made of **segments** from each service and **subsegments** within them.
- The **service map** draws the call graph automatically, with latency and error rates on each edge.
- **Annotations are indexed** and can be filtered on. **Metadata is not indexed**, so it is for context you read, not search.
- **Sampling rules** control cost: by default one request per second plus a percentage of the rest.

> ON THE EXAM
>
> Annotation versus metadata is a favourite detail. If a question needs to filter traces by customer ID, that value must be an annotation.

Currency: the X-Ray SDKs are in maintenance mode

- **The X-Ray SDKs and the X-Ray daemon formally entered maintenance mode in 2026.** Security fixes only, no new features.
- **The X-Ray service itself is fully supported.** Console, trace processing and backend capabilities are unchanged.
- The instrumentation path forward is **OpenTelemetry, via the AWS Distro for OpenTelemetry**.
- Migration guides exist for Java, Python, Node.js, .NET, Go and Ruby, with both zero-code and manual instrumentation.

> ON THE EXAM
>
> Be precise about the boundary. The SDKs are frozen; the service is not. Do not tell an interviewer that X-Ray is deprecated.

AWS Distro for OpenTelemetry

- **ADOT** is AWS's supported build of the OpenTelemetry Collector. One agent collects **metrics, traces and logs**.
- Runs on **EKS, ECS, Lambda and EC2**, as a sidecar, a DaemonSet or a Lambda layer.
- Sends to **CloudWatch, X-Ray, Managed Service for Prometheus and OpenSearch**. Changing destination is a config change.
- **Vendor-neutral instrumentation.** Instrument once, and the backend becomes a decision you can revisit.

> ON THE EXAM
>
> "Avoid vendor lock-in" or "one agent for metrics and traces" points at ADOT. That is the whole design goal.

CloudWatch Application Signals

- **Auto-instruments** applications on EKS, ECS, EC2 and Lambda with no code change, using OpenTelemetry underneath.
- Produces standard **service-level metrics**: latency, faults, errors and call volume, plus a service map.
- Define **Service Level Objectives** against those metrics, and it tracks **error budget** burn for you.
- 2026 additions: **SLO recommendations** from historical performance, **service-level SLOs**, and an **SLO performance report**.

> ON THE EXAM
>
> X-Ray shows you one request. Application Signals shows you the service's health as a whole, and whether it is meeting its target.

X-Ray or Application Signals?

X-RAY WHEN

One request, in detail

- Where did the time go in this trace?
- Segment and subsegment level detail
- Filter by annotation to find specific traces
- Debugging a specific slow path

APPLICATION SIGNALS WHEN

One service, over time

- Is this service meeting its objective?
- Standard golden metrics, no code change
- SLOs and error budget tracking
- Ongoing operations rather than debugging

THE TIEBREAKER

They are layers, not alternatives. Application Signals gives you the health view; X-Ray gives you the trace behind a bad one.

Amazon Managed Service for Prometheus

- A managed, **Prometheus-compatible** metrics store. You create a **workspace** and write to it.
- Query with **PromQL**, the language teams already know from open-source Prometheus.
- Ingest via **remote write** from your own Prometheus, from ADOT, or with the **managed collector** that scrapes EKS for you.
- Includes **recording rules and alerting rules**, and an Alert Manager, so alerting need not go through CloudWatch.

> ON THE EXAM
>
> "We already use Prometheus and PromQL and do not want to rewrite our dashboards and alerts" is exactly this service.

Amazon Managed Grafana

- Managed **open-source Grafana**. Workspaces, dashboards, alerting, and authentication through **IAM Identity Center** or SAML.
- Its strength is **many data sources on one dashboard**: CloudWatch, Managed Prometheus, OpenSearch, X-Ray, Timestream, Athena, and third parties.
- Ideal for a **single pane across AWS and non-AWS** systems, including on-premises and other clouds.
- 2026: **Grafana 12.4** workspaces, customer managed KMS keys, and GovCloud availability.

> ON THE EXAM
>
> The decisive word is heterogeneous. CloudWatch dashboards graph AWS well; Grafana graphs AWS and everything else together.

When logs outgrow CloudWatch Logs

- **Amazon OpenSearch Service** is the answer for full-text search, long retention and complex log analytics at scale.
- Get logs there with a **subscription filter**, directly or through Amazon Data Firehose. Module four covered the mechanism.
- Its **Observability plugin** adds trace analytics, and it can now query Managed Prometheus metrics with native PromQL.
- It is a **cluster you size and pay for**. CloudWatch Logs is serverless, so do not reach for OpenSearch by default.

> ON THE EXAM
>
> Athena over exported logs in S3 is the cheaper alternative when queries are occasional rather than interactive.

CloudWatch dashboards or Managed Grafana?

CLOUDWATCH DASHBOARDS

AWS-native and simple

- No extra service to run or pay for
- Cross-account through the sink and link model
- Alarms and Logs Insights widgets built in
- Limited to CloudWatch data

MANAGED GRAFANA

Heterogeneous and rich

- Many data sources, AWS and not, on one panel
- Existing Grafana dashboards work unchanged
- Richer visualisations and templating
- Charged per active user per month

THE TIEBREAKER

Only AWS data and a small team: CloudWatch. Existing Grafana dashboards, or data from outside AWS: Managed Grafana.

Synthetics or RUM?

CLOUDWATCH SYNTHETICS

Robots, all the time

- Canaries run scripted journeys on a schedule
- Detects outages with no users present
- Blueprints: heartbeat, API, broken links, visual diff
- Screenshots and HAR files on failure

CLOUDWATCH RUM

Real users, real browsers

- A JavaScript snippet in the page
- Actual page load times, errors, device and geography
- Session replay for reproducing a reported issue
- Only shows what real traffic exercised

THE TIEBREAKER

Synthetics catches an outage at 3am on a page nobody visited. RUM tells you the checkout is slow on Android in Australia.

Synthetics canaries in practice

- A **canary** is a Node.js or Python script on a schedule. **Blueprints** cover heartbeat, API, broken links, visual diff and a recorder.
- Each run stores **screenshots, HAR files and logs** in S3, so a failure at 3am is still reproducible in the morning.
- Emits **SuccessPercent** and **Duration** metrics, so an alarm on a canary is an ordinary CloudWatch alarm.
- Canaries can run **inside a VPC**, which is how you monitor an internal application with no public endpoint.

> ON THE EXAM
>
> The visual monitoring blueprint compares screenshots against a baseline, catching a broken layout that returns HTTP 200 perfectly happily.

AWS Health Dashboard

- **Service health** is the public view of AWS service status. **Your account health** is personalised to your resources.
- Publishes events to the **default EventBridge bus**, so scheduled changes can trigger automation. Module eight used this.
- **Organizational view** aggregates health events across every account in the organisation.
- The **Health API** requires a **Business, Enterprise On-Ramp or Enterprise** Support plan. The console view does not.

> ON THE EXAM
>
> Added to the in-scope list in exam guide v1.1. It is the only service that warns you before anything has actually broken.

Where AWS is heading, in one slide

- **OpenTelemetry is the instrumentation standard.** X-Ray SDKs frozen, ADOT everywhere, OTLP ingestion into CloudWatch in preview.
- **PromQL is becoming a first-class CloudWatch language**, alongside Logs Insights QL and Metrics Insights.
- **Container Insights is moving to OpenTelemetry** collection for EKS.
- **CloudWatch Evidently reached end of life in October 2025.** If older material mentions it, that material is stale.

> ON THE EXAM
>
> You do not need preview features for the exam. You do need to recognise the direction, because it explains why answers now favour ADOT.

Which tool answers which question

THE QUESTION	THE TOOL
Is this service meeting its target?	Application Signals SLOs
Where did the time go in this request?	X-Ray
What did real customers experience?	CloudWatch RUM
Is the site up when nobody is looking?	CloudWatch Synthetics
We already have PromQL rules and dashboards	Managed Prometheus and Managed Grafana
One dashboard across AWS and elsewhere	Amazon Managed Grafana
Is AWS about to change something under us?	AWS Health Dashboard

ON THE EXAM

Read a scenario for the question being asked rather than the technology mentioned. The question maps to exactly one row far more often than not.

A team is instrumenting a new set of microservices on EKS in 2026. They want distributed tracing into X-Ray and metrics into CloudWatch, and they may later move metrics to a third-party backend without re-instrumenting.

An engineer proposes adding the AWS X-Ray SDK to each service, plus a separate metrics library.

What should the team do instead?

A Proceed with the X-Ray SDK, since X-Ray is the AWS-native tracing service

B Instrument with OpenTelemetry and deploy the ADOT Collector, exporting traces to X-Ray and metrics to CloudWatch

C Use the CloudWatch agent DaemonSet only, and rely on Container Insights for tracing

D Deploy Amazon Managed Service for Prometheus and use PromQL for traces

◆ PAUSE AND DECIDE

What should the team do instead?

A X-Ray SDK

The SDKs are in maintenance mode: security fixes only. Building new instrumentation on a frozen library, and it locks the backend in.

B OpenTelemetry with ADOT

One agent for traces and metrics, X-Ray and CloudWatch as exporters today, and a different backend later is a config change.

C CloudWatch agent only

Container Insights gives cluster and container metrics. It does not produce distributed traces, which is half the requirement.

D Prometheus for traces

Prometheus is a metrics system and PromQL is a metrics language. Neither handles traces.

THE SIGNAL

Two clauses: tracing into X-Ray, and a possible backend change later. ADOT satisfies both, and A satisfies neither well.

A company runs workloads on AWS, in an on-premises data centre, and in another cloud. Three teams each maintain their own dashboards. Leadership wants one dashboard showing service health across all three environments, and the on-premises team already has extensive Grafana dashboards backed by Prometheus.

The company wants to reuse existing work where possible.

What should the company implement?

A Recreate every dashboard in CloudWatch and use cross-account observability

B Amazon Managed Grafana, with CloudWatch, Amazon Managed Service for Prometheus and the existing Prometheus as data sources

C Export all metrics to S3 and build dashboards in Amazon QuickSight

D Install the CloudWatch agent on every on-premises and other-cloud server, and use CloudWatch dashboards

◆ PAUSE AND DECIDE

What should the company implement?

A Recreate in CloudWatch

Throws away the existing Grafana work the scenario asks to reuse, and cross-account observability is within AWS only.

B Managed Grafana with several data sources

One dashboard across all three environments, existing Grafana dashboards work unchanged, and the existing Prometheus stays a data source.

C S3 plus QuickSight

QuickSight is business intelligence over datasets, not operational monitoring. No alerting, no live metrics.

D CloudWatch agent everywhere

Technically possible, and it means re-plumbing every non-AWS system and abandoning the Grafana dashboards. Maximum effort, least reuse.

THE SIGNAL

"Heterogeneous" plus "reuse existing work" is the Managed Grafana signature. Both halves point the same way.

> An e-commerce checkout page is reported as slow by a small number of customers, mostly in one country. CloudWatch shows the load balancer and application servers well within normal latency, and Application Signals reports the checkout service is meeting its SLO.
>
> The team needs to understand what those customers actually experienced, including whether the page rendered correctly.

What should the team implement?

A CloudWatch Synthetics canaries running the checkout journey every minute

B CloudWatch RUM, with session replay enabled

C X-Ray with a sampling rule capturing 100 percent of checkout requests

D Enable detailed monitoring on the application servers

◆ PAUSE AND DECIDE

What should the team implement?

A Synthetics canaries

Canaries run from AWS on a schedule. They cannot reproduce a real customer's browser, device or network in a specific country.

B RUM with session replay

Reports what real browsers experienced, broken down by geography and device, and replay shows whether the page actually rendered.

C 100 percent X-Ray sampling

Traces stop at the server. Every server-side measurement is already normal, so more of the same data will not explain it.

D Detailed monitoring

One-minute instead of five-minute server metrics. The server metrics are already fine; frequency does not change that.

THE SIGNAL

Server-side is healthy and users are not. That gap is the definition of what RUM measures and nothing server-side can see.

> A platform team runs 40 EKS clusters and has years of Prometheus recording rules, alerting rules and Grafana dashboards written in PromQL. They want to stop running and scaling their own Prometheus servers, without rewriting any of that work.
>
> They also want a managed way to scrape the clusters rather than running their own collectors.

What should the team adopt?

A. Amazon Managed Service for Prometheus with its managed collector, queried from Amazon Managed Grafana

B. Convert all PromQL rules to CloudWatch metric math and Container Insights

C. CloudWatch Application Signals on every cluster

D. Self-managed Prometheus on EKS, with remote write to CloudWatch

◆ PAUSE AND DECIDE

What should the team adopt?

A Managed Prometheus plus managed collector

PromQL rules and Grafana dashboards carry over unchanged, the managed collector scrapes the clusters, and nothing is self-hosted.

B Convert PromQL to metric math

Exactly the rewrite the scenario forbids. Years of rules, translated by hand, with every translation a chance to introduce a bug.

C Application Signals

Excellent for standard service metrics with no code change, and it does not run PromQL or accept existing Prometheus rules.

D Self-managed Prometheus

Keeps the operational burden the scenario is trying to remove. They still run and scale Prometheus themselves.

THE SIGNAL

"Without rewriting" is the constraint. Only a PromQL-compatible store preserves recording rules, alerting rules and dashboards intact.

An internal HR application runs on private subnets with no public endpoint. It was unavailable for six hours over a weekend and nobody noticed until Monday morning. Server metrics stayed normal throughout, because the servers were healthy; a dependency the login page called had failed.

The team wants to detect this class of failure automatically, in a way that also proves the login journey works end to end.

What should the team implement?

A. A CloudWatch Synthetics canary running the login journey on a schedule, configured to run inside the VPC

B. CloudWatch RUM on the login page

C. A composite alarm across all server-level metrics for the application

D. An AWS Health Dashboard EventBridge rule for the application's Region

◆ PAUSE AND DECIDE

What should the team implement?

A VPC canary running the login journey

Exercises the whole journey on a schedule whether or not anyone is using it, and canaries can run inside the VPC to reach a private endpoint.

B RUM on the login page

RUM only reports what real users generate. At 2am on a Saturday there are no users, so it would have stayed silent exactly as everything else did.

C Composite alarm on server metrics

The scenario states server metrics were normal throughout. Combining metrics that were all healthy produces an alarm that stays in OK.

D Health Dashboard rule

Health reports AWS-side events. A failed application dependency is your problem, and AWS has nothing to report about it.

THE SIGNAL

"Nobody noticed until Monday" is the Synthetics signature. RUM needs users; a weekend outage is precisely when there are none.

The five things to carry forward

- **X-Ray SDKs and daemon are in maintenance mode; the X-Ray service is not.** New instrumentation uses ADOT.
- **Application Signals for service health and SLOs; X-Ray for one request.** Layers, not alternatives.
- **Existing PromQL and Grafana work means Managed Prometheus and Managed Grafana.** Rewriting is the wrong answer.
- **Synthetics is robots on a schedule; RUM is real browsers.** Healthy server plus unhappy users means RUM.
- **AWS Health warns before anything breaks**, and publishes to EventBridge.

> ON THE EXAM
>
> That completes domain one. Next: Auto Scaling in depth, and the start of domain two.

MODULE 12 · DOMAIN 2 - RELIABILITY AND BUSINESS CONTINUITY

Auto Scaling in Depth

Policies, health checks, warm pools, lifecycle hooks and instance refresh. The start of domain two.

DOMAIN 2 of 5 EXAM WEIGHT 22% MODULE 12 of 35

admin@sthithapragna.com

An Auto Scaling group is a **control loop**. Policies move desired capacity; everything else is about **timing** - how fast, how long to wait, when to judge health.

Launch templates, and the end of launch configurations

- **Launch templates are versioned.** You can roll forward and roll back, and an ASG points at a specific version or at Latest.
- **Launch configurations are legacy.** No new EC2 instance types since 1 January 2023.
- **Accounts created on or after 1 October 2024 cannot create one at all**, by console, CLI, API or CloudFormation.
- Only launch templates support **mixed instances, Spot alongside On-Demand, T unlimited mode, placement groups and IMDSv2 defaults**.

> ON THE EXAM
>
> If an option proposes a launch configuration, it is either wrong or describing a legacy estate. Templates are the only supported choice for new work.

The group itself

- **Minimum, maximum and desired capacity.** Policies change desired; the group never goes outside min and max.
- Spread across **multiple Availability Zones**, and the group rebalances automatically if one AZ becomes uneven.
- **AZ rebalancing launches before terminating**, so it can briefly exceed desired capacity. That is normal.
- **Group metrics are off by default.** GroupInServiceInstances and friends must be enabled, as module one covered.

> ON THE EXAM
>
> A scaling policy that appears to do nothing is often a group already at its maximum. Check the ceiling before the policy.

Health checks, and the grace period trap

- **EC2 health checks** are the default. They only confirm the instance is running and passing status checks.
- **ELB health checks** ask the load balancer whether the target is actually serving. Enable these for anything behind a load balancer.
- **Custom health checks** let your own code mark an instance unhealthy through SetInstanceHealth.
- **The health check grace period** is how long after launch before checks count. Too short and instances are killed mid-boot, forever.

> ON THE EXAM
>
> "Instances launch, terminate, and launch again in a loop" is a grace period shorter than the application's start-up time. Nothing else produces that pattern.

Five ways to scale

POLICY TYPE	USE IT WHEN
Target tracking	You know the metric value you want to hold. The default choice
Step scaling	You want different responses to different severities of breach
Simple scaling	Legacy. One adjustment, then a cooldown. Rarely the answer
Scheduled	Load changes by the clock: business hours, batch windows, a known event
Predictive	Recurring daily or weekly patterns, and scaling out reactively is too slow

ON THE EXAM

Target tracking unless the scenario gives you a reason not to. Scheduled and predictive can run alongside a dynamic policy, and normally should.

Target tracking or step scaling?

TARGET TRACKING

Hold this number

- Pick a metric and a target, such as 50% CPU
- AWS creates and manages the CloudWatch alarms
- Scales out and in to keep the metric near target
- Simplest to reason about and to review

STEP SCALING

Respond in proportion

- Steps defined by how far past the threshold you are
- Add 2 instances at 60%, add 6 at 85%
- You own the alarms and the steps
- For sharp, uneven load spikes

THE TIEBREAKER

Target tracking is a thermostat. Step scaling is a set of rules for how hard to react. If the scenario does not describe varying severity, it wants target tracking.

Target tracking, in detail

- Predefined metrics: **average CPU**, **average network in or out**, and **ALB request count per target**.
- Custom metrics and metric math work too, so you can track queue depth per instance or a business metric.
- You may have **several target tracking policies** at once. The group scales out to satisfy **whichever demands most**.
- **Disable scale-in** when something else, such as a scheduled policy, should own scaling down.

> ON THE EXAM
>
> ALBRequestCountPerTarget is the underrated one. It tracks demand directly rather than the CPU symptom of demand.

Cooldown or warm-up? A real distinction

- **Cooldown** is a pause after a scaling activity before another may start. It belongs to **simple scaling**, and defaults to 300 seconds.
- **Instance warm-up** is how long a new instance is excluded from the group's metrics while it starts up.
- **Target tracking and step scaling use warm-up, not cooldown.** They can keep scaling while earlier instances are still warming.
- Warm-up set too low means new instances drag the average down before they are ready, which causes **over-scaling then a sharp scale-in**.

> ON THE EXAM
>
> Cooldown blocks further scaling. Warm-up only hides a new instance's metrics. Confusing them produces either a sluggish group or a thrashing one.

Scheduled and predictive scaling

- **Scheduled actions** set minimum, maximum or desired capacity at a time you choose. Cron expressions support a **local time zone**, so daylight saving is handled.
- **Predictive scaling** forecasts up to 48 hours ahead from history and scales out **before** demand arrives.
- **Predictive scaling only scales out.** Pair it with target tracking, which handles scale-in and unexpected spikes.
- Start in **ForecastOnly** mode to review predictions, then switch to **ForecastAndScale**.

> ON THE EXAM
>
> "Traffic ramps faster than instances can boot" is predictive scaling. Reactive scaling cannot beat a spike that outruns your start-up time.

The instance lifecycle

01

Pending

Launching. A launch lifecycle hook holds it in Pending:Wait.

›

02

InService

Serving traffic. Health checks apply after the grace period.

›

03

Standby

Optional. Out of service for maintenance, not replaced.

›

04

Terminating

A termination hook holds it in Terminating:Wait.

›

05

Terminated

Or returned to the warm pool, if reuse is enabled.

ON THE EXAM

Hooks act at the two Wait states. Standby is the manual detour. Warm pool reuse replaces the final step.

Lifecycle hooks

- Pause an instance in **Pending:Wait** before it joins, or **Terminating:Wait** before it goes, while your automation does something.
- Launch uses: install software, register with a configuration system, warm a cache, pull data.
- Termination uses: drain connections, upload logs, deregister from a service, take a final snapshot.
- Default timeout is **one hour**. Call **CompleteLifecycleAction** when done, or send heartbeats to extend it.

> ON THE EXAM
>
> "Upload the logs before the instance disappears" is a termination lifecycle hook. Nothing else gives you a window after the decision to terminate.

Warm pools

- A pool of **pre-initialised instances** kept outside the group, usually **Stopped**, sometimes Running or Hibernated.
- On scale-out the group takes an instance from the pool instead of launching cold, so start-up drops from minutes to seconds.
- You pay for **storage but not compute** while instances sit stopped, which is why the pattern is affordable.
- Instances can be **returned to the pool on scale-in** rather than terminated, so the initialisation work is not repeated.

> ON THE EXAM
>
> Warm pools are for applications with long start-up: large AMIs, heavy runtimes, big caches to populate. They do nothing for a fast-booting service.

Warm pool or a better AMI?

WARM POOL WHEN

Initialisation cannot be baked

- Cache warming, data loading, licence checkout
- Work that depends on current data
- Start-up is genuinely minutes
- Adds a pool to manage and pay storage for

GOLDEN AMI WHEN

Initialisation is installation

- Installing packages, runtimes, agents, application code
- EC2 Image Builder produces it on a schedule
- No ongoing cost beyond snapshot storage
- Fix start-up once, for every future instance

THE TIEBREAKER

Ask what the boot time is spent on. Installing software belongs in the image. Loading today's data does not.

Instance refresh

- Rolling replacement of every instance in the group, to pick up a new launch template version or AMI.
- **MinHealthyPercentage** controls how much capacity may be lost. Setting it to **100** gives **launch-before-terminate**.
- **Checkpoints** pause at chosen percentages with a bake time, so you can watch before continuing.
- **Skip matching** leaves instances that already have the desired configuration alone. **Alarm-based auto-rollback** reverses a bad rollout.

> ON THE EXAM
>
> Scaling policies and health checks stay active during an instance refresh, unlike the old rolling update. The group can still scale mid-deployment.

New: instance refresh as a CloudFormation update policy

- **Announced 29 July 2026.** The **AutoScalingInstanceRefresh** update policy on AWS::AutoScaling::AutoScalingGroup.
- CloudFormation triggers a refresh automatically when you change the launch template or mixed instances policy.
- It is **mutually exclusive with AutoScalingRollingUpdate**, the older policy, which suspends scaling and ignores your maintenance policy.
- Brings checkpoints, bake time, launch-before-terminate and alarm rollback into the stack update itself. No extra cost.

> ON THE EXAM
>
> Before this, teams either accepted rigid rolling updates or ran refreshes outside the stack and created drift. This closes that gap.

Which instance gets terminated

- **Default policy**: balance across Availability Zones first, then oldest launch template or configuration, then closest to the next billing hour.
- Alternatives include **OldestInstance**, **NewestInstance**, **AllocationStrategy** for Spot, or a custom ordered list.
- **Instance scale-in protection** exempts specific instances, for example one running a long job.
- **Standby** removes an instance from service for maintenance without the group replacing it.

> ON THE EXAM
>
> "A long-running job was killed by a scale-in" has two answers: scale-in protection for the instance, or a termination lifecycle hook to let it finish.

Suspending processes

- Individual group processes can be **suspended and resumed**: Launch, Terminate, HealthCheck, ReplaceUnhealthy, AZRebalance, AlarmNotification, ScheduledActions, AddToLoadBalancer, InstanceRefresh.
- Suspending **Terminate** and **ReplaceUnhealthy** during an investigation stops the group destroying the evidence.
- **Suspending Launch also blocks scale-out**, and suspending AddToLoadBalancer means new instances never receive traffic.
- **AWS itself suspends processes** when a group repeatedly fails to launch. A group that has stopped scaling may be suspended, not misconfigured.

> ON THE EXAM
>
> "The group has stopped scaling and nobody changed anything" is worth checking here before anywhere else.

Mixed instances and Spot

- A **mixed instances policy** lets one group use several instance types, and On-Demand and Spot together.
- Set an **On-Demand base capacity** for the part that must never be interrupted, then a percentage split above that.
- **price-capacity-optimized** is the recommended Spot allocation strategy: cheap, from the deepest capacity pools.
- **Attribute-based instance type selection** expresses requirements as vCPU and memory ranges, so new instance types are used automatically.

> ON THE EXAM
>
> Capacity Rebalancing acts on a Spot rebalance recommendation, replacing an instance before it is interrupted rather than after.

Application Auto Scaling is a different service

- **EC2 Auto Scaling** scales EC2 instances in an Auto Scaling group. That is all it does.
- **Application Auto Scaling** scales everything else: **ECS services, DynamoDB tables and indexes, Aurora replicas, Lambda provisioned concurrency, SageMaker endpoints, Spot Fleet**.
- Same policy concepts: target tracking, step scaling and scheduled scaling.
- **Aurora Serverless v2 and DynamoDB on-demand scale themselves**, and need no policy at all.

> ON THE EXAM
>
> "Scale the ECS service when the queue grows" is Application Auto Scaling, not EC2 Auto Scaling. Getting the service name right matters here.

"The group did not scale" checklist

- **Is desired already at maximum?** The policy fires, requests more, and the ceiling refuses. Most common cause.
- **Are processes suspended?** Either by you, or automatically after repeated launch failures.
- **Is the alarm actually in ALARM?** Module two applies: M out of N, missing data, and a period shorter than the publishing interval.
- **Is capacity available?** An instance type with no capacity in that AZ, or an exhausted subnet with no free IP addresses, fails silently at launch.

> ON THE EXAM
>
> Scaling activity history on the group records every attempt and its failure reason. Read that before theorising.

A Java application takes about four minutes to start and pass its health check. An Auto Scaling group behind an ALB uses ELB health checks with a health check grace period of 120 seconds.

Instances launch, are marked unhealthy, are terminated and replaced. The group never reaches its desired capacity, and this repeats indefinitely.

What is the cause and the fix?

A The ALB target group's health check threshold is too strict. Increase the unhealthy threshold

B The health check grace period is shorter than start-up time. Increase it beyond four minutes

C The instance warm-up is too low. Increase it to 300 seconds

D Switch the group to EC2 health checks instead of ELB health checks

◆ PAUSE AND DECIDE

What is the cause and the fix?

A. Raise the unhealthy threshold

Would delay the verdict a little, and 120 seconds against a four-minute start-up is not a threshold that tuning can rescue.

B. Increase the grace period

The grace period is precisely how long after launch before health checks count. It is set to half the application's start-up time.

C. Increase instance warm-up

Warm-up excludes a new instance from scaling metrics. It has no effect on whether health checks terminate it.

D. Use EC2 health checks

Hides the problem by no longer checking whether the application serves traffic. The loop stops and real failures stop being detected too.

THE SIGNAL

Launch, terminate, launch again, forever, is the signature of a grace period shorter than start-up. Two numbers in the setup are all you need.

> An online retailer sees traffic climb steeply from 08:00 every weekday, reaching four times its overnight level within twenty minutes. Instances take six minutes to become useful. Target tracking on CPU is configured, and customers still see errors between 08:00 and 08:30 every day.
>
> The pattern has been consistent for over a year.

What should the team add?

A. Lower the target tracking CPU target from 60 percent to 40 percent

B. Predictive scaling in ForecastAndScale mode, keeping target tracking for unexpected spikes

C. A step scaling policy with more aggressive steps

D. Increase the group's maximum capacity

◆ PAUSE AND DECIDE

What should the team add?

A. Lower the CPU target

Reacts sooner and still only after load arrives, then runs excess capacity for the other twenty-two hours of the day.

B. Predictive scaling plus target tracking

A year of consistent history is exactly what the forecast needs, and capacity arrives before 08:00 rather than six minutes after demand.

C. More aggressive step scaling

Still reactive. However aggressive the steps, instances still need six minutes, and the ramp is twenty minutes long.

D. Increase maximum capacity

Raises the ceiling. Nothing in the scenario says the ceiling was reached; the problem is arrival time, not the limit.

THE SIGNAL

Every reactive answer loses the same race: six minutes to boot against a twenty-minute ramp. Only scaling before 08:00 wins it.

A video processing fleet runs jobs that take up to 40 minutes. During scale-in, instances are terminated mid-job and the work is lost. The team also needs each instance to upload its logs to S3 before it disappears.

Jobs cannot be made resumable in the near term.

Which combination should the team implement?

A. Instance scale-in protection while a job is running, plus a termination lifecycle hook to upload logs

B. Set the termination policy to NewestInstance and increase the cooldown

C. Disable scale-in on the target tracking policy and increase the health check grace period

D. Move the instances to a warm pool when they finish a job

◆ PAUSE AND DECIDE

Which combination should the team implement?

A Scale-in protection plus a termination hook

Protection stops a busy instance being chosen at all; the hook gives a window after the decision to upload logs. Two requirements, two mechanisms.

B NewestInstance plus cooldown

Changes which instance dies, not whether it is busy. The newest instance can be mid-job just as easily.

C Disable scale-in

Solves it by never scaling in, so the fleet only grows. It also does nothing about uploading logs.

D Warm pool on job completion

Warm pools accelerate scale-out. They are not a mechanism for protecting running work or for draining it.

THE SIGNAL

Two requirements again: do not kill busy instances, and do something before an instance dies. Protection answers the first, a lifecycle hook the second.

A team must deploy a new AMI to a 60-instance Auto Scaling group during business hours. Capacity must never drop below current levels. The rollout must pause for review after the first quarter, and reverse itself automatically if error rates rise.

The group is defined in CloudFormation and the team wants the stack to stay consistent with reality.

What should the team use?

A The AutoScalingRollingUpdate CloudFormation update policy with MaxBatchSize set to 15

B The AutoScalingInstanceRefresh update policy with MinHealthyPercentage 100, checkpoints and an alarm specification

C Run an instance refresh manually from the console after updating the stack

D Create a second Auto Scaling group with the new AMI and shift the ALB weighting

◆ PAUSE AND DECIDE

What should the team use?

A AutoScalingRollingUpdate

No checkpoints, no alarm rollback, and it terminates before launching, so capacity dips. It also suspends scaling policies during the update.

B AutoScalingInstanceRefresh policy

MinHealthyPercentage 100 gives launch-before-terminate, checkpoints give the review pause, and the alarm specification gives automatic rollback, all inside the stack.

C Manual refresh after the stack update

Gets the deployment right and breaks the requirement that the stack stays consistent. The refresh happens outside CloudFormation's knowledge.

D Second group with ALB weighting

A valid blue/green pattern, and it doubles the fleet, duplicates the stack and is far more machinery than the requirements ask for.

THE SIGNAL

Four requirements, and the July 2026 update policy is the only option that meets all four without leaving CloudFormation.

An Auto Scaling group stopped scaling out three days ago. CPU regularly exceeds the target tracking threshold and the alarm is firing correctly, but desired capacity never changes. The group is at 12 instances with a maximum of 40.

Nobody has modified the group. Scaling activity history shows repeated failed launches ending in an error about available IP addresses.

What is the most likely explanation?

A The subnets are exhausted, launches failed repeatedly, and Auto Scaling has suspended the Launch process

B The target tracking policy needs its cooldown reduced

C The group has reached its maximum capacity

D The health check grace period is too short

◆ PAUSE AND DECIDE

What is the most likely explanation?

A Subnet exhaustion, then automatic suspension

The activity history names the cause, and AWS suspends processes after repeated launch failures. That is why it stopped rather than merely failing.

B Reduce the cooldown

Cooldown belongs to simple scaling and would delay scaling, not prevent it entirely for three days.

C At maximum capacity

The first thing to check, and the scenario has already ruled it out: 12 instances against a maximum of 40.

D Grace period too short

That produces a launch-terminate loop with instances constantly appearing. Here nothing launches at all.

THE SIGNAL

Two facts are handed to you: 12 of 40, and an IP address error in the activity history. Together they eliminate everything except suspension.

The five things to carry forward

- **Launch, terminate, repeat forever** is a health check grace period shorter than start-up time.
- **Cooldown blocks scaling; warm-up hides a new instance's metrics.** Target tracking and step scaling use warm-up.
- **Reactive scaling cannot beat a ramp faster than boot time.** That is what predictive scaling is for, and it only scales out.
- **Scale-in protection stops the choice; a lifecycle hook creates a window after it.**
- **AutoScalingInstanceRefresh (July 2026)** brings checkpoints, launch-before-terminate and alarm rollback into CloudFormation.

> ON THE EXAM
>
> Next: load balancing, and the error codes that tell you exactly which part of the path is broken.

MODULE 13 · DOMAIN 2 - RELIABILITY AND BUSINESS CONTINUITY

Load Balancing and Its Error Codes

ALB, NLB, target groups – and reading 502, 503 and 504 as a map of where the request died.

DOMAIN 2 of 5 EXAM WEIGHT 22% MODULE 13 of 35

admin@sthithapragna.com

The load balancer sits in the middle of three hops. **The error code tells you which hop broke**, before you look at anything else.

Four load balancers

TYPE	WHAT IT IS FOR
Application Load Balancer	Layer 7. HTTP and HTTPS. Content-based routing, authentication, WAF
Network Load Balancer	Layer 4. TCP, UDP, TLS. Static IPs, extreme throughput, source IP preserved
Gateway Load Balancer	Layer 3. Transparently inserts third-party appliances using GENEVE on port 6081
Classic Load Balancer	Previous generation. Migration target, not a choice for new work

ON THE EXAM

Only ALB parses HTTP, so only ALB can route on a path or a header. Only NLB gives you a static IP. Only GWLB inserts a firewall transparently.

ALB or NLB?

ALB WHEN

HTTP intelligence

- Route by path, host, header, query or method
- Authenticate with Cognito or OIDC
- WAF attaches directly
- Lambda and IP targets, weighted target groups

NLB WHEN

Speed and addresses

- Static IP per AZ, or bring your own Elastic IP
- Non-HTTP protocols: TCP, UDP, TLS
- Client source IP preserved to the target
- Millions of requests per second, ultra-low latency

THE TIEBREAKER

Need static IPs and path routing? Put an ALB behind an NLB, using an ALB-type target group. That is a supported pattern, not a hack.

Listeners, rules and targets

- A **listener** watches a port and protocol. **Rules** are evaluated in **priority order**, and the **default rule** catches everything else.
- Conditions: **host header, path, HTTP header, query string, source IP, HTTP method**. Actions: forward, redirect, fixed response, authenticate.
- Target types: **instance**, **IP**, **Lambda**, and **ALB** (as a target of an NLB).
- **IP targets are required** for targets outside the VPC, reachable over peering, VPN or Direct Connect.

> ON THE EXAM
>
> Rules are first match wins, in priority order. A broad rule at priority 1 silently shadows every specific rule beneath it.

Target group health checks

- Protocol, port, path, **interval**, **timeout**, **healthy threshold**, **unhealthy threshold**, and a **success matcher** such as 200 or 200-299.
- The health check runs from the load balancer, so the **target's security group must allow the load balancer's security group** on the health check port.
- Point the check at a **dedicated endpoint** that verifies dependencies, not at the home page. A 200 from a static page proves nothing.
- **Target group health** lets you set a minimum healthy count or percentage, and what the load balancer does when that is not met.

> ON THE EXAM
>
> A health check path that touches the database turns a database outage into an empty target group. A path that touches nothing hides real failures. Choose deliberately.

The error codes, as a map

CODE	WHAT IT MEANS
400	Malformed request from the client. Not your target's fault
403	Blocked by AWS WAF, or by a rule returning a fixed response
460	The client closed the connection before the load balancer could respond
463	X-Forwarded-For header contained more than 30 IP addresses
500	An internal error inside the load balancer itself
502	The target returned a malformed response, or closed the connection
503	No healthy targets. The target group is empty or all targets failed
504	The target did not respond within the idle timeout

ON THE EXAM

460 is the one people misdiagnose. It means the client gave up, so look at client-side timeouts, not at your targets.

Where each code comes from

01

Client

460: the client gave up first. 400: it sent something malformed.

02

Load balancer

403 from WAF. 500 from the load balancer itself.

03

Target selection

503: there was no healthy target to choose.

04

Target connection

502: the target answered badly or hung up.

05

Target response

504: nothing came back before the idle timeout.

ON THE EXAM

Walk the path left to right and the code tells you exactly where to stop and look.

502, 503 and 504 in detail

- **502 Bad Gateway.** A target exists and answered wrongly: it crashed mid-response, returned malformed headers, or closed the connection.
- **503 Service Unavailable.** No healthy target. Check target health, the health check path, and the target security group.
- **504 Gateway Timeout.** The target was too slow. Default ALB idle timeout is **60 seconds**.
- For 504, raise the idle timeout **only if the work genuinely takes that long**. Otherwise fix the slow query, or make the work asynchronous.

> ON THE EXAM
>
> 502 means someone answered badly. 503 means nobody answered. 504 means nobody answered in time. That one sentence separates all three.

Draining, stickiness and slow start

- **Deregistration delay**, also called connection draining, defaults to **300 seconds**. In-flight requests finish before the target is removed.
- Too long and deployments crawl. Too short and users see errors mid-request. Match it to your longest normal request.
- **Stickiness**: a load balancer cookie for a duration, or an **application-based cookie** the target controls. NLB uses source IP.
- **Slow start** ramps traffic to a new target over 30 to 900 seconds, so a cold cache or JIT warm-up does not get hit at full rate.

> ON THE EXAM
>
> Slow start and Auto Scaling's instance warm-up solve the same problem at different layers. Slow start controls traffic; warm-up controls metrics.

Cross-zone load balancing, and its bill

- **ALB: always on** at the load balancer level, and **free**. It can be turned off per target group.
- **NLB: off by default**, and when enabled you are **charged for inter-AZ data transfer**.
- With it off, each zone's load balancer node only sends to targets in **its own zone**. Uneven target counts mean uneven load.
- Off is not a bug. It keeps traffic zonal, which lowers cost and limits the blast radius of a failed zone.

> ON THE EXAM
>
> "Two instances in one AZ are overloaded while eight in another are idle" behind an NLB is cross-zone load balancing being off. That is the default.

TLS and authentication

- Terminate TLS at the load balancer with a certificate from **ACM**. ACM certificates **renew themselves** when used this way.
- **SNI** lets one listener serve many certificates, so multiple domains share one load balancer.
- **Security policies** choose which TLS versions and ciphers are accepted. This is how you drop TLS 1.0 and 1.1.
- ALB can **authenticate users** via Cognito or any OIDC provider, and supports **mutual TLS** and **JWT validation** for machine-to-machine traffic.

> ON THE EXAM
>
> "The certificate expired and nobody renewed it" cannot happen with an ACM certificate attached to a load balancer. That is a strong signal for ACM.

What the load balancer can tell you

- **Access logs** to S3 record every request: client, target, latencies broken into three parts, and the status codes.
- Both the **ELB status code** and the **target status code** are logged, which separates a load balancer 502 from a target's own 500.
- **Connection logs** record TLS handshakes and client connections, including failures that never became a request.
- **Access logs are off by default**, and they are **not real time**. Files are delivered every 5 minutes.

> ON THE EXAM
>
> TargetResponseTime, plus target_status_code in the access log, is how you prove the slowness is the application rather than the network.

How targets are chosen

- **Round robin** is the ALB default, and it ignores how busy each target already is.
- **Least outstanding requests** sends to the target with fewest in-flight requests. Better when request cost varies a lot.
- **Weighted random** supports **automatic target weights**, which shifts traffic away from targets showing elevated errors.
- **Weighted target groups** split traffic between two groups by percentage, which is how you do blue/green and canary on an ALB.

> ON THE EXAM
>
> Weighted target groups are the ALB deployment mechanism. Module 22 uses them for blue/green; note the name now.

New: ALB Target Optimizer

- **Generally available 20 November 2025.** Enforces a **maximum number of concurrent requests per target**.
- Built for **compute-intensive, low-concurrency workloads** such as model inference, where a target may handle only one to five requests at a time.
- Enabled with a **target control port** on a new target group, plus an **AWS-provided agent** running on the targets.
- Traffic through such a target group **generates more LCU usage**, so it is not free.

> ON THE EXAM
>
> Without it, a hot-spotted target receives more than it can process, clients get errors and retry, and the retries add load. Target Optimizer removes that loop.

Capacity, and getting out of a bad zone

- **Load Balancer Capacity Unit Reservation** pre-provisions a minimum capacity ahead of a known surge. ALB and NLB.
- Consider it when you expect traffic to **more than double in under five minutes**: a ticket sale, a product launch, a broadcast.
- **Zonal shift** moves traffic away from one impaired Availability Zone, through Amazon Application Recovery Controller.
- **Zonal autoshift** lets AWS do it automatically when it detects a problem. Both are **off by default**.

> ON THE EXAM
>
> Load balancers scale automatically for organic growth. Reservation exists for the step change that outruns the scaling rate.

NLB and GWLB specifics

- **NLB gives a static IP per Availability Zone**, and you can attach your own Elastic IP. That is what firewall allow-lists need.
- **Source IP is preserved** to instance targets, so the application sees the real client address without X-Forwarded-For.
- **NLB TCP idle timeout is 350 seconds** and connections idle longer are dropped. Enable TCP keepalive for long-lived connections.
- **GWLB** uses **GENEVE on port 6081** to send traffic transparently through third-party firewalls and IDS appliances.

> ON THE EXAM
>
> "Our partner will only allow-list fixed IP addresses" is an NLB or Global Accelerator answer. An ALB's addresses change.

> After a deployment, an ALB begins returning HTTP 503 to all requests. The Auto Scaling group shows six instances in the InService state and CloudWatch shows normal CPU on all of them. Application logs show the service started successfully on each instance.
>
> The target group shows all six targets as unhealthy, with the reason 'Health checks failed'.

What is the most likely cause?

A. The ALB's idle timeout is too low for the application

B. The health check path or port changed, or the target security group does not allow the ALB security group on the health check port

C. Cross-zone load balancing is disabled on the target group

D. The deregistration delay is set too high

◆ PAUSE AND DECIDE

What is the most likely cause?

A Idle timeout too low

An idle timeout problem produces 504, not 503. The codes are not interchangeable, and that is the point of the table.

B Health check path, port or security group

503 means no healthy target. The application is running, so the check itself is failing: wrong path, wrong port, or the ALB cannot reach it.

C Cross-zone disabled

Causes uneven distribution, not universal failure. It is also always on for an ALB at the load balancer level.

D Deregistration delay too high

Affects how long removed targets keep draining. It cannot make registered, running targets fail their health checks.

THE SIGNAL

503 plus a running application means the health check disagrees with reality. Path, port, and the security group between ALB and target, in that order.

A reporting endpoint behind an ALB runs a query that legitimately takes about 90 seconds. Users receive HTTP 504 after roughly a minute. The targets are healthy and the query completes successfully when run directly on the instance.

The business wants the report to keep working, and the engineering team wants to avoid long-running HTTP requests.

Which two actions together are the best response? (Choose two.)

A. Increase the ALB idle timeout above 90 seconds as an immediate mitigation

B. Re-architect the report to run asynchronously, returning a job ID and polling for the result

C. Enable stickiness on the target group

D. Switch the target group's algorithm to least outstanding requests

◆ PAUSE AND DECIDE

Which two actions together are the best response?

A Raise the idle timeout

The default 60 seconds is exactly where the failure occurs. Raising it restores the report today, which the business asked for.

B Make the report asynchronous

Removes the long-lived HTTP request entirely, which is what the engineering team asked for. The proper fix, on a longer timescale.

C Enable stickiness

Binds a client to one target. It has nothing to do with how long a single request takes.

D Least outstanding requests

Changes which target is chosen. The chosen target is not the problem; the duration of the work is.

THE SIGNAL

Two stakeholders, two answers. "Choose two" questions often pair an immediate mitigation with the structural fix, and both are required.

An NLB fronts a fleet spread across three Availability Zones: 2 instances in eu-west-1a, 8 in eu-west-1b, and 8 in eu-west-1c. The two instances in eu-west-1a run consistently at 90 percent CPU while the others sit near 25 percent.

Health checks pass on every instance and the Auto Scaling group is configured across all three zones.

What explains this, and what is the trade-off in fixing it?

A Cross-zone load balancing is off by default on an NLB. Enabling it evens the load, but adds inter-AZ data transfer charges

B The target group is using round robin. Switch to least outstanding requests

C Sticky sessions are pinning clients to eu-west-1a

D The Auto Scaling group needs AZ rebalancing enabled

◆ PAUSE AND DECIDE

What explains this, and what is the trade-off in fixing it?

A Cross-zone off by default on NLB

Each zone's node serves only its own zone, so 2 instances absorb a third of the traffic. Enabling it is correct, and inter-AZ transfer is charged.

B Least outstanding requests

An ALB algorithm. It also would not help, because the imbalance is between zones rather than within one.

C Sticky sessions

Would concentrate individual clients, not produce a clean per-zone split matching the instance counts.

D ASG AZ rebalancing

The genuinely useful alternative: even out instance counts per zone. It fixes the symptom without the transfer cost, but the scenario asks what explains it.

THE SIGNAL

The numbers give it away. Three zones, traffic split three ways, and one zone holding a fifth of the instances. That is zonal routing, not an algorithm.

> A partner will only connect to the company's API if the endpoint has fixed IP addresses that they can add to their firewall. The API also needs path-based routing, because /v1 and /v2 are served by different target groups, and it must sit behind AWS WAF.
>
> The team has proposed giving the ALB an Elastic IP.

What should the team do?

A. Assign Elastic IPs to the ALB as proposed

B. Put an NLB in front of the ALB, using an ALB-type target group, and attach Elastic IPs to the NLB

C. Replace the ALB with an NLB and move path routing into the application

D. Publish the ALB's current IP addresses to the partner and update them when they change

◆ PAUSE AND DECIDE

What should the team do?

A Elastic IPs on the ALB

Not possible. An ALB does not support Elastic IPs; its addresses are managed by AWS and change as it scales.

B NLB in front of the ALB

The NLB supplies the static addresses, the ALB keeps path routing and WAF. The ALB-type target group is the supported way to join them.

C NLB only, routing in the app

Gets static IPs by throwing away path routing and WAF, since WAF does not attach to an NLB. It solves one requirement by breaking two.

D Publish and update addresses

The addresses change without warning as the ALB scales, so this is an outage waiting to be scheduled by AWS rather than by you.

THE SIGNAL

Three requirements that no single load balancer satisfies. The layered pattern exists precisely for this combination.

A machine learning inference service behind an ALB returns intermittent 502 errors under load. Each target can process about two requests concurrently before its queue builds and the process is killed by its own watchdog. Adding targets reduces but does not eliminate the errors, and clients retry, which increases load further.

The team wants to stop targets being sent more work than they can handle.

What should the team implement?

A ALB Target Optimizer, capping concurrent requests per target

B Increase the ALB idle timeout so slow requests are not cut off

C Enable slow start on the target group

D Switch the routing algorithm to round robin

◆ PAUSE AND DECIDE

What should the team implement?

A ALB Target Optimizer

Built for exactly this: low-concurrency compute-intensive targets. Caps concurrent requests per target, so a target is never over-committed.

B Raise the idle timeout

Addresses 504, not 502. The targets are dying, not being cut off, so a longer wait changes nothing.

C Slow start

Ramps traffic to a newly healthy target. Once the target is warm it receives full load again, and the problem returns.

D Round robin

The default, and it is unaware of concurrency. It is the algorithm that allows the over-commitment in the first place.

THE SIGNAL

The retry loop is the giveaway. Overloaded targets error, clients retry, retries add load. Only capping concurrency breaks that cycle.

The five things to carry forward

- **502 answered badly, 503 nobody answered, 504 nobody answered in time.** 460 means the client gave up.
- **503 with a running application** is the health check: path, port, or the security group between ALB and target.
- **Cross-zone is always on and free for ALB, off and charged for NLB.** Uneven zonal load is that default.
- **Static IPs plus path routing means NLB in front of ALB.** An ALB cannot take an Elastic IP.
- **Target Optimizer caps concurrency per target**, for compute-heavy workloads that handle only a few requests at once.

> ON THE EXAM
>
> Next: Multi-AZ, failover and health checks - RDS, Aurora, EFS and Route 53.

MODULE 14 · DOMAIN 2 - RELIABILITY AND BUSINESS CONTINUITY

Multi-AZ, Failover and Health Checks

RDS, Aurora, EFS and Route 53 - what survives an Availability Zone failure, and how long it takes.

DOMAIN 2 of 5 EXAM WEIGHT 22% MODULE 14 of 35

admin@sthithapragna.com

Multi-AZ answers one question: **does the service survive losing a whole Availability Zone?** Everything else is how fast, and what breaks meanwhile.

admin@sthithapragna.com

Multi-AZ DB instance or Multi-AZ DB cluster?

MULTI-AZ DB INSTANCE

One hidden standby

- One synchronous standby in another AZ
- The standby serves NO traffic at all
- Failover typically 60 to 120 seconds
- All engines, including Oracle and SQL Server

MULTI-AZ DB CLUSTER

Two readable standbys

- One writer plus two readable standbys
- Spread across three Availability Zones
- Failover typically under 35 seconds
- MySQL and PostgreSQL only

THE TIEBREAKER

The classic Multi-AZ standby is invisible. You cannot read from it, connect to it, or take a backup from it in the way people expect.

Multi-AZ or a read replica?

MULTI-AZ IS FOR

Availability

- Synchronous replication, no data loss on failover
- Automatic failover, same endpoint
- Standby in a different AZ, same Region
- Does not improve read performance at all

READ REPLICAS ARE FOR

Scale

- Asynchronous replication, so replica lag exists
- Manual promotion, and a different endpoint
- Same AZ, another AZ, or another Region
- Offloads read traffic from the primary

THE TIEBREAKER

This is the single most confused pair in the RDS syllabus. Availability versus scale, synchronous versus asynchronous, automatic versus manual.

What actually happens during an RDS failover

- The **DNS endpoint is repointed** at the standby. Your connection string never changes.
- **Existing connections are dropped.** The application must reconnect, so connection pools and retry logic matter.
- Triggers: AZ outage, primary instance failure, storage failure, instance type change, or OS patching.
- **Reboot with failover** forces one deliberately. That is how you test, and how you apply some changes with one controlled outage.

> ON THE EXAM
>
> Applications that cache the resolved IP address rather than honouring DNS TTL will keep failing after the database has recovered. That is an application bug, not an AWS one.

Aurora is built differently

- Storage is a **shared cluster volume**, six copies across three AZs. Compute instances attach to it rather than owning a copy.
- Up to **15 replicas**, all reading the same volume, so replica lag is typically well under a second.
- **Failover promotes a replica**, typically in under 30 seconds. With no replica, Aurora creates a new instance, which takes far longer.
- **Failover priority tiers 0 to 15** decide who is promoted. Lowest tier first; on a tie, the largest instance.

> ON THE EXAM
>
> An Aurora cluster with no replica is not highly available. The storage survives, but there is nothing to promote, so recovery means launching a new instance.

Aurora endpoints

- **Cluster endpoint** always points at the current writer. Use it for writes, and it follows failover automatically.
- **Reader endpoint** load-balances across all available replicas. Use it for read traffic.
- **Custom endpoints** group a chosen subset, for example sending reporting queries only to two large replicas.
- **Instance endpoints** address one specific instance. Useful for diagnosis, dangerous in application configuration.

> ON THE EXAM
>
> An application pointed at an instance endpoint will not follow a failover. That is the Aurora equivalent of hard-coding an IP address.

Failover times, side by side

DEPLOYMENT	TYPICAL FAILOVER
RDS Multi-AZ DB instance	60 to 120 seconds
RDS Multi-AZ DB cluster	Under 35 seconds
Aurora, with at least one replica	Under 30 seconds
Aurora, no replica	Minutes. A new instance must be created
Read replica promotion	Manual, and it is not a failover mechanism

ON THE EXAM

Replica lag bounds failover time. A promoted instance must apply outstanding transactions before it can accept writes.

EFS and the rest of the stack

- **EFS Regional** stores data across multiple AZs and survives losing one. **EFS One Zone** does not, and is cheaper.
- Clients mount through an **AZ-specific mount target**. Create one in every subnet your instances use.
- A **NAT gateway lives in one AZ**. One NAT gateway means an AZ failure removes outbound internet for every private subnet routed to it.
- **ElastiCache** needs Multi-AZ with automatic failover enabled, and replicas in other zones, to survive a zone loss.

> ON THE EXAM
>
> The database being Multi-AZ does not make the system Multi-AZ. A single NAT gateway or a single-AZ cache defeats the whole design quietly.

Static stability

- A statically stable system **keeps working during a failure without needing to change anything**.
- Pre-provision capacity in every AZ to handle the loss of one, rather than relying on scaling out during the incident.
- Recovery that depends on the control plane is fragile, because control planes are often the busiest thing during a large event.
- Three AZs at 50 percent utilisation survives losing one at 75 percent. Two AZs at 50 percent becomes 100 percent, with no headroom.

> ON THE EXAM
>
> "It will just scale out when the AZ fails" assumes launching instances works during the exact moment everyone else is also launching instances.

Route 53 health checks: three kinds

- **Endpoint health checks** probe an HTTP, HTTPS or TCP endpoint from checkers around the world.
- **CloudWatch alarm health checks** take their state from an alarm. This is how you health-check something private.
- **Calculated health checks** combine other health checks with boolean logic: healthy if at least 2 of 3 are healthy.
- **Endpoint checks run from the public internet**, so they cannot reach anything inside a VPC. That is not a configuration problem.

> ON THE EXAM
>
> "Health check a private resource" always means the CloudWatch alarm type. There is no way to make a public checker reach a private subnet.

How fast DNS failover really is

- **Request interval**: 30 seconds standard, or 10 seconds fast. **Failure threshold**: 1 to 10, default 3.
- Detection time is roughly **threshold multiplied by interval**. Then add the record's **TTL**.
- Then add **resolver caching** and **client-side connection pinning**, which you do not control.
- Standard 30-second checks with threshold 3 and a 60-second TTL can mean **two to four minutes** of user-visible failure.

> ON THE EXAM
>
> "Our TTL is 60 seconds so failover takes a minute" is true at the authoritative layer and misleading as a promise to users.

Health check details that surprise people

- When you specify an endpoint **by domain name**, Route 53 health checks use **IPv4 only**. An IPv6-only domain fails DNS resolution.
- An HTTPS health check confirms a response, not certificate hygiene. Pair it with a **separate ACM certificate expiry alarm**.
- **String matching** checks the first 5,120 bytes of the body, so a health page can assert on real content rather than just a 200.
- For weighted, latency and multivalue answers, **if every record is unhealthy Route 53 responds as though all were healthy**.

> ON THE EXAM
>
> That last behaviour is deliberate. Returning nothing helps nobody, so Route 53 would rather hand back a possibly-broken answer than no answer at all.

Evaluate target health, or a separate health check?

EVALUATE TARGET HEALTH

For alias records

- Alias to an ALB, NLB, S3 website or another record
- Uses the target's own health directly
- No health check to create, and no monthly charge
- Simplest correct answer for an ALB alias

A SEPARATE HEALTH CHECK

When you need more

- Non-alias records, or an IP address target
- Custom path, string matching, or a fast interval
- Calculated logic across several signals
- CloudWatch alarm type, for private resources

THE TIEBREAKER

For an alias to a load balancer, evaluate target health is usually right and often forgotten. It inherits health that already exists.

Three different things called a health check

- **Auto Scaling health check** decides whether to **replace an instance**. EC2 status checks, ELB health, or custom.
- **Target group health check** decides whether to **send a request to a target**. Removes it from rotation; does not terminate it.
- **Route 53 health check** decides **which DNS answer to return**. Operates at the record level, not the instance level.
- They chain: an ELB health check can feed the ASG's decision, and Route 53 can evaluate the load balancer's health.

> ON THE EXAM
>
> Replace it, stop sending to it, or stop resolving to it. Three different verbs, and a scenario always tells you which one it wants.

Failover routing in practice

- **Failover routing** uses a primary and a secondary record. The secondary is returned when the primary's health check fails.
- **Active-passive**: the secondary is a standby site. **Active-active**: use weighted or latency routing with health checks on every record.
- A common secondary is a **static S3 or CloudFront maintenance page**, so users see something honest rather than a timeout.
- Test failover deliberately. A secondary that has never served traffic is a hypothesis, not a plan.

> ON THE EXAM
>
> Failover routing needs exactly one primary and one secondary. For more than two targets, or for load sharing, use weighted or latency routing with health checks.

An RDS for PostgreSQL database is a Multi-AZ deployment. Reporting queries are slowing the application, and a developer proposes pointing the reporting tool at the standby instance to offload the reads.

The team also wants failover to complete faster than the current 90 seconds, and reporting must not affect the writer.

What should the team do?

A Point the reporting tool at the standby, as proposed

B Convert to a Multi-AZ DB cluster, and send reporting to the reader endpoint

C Create a read replica and leave the Multi-AZ deployment as it is

D Increase the instance class of the primary

◆ PAUSE AND DECIDE

What should the team do?

A Read from the standby

Impossible. The classic Multi-AZ standby serves no traffic at all and has no endpoint to connect to.

B Multi-AZ DB cluster

Two readable standbys give the read offload, and failover drops from 60-120 seconds to under 35. Both requirements, one change.

C Read replica alongside Multi-AZ

The strongest alternative: it does solve the reporting offload. It does nothing about the 90-second failover requirement.

D Bigger primary instance

Buys headroom while leaving reporting on the writer. It also does not change failover time at all.

THE SIGNAL

Two requirements again. Reporting offload alone would allow option C; the failover requirement is what forces the cluster.

A team configures Route 53 failover routing between two Regions. The primary record has a health check against an internal application load balancer in a private subnet. The health check has been permanently unhealthy since it was created, so all traffic goes to the secondary Region.

The load balancer and its targets are confirmed healthy.

What is the cause?

A The failure threshold is set too low

B Route 53 endpoint health checkers run on the public internet and cannot reach a private endpoint

C The record's TTL is too high

D Failover routing requires a calculated health check

◆ PAUSE AND DECIDE

What is the cause?

A Failure threshold too low

Would cause flapping on intermittent problems, not a check that has never once succeeded since creation.

B Public checkers cannot reach a private endpoint

Endpoint health checks originate from the public internet. An internal load balancer has no public address, so every probe fails.

C TTL too high

TTL affects how long clients cache an answer. It has no bearing on whether a health check succeeds.

D Calculated check required

Invented requirement. Failover routing works with any health check type, including none at all.

THE SIGNAL

Never healthy since creation is the signal. Intermittent problems flap; a structural impossibility fails from the first probe.

An architecture runs across three Availability Zones: EC2 instances in private subnets in each, an Auto Scaling group spanning all three, an ALB across all three, and an RDS Multi-AZ database. There is a single NAT gateway in the first AZ.

During a simulated failure of the first AZ, instances in the other two zones lose the ability to reach an external payment API, and the application fails.

What should be changed?

A Deploy a NAT gateway in each Availability Zone, with each private subnet's route table pointing to its local one

B Add a second ALB in another Availability Zone

C Convert the RDS deployment to a Multi-AZ DB cluster

D Enable cross-zone load balancing on the ALB

◆ PAUSE AND DECIDE

What should be changed?

A A NAT gateway per AZ

A NAT gateway lives in one AZ. Routing all private subnets through one makes that zone a single point of failure for all outbound traffic.

B A second ALB

An ALB already spans the zones you enable. The load balancer was never the failing component here.

C Multi-AZ DB cluster

Improves database failover time. The database was already Multi-AZ and is not what broke.

D Cross-zone load balancing

Always on for an ALB anyway, and it concerns inbound distribution rather than outbound internet access.

THE SIGNAL

The scenario carefully lists everything that IS multi-AZ, then names one thing that is not. That asymmetry is the whole question.

> A team needs user-visible failover to a secondary Region within 60 seconds. They use Route 53 failover routing with a standard 30-second health check interval. The failure threshold is 3, and the record TTL is 300 seconds.
>
> Testing shows failover taking between four and six minutes.

Which combination brings this closest to the target? (Choose two.)

A. Change the health check to a 10-second fast interval and reduce the failure threshold to 2

B. Reduce the record TTL from 300 seconds to 60 seconds or lower

C. Switch from failover routing to weighted routing

D. Enable evaluate target health on the primary record

◆ PAUSE AND DECIDE

Which combination brings this closest to the target?

A Fast interval, threshold 2

Detection drops from 90 seconds to 20. The single largest saving available on the detection side.

B Reduce the TTL

300 seconds of caching dominates everything else. No detection improvement matters while clients cache the old answer for five minutes.

C Weighted routing

Changes how traffic is distributed, not how quickly a failure is noticed or how long answers are cached.

D Evaluate target health

Removes the need for a separate health check on an alias. It does not make detection faster, and here a custom check is wanted.

THE SIGNAL

Failover time is detection plus caching. Fixing only one leaves the other dominating, which is why this is a "choose two".

An Aurora PostgreSQL cluster runs a single writer instance with no replicas. The team believes it is highly available because Aurora stores six copies of the data across three Availability Zones.

During an AZ failure the database was unavailable for several minutes, and the team wants to know why.

What explains this, and what is the fix?

A Aurora storage is not multi-AZ; enable Multi-AZ on the cluster

B With no replica there is nothing to promote, so Aurora had to create a new instance. Add at least one replica in another AZ

C The cluster endpoint had cached the failed instance's IP address; reduce the TTL

D Aurora Serverless v2 is required for automatic failover

◆ PAUSE AND DECIDE

What explains this, and what is the fix?

A Storage is not multi-AZ

The team's premise is correct: the storage genuinely is spread across three AZs. Durability was never the problem.

B No replica to promote

Storage survived; compute did not. Fast failover means promoting an existing replica, and there was none to promote.

C Endpoint cached an IP

The cluster endpoint follows failover. The delay was creating a writer, not resolving to one.

D Serverless v2 required

Invented requirement. Provisioned Aurora fails over automatically, provided there is a replica available.

THE SIGNAL

Durable is not the same as available. The data was safe throughout; there was simply no compute able to serve it.

The five things to carry forward

- **Multi-AZ is availability, replicas are scale.** The classic standby is invisible and serves nothing.
- **60-120 seconds for a Multi-AZ instance, under 35 for a Multi-AZ cluster, under 30 for Aurora with a replica.**
- **Aurora with no replica is not highly available.** Durable storage is not the same as available compute.
- **Route 53 endpoint checks cannot reach private resources.** Use the CloudWatch alarm type.
- **Replace it, stop sending to it, stop resolving to it.** Auto Scaling, target group, and Route 53 health checks.

> ON THE EXAM
>
> Next: scaling the data tier - read replicas, Aurora Serverless v2, DynamoDB modes and caching.

MODULE 15 · DOMAIN 2 - RELIABILITY AND BUSINESS CONTINUITY

Scaling the Data Tier

Read replicas, Aurora serverless, DynamoDB capacity, ElastiCache - and why on-demand still throttles.

DOMAIN 2 of 5 EXAM WEIGHT 22% MODULE 15 of 35

admin@sthithapragna.com

Three axes: make it **bigger**, add **more of them**, or make the work **smaller**. Most scaling questions are asking which axis, not which service.

Vertical and horizontal, for databases

- **Vertical**: a bigger instance class. Simple, effective, and it requires a restart or a failover, plus it has a maximum size.
- **Horizontal reads**: read replicas. Straightforward, and it introduces replication lag your application must tolerate.
- **Horizontal writes** are the hard one. A relational database has one writer, so writes scale vertically or by sharding the application.
- On Multi-AZ, resizing modifies the **standby first**, then fails over, so the disruption is one failover rather than an outage.

> ON THE EXAM
>
> "Scale writes" in a relational database is usually a design question, not a configuration one. Reads are easy; writes are not.

Read replicas in depth

- Asynchronous replication from the source. Up to **15 for Aurora**, and typically **5 per source** for RDS engines.
- Can live in the **same AZ, another AZ, or another Region**. Cross-Region replicas also serve as a disaster recovery position.
- **Promotion is manual** and breaks replication permanently. The promoted replica becomes an independent database.
- A replica can itself be **Multi-AZ**, and RDS replicas can be **cascaded**, which adds lag at every hop.

> ON THE EXAM
>
> Applications must be changed to use a replica. Read traffic does not move there by itself, which is the difference from an Aurora reader endpoint.

Replica lag, and what causes it

- **ReplicaLag** is the metric. Alarm on it, because an application reading stale data usually fails quietly rather than loudly.
- Causes: heavy writes on the source, a large transaction, an undersized replica, or a long-running query blocking apply.
- **Aurora lag is typically well under a second**, because replicas read the shared storage volume rather than replaying a log.
- Lag also **bounds failover time**, as module fourteen noted. A lagging replica is slow to promote.

> ON THE EXAM
>
> "Users see their own change disappear after saving" is replica lag with read-after-write on a replica. Route those reads to the writer.

Aurora replica auto scaling

- **Application Auto Scaling** adds and removes Aurora replicas based on a target: average CPU, or average connections.
- You set a **minimum and maximum replica count**, and a target value. Same target tracking model as module twelve.
- New replicas join the **reader endpoint** automatically, so read traffic spreads with no application change.
- Scaled replicas are added with a **promotion tier of 15**, so they are the last candidates for promotion on failover.

> ON THE EXAM
>
> This is EC2 Auto Scaling's model applied to database readers. Note it is Application Auto Scaling, which module twelve distinguished carefully.

Naming: v2 is now Aurora serverless

- **In April 2026 AWS renamed Aurora Serverless v2 to simply Aurora serverless.** No action required, same product.
- The **exam guide's in-scope list still says Aurora Serverless v2**. Learn the capability, and recognise both names.
- **Aurora Serverless v1 was a different architecture** and is deprecated. Do not confuse it with either name above.
- v1 doubled capacity in steps and paused disruptively. The current product scales in fine increments without dropping connections.

> ON THE EXAM
>
> Three names, two products. v1 is gone, and v2 is now called Aurora serverless. Exam material will use the older name for a while yet.

How Aurora serverless scales

- Capacity is measured in **Aurora Capacity Units**, each roughly **2 GiB of memory** with matching CPU and network.
- Adjusts in increments as small as **0.5 ACU**, up to a maximum of **256 ACUs**, without dropping connections.
- Recent platform versions **add 12 ACUs within a second** and keep climbing, which suits sharp unpredictable bursts.
- It can scale to **zero ACUs** and pause, then resume on the next connection. That resume is a cold start.

> ON THE EXAM
>
> Set a minimum above zero for production. Scale-to-zero is a development and test feature, and the resume latency is real.

The Aurora serverless limitation people miss

- **Aurora Auto Scaling, which adds reader replicas by count, is not supported on Aurora serverless.**
- Serverless scales each instance **vertically**, by growing its ACUs. It does not add readers for you.
- To scale reads horizontally on serverless, you **add reader instances yourself**, each of which then scales its own capacity.
- **Mixed clusters are allowed**: a provisioned writer with serverless readers, or the reverse.

> ON THE EXAM
>
> "Serverless means it handles everything automatically" is the wrong mental model. It automates instance size, not instance count.

Provisioned Aurora or Aurora serverless?

PROVISIONED WHEN

Load is steady

- Predictable, sustained throughput
- Cheaper per unit of work at steady high load
- Reserved instances available for further savings
- Aurora Auto Scaling can add readers by CPU

SERVERLESS WHEN

Load is spiky or unknown

- Bursty, intermittent or unpredictable traffic
- Development and test, where scale to zero pays
- No capacity planning, fine-grained billing
- Not automatically cheaper at sustained high load

THE TIEBREAKER

Do the arithmetic. A database busy 24 hours a day is usually cheaper provisioned, and serverless wins on the workload that is idle most of the week.

DynamoDB capacity, revisited for growth

- **On-demand is now the default and AWS's recommended mode.** It scales automatically and charges per request.
- **Provisioned with auto scaling** is cheaper for steady, predictable load, and reserved capacity cheaper still.
- **Maximum throughput for on-demand tables** caps reads or writes per second, protecting the budget and downstream services.
- Default account limits are **40,000 read and 40,000 write units per table**, raisable on request.

> ON THE EXAM
>
> The maximum throughput setting is the answer to "a runaway script cost us thousands overnight" and to "the database overwhelmed our downstream API".

Warm throughput: why on-demand still throttles

- Every table, index and replica has a **warm throughput**: what it can serve **instantly**, without waiting to scale.
- A new on-demand table starts at about **12,000 reads and 4,000 writes per second**.
- Beyond that, DynamoDB **does** scale, but scaling takes time, and requests arriving faster than it scales are **throttled**.
- Warm throughput **only ratchets upward**. **Pre-warming** raises it ahead of a launch, a sale or a batch migration.

> ON THE EXAM
>
> "On-demand means it never throttles" is wrong. It means it always eventually scales. Warm throughput is the gap between those two statements.

DynamoDB auto scaling, and why it looks slow

- Provisioned auto scaling uses **Application Auto Scaling** with CloudWatch alarms, targeting a utilisation percentage.
- It scales **up** after utilisation exceeds the target for about **2 consecutive minutes**.
- It scales **down** only after utilisation is **20 percent or more below target for 15 consecutive minutes**.
- So a sharp spike is throttled for a couple of minutes before capacity arrives. **Burst capacity** absorbs some of that, briefly.

> ON THE EXAM
>
> Provisioned auto scaling is designed for gradual change. For genuinely sudden spikes, on-demand or pre-warming is the answer, not a lower target.

Indexes have their own capacity

- A **global secondary index** has its own throughput. In provisioned mode you scale it separately from the table.
- **A throttled GSI throttles writes to the base table**, because a write must succeed on both.
- Projecting fewer attributes into a GSI reduces its write cost, since every base-table write updates every projecting index.
- **Local secondary indexes** share the table's capacity and must be created with the table. They cannot be added later.

> ON THE EXAM
>
> "The table has plenty of capacity but writes are throttled" is nearly always a global secondary index that does not.

ElastiCache: node-based or Serverless?

NODE-BASED WHEN

You want control

- Choose node types and counts yourself
- Shards for write scaling, replicas for read scaling
- Reserved node discounts available
- Predictable hourly cost regardless of traffic

SERVERLESS WHEN

You want it to just work

- Scales automatically, no capacity planning
- Billed per ECPU plus stored GB-hours
- Very low floor: about 100 MB minimum for Valkey
- Can exceed node-based cost at very high request rates

THE TIEBREAKER

AWS recommends Valkey for new deployments. It is roughly 20 percent cheaper node-based and 33 percent cheaper serverless than Redis OSS.

Caching strategies

- **Lazy loading**: read the cache, and on a miss read the database and populate. Only requested data is cached.
- Its costs: a **three-trip penalty on every miss**, and stale data until the entry expires.
- **Write-through**: update the cache whenever you write. Data is never stale, and the cache fills with data nobody reads.
- **A TTL on every key** is the practical safety net. It bounds staleness whichever strategy you use.

> ON THE EXAM
>
> Most production systems use lazy loading plus a TTL, and add write-through only for the small set of keys where staleness is unacceptable.

Scale the database, or add a cache?

SCALE THE DATABASE WHEN

The work is genuinely new

- Writes are the bottleneck
- Queries are diverse, with little repetition
- Every read must be strongly consistent
- Data changes faster than it is read

ADD A CACHE WHEN

The same work repeats

- A small set of items dominates reads
- Reads vastly outnumber writes
- Some staleness is acceptable
- Expensive queries with stable results

THE TIEBREAKER

A cache is the cheapest scaling there is when the read pattern is skewed. It is useless when every query is different or every read must be current.

An Aurora PostgreSQL cluster is configured as Aurora serverless with a minimum of 2 and a maximum of 64 ACUs. Read traffic has grown steadily and the single instance now sits near its maximum during business hours. Reads are 90 percent of the workload.

The team expects Aurora Auto Scaling to add reader instances and is confused that it has not.

What should the team do?

A Enable Aurora Auto Scaling on the cluster to add readers automatically

B Add reader instances to the cluster and send read traffic to the reader endpoint

C Raise the maximum to 256 ACUs and leave the topology unchanged

D Convert the cluster to provisioned Aurora with a larger instance class

◆ PAUSE AND DECIDE

What should the team do?

A Enable Aurora Auto Scaling

Not supported on Aurora serverless. It adds readers by count; serverless scales each instance's capacity instead.

B Add readers, use the reader endpoint

Reads are 90 percent of the load, so horizontal read scaling is the right axis. Each added reader then scales its own ACUs.

C Raise the maximum to 256

Buys headroom on one instance and keeps every read on the writer. It is vertical scaling applied to a horizontal problem.

D Convert to provisioned

A large change that would let Aurora Auto Scaling work, at the cost of losing fine-grained scaling. Adding readers is far less disruptive.

THE SIGNAL

Serverless automates instance size, not instance count. Ninety percent reads is the clue that count is what needs to change.

A retailer moves a DynamoDB table to on-demand capacity mode before a flash sale, reasoning that on-demand scales automatically and cannot throttle. The table normally serves about 800 reads per second.

At the start of the sale, traffic jumps to roughly 60,000 reads per second within thirty seconds. Customers see errors, and CloudWatch shows ReadThrottleEvents for several minutes.

What explains this, and what should they have done?

A On-demand tables have a fixed 40,000 read limit that cannot be raised

B The table's warm throughput was too low for the spike. Pre-warm it before the event, or request a higher throughput ahead of time

C Switch back to provisioned mode with auto scaling and a high target utilisation

D Add a global secondary index to spread the read load

◆ PAUSE AND DECIDE

What explains this, and what should they have done?

A Fixed 40,000 limit

There is a default account-level limit around that figure, and it is raisable on request, so "cannot be raised" makes this wrong.

B Warm throughput too low; pre-warm

On-demand scales, but not instantly. Warm throughput is what it serves immediately, and pre-warming raises it ahead of a known event.

C Provisioned with auto scaling

Worse for this shape. Provisioned auto scaling takes about two minutes to react, which is slower than on-demand, not faster.

D Add a GSI

An index serves different query patterns. It does not increase capacity for the same reads, and it adds write cost.

THE SIGNAL

The retailer's stated reasoning is the distractor. On-demand means it always eventually scales, not that it never throttles.

> A provisioned DynamoDB table has 20,000 write capacity units and consumes about 9,000. Writes are being throttled intermittently. The table has three global secondary indexes; one of them is provisioned at 2,000 write units and is consistently at its limit.
>
> The partition key is a high-cardinality UUID and traffic is evenly distributed.

What is the cause?

A. A hot partition on the base table

B. The throttled GSI is throttling base-table writes, because a write must succeed on the table and every projecting index

C. Auto scaling is scaling down too aggressively

D. The table needs to be switched to on-demand mode

◆ PAUSE AND DECIDE

What is the cause?

A **Hot partition**

Explicitly ruled out. A high-cardinality key with evenly distributed traffic is the opposite of a hot partition.

B **The GSI is the bottleneck**

A write must land on the base table and every index that projects the written attributes. A throttled index throttles the write.

C **Auto scaling too aggressive**

The base table is at 45 percent of its provisioned capacity, so nothing about the base table's scaling is the constraint.

D **Switch to on-demand**

Would mask it by removing provisioning, at higher cost, without addressing an index that is genuinely undersized.

THE SIGNAL

Compare this with module ten's hot-partition scenario. Same symptom, opposite cause, and the partition key detail is what separates them.

A product catalogue API serves 40,000 reads per second against RDS for MySQL. About 200 popular products account for 85 percent of requests, and the catalogue is updated a few times a day. The database CPU is saturated and the team has already scaled the instance twice.

A brief delay in reflecting catalogue updates is acceptable.

What is the most cost-effective way to scale this?

A. Add ElastiCache in front of the database, using lazy loading with a TTL

B. Add five read replicas and distribute reads across them

C. Scale the instance class up again

D. Migrate the catalogue to DynamoDB with on-demand capacity

◆ PAUSE AND DECIDE

What is the most cost-effective way to scale this?

A ElastiCache, lazy loading with a TTL

Highly skewed reads, rare writes, and staleness tolerated. A cache absorbs 85 percent of the load for a fraction of the cost of database capacity.

B Five read replicas

Works, and it is five more database instances to pay for and operate, all repeatedly answering the same 200 questions.

C Scale up again

The team has already done this twice, which is the scenario telling you the vertical axis is exhausted.

D Migrate to DynamoDB

A large migration and an application rewrite to solve a read-skew problem that a cache solves in an afternoon.

THE SIGNAL

Three properties in the setup are the textbook caching signature: skewed reads, infrequent writes, and tolerated staleness.

A reporting dashboard reads from an RDS for PostgreSQL read replica. Users report that after saving a change they sometimes do not see it, and refreshing a few seconds later shows it correctly. The application writes to the primary and reads from the replica for all queries.

ReplicaLag averages 1.5 seconds and peaks at 8 seconds during batch loads.

What should the team change?

A. Route reads that immediately follow a write to the primary, and leave other reads on the replica

B. Increase the replica's instance class to eliminate lag entirely

C. Convert the replica into a Multi-AZ standby

D. Add a second read replica and load-balance between them

◆ PAUSE AND DECIDE

What should the team change?

A Read-after-write goes to the primary

Asynchronous replication always has some lag. Routing only the reads that must be current to the writer keeps the offload and fixes the symptom.

B Bigger replica instance

Reduces lag; cannot remove it. Asynchronous means the replica is always at least a little behind, so the bug would become rarer and stay.

C Convert to a Multi-AZ standby

The standby serves no reads at all, so this removes the read offload entirely and solves nothing about the dashboard.

D A second replica

Doubles read capacity and doubles the number of places serving stale data. It makes the symptom no less likely.

THE SIGNAL

This is a read-after-write consistency problem, not a capacity problem. No amount of extra replica capacity makes asynchronous replication synchronous.

The five things to carry forward

- **Bigger, more of them, or less work.** Decide the axis before the service.
- **Aurora Auto Scaling adds readers and is not supported on Aurora serverless**, which scales size rather than count.
- **On-demand DynamoDB still throttles** beyond its warm throughput. Pre-warm before a known spike.
- **A throttled GSI throttles base-table writes.** Check indexes when the table looks comfortable.
- **Skewed reads, rare writes, tolerable staleness: cache.** Read-after-write goes to the writer.

> ON THE EXAM
>
> Next: backup and restore - AWS Backup, snapshots, point-in-time recovery, versioning and Vault Lock.

MODULE 16 · DOMAIN 2 - RELIABILITY AND BUSINESS CONTINUITY

Backup and Restore

AWS Backup, snapshots, point-in-time recovery, Object Lock and Vault Lock - and proving any of it works.

DOMAIN 2 of 5 EXAM WEIGHT 22% MODULE 16 of 35

admin@sthithapragna.com

A backup you have never restored is a **hypothesis**. The exam tests the restore path at least as often as the backup path.

Native backup, service by service

SERVICE	NATIVE MECHANISM
Amazon EBS	Snapshots, incremental. Automated by Data Lifecycle Manager
Amazon RDS	Automated backups with PITR, plus manual snapshots
Amazon Aurora	Continuous backup to S3, plus Backtrack on MySQL and cloning
Amazon DynamoDB	Point-in-time recovery for 35 days, plus on-demand backups
Amazon S3	Versioning, replication and Object Lock. Not snapshots
Amazon EFS and FSx	AWS Backup. EFS has no native snapshot of its own

ON THE EXAM

Every one of these can also be driven centrally by AWS Backup, which is usually the answer once more than one service is involved.

RDS automated backups or manual snapshots?

AUTOMATED BACKUPS

Continuous, and temporary

- Retention 0 to 35 days; 0 disables them
- Enable point-in-time recovery within that window
- Taken during the backup window you configure
- Deleted with the instance unless you retain them

MANUAL SNAPSHOTS

A point in time, kept

- Taken on demand, kept until you delete them
- Survive deletion of the DB instance
- Can be copied across Regions and accounts
- No point-in-time recovery from a snapshot alone

THE TIEBREAKER

Automated backups die with the instance. If an accidental deletion must be survivable, a manual snapshot or an AWS Backup vault copy is required.

What an RDS restore actually gives you

- **A restore always creates a NEW DB instance**, with a **new endpoint**. You cannot restore in place.
- So a restore is followed by **repointing the application**, which is part of your RTO whether you planned for it or not.
- **Point-in-time recovery** restores to any second in the retention window, typically to within about 5 minutes of now.
- The new instance uses the **default parameter and security groups** unless you specify otherwise. That surprises people mid-incident.

> ON THE EXAM
>
> Practise the repoint, not just the restore. A recovered database nobody can reach has not recovered anything.

Aurora: backtrack and cloning

- **Backtrack** rewinds an Aurora MySQL cluster **in place**, up to 72 hours, in minutes. No new instance and no new endpoint.
- **MySQL-compatible only**, must be enabled in advance, and it is **not a backup**: it cannot recover a deleted cluster.
- **Cloning** creates a copy-on-write clone of the cluster volume in minutes, paying only for changed pages.
- Clones are how you get a realistic test environment, or a safe place to try a destructive migration.

> ON THE EXAM
>
> Backtrack is the only mechanism here that recovers in place. That is what makes it fast, and also why it cannot survive the cluster being deleted.

EBS snapshots

- **Incremental**: each snapshot stores only blocks changed since the last one, but any single snapshot can be deleted safely.
- **Data Lifecycle Manager** schedules them by tag, with retention, cross-Region copy and cross-account sharing.
- **Fast Snapshot Restore** removes first-touch latency on a restored volume. Charged per snapshot per AZ per hour.
- **Snapshot Archive** is cheaper for long retention, with a **90-day minimum** and a restore that can take up to 72 hours.

> ON THE EXAM
>
> A restored volume is normally lazily loaded from S3, so the first read of each block is slow. That is what Fast Snapshot Restore removes.

DynamoDB backup

- **Point-in-time recovery** covers the last **35 days**, to any second. Enabled per table, off by default.
- **On-demand backups** are full backups kept until deleted, with no effect on table performance or capacity.
- **Both restore to a NEW table.** The same lesson as RDS: recovery includes repointing the application.
- **Export to S3** is a third path, for analytics rather than recovery. It consumes no read capacity.

> ON THE EXAM
>
> A restored DynamoDB table does not carry over auto scaling settings, TTL configuration, or Streams. Check those after any restore.

S3 versioning: what it does and does not protect

- **Protects against overwrite and delete.** A delete creates a **delete marker**; the previous version is still there.
- **MFA delete** requires a hardware or virtual MFA token to delete a version or disable versioning.
- It does **not** protect against someone with permission deleting **every version**, which is exactly what ransomware does.
- Versioning **cannot be switched off** once enabled, only suspended, and old versions keep costing storage until a lifecycle rule removes them.

> ON THE EXAM
>
> Versioning is an undo button. Object Lock is a padlock. A scenario about a malicious insider or ransomware needs the padlock.

S3 Object Lock

- Write once, read many. **Requires versioning**, and is normally enabled at bucket creation.
- **Governance mode**: protected, but a user with the **BypassGovernanceRetention** permission can override it.
- **Compliance mode**: nobody can shorten or remove the retention, **including the root user**, until it expires.
- **Legal hold** has no expiry. It blocks deletion indefinitely until someone with permission removes it.

> ON THE EXAM
>
> "Including administrators" or "including the root user" in a requirement always means compliance mode. Governance mode is designed to be overridable.

AWS Backup: the central service

- A **backup plan** contains **rules**: schedule, backup window, lifecycle to cold storage, retention, and copy destinations.
- A **resource selection** chooses what the plan covers, usually **by tag**, so new resources are protected automatically.
- Backups land in a **vault**, which is the unit of encryption, access policy and locking.
- **Organization backup policies** push plans from the management account so member accounts cannot opt out.

> ON THE EXAM
>
> Tag-based selection is the point. "New resources must be backed up without anyone remembering" is a tag-driven AWS Backup plan.

Copies: across Regions and accounts

- **Cross-Region copy** is a rule in the plan. It is how backups survive a Regional event.
- **Cross-account copy** is the ransomware answer: backups live in an account the compromised one cannot reach.
- A copy in the **same account** protects against deletion of the original resource, not against the account being compromised.
- Encrypted copies need the destination vault's **KMS key policy** to permit the copy. This is the usual failure.

> ON THE EXAM
>
> Ask what you are defending against. A mistake needs another copy. An attacker with your credentials needs another account.

Vault Lock: governance or compliance?

GOVERNANCE MODE

Guard rail

- Enforces retention against ordinary users
- Privileged users can remove the lock
- Right for preventing mistakes
- Reversible, so safe to adopt early

COMPLIANCE MODE

One-way door

- After the grace period, nobody can remove it
- Not the root user, not AWS Support
- Retention cannot be shortened, backups cannot be deleted
- The only exit is closing the AWS account

THE TIEBREAKER

Compliance mode has a grace period, minimum three days, during which it can still be cancelled. After that it is permanent. Test in governance mode first.

Logically air-gapped vaults

- A vault type that is **automatically locked in compliance mode** and encrypted, generally available since August 2024.
- Can be **shared with other accounts through AWS RAM**, including accounts outside your organisation.
- Shared accounts can **restore directly from it**, with no copy step first. That is what compresses recovery time.
- Since **November 2025** it can be the **primary backup target**, not only a copy destination.

> ON THE EXAM
>
> The direct restore is the point. Traditional isolated backups had to be copied somewhere usable first, and that copy was pure RTO.

New: scanning backups before you restore them

- **GuardDuty Malware Protection for AWS Backup**, generally available **November 2025**.
- Scans backup data with multiple detection engines. **No agent and no extra security software** on the workload.
- Covers **EC2 instance backups, EBS snapshots and S3 backups**.
- It addresses the failure nobody plans for: **restoring the malware along with the data**.

> ON THE EXAM
>
> Ransomware often sits dormant for weeks before triggering, so the backups you trust may already contain it. Scanning before restore is the control for that.

Proving it works

- **Restore testing** runs scheduled, automated restore jobs and validates them, then cleans up the restored resources.
- It produces evidence of **recovery time**, which is the only honest way to know your RTO.
- **Backup Audit Manager** checks controls: is everything tagged for backup actually backed up, and to the required retention?
- It reports on **coverage gaps**, which is the failure mode where a resource was simply never included in any plan.

> ON THE EXAM
>
> "Demonstrate to an auditor that backups exist, meet retention, and can be restored" is Backup Audit Manager plus restore testing, not a spreadsheet.

What restore actually produces

- **RDS and DynamoDB**: a new instance or table, with a new endpoint or name. Repointing is your job.
- **EBS**: a new volume, which must then be attached, and possibly mounted, before anything sees it.
- **Aurora Backtrack**: the same cluster, rewound in place. The only true in-place recovery here.
- **S3 versioning**: delete the delete marker and the object is back. The closest thing to a genuine undo.

> ON THE EXAM
>
> Rank recovery mechanisms by how much work happens after the restore finishes. That work is invisible in the backup plan and very visible during an incident.

> An engineer deletes a production RDS for MySQL instance by mistake. Automated backups were enabled with 7-day retention, and the 'retain automated backups' option was not selected on deletion. There are no manual snapshots.
>
> The team asks how to recover the database to five minutes before the deletion.

What is the situation?

A Restore to the required point in time from the automated backups

B The automated backups were deleted with the instance, so there is nothing to restore from

C Use Aurora Backtrack to rewind past the deletion

D Restore from the final snapshot RDS always takes automatically on deletion

◆ PAUSE AND DECIDE

What is the situation?

A Restore from automated backups

There are none left. Automated backups are removed with the instance unless retention was explicitly requested at deletion.

B Nothing to restore from

Uncomfortable and correct. This is precisely why manual snapshots or an AWS Backup vault copy exist as a separate control.

C Aurora Backtrack

MySQL-compatible Aurora only, not RDS for MySQL. It also cannot rewind a cluster that no longer exists.

D The automatic final snapshot

A final snapshot is offered at deletion, not taken automatically. The scenario says it was not selected.

THE SIGNAL

Some questions have an unpleasant correct answer. Recognising that a recovery is impossible is a real skill, and the exam does test it.

A regulator covers seven years of financial records in S3. Nobody in the company may delete or alter them for the full retention period. That includes administrators and the root user.

The bucket currently has versioning enabled and a bucket policy denying deletes to everyone except a small admin group.

What should the company implement?

A S3 Object Lock in compliance mode with a seven-year retention period

B S3 Object Lock in governance mode with a seven-year retention period

C Enable MFA delete on the bucket

D Cross-Region replication to a bucket in another account

◆ PAUSE AND DECIDE

What should the company implement?

A Object Lock, compliance mode

The only control here that the root user cannot override. Retention cannot be shortened and objects cannot be deleted until it expires.

B Object Lock, governance mode

Designed to be overridable by a user holding BypassGovernanceRetention. The requirement says nobody, which rules that out.

C MFA delete

Raises the bar and does not remove the capability. An administrator with the MFA device can still delete.

D Replication to another account

Improves durability and isolation. It does not make anything immutable, and the copies are deletable too.

THE SIGNAL

Same discriminator as the CloudTrail module: "including the root user" eliminates every control that a privileged user can undo.

A company is compromised by ransomware. The attacker had administrator credentials in the production account for several days before triggering, and deleted every EBS snapshot and RDS snapshot in that account. Backups were being copied to a second vault in the same account.

The company wants a design that survives this next time, and wants recovery to begin without a lengthy copy step.

What should the company implement?

A. A logically air-gapped vault in a separate account, shared for direct restore via AWS RAM

B. A second backup vault in the production account with Vault Lock in governance mode

C. Cross-Region copy to another Region in the same account

D. Increase the retention period on the existing backup plan

◆ PAUSE AND DECIDE

What should the company implement?

A Air-gapped vault in a separate account

Compliance-locked by default, in an account the attacker had no credentials for, and RAM sharing allows restore directly without copying first.

B Governance-mode vault, same account

Fails twice: an administrator can remove a governance lock, and it is in the account that was compromised.

C Cross-Region, same account

Another Region is not another blast radius when the credentials are account-wide. The attacker can delete it too.

D Longer retention

Keeps deleted backups for longer, which helps nobody once they have been deleted.

THE SIGNAL

Two clauses drive it: the attacker had administrator credentials, and recovery must not wait for a copy. Only the air-gapped vault answers both.

A team restores an RDS database from a snapshot during a disaster recovery test. The restore itself completes in about 25 minutes. The team records an RTO of 25 minutes.

During a real incident three months later, the total outage lasts nearly two hours despite the restore again taking 25 minutes.

What most likely accounts for the difference?

A The snapshot was in cold storage and had to be retrieved

B The restore creates a new instance with a new endpoint, and repointing the application, security groups and parameter groups was never measured

C Fast Snapshot Restore was not enabled

D Point-in-time recovery is slower than snapshot restore

◆ PAUSE AND DECIDE

What most likely accounts for the difference?

A **Cold storage retrieval**

Would have made the restore itself slower. The scenario states the restore took the same 25 minutes both times.

B **Everything after the restore was never measured**

The restore produces a new endpoint. Repointing, fixing security groups and parameter groups is real work that the test skipped.

C **Fast Snapshot Restore**

An EBS feature affecting volume first-touch latency. It does not apply to an RDS snapshot restore.

D **PITR is slower**

The restore duration is stated as identical in both cases, so the mechanism's speed is not the variable.

THE SIGNAL

The scenario fixes the restore time at 25 minutes twice, deliberately. Whatever explains the difference has to be outside the restore.

> An operations team must ensure that every EBS volume and RDS database created by any of 30 accounts is backed up daily, retained for 90 days, and copied to a second Region, with no manual step when new resources are created.
>
> They must also be able to show an auditor which resources are not covered.

Which combination should they implement?

A. An organization backup policy with tag-based resource selection and a cross-Region copy rule, plus Backup Audit Manager

B. Data Lifecycle Manager policies in each account, plus RDS automated backups

C. A Lambda function on an EventBridge schedule that snapshots every volume and database

D. AWS Backup plans created individually in each of the 30 accounts

◆ PAUSE AND DECIDE

Which combination should they implement?

A Organization policy plus Audit Manager

One policy pushed to all 30 accounts, tag selection covers resources created later, and Audit Manager reports the coverage gaps the auditor wants.

B DLM plus RDS automated backups

DLM covers EBS only, RDS automated backups do not do cross-Region copy this way, and both need configuring in every account.

C Lambda on a schedule

Rebuilds AWS Backup by hand across 30 accounts, with no coverage reporting and a function to maintain forever.

D Plans in each account

Works and drifts. Thirty independently maintained plans is exactly the divergence an organization policy exists to prevent.

THE SIGNAL

Three requirements: automatic coverage of new resources, thirty accounts, and evidence of gaps. Tag selection, organization policy, Audit Manager.

The five things to carry forward

- **Automated backups die with the instance.** Manual snapshots and vault copies survive it.
- **Restore creates something new.** Repointing is part of your RTO, and Aurora Backtrack is the only in-place exception.
- **Versioning is undo; Object Lock is a padlock.** "Including the root user" means compliance mode.
- **Another Region for a Regional event; another account for a compromised account.**
- **Restore testing measures RTO; Audit Manager finds coverage gaps.** GuardDuty scans backups before you restore malware.

> ON THE EXAM
>
> Next: disaster recovery proper - RPO, RTO, the four strategies, and Application Recovery Controller.

MODULE 17 · DOMAIN 2 - RELIABILITY AND BUSINESS CONTINUITY

Disaster Recovery

RPO, RTO, the four strategies AWS names explicitly - and Amazon Application Recovery Controller.

DOMAIN 2 of 5 EXAM WEIGHT 22% MODULE 17 of 35

admin@sthithapragna.com

DR is a business decision expressed as two numbers. **RPO** is how much data you can lose. **RTO** is how long you can be down. The strategy follows.

RPO and RTO, precisely

- **RPO looks backwards.** Nightly backups mean an RPO of up to 24 hours, because a failure at 5pm loses the whole day.
- **RTO looks forwards.** It is the time from the failure to the service being usable, not to the restore finishing.
- **They are set by the business**, per workload. A payments system and an internal wiki should not share a target.
- A target you have never **measured** is an aspiration. Module sixteen's restore testing is how you turn one into a number.

> ON THE EXAM
>
> RPO is decided by how often you replicate. RTO is decided by how much has to happen after the failure. They are tuned by different levers.

The four strategies

STRATEGY	TYPICAL RPO AND RTO, AND WHAT RUNS
Backup and restore	RPO hours, RTO hours to days. Nothing runs in the DR Region
Pilot light	RPO minutes, RTO tens of minutes. Data replicated; compute switched off
Warm standby	RPO seconds, RTO minutes. A scaled-down but working copy runs
Active/active	RPO and RTO near zero. Full capacity serving in both Regions

ON THE EXAM

Cost rises down the table and recovery time falls. There is no strategy that is both cheapest and fastest, and questions test whether you accept that.

Backup and restore

- Copy backups to the second Region. Nothing else exists there until you need it.
- Cheapest by a wide margin, and the correct answer for workloads that can be down for a day.
- **Recovery includes building the infrastructure**, which is why infrastructure as code turns days into hours here.
- Watch **service quotas** in the recovery Region. Quotas are per Region, and a fresh Region has default limits.

> ON THE EXAM
>
> The RTO here is dominated by everything that is not the data: VPCs, load balancers, instances, DNS. Templates are the difference between hours and days.

Pilot light

- **The data layer is live and replicating.** The compute layer exists as configuration but is switched off.
- Typically: a cross-Region read replica or global table running, AMIs and launch templates ready, Auto Scaling groups at zero.
- Recovery means **promoting the database and scaling compute up from zero**.
- You pay for storage and replication continuously, and for compute only during a disaster or a test.

> ON THE EXAM
>
> The name is literal. A pilot light is the small permanent flame you use to light the main burner quickly. The data is the flame.

Warm standby

- A **complete, working copy** of the environment runs in the second Region, at reduced capacity.
- Because it is running, it can **serve a little real traffic**, which proves continuously that it works.
- Recovery means **scaling it up** and shifting traffic. There is nothing to build and nothing to promote from cold.
- More expensive than pilot light, because you are paying for running compute you are not fully using.

> ON THE EXAM
>
> The decisive advantage is not speed. It is that a warm standby is tested by simply existing, whereas a pilot light is tested only when you deliberately test it.

Active/active

- Both Regions serve production traffic **all the time**. A failure removes capacity rather than causing an outage.
- Requires **multi-Region data**: DynamoDB global tables, Aurora Global Database, or S3 replication.
- The hard part is **write conflicts and consistency**, not infrastructure. Two Regions accepting writes is an application design problem.
- Most expensive, and it constrains how you build the application from the beginning.

> ON THE EXAM
>
> This is the only strategy where a Region failure is a capacity event rather than a recovery event. That is what you are paying for.

Pilot light or warm standby?

PILOT LIGHT

Data warm, compute cold

- Compute is off; nothing serves traffic
- Recovery: promote the database, scale from zero
- Cheaper: you pay for data, not compute
- Untested unless you deliberately test it

WARM STANDBY

Everything on, but small

- A scaled-down environment is running and serving
- Recovery: scale up and shift traffic
- More expensive: running compute all the time
- Continuously proven, because it is in use

THE TIEBREAKER

Ask whether anything is running and serving in the second Region. If yes, warm standby. If only the data is live, pilot light.

Getting the data there

SERVICE	CROSS-REGION MECHANISM
Aurora	Global Database. RPO about 1 second, managed failover in about a minute
RDS	Cross-Region read replica, or cross-Region automated backups
DynamoDB	Global tables. Multi-active, last writer wins
S3	Cross-Region Replication. Replication Time Control gives a 15-minute SLA
EBS and AMIs	Snapshot and AMI copy, or AWS Backup cross-Region copy
ECR	Cross-Region and cross-account replication rules

ON THE EXAM

Replication frequency sets your RPO. Everything in this table except backup copying gives you an RPO measured in seconds or minutes.

The half that is not data

- **AMIs and container images** must exist in the recovery Region. Copy them on a schedule, not during an incident.
- **Infrastructure as code**, deployable into the second Region. StackSets or a pipeline, not a template nobody has run.
- **Certificates**: ACM certificates are **Regional**. A certificate for the primary Region does not exist in the secondary.
- **Secrets and parameters**: Secrets Manager replicates; Parameter Store does not, so plan for it.

> ON THE EXAM
>
> Most failed DR tests fail here, not on the data. The database came up fine and there was no AMI, no certificate, and no route to anything.

Service quotas: the classic failure

- **Quotas are per account per Region.** Your recovery Region has default limits, not the limits you raised over three years.
- Common ones: EC2 vCPU limits by instance family, Elastic IPs, VPCs, security group rules, Lambda concurrency.
- **Raise them in advance.** Quota increases are handled by AWS and can take time you will not have.
- This is exactly what ARC readiness check was built to monitor, and what Region switch plan evaluation now covers.

> ON THE EXAM
>
> A pilot light that cannot scale past 20 vCPUs is not a recovery plan. The quota is invisible until the moment it matters most.

Amazon Application Recovery Controller

- Formerly **Route 53 Application Recovery Controller**. Two domains: **Multi-AZ recovery** and **Multi-Region recovery**.
- **Multi-AZ**: zonal shift and zonal autoshift, for a single impaired Availability Zone.
- **Multi-Region**: routing controls, Region switch, and readiness check.
- Its point is a **data plane that keeps working while a Region is impaired**, which ordinary control planes may not.

> ON THE EXAM
>
> Most resilience events are zonal, not Regional. The Multi-AZ half of ARC is the part most workloads actually need.

Zonal shift and zonal autoshift

- **Zonal shift** is manual: you move traffic for a supported resource away from one Availability Zone, temporarily.
- **Zonal autoshift** is automatic: AWS shifts traffic away when its **internal telemetry** indicates an impairment.
- AWS's telemetry draws on the network, EC2 and Elastic Load Balancing, so it sees things your own metrics may not.
- **Both are temporary.** AWS ends an autoshift once the indicators clear. Neither is a permanent configuration change.

> ON THE EXAM
>
> Requires capacity in the remaining zones. Autoshift assumes you are statically stable enough to lose a zone, which is module 14's point again.

Routing controls and safety rules

- A **routing control** is a simple on/off switch that changes the health of a Route 53 record. Flipping it moves traffic.
- It is hosted on a **cluster of five redundant endpoints in five Regions**, so you can operate it during a Regional event.
- **Safety rules** prevent dangerous combinations: an assertion rule can stop you turning off both Regions at once.
- A cluster costs by the hour and there is a **maximum of two per account**, so this is a deliberate, funded design choice.

> ON THE EXAM
>
> The point is not that a switch flips DNS. It is that the switch itself is reachable when the thing you are failing away from is broken.

Region switch, and one closure

- **Region switch** orchestrates a full multi-Region recovery: a plan, executed across multiple accounts, centrally and observably.
- It includes **plan evaluation**, which continually checks that the plan is still executable.
- **ARC readiness check closed to new customers on 30 April 2026.** Existing customers continue.
- **ARC itself and Region switch are fully supported.** Only readiness check is affected, and Region switch is the recommended replacement.

> ON THE EXAM
>
> The third "still examinable, no longer buildable" item in this course, after CloudTrail Lake and Systems Manager Incident Manager. Learn it, do not design on it.

Failback, and testing

- **Failback is harder than failover.** The primary Region now has stale data, and reversing replication is rarely symmetrical.
- Decide in advance whether you fail back at all, or simply run in the recovery Region until a planned move.
- **Game days** exercise the whole plan, including the human parts: who decides, who has access, who is awake.
- **AWS Fault Injection Service** injects controlled failures, so you test the response rather than assuming it.

> ON THE EXAM
>
> A plan that has only ever been read is not a plan. Most of what goes wrong in a real failover is organisational, not technical.

A company must recover a payments application in a second Region. The RPO is under 5 seconds and the RTO under 10 minutes. Cost is a secondary consideration. Writes must continue to be served from a single Region to avoid conflict handling.

The application runs on EC2 behind an ALB with an Aurora PostgreSQL cluster.

Which strategy should the company implement?

A. Backup and restore, with AWS Backup cross-Region copy

B. Pilot light, with an Aurora Global Database and Auto Scaling groups at zero

C. Warm standby, with an Aurora Global Database and a scaled-down running environment

D. Active/active, with writes accepted in both Regions

◆ PAUSE AND DECIDE

Which strategy should the company implement?

A Backup and restore

RPO and RTO measured in hours. Both requirements are missed by two orders of magnitude.

B Pilot light

The genuinely close alternative. The Global Database meets the RPO, but scaling compute from zero and warming caches makes 10 minutes tight.

C Warm standby

Global Database gives roughly a one-second RPO; a running scaled-down environment needs only scaling up, which fits comfortably inside 10 minutes.

D Active/active

Explicitly excluded. The requirement says writes must come from one Region to avoid conflict handling, which is what active/active demands.

THE SIGNAL

Three clauses each eliminate something: the RPO kills A, the RTO makes B risky, and the single-writer constraint kills D.

A team tests its pilot light DR plan for the first time. The Aurora Global Database promotes successfully in 45 seconds. The Auto Scaling group then fails to launch beyond 8 instances, reporting a vCPU limit error, when 60 are required.

The primary Region has had its limits raised repeatedly over four years.

What is the cause and the fix?

A The launch template references an AMI that does not exist in the DR Region

B Service quotas are per Region. The DR Region still has default vCPU limits, and increases must be requested in advance

C The Auto Scaling group's maximum capacity is set too low

D Aurora Global Database promotion blocks compute scaling until replication completes

◆ PAUSE AND DECIDE

What is the cause and the fix?

A Missing AMI

A real and common DR failure, and it would fail every launch with an AMI error. Eight launched successfully, so the AMI exists.

B Per-Region quotas at defaults

The error names a vCPU limit, and quotas are per account per Region. Four years of increases in the primary Region mean nothing in the secondary.

C Maximum capacity too low

Would fail silently at the ceiling, not produce a vCPU limit error. The error text names the actual cause.

D Promotion blocks scaling

Invented behaviour. The scenario also states promotion completed successfully in 45 seconds.

THE SIGNAL

Eight instances launching is the clue. A missing AMI or a broken template fails at zero; a quota fails partway through.

During a Regional event, an operations team needs to shift traffic away from the impaired Region. Their failover mechanism updates Route 53 records using the AWS Management Console and the Route 53 API from the affected Region's console session.

The team wants a mechanism they can rely on to work while a Region is degraded, and wants to prevent anyone accidentally disabling both Regions.

What should the team implement?

A. ARC routing controls on a cluster, with a safety rule preventing both Regions being turned off

B. Route 53 failover routing with health checks on both Regions

C. ARC zonal autoshift on the load balancers in both Regions

D. A Lambda function in the secondary Region that rewrites Route 53 records

◆ PAUSE AND DECIDE

What should the team implement?

A Routing controls with a safety rule

The cluster spans five Regions, so the switch is operable during a Regional event, and safety rules block the both-off state.

B Failover routing with health checks

Useful and automatic, and it gives no manual control and no safety rules. The team asked for a mechanism they operate deliberately.

C Zonal autoshift

Addresses a single impaired Availability Zone within a Region. This is a Regional event, which is the other half of ARC.

D Lambda rewriting records

Builds the switch by hand, with no safety rules, and depends on Lambda and the Route 53 control plane behaving during the event.

THE SIGNAL

Two requirements: operable during a Regional impairment, and impossible to turn everything off. Only routing controls answer both.

> An internal HR reporting system has an agreed RTO of 24 hours and an RPO of 12 hours. It runs on two EC2 instances and an RDS for MySQL database. The finance director has asked why the team is proposing to spend money on a second Region at all.
>
> The team must protect against the loss of the primary Region.

What should the team propose?

A Warm standby, because it is the safest option

B Backup and restore, using AWS Backup cross-Region copy and CloudFormation templates for the infrastructure

C Pilot light, with a cross-Region read replica running continuously

D No DR at all, since the system is internal

◆ PAUSE AND DECIDE

What should the team propose?

A Warm standby

Massively over-engineered for a 24-hour RTO, and it spends continuously on running compute nobody needs.

B Backup and restore with templates

Matches the agreed targets at the lowest cost. Templates are what keep the rebuild inside 24 hours rather than stretching to days.

C Pilot light

Better than needed. A continuously running cross-Region replica buys an RPO of seconds when 12 hours was agreed.

D No DR

The requirement explicitly says the loss of the Region must be survivable. Internal does not mean expendable.

THE SIGNAL

Over-engineering is a wrong answer, not a safe one. The targets are agreed, and exceeding them costs money the business chose not to spend.

> A team designs a new multi-Region recovery plan in 2026 and wants continuous confirmation that the secondary Region remains capable of taking over: correct quotas, sufficient capacity, and matching routing configuration.
>
> An architect recommends ARC readiness checks, which they used at a previous employer.

What should the team do?

A Implement ARC readiness checks as recommended

B Onboard to ARC Region switch and use its plan evaluation capability

C Use Route 53 health checks against the secondary Region's endpoint

D Use AWS Config conformance packs in the secondary Region

◆ PAUSE AND DECIDE

What should the team do?

A ARC readiness checks

Closed to new customers on 30 April 2026. A team designing a new plan cannot onboard, whatever the architect used previously.

B Region switch plan evaluation

AWS's own recommended replacement. Plan evaluation continually monitors that the recovery plan remains executable.

C Route 53 health checks

Confirms an endpoint responds. It says nothing about quotas, capacity or configuration parity.

D Config conformance packs

Checks resource configuration against rules, which helps. It does not evaluate quotas, capacity or readiness to fail over.

THE SIGNAL

The same shape as the Incident Manager scenario in module 7: an experienced recommendation that is no longer available to a new customer.

The five things to carry forward

- **RPO is set by replication frequency; RTO by what must happen after the failure.** Different levers.
- **Is anything running and serving in the second Region?** Yes is warm standby, no is pilot light.
- **Over-engineering is a wrong answer.** Meet the agreed targets, do not exceed them expensively.
- **Quotas, AMIs and certificates are per Region.** That is what fails a DR test, not the data.
- **Zonal shift for one AZ, routing controls and Region switch for a Region.** Readiness check is closed to new customers.

> ON THE EXAM
>
> That completes domain two. Next: CloudFormation, and the start of domain three.

MODULE 18 · DOMAIN 3 - DEPLOYMENT, PROVISIONING, AND AUTOMATION

CloudFormation: Template Anatomy

Sections, functions, and the five resource attributes that decide what happens when things go wrong.

DOMAIN 3 of 5 EXAM WEIGHT 22% MODULE 18 of 35

admin@sthithapragna.com

The template says what you want. The **resource attributes** say what happens when creation fails, when an update replaces something, and when the stack is deleted.

The template sections

SECTION	WHAT IT DOES
AWSTemplateFormatVersion	Optional, and effectively always 2010-09-09
Description, Metadata	Documentation, and console grouping of parameters
Parameters	Inputs supplied at deployment time
Rules	Validate parameter combinations before anything is created
Mappings	Static lookup tables, most often keyed by Region
Conditions	Named booleans that switch resources and properties on and off
Transform	Macros: SAM, AWS::Include, AWS::LanguageExtensions
Resources	The only required section
Outputs	Values to return, and optionally export for other stacks

ON THE EXAM

Resources is the only mandatory section. A template with one resource and nothing else is completely valid.

Parameters

- Types include **String, Number, CommaDelimitedList**, and **AWS-specific types** such as AWS::EC2::Subnet::Id.
- AWS-specific types give a **validated dropdown in the console** and fail fast on a bad value, rather than failing halfway through a deployment.
- **SSM parameter types** read a value from Parameter Store at deployment time, which is how you avoid hard-coded AMI IDs.
- **NoEcho** masks a value in the console, CLI and API. It does **not** encrypt it, and anyone who can read the template still sees a default.

> ON THE EXAM
>
> Constraints belong in the template. AllowedValues, AllowedPattern, MinLength and MaxLength turn a runtime failure into an immediate rejection.

Pseudo parameters

- **AWS::Region**, **AWS::AccountId**, **AWS::StackName**, **AWS::StackId**. Supplied by CloudFormation, never declared.
- **AWS::Partition** and **AWS::URLSuffix** make a template work in GovCloud and China as well as commercial Regions.
- **AWS::NoValue** removes a property entirely, which is how a condition makes a property optional rather than empty.
- **AWS::NotificationARNs** gives the SNS topics associated with the stack.

> ON THE EXAM
>
> Fn::If with AWS::NoValue is the idiom for "include this property only sometimes". Setting it to an empty string is not the same thing.

Intrinsic functions worth knowing

FUNCTION	WHAT IT RETURNS
`Ref`	A parameter's value, or a resource's default identifier
`Fn::GetAtt`	A named attribute of a resource, such as an ARN or a DNS name
`Fn::Sub`	A string with ${variables} substituted. The readable choice
`Fn::Join`	Values joined by a delimiter. Older and harder to read than Sub
`Fn::FindInMap`	A value from the Mappings section
`Fn::ImportValue`	A value exported by another stack
`Fn::GetAZs, Fn::Select, Fn::Split`	Availability Zones, and list manipulation
`Fn::If, Fn::Equals, Fn::And, Fn::Or, Fn::Not`	Condition logic

ON THE EXAM

Fn::Sub replaced Fn::Join for almost all practical purposes. Both appear in exam templates, so read both.

Ref or GetAtt?

REF RETURNS

The default identifier

- For a parameter: its value
- For an EC2 instance: the instance ID
- For an S3 bucket: the bucket name
- For a security group: the group ID

GETATT RETURNS

A specific named attribute

- Bucket ARN, DomainName, WebsiteURL
- Instance PrivateIp, PublicDnsName
- Load balancer DNSName, CanonicalHostedZoneID
- Whatever the resource documentation lists

THE TIEBREAKER

Ref returns one thing per resource type and you have to know which. GetAtt returns whatever you name, if the resource publishes it.

Conditions and Mappings

- A **Condition** is a named boolean, evaluated once at deployment. Attach it to a resource with the **Condition** attribute.
- The usual pattern: one template for all environments, with production-only resources behind a condition.
- **Mappings** are static lookups, most often **Region to AMI ID** or environment to instance size.
- Mappings cannot use parameters or functions as keys unless you add the **AWS::LanguageExtensions** transform.

> ON THE EXAM
>
> An SSM parameter type is usually better than a Region-to-AMI mapping. The mapping goes stale; Parameter Store does not.

Dynamic references

- **{{resolve:ssm:name:version}}** pulls a plaintext value from Parameter Store at deployment time.
- **{{resolve:secretsmanager:...}}** pulls a secret, so a password never appears in the template or in a parameter.
- This is the correct answer to "how do we avoid putting the database password in the template?"
- The value is resolved at **deployment**, so rotating the secret afterwards does not update the deployed resource by itself.

> ON THE EXAM
>
> A parameter with NoEcho hides the value in the console. A dynamic reference means the value was never in the template at all.

Outputs and exports

- **Outputs** return values from a stack. Adding **Export** makes one importable by other stacks in the same account and Region.
- **Export names must be unique per account per Region**, and they do not cross Region or account boundaries.
- **You cannot delete a stack whose exports are being imported**, and you cannot change the exported value while it is in use.
- That rigidity is why **nested stacks** are often preferred for tightly coupled resources. Module 19 compares them.

> ON THE EXAM
>
> Exports create a hard dependency that is invisible from the importing stack's template. That is the cost of cross-stack references.

The five resource attributes

ATTRIBUTE	WHAT IT CONTROLS
`DependsOn`	Explicit ordering, when CloudFormation cannot infer the dependency
`DeletionPolicy`	What happens to the resource when it is removed from the stack
`UpdateReplacePolicy`	What happens to the OLD resource when an update replaces it
`CreationPolicy`	Wait for signals before declaring the resource created
`UpdatePolicy`	How to update an Auto Scaling group, Lambda alias or cache cluster

ON THE EXAM

This table is the module. Almost every non-trivial CloudFormation question turns on one of these five, and most turn on the middle two.

DeletionPolicy

- **Delete** is the default for most resources. **Retain** keeps the resource and removes it from the stack's management.
- **Snapshot** takes a final snapshot first. Supported by resources that have snapshots: RDS, EBS volumes, ElastiCache, Redshift.
- **RetainExceptOnCreate** retains on delete, but cleans up if the **initial creation** fails. Avoids orphans from a failed first deploy.
- RDS DB instances and clusters that do not specify a cluster identifier **default to Snapshot**, not Delete.

> ON THE EXAM
>
> Retain on a database is the difference between deleting a stack and deleting a company's data. Set it deliberately, not by accident.

DeletionPolicy or UpdateReplacePolicy?

DELETIONPOLICY FIRES WHEN

The resource leaves the stack

- The stack is deleted
- The resource is removed from the template
- Values: Delete, Retain, Snapshot, RetainExceptOnCreate

UPDATEREPLACEPOLICY FIRES WHEN

An update replaces the resource

- A property change requires replacement
- The OLD resource is what this governs
- Same values, and it defaults to Delete

THE TIEBREAKER

Set both on anything holding data. A DeletionPolicy of Retain does nothing if an update quietly replaces the database and deletes the old one.

DependsOn, and why implicit ordering usually suffices

- CloudFormation **infers** ordering from Ref and GetAtt. If A references B, B is created first, automatically.
- **DependsOn** is for dependencies with no reference between them, such as a route needing the internet gateway attached.
- Over-using DependsOn **serialises the deployment**, turning parallel creation into a slow chain.
- The classic legitimate case: **AWS::EC2::Route depending on AWS::EC2::VPCGatewayAttachment**.

> ON THE EXAM
>
> If a template is slow to deploy, look for DependsOn chains. CloudFormation parallelises aggressively unless you tell it not to.

CreationPolicy and cfn-signal

- **CreationPolicy** makes CloudFormation wait for a number of success signals within a timeout before marking a resource created.
- The instance sends them with **cfn-signal**, usually at the end of user data, once the application is genuinely ready.
- Without it, an EC2 instance is **CREATE_COMPLETE the moment it launches**, long before the application works.
- Applies to EC2 instances, Auto Scaling groups, WaitConditions and AppStream fleets.

> ON THE EXAM
>
> "The stack reports success but the application is not running" is a missing CreationPolicy. Launched is not the same as ready.

UpdatePolicy

- For Auto Scaling groups: **AutoScalingRollingUpdate**, **AutoScalingReplacingUpdate**, **AutoScalingScheduledAction**.
- **AutoScalingInstanceRefresh**, added July 2026, is the modern option. Module twelve covered it: checkpoints, launch-before-terminate, alarm rollback.
- It is **mutually exclusive with AutoScalingRollingUpdate**, which suspends scaling policies and ignores your maintenance policy.
- Also covers **Lambda alias** deployments through CodeDeploy, and ElastiCache online resharding.

> ON THE EXAM
>
> The old rolling update terminates before launching, so capacity dips. The new instance refresh policy can launch first. That is the deciding difference.

What an update actually does

- **Update with no interruption**: the resource keeps running and keeps its physical ID. Changing a Lambda function's memory, for example.
- **Update with some interruption**: the resource is briefly unavailable but keeps its ID. Changing an EC2 instance type.
- **Replacement**: a **new resource is created and the old one deleted**. A new physical ID, and anything depending on it updates too.
- Which one applies is documented **per property** in the resource reference, and a change set tells you before you commit.

> ON THE EXAM
>
> Replacement is where data disappears. Changing an RDS instance's DBInstanceIdentifier replaces the database, and without an UpdateReplacePolicy the old one is deleted.

Stack policies

- A **stack policy** is JSON attached to a stack that denies update actions on chosen resources.
- The usual pattern: **deny Update:Replace and Update:Delete on the database**, allow everything else.
- Once applied, a stack policy **cannot be removed**, only replaced with another one.
- To update a protected resource deliberately, supply a **temporary overriding policy** with the update request.

> ON THE EXAM
>
> A stack policy protects against updates. A DeletionPolicy protects against deletion. They cover different accidents and are not substitutes.

Transform, and language extensions

- **AWS::Serverless** is SAM, a shorthand for Lambda, API Gateway and DynamoDB that expands into full CloudFormation.
- **AWS::Include** inserts a template snippet from S3, for reusable boilerplate.
- **AWS::LanguageExtensions** adds **Fn::ForEach**, **Fn::Length**, **Fn::ToJsonString**, and a default value for Fn::FindInMap.
- Language extensions work only in **Resources, Conditions and Outputs**, and must be listed **before AWS::Serverless**.

> ON THE EXAM
>
> Fn::ForEach removes the copy-paste template. Twenty near-identical resources become one definition and a list.

CloudFormation Hooks

- A **Hook** inspects resource configuration **before** provisioning and can **warn** or **fail** the operation.
- Four kinds: **proactive controls** from the Control Tower Control Catalog, **Guard Hooks**, **Lambda Hooks**, and custom Hooks.
- Managed proactive controls arrived in **September 2025**, so common checks need no custom code at all.
- This is a **preventive** control. AWS Config is detective, catching the same problem after it exists.

> ON THE EXAM
>
> Warn mode first, then fail. It lets you measure how often a control would have blocked a deployment before it actually does.

A CloudFormation stack manages an application and its RDS database. The database resource has DeletionPolicy set to Retain. A developer changes a property that requires replacement of the DB instance and applies the update.

After the update, the original database no longer exists. The team expected Retain to protect it.

What happened, and what should have been set?

A DeletionPolicy only applies to stack deletion and resource removal. UpdateReplacePolicy: Retain governs replacement

B A stack policy was required to prevent the update

C DeletionPolicy: Retain is not supported on RDS instances

D The update should have been made through a change set

◆ PAUSE AND DECIDE

What happened, and what should have been set?

A UpdateReplacePolicy governs replacement

The two attributes cover different events. Replacement deletes the old resource under UpdateReplacePolicy, which defaults to Delete.

B A stack policy

Genuinely would have blocked the update, and it is a different control. The question asks what governs the old resource's fate, not how to block the change.

C Retain unsupported on RDS

It is fully supported. RDS instances without a cluster identifier even default to Snapshot rather than Delete.

D Use a change set

A change set would have warned that replacement was coming, which is valuable. It does not change what happens to the old resource once you proceed.

THE SIGNAL

Set both attributes on anything holding data. This is the most expensive gap in the module and it looks like a single setting.

A CloudFormation stack creates an Auto Scaling group of application servers. The stack reports CREATE_COMPLETE within four minutes, but the application takes around eight minutes to install and start on each instance.

A pipeline runs smoke tests immediately after the stack completes, and they fail intermittently.

What should be added to the template?

A. A DependsOn attribute linking the Auto Scaling group to the load balancer

B. A CreationPolicy with a ResourceSignal, and cfn-signal at the end of user data

C. An UpdatePolicy with AutoScalingRollingUpdate

D. A WaitCondition with a fixed 10-minute timeout and no signal

◆ PAUSE AND DECIDE

What should be added to the template?

A DependsOn the load balancer

Changes ordering between resources. The problem is not order; it is that an instance counts as created before it is ready.

B CreationPolicy plus cfn-signal

The stack waits for each instance to signal success from its own user data, so CREATE_COMPLETE means the application is actually running.

C UpdatePolicy rolling update

Governs updates, not creation. The scenario describes the initial deployment reporting success too early.

D A fixed 10-minute wait

The tempting shortcut. It waits whether or not anything worked, so it turns an intermittent failure into a slower intermittent failure.

THE SIGNAL

Launched is not ready. CreationPolicy is the only mechanism that makes CloudFormation's definition of complete match the application's.

A template must not contain the database master password. The password is already stored in AWS Secrets Manager. The team currently passes it as a template parameter with NoEcho set to true.

A security review objects that the password still appears in the pipeline's parameter file and in CloudTrail-visible API calls.

What should the team change?

A Keep the parameter and encrypt the parameter file at rest

B Use a dynamic reference: {{resolve:secretsmanager:...}} directly in the resource property

C Change the parameter type to AWS::SSM::Parameter::Value<String>

D Move the password into a Mappings section

◆ PAUSE AND DECIDE

What should the team change?

A Encrypt the parameter file

The value still travels through the pipeline and the API call. Encrypting where it rests does not remove it from where it moves.

B Dynamic reference to Secrets Manager

CloudFormation resolves the secret itself at deployment. The password is never in the template, the parameter file or the API call.

C SSM parameter type

Better than a plaintext parameter, and Parameter Store is not where the secret lives, and this type reads plaintext values.

D Mappings

Mappings are plaintext in the template, which is strictly worse than a NoEcho parameter.

THE SIGNAL

NoEcho hides a value that is present. A dynamic reference means the value was never present. The review objected to presence, not visibility.

> A template creates 24 nearly identical SQS queues, one per business region, differing only in name. Adding a property to all of them means editing 24 blocks by hand, and a recent change was applied to 23 of them.
>
> The team wants one definition driven by a list.

What should the team use?

A. Fn::ForEach with the AWS::LanguageExtensions transform

B. A nested stack containing one queue, instantiated 24 times

C. A Mappings section keyed by region name

D. A custom resource backed by a Lambda function that creates the queues

◆ PAUSE AND DECIDE

What should the team use?

A Fn::ForEach

Exactly what it was built for: one definition, a list, and CloudFormation generates the resources. A property change is edited once.

B 24 nested stacks

Solves the duplication and replaces it with 24 stacks to deploy, monitor and update. Far heavier than the problem requires.

C Mappings

Mappings supply values to resources. They do not create resources, so all 24 blocks would still exist.

D Lambda custom resource

Moves the resources outside CloudFormation's model, so drift detection and deletion no longer see them properly.

THE SIGNAL

The clue is 23 of 24. Copy-paste templates fail by omission, and that failure mode is what a loop removes.

> A platform team covers the whole organisation. No CloudFormation deployment may create an unencrypted S3 bucket, or an unencrypted EBS volume. They want the deployment to fail, not to be remediated afterwards.
>
> They also want to trial the control without blocking teams first.

What should the team implement?

A AWS Config rules with automatic SSM Automation remediation

B CloudFormation Hooks using managed proactive controls, in warn mode first and then fail mode

C A stack policy applied to every stack

D An SCP denying s3:CreateBucket without encryption

◆ PAUSE AND DECIDE

What should the team implement?

A. Config rules with remediation

Detective, then corrective. The resource is created non-compliant and fixed afterwards, which the requirement explicitly rejects.

B. Hooks with managed controls

Preventive: the deployment fails before provisioning. Managed controls need no custom code, and warn mode allows a safe trial.

C. Stack policies everywhere

Stack policies deny updates to existing resources in one stack. They cannot evaluate whether a new resource is compliant.

D. SCP on s3:CreateBucket

Genuinely preventive and covers only the API-level condition, with no equivalent for EBS here, and no warn mode to trial with.

THE SIGNAL

Two clauses: fail rather than remediate, and trial before enforcing. Warn mode is the second one, and only Hooks offer it.

The five things to carry forward

- **DeletionPolicy and UpdateReplacePolicy cover different events.** Set both on anything holding data.
- **CreationPolicy plus cfn-signal** makes CREATE_COMPLETE mean the application is actually running.
- **Ref gives one default value per resource type; GetAtt gives whatever you name.**
- **Dynamic references keep secrets out of the template entirely.** NoEcho only hides a value that is present.
- **Hooks are preventive; Config is detective.** Fn::ForEach removes the copy-paste template.

> ON THE EXAM
>
> Next: CloudFormation operations - change sets, drift, nested stacks, StackSets and failed rollbacks.

MODULE 19 · DOMAIN 3 - DEPLOYMENT, PROVISIONING, AND AUTOMATION

CloudFormation Operations

Stack states, change sets, drift, nested stacks, StackSets – and getting out of a failed rollback.

DOMAIN 3 of 5 EXAM WEIGHT 22% MODULE 19 of 35

admin@sthithapragna.com

A stack is a **state machine**. The state you are in determines what operations are legal, and one state permits only deletion.

The states that matter

STATE	WHAT YOU CAN DO FROM HERE
CREATE_COMPLETE / UPDATE_COMPLETE	Everything. Update, delete, create change sets
ROLLBACK_COMPLETE	DELETE ONLY. The stack cannot be updated
UPDATE_ROLLBACK_COMPLETE	Normal operations resume. This one is fine
UPDATE_ROLLBACK_FAILED	Continue update rollback, optionally skipping resources
DELETE_FAILED	Retry the delete, optionally retaining the resources that blocked it
REVIEW_IN_PROGRESS	A change set exists but has never been executed

ON THE EXAM

ROLLBACK_COMPLETE and UPDATE_ROLLBACK_COMPLETE sound almost identical and are completely different. One is a dead end, the other is recovery.

ROLLBACK_COMPLETE: the dead end

- It means the **initial creation** failed and the rollback succeeded. The stack exists as an empty shell.
- **You cannot update it.** The only permitted operation is delete.
- Fix the template, **delete the stack, and create it again**. There is no repair path.
- It only ever applies to a **first creation**. A stack that succeeded once will never reach this state.

> ON THE EXAM
>
> "The stack is in ROLLBACK_COMPLETE and my update fails" is not a permissions problem or a template problem. That state permits nothing but deletion.

When the rollback itself fails

- **UPDATE_ROLLBACK_FAILED** means an update failed, and putting things back also failed. Usually an external change or a dependency.
- **ContinueUpdateRollback** retries. If a specific resource keeps blocking it, use **ResourcesToSkip**.
- Skipping leaves that resource **out of sync with the template**, so fix it manually afterwards and confirm with drift detection.
- Common cause: somebody deleted or modified a resource outside CloudFormation while the stack was mid-update.

> ON THE EXAM
>
> Continue update rollback is the only way out. Deleting the stack from this state usually fails for the same reason the rollback did.

Failing without rolling back

- **Disable rollback** on a create or update keeps successfully provisioned resources in place when something fails.
- That lets you **inspect the half-built stack** and read the actual error on the resource, rather than watching it disappear.
- After fixing the cause, you can **retry the operation** from where it stopped rather than starting again.
- The stack sits in a failed state meanwhile, so this is a debugging tool rather than a production default.

> ON THE EXAM
>
> The classic frustration is a resource failing, rolling back, and being deleted before anyone could look at it. Disabling rollback is the fix for that.

Rollback triggers

- **Rollback triggers** name CloudWatch alarms that CloudFormation monitors during a create or update.
- If any named alarm enters ALARM, CloudFormation **rolls back the whole operation automatically**.
- Monitoring continues for a period **after** the operation completes, up to 180 minutes, so a delayed failure still triggers a rollback.
- Point them at real signals: application error rate, latency, or a business metric.

> ON THE EXAM
>
> This is how a deployment becomes self-reversing. The stack succeeding is not the same as the application still working.

Change sets

- A **change set** is a preview: what will be added, modified or removed, and crucially whether each change causes **replacement**.
- The **Replacement** column reads True, False or **Conditional**. Conditional means it depends on values CloudFormation cannot evaluate yet.
- Creating a change set on a new stack puts it in **REVIEW_IN_PROGRESS** until you execute it.
- Since 2025, CloudFormation runs **pre-deployment validation** at change set creation, catching property syntax errors and name conflicts early.

> ON THE EXAM
>
> Read the Replacement column before every production update. It is the difference between changing a database and creating a new empty one.

New: drift-aware change sets

- Announced **18 November 2025**. A standard change set compares the new template with the last deployed one, and ignores drift.
- A drift-aware change set does a **three-way diff**: new template, last deployed template, and **actual infrastructure state**.
- On execution it **reverts drift** to the template values, and **recreates resources deleted outside CloudFormation**.
- Create it with change set type **Drift-aware**, or **--deployment-mode REVERT_DRIFT**.

> ON THE EXAM
>
> Before this, reverting drift meant detecting it, then working out by hand what to change. Now the existing template is the remediation.

Drift detection

- Compares the **actual configuration** of stack resources against the template. Per resource: IN_SYNC, MODIFIED, DELETED or NOT_CHECKED.
- **Not every resource type supports it**, and unsupported ones report NOT_CHECKED rather than failing.
- It is **on demand**, not continuous. Run it on a schedule, or trigger it from EventBridge.
- StackSets has its own drift detection across every stack instance, which is how you find one account that was edited by hand.

> ON THE EXAM
>
> Drift detection tells you something changed. Drift-aware change sets are how you put it back. Detection and remediation are now separate features.

Nested stacks or cross-stack exports?

NESTED STACKS

One stack, composed

- A parent template referencing child templates
- Deployed, updated and deleted as one unit
- Values passed as parameters, returned as outputs
- For reusable components in one application

CROSS-STACK EXPORTS

Separate, loosely joined

- Independent stacks with their own lifecycles
- Export and Fn::ImportValue between them
- For different teams owning different layers
- Rigid: an export in use cannot change

THE TIEBREAKER

Ask who owns the lifecycle. One team deploying one application is nested stacks. A network team and an application team is cross-stack.

Nested stack mechanics

- A child is an **AWS::CloudFormation::Stack** resource whose TemplateURL points at S3.
- **Update from the root stack**, never the child directly. Updating a child directly makes the parent drift from reality.
- The **root stack** is the top of the tree; a **parent** is the immediate stack above a given child.
- Nested stacks each count toward the resource limit separately, which is how large architectures get past the 500-resource ceiling.

> ON THE EXAM
>
> Deleting the root deletes every nested stack. That is the point of nesting, and it is also why you never nest a database you must keep.

Bringing existing resources under management

- **Resource import** brings an existing resource into a stack without recreating it, matched by its physical identifier.
- **The IaC generator** scans an account and produces a template from resources that already exist.
- It works within **one account and one Region**, and generates **literal values** rather than parameters.
- Expect a refactoring pass afterwards to introduce parameters, mappings and conditions. The generated template is a starting point.

> ON THE EXAM
>
> "We built it in the console and now we need it in code" is the IaC generator, followed by resource import. Neither recreates anything.

Stack refactoring

- **Move resources between stacks**, or rename their logical IDs, **preserving state and data**.
- Without it, moving a resource meant removing it from one template and adding it to another, which **deletes and recreates** it.
- Available through the CLI, and since 2025 through the **console and CDK** as well.
- The typical use: splitting one large stack that has outgrown itself, or extracting a shared component.

> ON THE EXAM
>
> Renaming a logical ID used to be a destructive operation. That surprised a lot of people, and refactoring is the supported way to avoid it.

StackSets

- One template, deployed as **stack instances** across many accounts and Regions from a single administrator account.
- The **StackSet** is the definition. A **stack instance** is one deployment of it into one account and Region.
- Updating the StackSet updates every instance, which is what stops ninety accounts drifting apart.
- A stack instance can fail independently. Failure tolerance decides whether that stops the whole operation.

> ON THE EXAM
>
> StackSets solves consistency across accounts. Nested stacks and exports solve structure within one account. They answer different questions.

Self-managed or service-managed permissions?

SELF-MANAGED

You create the roles

- An administration role in the admin account
- An execution role in every target account
- Works with accounts outside an organisation
- You add each target account explicitly

SERVICE-MANAGED

Organizations handles it

- Target organisational units, not account IDs
- AWS creates and manages the roles
- New accounts joining an OU are covered automatically
- Needs Organizations, all features enabled

THE TIEBREAKER

"New accounts must be covered automatically" is service-managed. That automatic deployment is the feature self-managed cannot offer.

StackSets operation preferences

- **Maximum concurrent accounts**: how many accounts are updated at once, as a number or a percentage.
- **Failure tolerance**: how many accounts may fail before the whole operation stops. Set it low for production.
- **Region concurrency**: sequential or parallel, plus a **Region order** so you can deploy to a test Region first.
- Failure tolerance of 0 with concurrency of 1 is the safest and slowest. Across 200 accounts, that is a very long afternoon.

> ON THE EXAM
>
> These are the StackSets equivalent of Run Command's rate control and instance refresh's checkpoints. Same idea, different service.

Operating StackSets

- **Delegated administration** lets a member account run StackSets, so the management account is not used for daily work.
- **Drift detection for StackSets** checks every stack instance, which is how you find the one account somebody edited by hand.
- **Parameter overrides** let one account differ, for example a different CIDR range, without a separate StackSet.
- Overrides are also how StackSets quietly become inconsistent. Use them sparingly and deliberately.

> ON THE EXAM
>
> Organization backup policies from module 16 and StackSets solve the same class of problem: push configuration down so accounts cannot opt out.

Git sync, and getting unstuck

- **CloudFormation Git sync** watches a repository and deploys a change set whenever a template or deployment file changes.
- Since September 2024 it posts **change set details as pull request comments**, so the review shows what will actually change.
- **Termination protection** blocks stack deletion until it is explicitly turned off. Enable it on production stacks.
- For a stack that will not delete, **force delete** options can retain the blocking resources and remove the stack.

> ON THE EXAM
>
> A pull request showing the change set is the cheapest safety control in this module. The reviewer sees replacement warnings before merging.

> A developer creates a new stack. It fails because an S3 bucket name was already taken, and CloudFormation rolls back. The stack now shows ROLLBACK_COMPLETE.
>
> The developer corrects the bucket name in the template and attempts a stack update, which fails immediately.

What should the developer do?

A Use ContinueUpdateRollback to clear the failed state

B Delete the stack and create it again with the corrected template

C Create a change set against the existing stack and execute it

D Enable disable-rollback and retry the update

◆ PAUSE AND DECIDE

What should the developer do?

A ContinueUpdateRollback

Applies to UPDATE_ROLLBACK_FAILED, a different state. There is no update rollback in progress to continue here.

B Delete and recreate

ROLLBACK_COMPLETE permits deletion only. There is no repair path, and the stack contains nothing worth preserving.

C Change set and execute

A change set is still an update, and updates are not permitted from this state. It fails for the same reason.

D Disable rollback and retry

Useful on the next attempt to keep resources for debugging. It does not make an update legal from ROLLBACK_COMPLETE.

THE SIGNAL

The similar names are the whole trap. ROLLBACK_COMPLETE is a first-creation dead end; UPDATE_ROLLBACK_COMPLETE and UPDATE_ROLLBACK_FAILED are different states entirely.

During an incident, an engineer manually increased an Auto Scaling group's maximum size and changed a security group rule, both outside CloudFormation. The stack's template still holds the original values.

The team wants to bring the resources back in line with the template, and wants to see exactly what will change before doing it.

What should the team use?

A. A drift-aware change set, reviewing the three-way diff before executing

B. Drift detection, then manually edit each resource back to its template value

C. A standard change set with no template changes

D. Delete the stack and redeploy it from the template

◆ PAUSE AND DECIDE

What should the team use?

A Drift-aware change set

The three-way diff shows template, last deployment and actual state, then execution reverts the drift. It answers both halves of the requirement.

B Detect, then edit by hand

What teams did before November 2025. It works, it is manual, and it is easy to miss a property.

C Standard change set

The sharpest distractor. A standard change set compares the new template with the last deployed one and does not consider drift at all, so it reports no changes.

D Delete and redeploy

Destroys and recreates everything to correct two properties. Maximum disruption for a small correction.

THE SIGNAL

Option C fails for a specific reason worth remembering: a standard change set is blind to drift. That blindness is exactly what the new type removes.

> An organisation with 140 accounts must ensure every account has a standard set of IAM roles and a Config recorder. New accounts are created roughly weekly and must be covered without anyone remembering. The organisation uses AWS Organizations with all features enabled.
>
> Deployment must stop if more than two accounts fail.

What should the organisation implement?

A. A service-managed StackSet targeting the organisation's OUs, with automatic deployment enabled and failure tolerance set to 2

B. A self-managed StackSet listing all 140 account IDs

C. A CloudFormation template deployed by a pipeline into each account

D. Nested stacks, with one child stack per account

◆ PAUSE AND DECIDE

What should the organisation implement?

A Service-managed StackSet on OUs

Automatic deployment covers accounts created later with no action, and failure tolerance of 2 implements the stated stopping condition.

B Self-managed with 140 account IDs

Works today and requires somebody to add each new account every week. That is precisely the manual step the requirement forbids.

C A pipeline per account

Rebuilds StackSets by hand, with no failure tolerance mechanism and 140 deployments to keep aligned.

D Nested stacks

Nesting composes a template within one account. It is not a multi-account mechanism at all.

THE SIGNAL

"New accounts must be covered without anyone remembering" is automatic deployment, and only service-managed permissions offer it.

A single CloudFormation stack has grown to manage networking, databases and three applications. The team wants to split it into four stacks owned by different teams, without recreating the RDS databases or the VPC.

Removing resources from one template and adding them to another would delete and recreate them.

What should the team use?

A Stack refactoring, to move resources between stacks while preserving state

B Resource import into new stacks after deleting the original stack with resources retained

C Convert the stack to nested stacks with the same resources

D Export the resources and use Fn::ImportValue in the new stacks

◆ PAUSE AND DECIDE

What should the team use?

A Stack refactoring

Purpose-built for exactly this: move resources between stacks and rename logical IDs while preserving state and data.

B Retain, delete, then import

The pre-refactoring workaround. It works, and it is several careful manual steps with a window where nothing is managed.

C Convert to nested stacks

Restructures the template and keeps one lifecycle. The requirement is separate ownership by different teams, which nesting does not give.

D Export and ImportValue

Shares values between stacks. It does not move a resource from one stack's management into another's.

THE SIGNAL

Option B is the honest historical answer and the reason refactoring exists. Recognising the manual workaround and the supported feature is worth knowing.

> A stack update fails partway through and then enters UPDATE_ROLLBACK_FAILED. Investigation shows that an engineer deleted a security group by hand during the update, so CloudFormation cannot restore the previous state.
>
> The team needs the stack back into a usable state.

What should the team do?

A. Delete the stack and redeploy from the template

B. Call ContinueUpdateRollback, skipping the security group if it still blocks, then fix it manually and verify with drift detection

C. Create a change set to reapply the previous template

D. Enable termination protection and retry the update

◆ PAUSE AND DECIDE

What should the team do?

A Delete and redeploy

Deleting from UPDATE_ROLLBACK_FAILED usually fails for the same reason the rollback did, and it destroys everything the stack manages.

B ContinueUpdateRollback, then repair

The documented way out. Skipping leaves that resource out of step with the template, so the manual fix and drift check complete the job.

C Change set on the previous template

Updates are not permitted while the stack is in UPDATE_ROLLBACK_FAILED. The rollback must be resolved first.

D Termination protection

Prevents deletion. It has no effect on a failed rollback and does not make an update legal.

THE SIGNAL

Note the second half of the answer. Skipping a resource clears the state and leaves a lie in the template, so the repair is not finished at that point.

The five things to carry forward

- **ROLLBACK_COMPLETE permits deletion only.** UPDATE_ROLLBACK_FAILED needs ContinueUpdateRollback.
- **A standard change set is blind to drift.** Drift-aware change sets add actual state and revert it.
- **Nested stacks share one lifecycle; exports keep lifecycles separate.** Ask who owns what.
- **Service-managed StackSets deploy to new accounts automatically.** Self-managed cannot.
- **Stack refactoring moves resources without recreating them.** Renaming a logical ID used to be destructive.

> ON THE EXAM
>
> Next: beyond CloudFormation - CDK, Terraform, Git workflows, Service Catalog, Control Tower and RAM.

MODULE 20 · DOMAIN 3 - DEPLOYMENT, PROVISIONING, AND AUTOMATION

Beyond CloudFormation

CDK, Terraform, Git workflows, Service Catalog, Control Tower and Resource Access Manager.

DOMAIN 3 of 5 EXAM WEIGHT 22% MODULE 20 of 35

admin@sthithapragna.com

None of these tools change what AWS does. They change **who owns the state**, **how intent is expressed**, and **who is allowed to press the button**.

The AWS CDK

- Define infrastructure in a **real programming language**: TypeScript, Python, Java, C#, Go. It **synthesises to CloudFormation**.
- Because the output is CloudFormation, **everything from modules 18 and 19 still applies**: stacks, change sets, drift, StackSets.
- Loops, conditionals, functions and unit tests come from the language, not from a transform.
- The state of record is still the **CloudFormation stack**. CDK is an authoring layer, not a separate engine.

> ON THE EXAM
>
> CDK questions are usually CloudFormation questions wearing different clothes. The deployed artefact is a stack either way.

CDK constructs, in three levels

LEVEL	WHAT IT GIVES YOU
L1, the Cfn* constructs	A one-to-one mapping of CloudFormation resources. Verbose, complete, no defaults
L2, curated constructs	Sensible defaults and helper methods. The level you normally write
L3, patterns	Whole architectures in one object, such as a load-balanced Fargate service

ON THE EXAM

L2 is where the value is. One line grants a Lambda function read access to a bucket, and the CDK writes the IAM policy for you.

The CDK workflow

- **cdk bootstrap** once per account and Region. It creates the **CDKToolkit stack**: an S3 bucket, an ECR repository and IAM roles.
- **cdk synth** produces the CloudFormation template. **cdk diff** compares it with what is deployed.
- **cdk deploy** creates a change set and executes it, so a CDK deployment is a CloudFormation deployment.
- **Forgetting to bootstrap** is the classic first failure. Deployment fails before anything is created.

> ON THE EXAM
>
> cdk diff is the CDK's change set preview. Use it in a pull request exactly as module 19 used change sets in Git sync.

CDK or plain CloudFormation?

CLOUDFORMATION WHEN

The template is the artefact

- Operations teams read and edit it directly
- No build step, no runtime, no dependencies
- Service Catalog and StackSets take templates
- Reviewers see exactly what deploys

CDK WHEN

The infrastructure has logic

- Repetition, conditionals, computed values
- Developers already own the code
- Unit tests over infrastructure
- Reviewers must trust the synthesis

THE TIEBREAKER

The reviewability trade is real. A template is exactly what deploys; CDK code is a program that produces what deploys.

Terraform on AWS

- A third-party tool using its own language, HCL, with an AWS **provider**. Also manages non-AWS resources.
- **terraform plan** previews, **terraform apply** executes. Plan is the change set equivalent.
- Terraform keeps its **own state file** recording what it believes exists. CloudFormation keeps that state for you, in the stack.
- The state file is the whole difference. Lose it, corrupt it, or run two applies at once, and Terraform loses track of your infrastructure.

> ON THE EXAM
>
> "We manage AWS, Azure and a SaaS provider from one workflow" is the strongest Terraform signal. CloudFormation and CDK are AWS-only.

Terraform state on AWS, corrected

- Store state in an **S3 bucket**, versioned and encrypted. That part has not changed.
- **Locking with a DynamoDB table is deprecated.** HashiCorp's own documentation says it will be removed in a future minor version.
- The current method is **S3 native locking**: set **use_lockfile = true**. Terraform writes a **.tflock** object beside the state file.
- Cheaper, simpler, and one fewer resource to manage. Both can be configured together during a migration.

> ON THE EXAM
>
> Nearly every SOA-C03 study guide still says "S3 plus a DynamoDB lock table". That was correct, and it is now the deprecated pattern.

Terraform or CloudFormation?

CLOUDFORMATION WHEN

AWS only, no state to own

- AWS manages state inside the stack
- Native drift detection and rollback
- StackSets for multi-account at scale
- Service Catalog consumes templates directly

TERRAFORM WHEN

Multiple providers

- AWS plus other clouds or SaaS in one workflow
- Existing team skills and modules
- A rich module ecosystem
- You own the state file and its protection

THE TIEBREAKER

New AWS-only work with no existing Terraform: CloudFormation or CDK. Anything spanning providers, or an existing Terraform estate: Terraform.

Git as the operational control

- The repository is the source of truth. Deployments come from a **merged commit**, not from somebody's laptop.
- **Pull request review** is where the safety lives. Module 19's Git sync posts the change set into the PR.
- Run **cfn-lint**, **CloudFormation Guard**, **cdk diff** or **terraform plan** in CI, so problems surface before review.
- Any manual console change becomes **drift**. Git only tells the truth if nobody edits production directly.

> ON THE EXAM
>
> The exam's interest in Git is operational, not technical. Branching strategy is not examinable; deploying only from reviewed, version-controlled code is.

AWS Service Catalog

- A **product** is a CloudFormation template. A **portfolio** groups products and is granted to IAM principals.
- Users launch approved products **without holding the underlying permissions**, which is the entire point.
- A **launch constraint** names the IAM role Service Catalog assumes to provision, so the user never needs it.
- Launched instances are **provisioned products**, tracked per user, and updatable to a newer product version.

> ON THE EXAM
>
> "Developers should self-serve databases without permission to create databases" is Service Catalog with a launch constraint. Nothing else does that.

Service Catalog constraints

CONSTRAINT	WHAT IT ENFORCES
Launch	The IAM role used to provision, so users need no underlying permissions
Template	Restricts parameter values: only these instance sizes, only these Regions
Notification	Sends stack events to an SNS topic
Stack set	Provisions the product across multiple accounts and Regions
Tag update	Whether tags may be changed on a provisioned product

ON THE EXAM

Template constraints are how you offer one product safely. The template allows any instance type; the constraint allows three.

AWS Control Tower

- Sets up and governs a multi-account **landing zone**: a management account, plus **Log Archive** and **Audit** accounts, and a Security OU.
- **Account Factory** provisions new accounts to a standard, with networking and guardrails already applied.
- Built on **Organizations, Config, CloudTrail, IAM Identity Center and Service Catalog**. It orchestrates rather than replaces them.
- **Landing zone drift** occurs when someone changes the underlying resources directly. Control Tower detects and reports it.

> ON THE EXAM
>
> Account Factory is a Service Catalog product. That is why the two services appear together so often.

Control Tower controls, in three kinds

- **Preventive** controls are implemented as **service control policies**. They stop the action from happening at all.
- **Detective** controls are implemented as **AWS Config rules**. They report a resource that is already non-compliant.
- **Proactive** controls are implemented as **CloudFormation Hooks**. They block a non-compliant resource before it is provisioned.
- Controls are drawn from a shared **Control Catalog**, and are applied to organisational units rather than to individual accounts.

> ON THE EXAM
>
> Three mechanisms you already know from three different modules, presented as one governance vocabulary. Preventive stops it, proactive blocks the template, detective finds it afterwards.

AWS Resource Access Manager

- Share resources with **specific accounts, organisational units, or the whole organisation**, without copying anything.
- Commonly shared: **VPC subnets, Transit Gateways, Route 53 Resolver rules, prefix lists, License Manager configurations, Capacity Reservations**.
- With a **shared subnet**, participants launch resources into the owner's VPC. One VPC, many accounts, no peering.
- The owner keeps control: participants **cannot modify or delete the subnet**, and cannot see other participants' resources.

> ON THE EXAM
>
> Sharing a subnet is not the same as granting access to an account. The resource stays owned, and only its use is shared.

RAM or a cross-account role?

RAM WHEN

Share the resource

- Participants use the resource in their own account
- The owner keeps control of its lifecycle
- No credentials to assume, no role chaining
- Subnets, Transit Gateways, Resolver rules

CROSS-ACCOUNT ROLE WHEN

Share the access

- A principal acts inside the other account
- Anything RAM does not support
- Temporary credentials via AssumeRole
- Auditable per session in CloudTrail

THE TIEBREAKER

RAM shares a thing. A role shares an identity. If the requirement is "launch instances in the shared VPC", that is RAM.

How the governance pieces fit

- **Organizations** is the account structure and the policy boundary. Everything else builds on it.
- **Control Tower** establishes and governs the landing zone, and applies controls to OUs.
- **Service Catalog** gives teams safe self-service inside that structure. Account Factory is itself a Service Catalog product.
- **RAM** shares infrastructure across the accounts, so central networking is not duplicated in every one.

> ON THE EXAM
>
> A question naming several of these is usually asking which layer solves the stated problem, not which service is best.

> Development teams need to create RDS databases on demand, but the security team will not grant rds:CreateDBInstance to developers. Every database must use approved instance classes, be encrypted, and be tagged with a cost centre.
>
> The platform team has a CloudFormation template that already does all of this.

What should the platform team implement?

A. A Service Catalog portfolio with the template as a product, a launch constraint, and a template constraint on instance classes

B. Grant developers rds:CreateDBInstance with an IAM condition restricting instance classes

C. A StackSet that deploys the template into each development account

D. A CDK construct published to an internal package repository

◆ PAUSE AND DECIDE

What should the platform team implement?

A Service Catalog with both constraints

The launch constraint means developers never hold the permission, and the template constraint limits instance classes. Self-service without privilege.

B Grant the permission with conditions

Directly contradicts the stated constraint. The security team will not grant it, conditioned or otherwise.

C A StackSet

Pushes the same resources to every account on the platform team's schedule. It is not on-demand self-service.

D A CDK construct

Standardises the code and still requires developers to hold the permissions to deploy it. It solves consistency, not privilege.

THE SIGNAL

The stated refusal to grant the permission is the whole question. Only the launch constraint provisions with a role the user does not have.

> A team is setting up Terraform state for a new AWS project in 2026. A colleague shares a runbook from an older project specifying an S3 bucket for state plus a DynamoDB table with a LockID partition key.
>
> A colleague shares a runbook from an older project. It specifies an S3 bucket for state, plus a DynamoDB table with a LockID partition key. The team wants the currently recommended configuration.

What should the team do?

A Follow the runbook: S3 for state and a DynamoDB table for locking

B Use an S3 bucket for state with use_lockfile = true, and no DynamoDB table

C Store state locally and commit it to Git

D Use CloudFormation instead, since Terraform state is unmanaged

◆ PAUSE AND DECIDE

What should the team do?

A S3 plus DynamoDB

Works, and DynamoDB locking is deprecated in HashiCorp's own documentation and slated for removal. It is a runbook that has aged.

B S3 with use_lockfile

S3 native locking is the current mechanism: a .tflock object beside the state file, one fewer resource, and no deprecated arguments.

C Local state in Git

State contains resource identifiers and often secrets, and committing it gives no locking at all. Two teammates applying at once corrupt it.

D Switch to CloudFormation

A reasonable tool choice in general, and it answers a different question. The team asked how to configure Terraform state correctly.

THE SIGNAL

The same shape as the ARC readiness check and Incident Manager scenarios: an experienced colleague's advice that has quietly gone out of date.

A company runs 60 accounts. Each application account currently has its own VPC, and connectivity between them is provided by a growing mesh of VPC peering connections. Address space is becoming difficult to manage.

A central networking team should own the network, while application teams continue to launch their own instances.

What should the company implement?

A Share subnets from a central VPC using AWS RAM, so application accounts launch into the owner's VPC

B Create a cross-account IAM role in the networking account for each application team

C Replace peering with a Transit Gateway and keep one VPC per account

D Use a StackSet to deploy an identical VPC into every account

◆ PAUSE AND DECIDE

What should the company implement?

A RAM-shared subnets

One VPC owned centrally, 60 accounts launching into it. No peering, one address space, and participants cannot alter the subnets.

B Cross-account roles

Shares an identity, so application teams would work inside the networking account. That is the opposite of teams owning their own instances.

C Transit Gateway

The strongest alternative. It genuinely replaces the peering mesh, and it leaves 60 VPCs and 60 CIDR ranges to manage.

D StackSet-deployed VPCs

Makes 60 VPCs consistent rather than reducing them to one. The address space problem is unchanged.

THE SIGNAL

Two problems are stated: a peering mesh and address space. Transit Gateway fixes the first; shared subnets fix both.

> A governance team must ensure that across every account in the organisation, S3 buckets can never be created without encryption. They want the CloudFormation deployment itself to fail, they want existing non-compliant buckets reported, and they want the control managed centrally per OU rather than per account.
>
> The organisation uses AWS Control Tower.

Which combination of Control Tower controls should they apply?

A. A proactive control for the deployment-time block, and a detective control for existing buckets

B. A preventive control only, since SCPs stop the API call

C. A detective control only, with automatic remediation

D. A proactive control only, since it blocks provisioning

◆ PAUSE AND DECIDE

Which combination of Control Tower controls should they apply?

A Proactive plus detective

Proactive is a CloudFormation Hook, so the deployment fails. Detective is a Config rule, which reports the buckets that already exist.

B Preventive only

An SCP blocks the API call, which is strong. It reports nothing about buckets that already exist, and the requirement asks for that.

C Detective only

Finds and fixes non-compliant buckets after creation. The requirement explicitly wants the deployment to fail.

D Proactive only

Blocks new deployments correctly, and says nothing about the buckets already in the estate.

THE SIGNAL

Two requirements, two control types. The word combination in the question is the hint that one control type will not cover both.

> A platform team maintains infrastructure code for 40 microservices. Each needs an almost identical set of resources, differing in a few parameters. The team wants unit tests over the infrastructure definitions and wants to publish a reusable component their developers consume.
>
> Everything is AWS-only and the team already writes TypeScript.

What should the team use?

A AWS CDK, publishing an L3 construct that developers instantiate

B One CloudFormation template with Fn::ForEach over a list of services

C Terraform modules with an S3 backend

D A Service Catalog product per microservice

◆ PAUSE AND DECIDE

What should the team use?

A CDK with a published L3 construct

Unit tests come from the language, an L3 construct is exactly a reusable component, and the team already writes TypeScript.

B Fn::ForEach in one template

Good for repetition inside one stack. It gives no unit tests, and one template for 40 services means one blast radius.

C Terraform modules

Modules are genuinely reusable and the estate is AWS-only with no existing Terraform, so this adds a state file to own for no gain.

D Service Catalog products

Solves governed self-service, not code reuse. Forty products would each still need a template maintained.

THE SIGNAL

"Unit tests over infrastructure" is the CDK signal. No template language offers them, because a template is data rather than code.

The five things to carry forward

- **CDK synthesises to CloudFormation.** A CDK question is usually a CloudFormation question.
- **Terraform's difference is the state file you own.** S3 native locking, not DynamoDB, is current.
- **A launch constraint provisions with a role the user does not have.** That is Service Catalog's whole purpose.
- **Preventive is an SCP, detective is a Config rule, proactive is a CloudFormation Hook.**
- **RAM shares a thing; a cross-account role shares an identity.** Shared subnets collapse a peering mesh.

> ON THE EXAM
>
> Next: images and containers for operators - EC2 Image Builder, AMIs, ECR, and ECS and EKS basics.

MODULE 21 · DOMAIN 3 - DEPLOYMENT, PROVISIONING, AND AUTOMATION

Images and Containers for Operators

EC2 Image Builder, AMI governance, ECR, ECS and EKS - all newly in scope for SOA-C03.

DOMAIN 3 of 5 EXAM WEIGHT 22% MODULE 21 of 35

admin@sthithapragna.com

An image is a **deployment artefact**. The operator's job is its lifecycle - built consistently, scanned, distributed, governed and expired - not what is inside it.

The golden AMI pattern

- Bake packages, agents, hardening and application code **into the image** rather than installing them at launch.
- Launch time drops from minutes to seconds, which module twelve showed is the difference between winning and losing a scaling race.
- Every instance is **identical**, so drift between instances stops being possible.
- The cost is a **rebuild cadence**. An image that is never rebuilt is a security debt that grows every month.

> ON THE EXAM
>
> Module twelve's warm pool decision reappears here. Installation belongs in the image; loading current data does not.

EC2 Image Builder: the four pieces

- **Recipe**: a parent image plus ordered **components** and volume configuration. Image recipes make AMIs; container recipes make container images.
- **Components** are YAML documents with **build** and **test** phases. AWS provides many; you write the rest.
- **Infrastructure configuration**: the instance type, subnet, IAM role and logging used **during the build**.
- **Distribution configuration**: which Regions and accounts receive the finished image, and its launch permissions.

> ON THE EXAM
>
> The test phase is what makes this more than a script. An image that fails its tests is never distributed.

An Image Builder pipeline

01
Trigger
A schedule, a dependency update, or a manual run.

02
Build
Launch a temporary instance, apply components in order.

03
Test
Run test components. Failure stops the pipeline here.

04
Distribute
Copy to target Regions and accounts, set launch permissions.

05
Expire
Lifecycle policies deprecate, disable or delete old images.

ON THE EXAM

"Rebuild monthly, or whenever the parent image is patched" is the schedule plus dependency-update trigger. That is the answer to stale AMIs.

AMI lifecycle for operators

- **Copy** to another Region, optionally **re-encrypting** with a different KMS key. An AMI is Regional.
- **Share** with specific accounts, an organisation, or publicly, using launch permissions.
- **Deprecate** hides an AMI from normal listings from a date, without breaking anything that already references it.
- **Deregister** removes it. Anything referencing that AMI ID afterwards **fails to launch**, which breaks Auto Scaling groups.

ON THE EXAM

Deprecate first, deregister much later. Deregistering an AMI still referenced by a launch template turns a scale-out into an outage.

Governing which AMIs may be used

- **Allowed AMIs** is an account-wide, per-Region EC2 setting restricting which AMIs are **discoverable and usable**.
- Criteria: trusted **accounts and owner aliases**, plus **marketplace codes, creation date, deprecation time and AMI name patterns**.
- **Audit mode** applies no restrictions and reports which AMIs **would** be blocked, so you can measure before enforcing.
- It **never restricts AMIs your own account owns**, and it must be configured in every Region, or applied by a declarative policy.

> ON THE EXAM
>
> Audit mode first, then enforce. The same pattern as CloudFormation Hooks' warn mode and predictive scaling's forecast-only mode.

Amazon ECR

- A managed container registry. **Private** repositories per account, and **ECR Public** for images you publish.
- Access is **IAM**: repository policies plus identity policies. There are no registry usernames and passwords.
- **Tag immutability** stops a tag being repointed at different content, so **latest** cannot silently change under you.
- **Lifecycle policies** expire images by age or by count, which is how a repository does not grow forever.

> ON THE EXAM
>
> Immutable tags plus deploying by digest is how you guarantee that what you tested is what you ran.

ECR scanning: basic or enhanced?

BASIC SCANNING

On push, operating system only

- Scans OS packages against a CVE database
- Triggered on push, or run manually
- No additional charge
- A point-in-time result that does not update

ENHANCED SCANNING

Amazon Inspector, continuous

- OS packages and application language packages
- Continuous rescanning as new CVEs are published
- Findings flow into Inspector and Security Hub
- Charged per image scanned

THE TIEBREAKER

Basic tells you an image was clean when you pushed it. Enhanced tells you it is still clean today.

ECR at scale

- **Replication rules** copy images to other Regions and accounts automatically, so a DR Region has the images it needs.
- **Pull through cache** mirrors an upstream registry such as Docker Hub or ECR Public into your own repository on first pull.
- That removes an external dependency at deployment time, and removes upstream rate limits from your critical path.
- Without replication, a disaster recovery Region has **no images**. Module 17 listed this as a classic DR test failure.

> ON THE EXAM
>
> Pull through cache is the answer to "our deployment failed because Docker Hub rate-limited us". It also gives you scanning on borrowed images.

ECS vocabulary

TERM	WHAT IT IS
Cluster	A logical grouping of capacity where tasks run
Task definition	The blueprint: image, CPU, memory, ports, roles, log configuration
Task	One running instantiation of a task definition
Service	Keeps a desired number of tasks running, and registers them with a load balancer
Capacity provider	Where capacity comes from: Fargate, Fargate Spot, or an Auto Scaling group

ON THE EXAM

A task is to a task definition what an EC2 instance is to a launch template. A service is the Auto Scaling group equivalent.

ECS on EC2 or on Fargate?

EC2 LAUNCH TYPE

You own the instances

- Choose instance types, including GPU
- Patch and manage the hosts yourself
- Better density: many tasks per instance
- Cheaper at steady high utilisation

FARGATE

No hosts at all

- Per-task CPU and memory, no instances
- No patching, no capacity planning
- Fargate Spot for interruptible work
- Higher unit price, less operational cost

THE TIEBREAKER

"No infrastructure to manage" means Fargate. Specific instance types, GPUs, or high density means EC2 - or, now, Managed Instances.

ECS Managed Instances

- A newer middle option: **real EC2 instances of any type**, with AWS handling **provisioning, scaling, patching and maintenance**.
- Gives you what Fargate cannot: **GPUs, specific CPU architectures, high network performance**, without owning the hosts.
- ECS launches them using an **infrastructure role** in your account, created for ECS to act on your behalf.
- **SCPs apply to that infrastructure role.** A policy restricting which AMIs may launch will break it unless the ECS AMI accounts are permitted.

> ON THE EXAM
>
> This is a genuine operations trap. A perfectly reasonable security policy silently stops a managed compute option from provisioning anything.

ECS task role or task execution role?

TASK ROLE

What your application can do

- Assumed by the code inside the container
- Read from S3, write to DynamoDB, call an API
- The container's own AWS identity
- Scope it to what the application needs

TASK EXECUTION ROLE

What ECS needs to start it

- Used by the ECS agent, not by your code
- Pull the image from ECR
- Write container logs to CloudWatch Logs
- Fetch secrets from Secrets Manager or SSM

THE TIEBREAKER

"The task will not start and cannot pull the image" is the execution role. "The application gets AccessDenied calling S3" is the task role.

Operating an ECS service

- **Rolling updates** are controlled by minimum and maximum healthy percent, which is how capacity is preserved during a deployment.
- The **deployment circuit breaker** detects a failing deployment and can **roll it back automatically**.
- **Service Auto Scaling** is Application Auto Scaling, from module twelve. Target tracking on CPU, memory or request count.
- **ECS Exec** opens a shell in a running container, using the same channel as Session Manager. No SSH, no bastion.

> ON THE EXAM
>
> ECS Exec is Session Manager for containers, and it is audited the same way. If a question asks how to debug a running container securely, that is the answer.

EKS compute options

OPTION	WHO MANAGES THE NODES
Self-managed nodes	You. Full control, full responsibility, including AMIs and patching
Managed node groups	AWS provisions and updates them; you choose types and scaling ranges
Fargate profiles	No nodes. One pod per micro-VM. No DaemonSets
EKS Auto Mode	AWS entirely: provisioning, patching, and the AMI choice

ON THE EXAM

The trend across ECS and EKS is identical: AWS takes over more of the node lifecycle, and you give up access to the node in exchange.

EKS Auto Mode

- Powered by **Karpenter**, running **Bottlerocket**-based AMIs on **EC2 managed instances**. AWS creates, patches and deletes nodes.
- **No SSH and no SSM access to nodes**, and **no custom AMIs**. That is the trade for AWS owning the operating system.
- **No Windows node support.** Windows workloads stay on managed or self-managed node groups.
- **From 22 April 2026**, new Auto Mode managed instances and their launch templates, volumes and ENIs are **hidden from the EC2 console and describe APIs by default**.

> ON THE EXAM
>
> Auto Mode manages nodes, not pods. You still need HPA or KEDA to decide how many replicas your application runs.

EKS identity: IRSA or Pod Identity?

IRSA

OIDC federation

- An OIDC provider per cluster, trusted by IAM
- Role trust policy references the cluster's OIDC issuer
- Works everywhere, including outside EKS
- More setup, and role trust must be edited per cluster

EKS POD IDENTITY

An agent and an association

- An add-on agent plus a role association
- One simple trust policy, reusable across clusters
- No OIDC provider to create per cluster
- Newer, and the simpler default for new clusters

THE TIEBREAKER

Both give a pod its own IAM role rather than borrowing the node's. That is the point, and it is the same argument as module 3's Pod Identity note.

Watching containers

- **Container Insights** gives cluster, node, pod and task level metrics for both ECS and EKS.
- On ECS: the **awslogs** driver or **FireLens**. On EKS: **Fluent Bit**, from the Observability add-on. Module three covered both.
- Container Insights with **enhanced observability** adds deeper per-container detail, charged per observation.
- **Fargate has no host**, so anything requiring a DaemonSet or a node agent does not apply there.

> ON THE EXAM
>
> The Fargate point recurs. No host means no node-level agent, which changes how logs and metrics are collected.

> An ECS service on Fargate fails to start. Tasks move from PROVISIONING to STOPPED with the message 'CannotPullContainerError: access denied'. The application code has not changed and the image exists in ECR.
>
> The task definition specifies both a task role and a task execution role.

Which role should be investigated?

A The task role, because the container cannot access ECR

B The task execution role, because ECS uses it to pull the image before the container starts

C The ECS cluster's instance profile

D The service-linked role for ECS

◆ PAUSE AND DECIDE

Which role should be investigated?

A The task role

The task role is the application's identity and is only used once the container is running. The failure happens before that.

B The task execution role

Pulling the image, writing logs and fetching secrets all happen under the execution role, before any application code runs.

C Cluster instance profile

There are no instances. Fargate has no hosts, so there is no instance profile to hold permissions.

D ECS service-linked role

Lets ECS manage load balancers and scaling on your behalf. It is not used to pull images.

THE SIGNAL

The stage of failure identifies the role. Anything that happens before your code runs is the execution role's job.

> A security team enables an SCP restricting which AMIs may launch EC2 instances. Only images owned by the company's own accounts are permitted. Shortly afterwards, an EKS Auto Mode cluster stops provisioning new nodes and an ECS Managed Instances capacity provider stops scaling.
>
> No other change was made.

What is the cause?

A. The SCP also applies to the roles those services use, and their AWS-owned AMI accounts are not permitted

B. EKS Auto Mode and ECS Managed Instances require the Allowed AMIs setting to be disabled

C. The clusters need their Kubernetes version upgraded

D. Service-linked roles are exempt from SCPs, so this cannot be the cause

◆ PAUSE AND DECIDE

What is the cause?

A The SCP applies to the service roles

Managed compute launches instances using a role in your account, and that role is subject to your SCPs. The AWS-owned AMI accounts must be permitted.

B Allowed AMIs must be disabled

Allowed AMIs can cause the same symptom and does not have to be disabled. You extend its criteria to include the service AMI accounts.

C Version upgrade needed

Nothing about a version changed. The timing points at the policy, which is the only change described.

D Roles are exempt from SCPs

Confidently wrong. SCPs always apply to actions performed with these infrastructure roles, which is precisely why this breaks.

THE SIGNAL

A reasonable security control silently disables a managed compute option. The fix is to permit the AWS-owned AMI accounts, not to remove the control.

An organisation requires that every EC2 instance launches from an approved AMI. Developers frequently launch instances from public Marketplace images. The security team wants to understand the impact before enforcing anything, because blocking launches unexpectedly would be disruptive.

They also want compliance reporting on instances already running.

Which combination should the team implement?

A. Allowed AMIs in audit mode first, then enabled, plus the AWS Config rule for instances launched with allowed AMIs

B. An SCP denying ec2:RunInstances outright

C. An IAM policy on each developer restricting AMI IDs

D. EC2 Image Builder pipelines producing approved AMIs

◆ PAUSE AND DECIDE

Which combination should the team implement?

A Audit mode, then enforce, plus the Config rule

Audit mode reports what would be blocked without blocking it, and the Config rule reports existing instances launched from disallowed AMIs.

B Deny RunInstances

Blocks every launch rather than every unapproved launch. It also offers no way to measure impact first.

C Per-developer IAM policies

Enforceable in principle and unmaintainable in practice, requiring every AMI ID listed and updated in every policy.

D Image Builder pipelines

Produces approved AMIs, which is necessary and not sufficient. Nothing stops a developer launching a different one.

THE SIGNAL

Two requirements again: measure before enforcing, and report on what already exists. Audit mode and the Config rule map onto one each.

> A company must be able to run its containerised platform from a second Region within 30 minutes. The EKS cluster definitions are in code and the data layer replicates. During a test, the cluster came up but every pod failed with ImagePullBackOff.
>
> All container images are stored in ECR in the primary Region only.

What should the company implement?

A. ECR cross-Region replication rules, so images exist in the recovery Region

B. ECR pull through cache configured against the primary Region's registry

C. Enhanced scanning on the ECR repositories

D. An ECR lifecycle policy retaining more image versions

◆ PAUSE AND DECIDE

What should the company implement?

A Cross-Region replication

Images are copied to the recovery Region automatically and continuously, so they are already there when the primary Region is not.

B Pull through cache from the primary

The tempting one. A cache populated on first pull depends on the source being reachable, and in a Regional failure it is not.

C Enhanced scanning

Improves vulnerability detection. It does not put an image in another Region.

D Longer image retention

Keeps more versions in the primary Region, which is the Region that is unavailable.

THE SIGNAL

Module 17's point made concrete: DR tests fail on the things that are not data. The cluster was fine and there were no images.

> An operations team runs an EKS cluster in Auto Mode. During an audit they cannot find the worker node EC2 instances in the EC2 console, and describe-instances does not list them. The cluster is running normally and pods are healthy.
>
> The team is concerned that instances are running without visibility.

What is the explanation?

A. Auto Mode uses Fargate, so there are no EC2 instances at all

B. From April 2026, Auto Mode managed instances are hidden from EC2 console views and describe API operations by default

C. The instances are in a different account owned by AWS

D. The audit role lacks ec2:DescribeInstances permission

◆ PAUSE AND DECIDE

What is the explanation?

A Auto Mode uses Fargate

It uses EC2 managed instances running Bottlerocket AMIs, provisioned by Karpenter. They are genuinely EC2 instances.

B Hidden by default since April 2026

New Auto Mode managed instances and their launch templates, volumes and ENIs are hidden from EC2 console views and describe list operations by default.

C In an AWS-owned account

They run in your account and you are billed for them. Ownership is not the reason they are not listed.

D Missing IAM permission

A plausible first guess, and it would hide all instances rather than only the Auto Mode ones. Everything else is visible.

THE SIGNAL

Instances that existed before April 2026 remain visible, which is why an estate can show some Auto Mode nodes and not others.

The five things to carry forward

- **Execution role starts the task; task role is the application.** Failure before your code runs is the execution role.
- **Basic scanning is a moment; enhanced scanning is continuous.** Inspector rescans as new CVEs appear.
- **ECR replication puts images in the DR Region.** A pull through cache depends on a source that may be down.
- **Allowed AMIs has an audit mode.** Measure before enforcing, as with Hooks and predictive scaling.
- **Managed compute launches under a role your SCPs govern.** A restrictive AMI policy will silently stop it.

> ON THE EXAM
>
> Next: deployment strategies - rolling, blue/green, canary, immutable, and how to roll back.

MODULE 22 · DOMAIN 3 - DEPLOYMENT, PROVISIONING, AND AUTOMATION

Deployment Strategies

Rolling, immutable, blue/green, canary - where each is implemented on AWS, and how you get back.

DOMAIN 3 of 5 EXAM WEIGHT 22% MODULE 22 of 35

admin@sthithapragna.com

Every strategy trades **capacity**, **speed** and **blast radius**. The one that matters most operationally is a fourth thing: **how fast you can get back**.

The strategies

STRATEGY	WHAT HAPPENS
All at once	Every instance updated together. Downtime, and instant rollback is impossible
Rolling	Batches updated in place. Reduced capacity while it runs
Rolling with additional batch	An extra batch launched first, so full capacity is maintained
Immutable	A full set of new instances alongside the old, then switch and terminate
Blue/green	Two complete environments; traffic switched between them
Canary and linear	A percentage of traffic to the new version, increased over time

ON THE EXAM

Immutable and blue/green both build new alongside old. The difference is whether the old environment survives after the switch.

Rolling, and its risk

- Instances are updated **in batches**, in place. Batch size controls how much capacity is unavailable at once.
- **Capacity drops during the deployment** unless you add an extra batch first. On a busy service that alone can cause errors.
- **Rollback means another rolling deployment**, which takes as long again. There is no switch to flip.
- Mixed versions serve traffic simultaneously, so both versions must tolerate each other.

> ON THE EXAM
>
> A partially completed rolling deployment is the worst state to be in: some instances new, some old, and no fast way back.

Immutable

- Launch a **complete new set of instances** alongside the existing ones, then move traffic and terminate the old.
- If the new instances **fail health checks, they are terminated and the originals are untouched**. Nothing was modified in place.
- Prevents the partially-completed state that makes a failed rolling deployment so awkward.
- Needs **double capacity** during the deployment, and takes longer because instances must launch and warm up.

> ON THE EXAM
>
> The name is the point: nothing existing is changed. A failed immutable deployment leaves the original environment exactly as it was.

Immutable or blue/green?

IMMUTABLE

Replace, then discard

- New instances join the same environment
- Old instances terminated once traffic moves
- Rollback after completion means deploying again
- One environment, temporarily doubled

BLUE/GREEN

Two environments, one switch

- Two complete environments exist independently
- Traffic switched by DNS, listener or target group
- The old environment survives, so rollback is a switch back
- Costs more: you keep both for a period

THE TIEBREAKER

Ask what happens to the old environment. Immutable terminates it; blue/green keeps it so you can switch back in seconds.

Canary and linear

- **Canary**: a small percentage of traffic to the new version, then a pause, then everything. Two steps.
- **Linear**: equal increments at a fixed interval. Ten per cent every minute, for example.
- Both need a **traffic-splitting mechanism**: weighted target groups, a weighted Lambda alias, or Route 53 weights.
- Both are only as useful as the **alarms watching them**. Shifting five per cent and not measuring it achieves nothing.

> ON THE EXAM
>
> The bake time is the feature, not the traffic split. The point is to give a problem time to appear before the rest of your users meet it.

Where AWS implements each

PLATFORM	MECHANISM
EC2 Auto Scaling	Instance refresh, with checkpoints and alarm rollback
CloudFormation	UpdatePolicy: AutoScalingInstanceRefresh, or the older AutoScalingRollingUpdate
Application Load Balancer	Weighted target groups: the raw traffic-shifting primitive
Amazon ECS	Rolling with min/max healthy percent, or native blue/green, canary and linear
AWS Lambda	Versions and aliases, with weighted routing between two versions
Elastic Beanstalk	Five deployment policies, plus environment swap for blue/green
Route 53	Weighted records, for cross-Region or cross-stack switching

ON THE EXAM

Weighted target groups on an ALB are the primitive underneath most of this. Recognise them and canary questions become simple.

EC2: instance refresh as the deployment mechanism

- **MinHealthyPercentage 100** gives launch-before-terminate, so capacity never dips. That is effectively an immutable deployment.
- **Checkpoints** with a bake time pause at chosen percentages, which is a canary in everything but name.
- **Alarm-based automatic rollback** reverses the refresh if a named CloudWatch alarm fires during it.
- Since July 2026 this is available as the **AutoScalingInstanceRefresh** CloudFormation update policy, inside the stack.

> ON THE EXAM
>
> One feature covers rolling, immutable and canary depending on how you set the percentages. The strategy is a configuration choice.

Elastic Beanstalk's five policies

- **All at once** causes downtime. **Rolling** reduces capacity. **Rolling with additional batch** maintains full capacity.
- **Immutable** launches a full set of new instances in a **separate Auto Scaling group**. Failures leave the originals untouched.
- **Traffic splitting** is immutable plus a percentage of traffic for an evaluation period, with automatic rollback. It **requires an ALB**.
- **Blue/green on Beanstalk is a separate concept**: clone the environment and **swap the CNAMEs**. It is not a deployment policy.

> ON THE EXAM
>
> Traffic splitting is Beanstalk's canary. Blue/green is the CNAME swap, and the two appear in different parts of the console for that reason.

New: ECS native blue/green

- **Launched July 2025.** Blue/green is built into ECS. Set the deployment controller to **ECS**, not CODE_DEPLOY.
- **October 2025** added **canary and linear** strategies natively, reaching parity with CodeDeploy.
- Includes **bake time**, **Lambda lifecycle hooks** for validation, and **CloudWatch alarm rollback**, all inside ECS.
- AWS's own guidance now names **ECS-native as the default choice for new deployments**, rather than CodeDeploy.

> ON THE EXAM
>
> Every course written before mid-2025 says ECS blue/green requires CodeDeploy. It does not, and AWS no longer recommends that path for new work.

ECS deployment safety

- **Minimum and maximum healthy percent** bound a rolling update, exactly as MinHealthyPercentage bounds an instance refresh.
- The **deployment circuit breaker** fails a deployment when tasks cannot reach a steady state, and can roll back automatically.
- **A test listener** lets you send synthetic traffic to the green environment before real users reach it. A dark canary.
- Native blue/green needs an IAM role permitting ECS to modify the load balancer, since it moves listener weights itself.

> ON THE EXAM
>
> The circuit breaker catches tasks that will not start. Alarms catch tasks that start and then misbehave. You want both.

Lambda deployments

- A **version** is immutable once published. An **alias** is a movable pointer to a version.
- An alias can be **weighted between two versions**, sending a percentage to each. That is the traffic-splitting primitive.
- Rollback is **repointing the alias**, which is instant. There is nothing to redeploy.
- Event sources and API Gateway should target the **alias**, never a version number, or the pointer stops meaning anything.

> ON THE EXAM
>
> Lambda has the fastest rollback of anything in this module: change where a pointer points. Compare that with a rolling redeploy of 200 instances.

What actually makes rollback fast

- **The old version still exists.** Blue/green and weighted aliases keep it; rolling and immutable have discarded it.
- **The switch is one operation.** A listener weight, an alias, a DNS record. Not a redeployment.
- **Something is watching.** An alarm that triggers rollback beats a human noticing, especially at 3am.
- **The database has not moved on.** This is the constraint nothing else can undo, and it is covered next.

> ON THE EXAM
>
> Rank strategies by rollback speed and blue/green and weighted aliases win. Rank by cost and they lose. That is the whole trade.

The database is not rollable

- You can switch traffic back in seconds. You cannot un-run a migration that dropped a column.
- **Expand and contract**: add the new structure, deploy code writing to both, backfill, deploy code reading the new, only later remove the old.
- Every intermediate state must work with **both versions of the application**, which is what makes rollback possible at all.
- Deploying a schema change and an application change together removes your ability to roll back either.

> ON THE EXAM
>
> Blue/green gives you a fast switch back. It gives you nothing if the green environment has already changed the shared database.

Separating deploy from release

- **Feature flags** let you deploy code with a feature switched off, then turn it on separately.
- **AWS AppConfig** manages flags and configuration with its own **deployment strategies**: growth rate and bake time.
- AppConfig can watch **CloudWatch alarms** during a configuration rollout and **roll the configuration back** automatically.
- Turning a flag off is faster than any deployment, and does not require the previous artefact to exist.

> ON THE EXAM
>
> This decouples the risky moment from the deployment. The code ships on Tuesday; the feature is enabled on Thursday, to ten per cent of users.

> A payments API on ECS Fargate must be updated with zero downtime. If error rates rise after the new version takes traffic, the team must be able to return to the previous version within one minute. They also want to run automated validation against the new version before any customer reaches it.
>
> The team is building this in 2026 and has no existing CodeDeploy configuration.

What should the team implement?

A. ECS native blue/green with a test listener, bake time and CloudWatch alarm rollback

B. ECS blue/green using CodeDeploy with an appspec file and a deployment group

C. An ECS rolling update with minimum healthy percent set to 100

D. Deploy to a second ECS cluster and switch Route 53 weighted records

◆ PAUSE AND DECIDE

What should the team implement?

A ECS native blue/green

The test listener gives pre-customer validation, bake time gives the observation window, and alarm rollback returns traffic in seconds.

B Blue/green via CodeDeploy

Works, and since July 2025 it is extra machinery: a CodeDeploy application, deployment group, appspec and role. AWS now recommends native for new work.

C Rolling at 100 percent

Avoids the capacity dip and discards the old tasks as it goes, so rollback means another full deployment. Not one minute.

D Second cluster plus Route 53

Achieves blue/green at the DNS layer, where TTLs and resolver caching make a one-minute switch back optimistic. Module 14 covered why.

THE SIGNAL

"No existing CodeDeploy configuration" and "building this in 2026" together point at the native path. Option B is not wrong, it is dated.

> A team performs a blue/green deployment. The green environment runs a database migration that renames a column and drops the old one. Twenty minutes after the switch, a serious bug is found in the new application version.
>
> The team switches traffic back to blue, and blue immediately begins failing.

What went wrong, and what should have been done?

A The blue environment's instances had been terminated automatically

B The schema change was not backwards compatible. An expand-and-contract migration would have kept blue working

C The load balancer needed connection draining configured

D The switch should have used Route 53 rather than target group weights

◆ PAUSE AND DECIDE

What went wrong, and what should have been done?

A **Blue was terminated**

The scenario states traffic was switched back to blue, so blue clearly still existed. It ran and then failed.

B **Non-backwards-compatible schema change**

Blue's code queries a column that no longer exists. Expand and contract keeps both readable until the old version is retired.

C **Connection draining**

Governs in-flight requests during a switch. It has nothing to do with blue failing consistently afterwards.

D **Use Route 53 instead**

Changes the switching mechanism, and the switch worked. What failed was the application once traffic arrived.

THE SIGNAL

The deployment strategy was correct and the migration was not. Blue/green protects the application layer; nothing protects a shared database from a destructive change.

> A Lambda function behind API Gateway serves 40,000 requests per minute. The team wants to expose a new version to 5 percent of traffic for ten minutes. They will monitor an error-rate alarm, and shift the rest only if it stays clear. Rollback must be immediate.
>
> The function is invoked through an alias.

What should the team use?

A. Weighted routing on the Lambda alias between the two versions, with an alarm watched during the bake period

B. Deploy the new code over the existing version and monitor afterwards

C. Two API Gateway stages with a Route 53 weighted record between them

D. An ALB with weighted target groups in front of two Lambda functions

◆ PAUSE AND DECIDE

What should the team use?

A Weighted alias routing

Built for exactly this: two immutable versions, a percentage split, and rollback by repointing the alias, which is instant.

B Deploy over the existing version

Published versions are immutable, so this creates a new one. It also gives no traffic split and no fast rollback.

C Stages plus Route 53 weights

Works and shifts at the DNS layer, where caching makes both the split and the rollback imprecise and slow.

D ALB with weighted target groups

Valid for Lambda targets, and it introduces a load balancer where API Gateway already fronts the function. Extra components for no gain.

THE SIGNAL

The alias is already there and already the invocation target. Weighting it is a configuration change, not an architecture change.

> An Auto Scaling group of 40 instances runs a service at 70 percent utilisation. A rolling deployment with a batch size of 25 percent causes elevated latency and occasional 503 errors every time it runs.
>
> The team must keep full capacity throughout, pause after the first quarter for review, and reverse automatically if error rates rise.

What should the team configure?

A. An instance refresh with MinHealthyPercentage 100, checkpoints at 25 percent, and an alarm specification

B. Reduce the rolling batch size to 10 percent

C. The AutoScalingRollingUpdate CloudFormation policy with MaxBatchSize 4

D. Increase the group's desired capacity before deploying, then reduce it afterwards

◆ PAUSE AND DECIDE

What should the team configure?

A Instance refresh, 100 percent, checkpoints, alarms

Launch-before-terminate keeps capacity, checkpoints give the review pause, and the alarm specification gives automatic reversal. All three requirements.

B Smaller batches

Reduces the capacity dip without removing it, and makes the deployment far longer. It also offers no pause and no rollback.

C AutoScalingRollingUpdate

Terminates before launching, so capacity still drops, and it has neither checkpoints nor alarm-based rollback.

D Over-provision manually

Solves capacity by hand for one deployment, with two manual steps to forget, and answers neither of the other requirements.

THE SIGNAL

Three requirements, and one feature covers all three by configuration. This is the module's point: the strategy is a setting, not a separate tool.

> A team wants to release a redesigned checkout flow to 10 percent of users. They will monitor conversion and error rates for a week, then expand or withdraw it based on results. The code for both flows is already deployed and passing tests.
>
> Withdrawing the feature must not require a deployment.

What should the team use?

A. AWS AppConfig feature flags, with a deployment strategy and CloudWatch alarm rollback

B. A canary deployment shifting 10 percent of traffic to a new version

C. Blue/green with the green environment serving 10 percent

D. Two Auto Scaling groups behind weighted target groups

◆ PAUSE AND DECIDE

What should the team use?

A AppConfig feature flags

The code is already deployed. A flag turns the feature on for a subset and off again instantly, with no deployment either way.

B Canary deployment

The closest competitor, and it splits traffic between versions. Both flows are already in the same deployed version, so there is nothing to split.

C Blue/green at 10 percent

Means running two full environments for a week, and withdrawing still means a traffic switch rather than a configuration change.

D Two ASGs, weighted

Doubles the fleet for a week to serve code that is already present in the existing fleet.

THE SIGNAL

"The code for both flows is already deployed" is the clause. Nothing needs deploying, so no deployment strategy is the answer.

The five things to carry forward

- **Immutable terminates the old; blue/green keeps it.** That is what makes blue/green rollback a switch.
- **Instance refresh is rolling, immutable or canary depending on configuration.** The strategy is a setting.
- **ECS blue/green is native since July 2025**, with canary and linear since October. CodeDeploy is no longer the default.
- **A Lambda alias is the fastest rollback here**: move a pointer, no redeployment.
- **No deployment strategy can undo a schema change.** Expand and contract, or lose your ability to roll back.

> ON THE EXAM
>
> Next: event-driven operations - Lambda, S3 notifications, Step Functions, service quotas and tagging.

MODULE 23 · DOMAIN 3 - DEPLOYMENT, PROVISIONING, AND AUTOMATION

Event-Driven Operations

Lambda concurrency and retries, S3 notifications, Step Functions, service quotas and tagging.

DOMAIN 3 of 5 EXAM WEIGHT 22% MODULE 23 of 35

admin@sthithapragna.com

Serverless removes the servers and keeps the limits. Concurrency, retries and quotas are where event-driven systems actually fail.

Three invocation models, three failure behaviours

MODEL	WHAT HAPPENS ON ERROR
Synchronous (API Gateway, ALB)	No retry. The caller sees the error and decides
Asynchronous (S3, SNS, EventBridge)	Two retries, then a destination or DLQ, or dropped
Event source mapping (SQS)	Visibility timeout and maxReceiveCount, then the queue's DLQ
Event source mapping (Kinesis, DDB Streams)	Retries in order, and can block the shard

ON THE EXAM

The stream row is the dangerous one. One poison-pill record can stall a shard for the whole retention period.

Asynchronous failure handling

- Two retries, with delays. **Maximum event age** defaults to **6 hours**; after that the event is discarded regardless.
- With **no destination and no DLQ, a failed event is simply lost**. There is no error anywhere except the metric.
- **On-failure destinations** are richer than a DLQ: they include the **request and response context**, not just the payload.
- Destinations also support **on-success**, and can target SNS, SQS, Lambda or EventBridge. A DLQ is failure-only, and SNS or SQS only.

> ON THE EXAM
>
> Destinations superseded the DLQ for asynchronous invocation. If a question offers both, destinations give you more and cost no more.

The concurrency model

- One **account-wide concurrency pool per Region**, defaulting to **1,000**. Every function shares it.
- One busy function can consume most of the pool, and every other function in the account fights over what is left.
- **Reserved concurrency** carves out a guaranteed slice for one function. It is both a **floor and a ceiling**.
- Reserving capacity **removes it from the shared pool**, so an over-reserved function starves everything else.

> ON THE EXAM
>
> Reserved concurrency set to zero is the emergency stop. It guarantees the function cannot run at all, which is occasionally exactly what you need.

Reserved or provisioned concurrency?

RESERVED CONCURRENCY

How many may run

- Guarantees a slice of the account pool
- Also caps the function at that number
- Protects other functions from this one
- No additional charge

PROVISIONED CONCURRENCY

How many are already warm

- Pre-initialised environments, no cold start
- Charged for the environments, whether used or not
- Auto-scalable with Application Auto Scaling on the alias
- Set within the reserved limit if both are used

THE TIEBREAKER

Reserved solves throttling and noisy neighbours. Provisioned solves cold-start latency. They answer completely different complaints.

Throttled with capacity to spare

- There is a second limit: the **scaling rate**. Lambda creates **1,000 new execution environments every 10 seconds**, per function, per Region.
- A sharp spike can be **throttled while the account pool is nowhere near full**. The dashboard shows plenty of capacity.
- The signature is a **stair-step ConcurrentExecutions graph** with a matching spike of Throttles.
- **ClaimedAccountConcurrency** shows how full the pool is. The scaling rate governs how fast you may fill it.

> ON THE EXAM
>
> "We were throttled but only using 30 percent of our concurrency" is the scaling rate, not the pool. Two limits, one metric people watch.

Protecting what is downstream

- Lambda scales far faster than most databases. A thousand concurrent functions means a thousand connection attempts.
- **RDS Proxy** pools those connections, as module ten covered. That is the relational answer.
- **Reserved concurrency** is the blunt answer: cap the function so the database is never asked for more than it can take.
- For SQS sources, **MaximumConcurrency on the event source mapping** caps concurrency without reserving account capacity.

> ON THE EXAM
>
> The event source mapping's MaximumConcurrency is the precise tool. Reserved concurrency also removes capacity from the shared pool; this does not.

Cold starts

- **SnapStart** takes a snapshot of the initialised environment and restores from it. Java, Python and .NET.
- **SnapStart and provisioned concurrency cannot be combined.** You choose one.
- SnapStart costs less and gives sub-second starts. Provisioned concurrency costs more and works for every runtime.
- **Attaching a function to a VPC** historically added start-up time. It also means the function needs NAT or endpoints to reach AWS APIs.

> ON THE EXAM
>
> Cold starts matter most on synchronous, user-facing paths. An asynchronous event handler rarely needs either mechanism.

S3 Event Notifications

- Destinations: **SNS, SQS, Lambda**, or **EventBridge**. Filter by object key **prefix and suffix**.
- **Overlapping prefix or suffix configurations for the same event type are not allowed.** This limitation forces awkward designs.
- Sending to **EventBridge** instead removes that limitation and gives far richer filtering, plus every EventBridge target.
- EventBridge also carries **more S3 event types** and integrates with archive, replay and cross-account buses.

> ON THE EXAM
>
> "Several teams need to react to the same uploads with different filters" is the overlap limitation. Route through EventBridge.

Step Functions: Standard or Express?

STANDARD

Long, durable, auditable

- Up to one year of execution
- Exactly-once execution semantics
- Full execution history in the console
- Priced per state transition

EXPRESS

Short, fast, high volume

- Up to five minutes
- At-least-once for async; at-most-once for sync
- History goes to CloudWatch Logs, not the console
- Priced per invocation and duration

THE TIEBREAKER

Volume decides it. Thousands of short executions per second is Express; an orchestration that waits hours for approval is Standard.

Step Functions for operations

- **Retry** and **Catch** are declarative: backoff, jitter, maximum attempts and error-specific handling, with no code.
- **Request-response** calls and returns. **.sync** starts a job and waits for it to finish. **.waitForTaskToken** pauses until something calls back.
- The callback pattern is how a workflow waits for **a human approval** or an external system, for up to a year.
- **Distributed Map** reads a large dataset from S3 and runs up to **10,000 parallel child executions**.

ON THE EXAM

Retry and Catch in the state machine replace error-handling code in every Lambda function. That is the operational argument for Step Functions.

At-least-once means design for duplicates

- **SQS standard queues, SNS, EventBridge and Lambda retries can all deliver the same event more than once.** That is normal, not a fault.
- **Idempotency** means processing the same event twice has the same effect as processing it once.
- The usual mechanism: an **idempotency key** from the event, recorded in DynamoDB with a TTL, checked before doing the work.
- **FIFO queues and FIFO topics** give exactly-once processing and ordering, at much lower throughput.

> ON THE EXAM
>
> Module eight said an automated fix must be safe to run twice. This is the same requirement, and here it is unavoidable rather than advisable.

Queues and topics, operationally

- **Visibility timeout** must exceed your processing time, or the same message is delivered again while you are still working on it.
- **maxReceiveCount** plus a dead-letter queue is how a poison message stops blocking the queue.
- **DLQ redrive** moves messages back to the source queue after you fix the cause. No custom script needed.
- **Alarm on ApproximateAgeOfOldestMessage**, not just queue depth. A shallow queue whose oldest message is hours old is stuck.

> ON THE EXAM
>
> Queue depth alone is a poor signal. A queue can be nearly empty and completely stalled on one message nobody can process.

SNS operationally

- **Fan-out**: one message to many subscribers. The classic pattern is SNS to several SQS queues, one per consuming team.
- **Subscription filter policies** let each subscriber receive only the messages it cares about, evaluated by SNS rather than the consumer.
- Each subscription can have its own **delivery retry policy** and its own **dead-letter queue**.
- A failed HTTP subscriber does not block the others. Delivery is per subscription, and so is failure.

> ON THE EXAM
>
> SNS to SQS is the durability pattern. The topic fans out; the queues absorb bursts and retain messages if a consumer is down.

SQS, SNS or EventBridge?

SERVICE	REACH FOR IT WHEN
Amazon SQS	One consumer, buffered. Absorb bursts, retain work, control the rate
Amazon SNS	Many subscribers, one message, very high throughput and low latency
Amazon EventBridge	Routing on event content, AWS service events, archive and replay
SNS to SQS	Fan-out plus durability. Each consumer gets its own buffered copy

ON THE EXAM

A queue decouples in time; a topic decouples in number; a bus decouples in content. Most real designs use more than one.

Service Quotas

- Quotas are **per account and per Region**. Some are adjustable, some are not, and the console tells you which.
- **CloudWatch alarms on quota utilisation** are supported for many quotas. Alarm at 80 percent, not at failure.
- A **quota request template** applies requested increases automatically to **new accounts** in the organisation.
- Increases are processed by AWS on their timescale. Module 17 covered what that means during a disaster recovery test.

> ON THE EXAM
>
> Quotas fail silently until they fail completely. Alarming on utilisation turns a future outage into a support ticket you raise calmly.

Tagging as an operational control

- **Tag policies** in Organizations enforce allowed keys, allowed values and casing. Without them, CostCentre and costcenter coexist.
- **Cost allocation tags** must be **activated in the Billing console** before they appear in cost reports, and they are not retroactive.
- **Attribute-based access control** uses tags in IAM conditions, so one policy governs many resources without listing them.
- Tags drive **Backup selections, State Manager targets, Run Command targets and Config rules**. They are wiring, not labels.

> ON THE EXAM
>
> Almost every automation in this course targets by tag. A tag policy is what stops that automation quietly missing resources.

A Lambda function triggered asynchronously by S3 fails permanently for about 2 percent of objects because of a malformed file format. The team discovers this weeks later. There is no record of which objects failed, and the function has no destination or dead-letter queue configured.

The team needs failed events captured with enough context to reprocess them.

What should the team configure?

A An on-failure destination on the function, targeting an SQS queue

B Increase the function's timeout and retry attempts

C Enable S3 versioning on the source bucket

D Switch the trigger to synchronous invocation

◆ PAUSE AND DECIDE

What should the team configure?

A On-failure destination

Captures the event with request and response context after retries are exhausted, so failures are visible and reprocessable.

B More retries

The failures are permanent. Retrying a malformed file more times produces the same result more slowly.

C Bucket versioning

Protects the objects, which were never at risk. It says nothing about which invocations failed.

D Synchronous invocation

S3 notifications to Lambda are asynchronous by design. It would also mean no retries at all.

THE SIGNAL

"No record of which objects failed" is the clause. Asynchronous invocation with nothing configured discards the event silently, leaving only a metric.

> During a marketing campaign, a Lambda function behind API Gateway returns throttling errors for about ninety seconds. CloudWatch shows ConcurrentExecutions peaking at roughly 300 against an account limit of 1,000, and a matching spike in Throttles. The graph shows concurrency rising in distinct steps.
>
> No other function in the account was busy.

What is the cause?

A The account concurrency limit was reached

B The function hit Lambda's scaling rate, which limits how fast new execution environments are created

C Reserved concurrency was set too low on the function

D The function's timeout is too short

◆ PAUSE AND DECIDE

What is the cause?

A. Account limit reached

The scenario states 300 against a limit of 1,000, and no other function was busy. The pool was 70 percent free.

B. The scaling rate

Lambda creates new environments at a fixed rate. A sharp spike hits that ceiling regardless of how much pool capacity is unused, producing the stair-step pattern.

C. Reserved concurrency too low

Would cap the function at a fixed number, producing a flat ceiling rather than a rising staircase. Nothing suggests one was set.

D. Timeout too short

Produces timeout errors in the function's own logs, not throttling. Different failure entirely.

THE SIGNAL

Two numbers and one graph shape. 300 of 1,000 rules out the pool; the stair-step is the documented signature of the scaling rate.

> Three teams need to react to uploads in the same S3 bucket. The analytics team wants objects under data/, the compliance team wants everything, and the imaging team wants files ending in .jpg. All three need the ObjectCreated event.
>
> An engineer configures three S3 event notifications and the third is rejected.

What should the engineer do?

A. Enable EventBridge notifications on the bucket and create three EventBridge rules

B. Create three buckets, one per team

C. Send one notification to an SNS topic and have each team subscribe

D. Use S3 Object Lambda to route the events

◆ PAUSE AND DECIDE

What should the engineer do?

A Route to EventBridge

Removes the overlapping-filter limitation entirely, gives each team its own rule with richer filtering, and adds archive and replay.

B Three buckets

Solves a configuration limitation by duplicating storage and forcing uploaders to know which team cares. Unworkable at scale.

C One notification to SNS

The strongest alternative. It works, and every subscriber receives every event and must filter for itself, which is what EventBridge does natively.

D S3 Object Lambda

Transforms objects as they are retrieved. It has nothing to do with event routing.

THE SIGNAL

The rejection is the clue. S3 refuses overlapping prefix or suffix configurations for the same event type, and EventBridge has no such restriction.

An SQS queue is processed by a Lambda function. During a backlog, the function scales to 900 concurrent executions. That exhausts the connection pool on the Aurora cluster behind it, causing errors across other applications sharing the database.

The team must cap this function's database load without reducing capacity available to other Lambda functions in the account.

What should the team configure?

A MaximumConcurrency on the SQS event source mapping

B Reserved concurrency on the function

C Provisioned concurrency on the function

D Increase the account concurrency quota

◆ PAUSE AND DECIDE

What should the team configure?

A MaximumConcurrency on the event source mapping

Caps how many invocations the SQS poller drives, without reserving or removing anything from the shared account pool.

B Reserved concurrency

The near-miss. It does cap the function, and reserved capacity is subtracted from the shared pool, reducing what other functions can use.

C Provisioned concurrency

Pre-warms environments to remove cold starts. It does nothing to limit how many run, and would make matters worse.

D Raise the account quota

Allows even more concurrency, which is the opposite of what the database needs.

THE SIGNAL

The second clause is the discriminator. Both A and B cap the function; only A leaves the shared pool untouched.

> An operations team runs a nightly job that processes about 400,000 records from S3. It currently runs as one Lambda function that loops, and regularly hits the 15-minute timeout. Each record takes about two seconds and records are independent.
>
> The team needs error handling per record, and a report of which records failed.

What should the team use?

A. A Step Functions Distributed Map reading from S3, with Retry and Catch on the child workflow

B. Increase the Lambda timeout beyond 15 minutes

C. An SQS queue with one message per record and a Lambda consumer

D. An EC2 instance running the job as a script

◆ PAUSE AND DECIDE

What should the team use?

A Distributed Map with Retry and Catch

Reads the dataset from S3, fans out to thousands of parallel child executions, handles errors per record declaratively, and reports results.

B Longer timeout

Fifteen minutes is Lambda's hard maximum and cannot be raised. 400,000 records at two seconds each is over nine days serially anyway.

C SQS with one message per record

A reasonable design that does parallelise the work. Per-record error reporting means building it yourself from the DLQ.

D An EC2 instance

Runs serially unless you write the concurrency, and reintroduces a server to patch for a job that runs once a night.

THE SIGNAL

The arithmetic settles it before any service knowledge: 400,000 records at two seconds is over nine days of serial work.

> An order-processing Lambda function reads from a standard SQS queue. Occasionally a customer is charged twice. Investigation shows the function completed successfully but took slightly longer than the queue's visibility timeout, so the message was delivered again.
>
> The team cannot easily shorten the processing time.

Which two actions together address this? (Choose two.)

A. Increase the visibility timeout to comfortably exceed the processing time

B. Make the handler idempotent using an idempotency key recorded in DynamoDB

C. Switch the queue to a FIFO queue and accept the throughput reduction

D. Reduce maxReceiveCount to 1 so messages are never redelivered

◆ PAUSE AND DECIDE

Which two actions together address this?

A Raise the visibility timeout

Removes the immediate cause. A message must stay invisible for longer than the work takes, or it is redelivered while still in progress.

B Make the handler idempotent

Standard queues are at-least-once by design, so duplicates remain possible whatever the timeout. Idempotency makes them harmless.

C Switch to FIFO

Gives exactly-once processing and cuts throughput substantially, and it still requires the visibility timeout to exceed processing time.

D maxReceiveCount of 1

Sends a message to the DLQ after one failure. It does not prevent redelivery of an in-flight message, and it discards genuine retries.

THE SIGNAL

Fix the cause and survive the class of problem. A standard queue will deliver twice eventually, whatever you tune.

The five things to carry forward

- **Retry behaviour depends on the invocation model.** Asynchronous with no destination discards failures silently.
- **Reserved concurrency is a floor and a ceiling**, and it removes capacity from the shared pool.
- **The scaling rate is a second limit.** You can be throttled with most of the pool free.
- **S3 forbids overlapping notification filters.** Route the bucket to EventBridge instead.
- **Alarm on quota utilisation and on message age**, not only on failure and depth.

> ON THE EXAM
>
> That completes domain three. Next: IAM mechanics, and the start of domain four.

MODULE 24 · DOMAIN 4 - SECURITY AND COMPLIANCE

IAM Mechanics

Policy evaluation, roles and trust, permissions boundaries, condition keys and Access Analyzer.

DOMAIN 4 of 5 EXAM WEIGHT 16% MODULE 24 of 35

admin@sthithapragna.com

Every request asks one question: **is this principal allowed this action on this resource, in this context?** The evaluation order is the answer.

The policy types

TYPE	WHAT IT DOES
Identity-based	Attached to a user, group or role. Grants permissions to that identity
Resource-based	Attached to a resource, such as an S3 bucket or KMS key. Names a Principal
Permissions boundary	A ceiling on an identity. It grants nothing
Service control policy	An organisation-wide filter on accounts. It grants nothing
Resource control policy	An organisation-wide filter on resources. It grants nothing
Session policy	Passed when assuming a role. Further restricts that session

ON THE EXAM

Only the first two ever grant permission. The rest can only take it away, which is why adding a boundary never fixes an access denied.

How a request is evaluated

01

Explicit deny

Any explicit Deny anywhere ends it. Nothing overrides this.

›

02

Organization policies

SCPs and RCPs must allow, or the request stops here.

›

03

Resource-based policy

An Allow here can be sufficient on its own, within one account.

›

04

Identity-based policy

Must allow, unless a resource policy already granted it.

›

05

Boundary and session

A permissions boundary and any session policy must also allow.

ON THE EXAM

The default is deny. Something must actively allow, and nothing anywhere may explicitly deny. Both conditions, every time.

Explicit deny and implicit deny

- **An explicit Deny always wins.** It cannot be overridden by any Allow in any other policy, including an administrator policy.
- **An implicit deny** is simply the absence of an Allow. It is the default outcome and it is easy to fix.
- Diagnosing the difference matters: an implicit deny needs a grant added; an explicit deny needs something found and removed.
- Explicit denies with condition keys are how guardrails work. Deny unless MFA is present, deny unless encrypted in transit.

> ON THE EXAM
>
> "I gave them administrator access and it still fails" is an explicit deny somewhere. Look at SCPs, boundaries and resource policies, in that order.

Identity-based, resource-based, and the cross-account rule

- **Within one account**, a resource-based policy naming the principal directly can be **sufficient on its own**.
- **Across accounts, both sides must allow.** The resource policy in one account, and the identity policy in the other.
- This is the most common cause of a cross-account access denied: one side was configured and the other was forgotten.
- Not every service supports resource-based policies. S3, KMS, SQS, SNS, Lambda and Secrets Manager do; EC2 does not.

> ON THE EXAM
>
> Cross-account is an AND, not an OR. Granting generously on the bucket achieves nothing if the calling role has no matching permission.

Roles and trust policies

- A role has two policies: a **trust policy** saying **who may assume it**, and permissions policies saying **what it can do**.
- The trust policy **is a resource-based policy**. That is why it names a Principal while permissions policies do not.
- **AssumeRole** for AWS principals, **AssumeRoleWithWebIdentity** for OIDC, **AssumeRoleWithSAML** for federated workforce identities.
- Credentials are **temporary**. Default one hour, up to the role's maximum session duration, and up to 12 hours.

> ON THE EXAM
>
> "Cannot assume role" is the trust policy. "Assumed the role and then got AccessDenied" is the permissions policy. Two different files.

STS, sessions and role chaining

- **AssumeRole** returns temporary credentials. Default **1 hour**, up to the role's **MaxSessionDuration**, which can be **12 hours**.
- **Role chaining** - assuming a role from an already-assumed role session - is **capped at 1 hour**, whatever the role allows.
- **GetSessionToken** is for an IAM user needing MFA-authenticated credentials. **AssumeRole** is for everything else.
- **Session tags** passed at AssumeRole become **aws:PrincipalTag** values, which is what makes ABAC work with federation.

> ON THE EXAM
>
> "Our 12-hour session keeps expiring after an hour" is role chaining. The cap is not configurable and it is easy to hit accidentally.

The confused deputy, and how to prevent it

- A **confused deputy** is a trusted service or third party tricked into using its permissions on an attacker's behalf.
- For third parties, use an **ExternalId** in the trust policy. The third party must supply it, and only your value works.
- For AWS services, use **aws:SourceArn** and **aws:SourceAccount** conditions, so the service may only act for your resources.
- **aws:PrincipalOrgID** restricts a resource policy to principals inside your organisation, without listing account IDs.

> ON THE EXAM
>
> aws:PrincipalOrgID is the maintainable version of a long account list. New accounts are covered automatically; closed ones stop working.

Getting non-AWS identities in

MECHANISM	USE IT FOR
IAM Identity Center	Workforce SSO across many accounts. The default for people
SAML 2.0 federation	A corporate IdP federating directly into IAM roles
OIDC / web identity	CI/CD such as GitHub Actions, and mobile apps. No stored keys
IAM Roles Anywhere	Servers outside AWS, using X.509 certificates from your own PKI
Cognito identity pools	Application end users needing temporary AWS credentials

ON THE EXAM

All five end in a role and temporary credentials. None needs a long-lived access key, which is the point.

Service-linked roles

- A predefined role that a service creates in your account to act on your behalf. Its trust policy names that service and **cannot be edited**.
- **Service control policies do not affect service-linked roles.** That exception appears in exam questions.
- You usually cannot delete one until you have **removed the resources that depend on it**.
- Distinct from the **infrastructure roles** in module 21, which ECS and EKS create for you and which SCPs **do** govern.

> ON THE EXAM
>
> Two similar-sounding things behave oppositely: SCPs skip service-linked roles, and SCPs apply fully to infrastructure roles.

Users and access keys, where they survive

- **Long-lived access keys are the credential that leaks.** They appear in repositories, laptops and shared documents.
- A user may hold **two access keys at once**, which exists precisely to make rotation possible without an outage.
- Rotation: create the second key, update everything, **deactivate** the first, confirm nothing broke, then delete it.
- The **credential report** is the evidence: key age, last used, and whether MFA is enabled, for every user.

> ON THE EXAM
>
> Deactivate before delete. Deactivating is reversible in seconds; deleting is not, and something you forgot is always still using it.

Permissions boundary or service control policy?

PERMISSIONS BOUNDARY

A ceiling on one identity

- Attached to a specific user or role
- Effective permissions are the intersection with the identity policy
- Grants nothing by itself
- Lets you delegate role creation safely

SERVICE CONTROL POLICY

A ceiling on whole accounts

- Attached to an OU or account in Organizations
- Applies to every principal in those accounts
- Grants nothing by itself
- Does not apply to the management account

THE TIEBREAKER

Both are ceilings and neither grants. The boundary is per identity; the SCP is per account. The classic boundary use is safe delegation.

Permissions boundaries in practice

- **Effective permissions are the intersection** of the identity policy and the boundary. Both must allow.
- **A boundary never grants.** Attaching one to fix an access denied makes things worse, never better.
- The delegation pattern: allow a developer to create roles, but **only if they attach your boundary**, using an iam:PermissionsBoundary condition.
- That condition is what makes it safe. Without it, they simply create a role with no boundary and full permissions.

> ON THE EXAM
>
> The boundary alone is not the control. The condition requiring the boundary to be attached is the control.

Condition keys worth knowing

KEY	WHAT IT RESTRICTS
aws:PrincipalOrgID	To principals in your organisation, without listing accounts
aws:SourceArn / aws:SourceAccount	Which resource an AWS service may act on your behalf for
aws:MultiFactorAuthPresent	Requires MFA on the session
aws:SecureTransport	Requires TLS. Deny when false is the standard bucket guardrail
aws:PrincipalTag / aws:ResourceTag	Attribute-based access control, matching tags to tags
aws:RequestTag / aws:TagKeys	What tags may be applied at creation time
aws:SourceVpce / aws:SourceVpc	Access only through a named VPC endpoint or VPC

ON THE EXAM

aws:SourceIp does not behave as expected through a VPC endpoint, because the traffic never traverses the public internet. Use the VPC keys instead.

Attribute-based access control

- One policy compares a **tag on the principal** with a **tag on the resource**. Access is granted when they match.
- The policy never changes as teams and resources are added. Only the tags change.
- **Session tags** can be passed when assuming a role, so a federated user carries their department as a tag.
- It depends entirely on **tagging discipline**. Module 23's tag policies are what make ABAC trustworthy.

> ON THE EXAM
>
> Role-based access control needs a new policy per team. ABAC needs a tag. That is the whole argument, and it only works if tagging is enforced.

Two policy-writing traps

- **NotAction with Allow** grants everything except what you listed, including services that did not exist when you wrote it.
- **NotResource with Allow** is the same trap for resources. Both are usually a mistake outside a Deny statement.
- **Policy variables** such as ${aws:username} let one policy give each user access to their own prefix or their own resource.
- **Wildcards in Action** are worth checking: s3:Get* is broad, and s3:* is broader than most people intend.

> ON THE EXAM
>
> NotAction inside a Deny is a legitimate and useful pattern. NotAction inside an Allow is almost always wrong.

IAM Access Analyzer: three kinds of analyzer

- **External access**: which resources are shared outside your zone of trust. **No additional charge.**
- **Unused access**: roles, users, permissions and credentials with no activity in a window you choose. Charged per identity analysed.
- **Internal access**: who **inside** your organisation can reach selected business-critical resources. Newer, and charged.
- **These are separate analyzers.** Having one does not give you the others, and each must be created explicitly.

> ON THE EXAM
>
> External access analysis is free, so there is no reason not to have it. The other two cost money and answer different questions.

Access Analyzer beyond findings

- **Policy generation** builds a least-privilege policy from **CloudTrail history** of what an identity actually did.
- **Policy validation** checks a policy against grammar and best practice, with security, error, warning and suggestion findings.
- **Custom policy checks** answer specific questions in a pipeline: **does this change grant new access**, or **does it grant a forbidden action**?
- That makes it a **preventive** control in CI/CD, alongside CloudFormation Hooks from module 18.

> ON THE EXAM
>
> Custom policy checks in a pull request are the IAM equivalent of a change set: see what the policy would newly permit, before merging.

Auditing what already exists

- **Credential report**: an account-wide CSV of every user, their key ages, password age, and MFA status.
- **Last accessed data**: which services, and for some services which actions, an identity has actually used, and when.
- That is the evidence for removing permissions, and it works on users, roles, groups and policies.
- **Policy simulator** tests whether a specific principal would be allowed a specific action, without making the call.

> ON THE EXAM
>
> Last accessed data plus Access Analyzer's unused access findings are the two evidence sources for a least-privilege exercise.

The root user, centrally managed

- **Centralised root access management** removes root credentials from member accounts in an organisation entirely.
- Privileged actions are then performed with **sts assume-root**, producing a short-lived session scoped by a **task policy**.
- That eliminates hundreds of root passwords, MFA devices and recovery email addresses.
- **It does not apply to the management account**, whose root user must still be secured the traditional way.

> ON THE EXAM
>
> Only a specific short list of actions genuinely requires root, such as removing an S3 bucket policy that locked everyone out. Everything else has an IAM path.

The access denied ladder

- **1. Is there an explicit deny?** SCP, RCP, boundary, resource policy or session policy. Nothing overrides one.
- **2. Is this cross-account?** If so, check both sides. Both must allow independently.
- **3. Is a condition failing?** MFA, source VPC endpoint, tag mismatch, TLS. The error message often names the key.
- **4. Is it KMS?** Access to an encrypted resource needs permission on the key as well as the resource.

> ON THE EXAM
>
> The KMS rung catches people constantly. Reading an encrypted object needs s3:GetObject and kms:Decrypt, from both the identity and the key policy.

> A developer has the AdministratorAccess managed policy attached to their role. They attempt to launch an EC2 instance in eu-west-1 and receive an AccessDenied error. Launching in eu-west-2 succeeds.
>
> No permissions boundary is attached to the role.

What is the most likely cause?

A The AdministratorAccess policy does not cover EC2 in all Regions

B A service control policy explicitly denies actions outside approved Regions

C The role's identity policy needs an explicit Allow for eu-west-1

D The role's trust policy does not permit the developer

◆ PAUSE AND DECIDE

What is the most likely cause?

A AdministratorAccess is Region-limited

*It grants Action * on Resource *, with no Region condition. It is not scoped by Region at all.*

B An SCP denying non-approved Regions

An explicit deny overrides any Allow, including AdministratorAccess. Region restriction is the most common SCP, and it explains the asymmetry exactly.

C Add an explicit Allow

*Nothing overrides an explicit deny. Adding permissions to an identity that already has Action * changes nothing.*

D Trust policy

They assumed the role successfully and are receiving AccessDenied on an action, not on AssumeRole. Wrong policy entirely.

THE SIGNAL

Administrator access plus AccessDenied means an explicit deny, always. The Region asymmetry then names which guardrail it is.

> Account A's application role must read objects from a bucket in account B. The bucket policy in account B allows s3:GetObject for the role's ARN in account A. The role in account A has no S3 permissions in its identity policy.
>
> Requests fail with AccessDenied.

What must change?

A Nothing. A resource-based policy naming the principal is sufficient

B Add s3:GetObject on that bucket to the role's identity policy in account A

C Add the bucket owner's account to the role's trust policy

D Make the bucket public

◆ PAUSE AND DECIDE

What must change?

A **Nothing needed**

True within a single account. Across accounts both sides must allow independently, which is the rule being tested.

B **Grant it in the identity policy too**

Cross-account access is an AND. The bucket policy permits it and the calling identity must also be permitted to attempt it.

C **Change the trust policy**

Trust policies govern who may assume the role. Nobody is assuming anything here; the role is calling S3 directly.

D **Make the bucket public**

Grants the world access to solve a two-account problem. It also still would not help if the identity policy forbids S3.

THE SIGNAL

Option A is correct within one account and wrong across two. That single-account exception is exactly why this trips people up.

> A platform team must let application teams create IAM roles for their own workloads. Those roles must never be able to modify IAM, delete CloudTrail trails, or operate outside the approved Regions.
>
> The platform team does not want to review every role by hand.

What should the platform team implement?

A. A permissions boundary, plus an iam:PermissionsBoundary condition on the application teams' policies requiring it on any role they create

B. A permissions boundary attached to the application teams' own roles

C. An SCP denying iam:CreateRole in the application accounts

D. A Config rule detecting over-permissive roles after creation

◆ PAUSE AND DECIDE

What should the platform team implement?

A Boundary plus the required-boundary condition

The condition forces every role they create to carry the boundary, and the boundary caps what those roles can ever do. Delegation with a guarantee.

B Boundary on their own roles

Caps what the application teams themselves can do. It does nothing about the roles they create, which is the actual requirement.

C Deny CreateRole

Removes the delegation entirely. The requirement is that teams should be able to create roles, safely.

D Config rule after creation

Detective, so an over-permissive role exists until someone acts. The requirement is that it never can.

THE SIGNAL

The boundary is not the control. The condition requiring the boundary is. Option B has the right component and the wrong attachment point.

> A security team must produce evidence for auditors across 40 accounts: which IAM roles have not been used in the last 90 days, and which resources are shared with accounts outside the organisation.
>
> They want a single organisation-wide view and want to minimise cost where possible.

What should they configure?

A. An organisation-level unused access analyzer and an organisation-level external access analyzer

B. A single organisation-level analyzer, which covers both finding types

C. The IAM credential report in each account

D. AWS Config rules in each account

◆ PAUSE AND DECIDE

What should they configure?

A Two analyzers, both organisation-level

The finding types come from separate analyzers. External access is free; unused access is charged per identity, so this is also the cheapest correct answer.

B One analyzer for both

The plausible assumption, and wrong. Creating an external access analyzer does not produce unused access findings; each type needs its own.

C Credential reports

Covers users and their credentials, not roles, and it is per account rather than organisation-wide.

D Config rules

Evaluates resource configuration. It does not compute unused access or analyse resource policies for external sharing.

THE SIGNAL

Access Analyzer is three separate analyzers sharing a name. Assuming one covers everything is the trap, and the pricing difference reinforces the split.

> An application role can list objects in an encrypted S3 bucket but receives AccessDenied when downloading them. The role's identity policy allows s3:GetObject and s3:ListBucket on the bucket. The bucket uses SSE-KMS with a customer managed key.
>
> There are no service control policies in the account.

What is missing?

A kms:Decrypt permission, in both the role's identity policy and the KMS key policy

B s3:GetObjectVersion on the bucket

C A bucket policy allowing the role

D Block Public Access must be disabled on the bucket

◆ PAUSE AND DECIDE

What is missing?

A kms:Decrypt, on both sides

Listing needs no decryption; downloading does. KMS keys have a key policy, so the identity and the key must both permit it.

B s3:GetObjectVersion

Needed only when requesting a specific version. Ordinary downloads use s3:GetObject, which is already granted.

C A bucket policy

Same-account access works from the identity policy alone. A bucket policy is not required here.

D Disable Block Public Access

Governs public access. The role is an authenticated principal in the same account, so it is irrelevant.

THE SIGNAL

List works and get fails is the encryption signature. Listing reads metadata; retrieving content requires decrypting it.

> A GitHub Actions pipeline deploys to AWS using an IAM user's long-lived access keys stored as repository secrets. A security review requires that no long-lived AWS credentials exist outside AWS.
>
> The pipeline must continue deploying with no manual credential handling.

What should the team implement?

A. An IAM OIDC identity provider for GitHub, with a role the workflow assumes via web identity federation

B. Rotate the access keys automatically every 24 hours with a Lambda function

C. Store the access keys in Secrets Manager and have the pipeline fetch them

D. IAM Roles Anywhere with certificates issued to the GitHub runners

◆ PAUSE AND DECIDE

What should the team implement?

A OIDC federation with GitHub

GitHub presents a signed token, AWS exchanges it for temporary credentials. No AWS credential exists outside AWS at any point.

B Rotate keys every 24 hours

A long-lived key that changes daily is still a long-lived key, and a leaked one is valid until the next rotation.

C Keys in Secrets Manager

The pipeline needs credentials to read Secrets Manager, so you still store an AWS credential in GitHub. It moves the problem.

D IAM Roles Anywhere

Built for servers outside AWS using your own PKI. GitHub-hosted runners already provide an OIDC token, so certificates are unnecessary machinery.

THE SIGNAL

Option C is the circular one worth spotting: fetching a secret requires a credential, so the credential you were trying to remove is still there.

The five things to carry forward

- **Only identity and resource policies grant.** Boundaries, SCPs, RCPs and session policies only restrict.
- **Administrator access plus AccessDenied means an explicit deny.** Find it and remove it; granting more will not help.
- **Cross-account is an AND.** Within one account, a resource policy naming the principal can be enough on its own.
- **The boundary is not the control; the condition requiring it is.**
- **List works, get fails, on an encrypted bucket** means kms:Decrypt, from the identity and the key policy.

> ON THE EXAM
>
> Next: multi-account - Organizations, SCPs, IAM Identity Center and delegated administration.

MODULE 25 · DOMAIN 4 - SECURITY AND COMPLIANCE

Multi-Account Governance

Organizations, SCPs, RCPs, declarative policies, delegated administration and IAM Identity Center.

DOMAIN 4 of 5 EXAM WEIGHT 16% MODULE 25 of 35

admin@sthithapragna.com

Four policy types, four different objects governed: **principals**, **resources**, **configuration**, and **metadata**. Match the question to the object.

The structure

- One **management account**, many **member accounts**, arranged in a tree of **organisational units** beneath the **root**.
- Policies attach to the root, an OU, or an individual account, and are **inherited downward**.
- **All features** must be enabled to use SCPs and RCPs. Consolidated billing only is the restricted mode.
- Keep the **management account empty of workloads**. Several controls do not apply to it, which makes it the wrong place for anything.

> ON THE EXAM
>
> The management account is exempt from SCPs and RCPs. Running production there means running it outside your own guardrails.

The organization policy types

POLICY TYPE	GOVERNS
Service control policy	What principals in member accounts may do
Resource control policy	What may be done to resources in member accounts
Declarative policy	The configuration of a service, maintained permanently
Tag policy	Allowed tag keys, values and casing
Backup policy	Backup plans pushed down so accounts cannot opt out
AI services opt-out	Whether AI services may store and use your content

ON THE EXAM

The first three are the ones that decide questions. Only the first two are access controls; declarative policies are configuration, not permission.

How SCPs actually behave

- An SCP **never grants**. It sets the maximum available permissions for principals in the accounts it covers.
- **Inheritance is an intersection.** A permission must be allowed at every level from the root down to the account.
- **FullAWSAccess** is attached at the root by default. Detach it and, unless you allow explicitly at every level, everything stops.
- It applies to **every principal in the account, including the root user**. That is what makes it a real boundary.

> ON THE EXAM
>
> SCPs limit what an account can do. They never give an account anything, so an account with only SCPs and no IAM grants has no access at all.

Deny list or allow list?

DENY LIST

The common approach

- Keep FullAWSAccess, add Deny statements
- Deny Regions, deny specific services, deny disabling CloudTrail
- Easy to add a rule; nothing breaks unexpectedly
- New AWS services are permitted by default

ALLOW LIST

Strict, and high maintenance

- Detach FullAWSAccess, allow only named services
- New services are blocked until explicitly added
- Very strong control in regulated environments
- Every new service adoption becomes a policy change

THE TIEBREAKER

Deny lists are what most organisations run. Allow lists are correct where the requirement is that nothing unapproved can ever be used.

Two exceptions worth memorising

- **SCPs do not apply to the management account**, whatever you attach and wherever you attach it.
- **SCPs do not apply to service-linked roles**, as module 24 covered. That exception exists so AWS services keep working.
- They **do** apply to infrastructure roles such as those used by ECS Managed Instances and EKS Auto Mode, which module 21 showed can break things.
- **RCPs also do not affect resources in the management account**, and do not affect resources owned outside the organisation.

> ON THE EXAM
>
> Two similar-sounding roles, opposite behaviour. Service-linked roles are exempt; infrastructure roles are not. That distinction has appeared twice in this course.

Resource control policies

- Launched **November 2024**. Where an SCP caps what your principals may do, an RCP caps **what may be done to your resources**.
- The headline use is a **data perimeter**: no principal outside my organisation may access my S3 buckets, regardless of any bucket policy.
- Started with **S3, STS, KMS, SQS and Secrets Manager**. By 2026 it covers **more than two dozen services**, including ECR, DynamoDB, Cognito and CloudWatch Logs.
- **RCPFullAWSAccess** is attached by default, exactly as FullAWSAccess is for SCPs.

> ON THE EXAM
>
> An SCP cannot stop a bucket policy someone wrote in a member account from granting access outward. An RCP can, centrally, for every bucket at once.

SCP or RCP?

SCP WHEN

The subject is your people

- Restrict which Regions may be used
- Prevent disabling CloudTrail or Config
- Block specific services entirely
- Applies to principals in member accounts

RCP WHEN

The subject is your data

- No access from outside the organisation
- Require TLS on every bucket, centrally
- Override a permissive resource policy you do not control
- Applies to resources in member accounts

THE TIEBREAKER

Ask who is acting. If the risk is your engineers doing something, that is an SCP. If the risk is somebody else reaching your data, that is an RCP.

Declarative policies

- Generally available **December 2024**. They enforce a **desired configuration** for a service, rather than a permission.
- **Set once and forget:** the configuration is maintained **even when the service adds new APIs or features**, and for accounts that join later.
- Today they cover **EC2, EBS and VPC**: VPC Block Public Access, image and snapshot block public access, **Allowed AMIs**, **IMDSv2 defaults**, serial console access.
- The **account status report** shows the current value of every attribute across the organisation, so you can assess readiness before enforcing.

> ON THE EXAM
>
> This is where module 21's Allowed AMIs and module 7's IMDSv2 requirement get enforced organisation-wide, rather than account by account.

Declarative policy or SCP?

SCP WHEN

Block an action

- Deny an API call outright
- Any service, any action
- Says what may not be done
- New APIs may not be covered by your wording

DECLARATIVE POLICY WHEN

Enforce a setting

- Declare the value a setting must have
- EC2, EBS and VPC today
- Says what the configuration must be
- Survives new APIs and features automatically

THE TIEBREAKER

An SCP denies actions you thought of. A declarative policy states an outcome, so a new API that would change that setting is covered without editing anything.

Delegated administration

- A **member account** is nominated to administer a service for the whole organisation, so the management account is not used daily.
- Supported widely: **GuardDuty, Security Hub, Config, IAM Access Analyzer, Backup, CloudFormation StackSets, Firewall Manager, Inspector, Macie**.
- This is **per service**. Delegating GuardDuty does not delegate Config, and each is registered separately.
- **Some actions still require the management account**, including creating accounts, and attaching most organisation policies.

> ON THE EXAM
>
> The goal is that nobody needs management account credentials for routine work. That is a security control, not an organisational preference.

IAM Identity Center

- One place for workforce sign-in across every account. Users get an **access portal** listing the accounts and roles they may use.
- **Identity sources**: the built-in Identity Center directory, Active Directory, or an external provider via SAML with SCIM for provisioning.
- A **permission set** is a template. When assigned, Identity Center **creates and maintains an IAM role** in that account.
- An assignment is three things together: **a user or group, a permission set, and an account**.

> ON THE EXAM
>
> Permission sets become IAM roles. Everything from module 24 still applies, including SCPs, boundaries and the evaluation order.

Identity Center or IAM users?

IDENTITY CENTER

People

- Central sign-in, one identity across all accounts
- Temporary credentials, no long-lived keys
- Joiners and leavers handled in the identity provider
- Session duration 1 to 12 hours

IAM USERS

Rarely the answer now

- Long-lived access keys that leak
- Per account, so one person needs many
- Deprovisioning means finding every account
- Occasionally unavoidable for legacy tooling

THE TIEBREAKER

"Users must be deprovisioned everywhere when they leave" is Identity Center. With IAM users, leaving is a search-and-delete exercise across every account.

Identity Center details worth knowing

- **Session duration** is configurable from 1 to 12 hours per permission set. Shorter for privileged access.
- **Attribute-based access control** uses identity attributes as session tags, so one permission set serves many teams.
- Permission sets can include **AWS managed policies, customer managed policies and a permissions boundary**.
- Deleting an assignment **removes the IAM role** from that account. The role is managed, not yours to edit.

> ON THE EXAM
>
> Editing the generated IAM role by hand is a mistake. Identity Center reconciles it, and your change disappears at the next provisioning.

Consolidated billing

- One bill for the organisation. **Usage aggregates**, so volume discount tiers are reached faster.
- **Reserved Instances and Savings Plans are shared** across accounts by default, so unused commitment benefits somebody else.
- Sharing can be **turned off per account**, which is how you stop one team consuming another team's commitment.
- **Cost allocation tags must be activated in the management account**, and they are not retroactive. Module 23 covered this.

> ON THE EXAM
>
> Discount sharing is on by default. If a team has bought capacity for a specific workload, someone must decide whether it should be shared.

> A security team attaches an SCP to the organisation root denying ec2:RunInstances outside three approved Regions. Testing confirms it works in member accounts. A week later they find an engineer has launched instances in an unapproved Region.
>
> The instances are in the management account.

What explains this?

A The SCP needs to be attached to each OU as well as the root

B SCPs do not apply to the management account

C The engineer used the root user, which SCPs do not affect

D The SCP takes up to 24 hours to propagate

◆ PAUSE AND DECIDE

What explains this?

A Attach to each OU

Policies attached at the root are inherited by every OU and account beneath it. Re-attaching changes nothing.

B SCPs do not apply to the management account

Documented behaviour, and the reason AWS advises keeping workloads out of the management account entirely.

C Root user is exempt

Precisely backwards. SCPs apply to every principal in a member account including the root user, which is what makes them a real boundary.

D 24-hour propagation

Invented. The scenario also states the policy was confirmed working in member accounts, so it had already taken effect.

THE SIGNAL

The last line of the setup is the whole answer. Option C is the same fact inverted, which makes it the most attractive wrong answer.

> An audit finds several S3 buckets across member accounts with bucket policies granting access to external AWS accounts. The security team cannot review every bucket policy, and application teams own their own buckets.
>
> They need a central control ensuring no principal outside the organisation can access any S3 bucket, regardless of what a bucket policy says.

What should the team implement?

A An SCP denying s3:PutBucketPolicy in all member accounts

B A resource control policy denying S3 access to principals outside the organisation

C S3 Block Public Access enabled at the account level everywhere

D An IAM Access Analyzer external access analyzer at organisation level

◆ PAUSE AND DECIDE

What should the team implement?

A Deny PutBucketPolicy

Stops new bucket policies being written and does nothing about the ones that already exist. It also blocks legitimate use entirely.

B RCP denying external principals

Caps what may be done to the resources themselves, overriding any bucket policy, for every bucket at once. Exactly the data perimeter use case.

C Account-level Block Public Access

Blocks public access. Access granted to a named external AWS account is not public, so it passes straight through.

D External access analyzer

Detective. It reports the sharing the audit already found, and prevents nothing.

THE SIGNAL

Option C is the sharp one: cross-account is not the same as public. Block Public Access would leave every one of these grants in place.

> An organisation must ensure that every EC2 instance launched anywhere, in any account, now or in future, requires IMDSv2. They previously wrote an SCP denying RunInstances without the correct metadata options. New launch paths and new APIs kept bypassing the wording.
>
> They want the setting itself enforced rather than specific calls denied.

What should they use?

A. A declarative policy setting instance metadata defaults across the organisation

B. A more comprehensive SCP covering every launch API

C. An AWS Config rule with automatic remediation

D. A CloudFormation Hook rejecting non-compliant templates

◆ PAUSE AND DECIDE

What should they use?

A Declarative policy for metadata defaults

Declares the setting's value rather than denying calls, and is maintained as the service adds new APIs and as accounts join.

B A better SCP

The approach that already failed, written more carefully. It still enumerates calls, so a future API needs a policy update.

C Config rule with remediation

Detective then corrective. Instances exist non-compliant before being fixed, which the requirement does not accept.

D CloudFormation Hook

Preventive, and only for resources created through CloudFormation. Console and CLI launches bypass it entirely.

THE SIGNAL

The scenario states the failure mode of enumeration: new APIs slip past. That is precisely the gap declarative policies were built to close.

> A company with 60 accounts wants its security team to manage GuardDuty and Security Hub findings organisation-wide. Nobody should use management account credentials for daily work.
>
> The security team also needs to create new accounts occasionally.

What should the company configure?

A Register the security account as delegated administrator for GuardDuty and for Security Hub separately, and keep account creation in the management account

B Register the security account as delegated administrator once, which covers all services

C Give the security team an IAM role in the management account with administrator access

D Create a separate organisation for the security team

◆ PAUSE AND DECIDE

What should the company configure?

A Delegate per service; keep account creation central

Delegated administration is registered per service, and account creation genuinely still requires the management account.

B Delegate once for everything

The plausible assumption, and wrong. Each service is registered independently; delegating GuardDuty says nothing about Security Hub.

C Admin role in the management account

Exactly what the requirement forbids: daily work performed with management account credentials.

D A separate organisation

Splits the estate in two, so organisation-wide findings become impossible. It defeats the purpose entirely.

THE SIGNAL

Two facts, both easy to get wrong: delegation is per service, and creating accounts is one of the things that stays in the management account.

> Engineers currently have IAM users in each of 30 accounts. When someone leaves, an administrator must find and delete their user in every account, and this has been missed twice. Access keys are shared in team documents.
>
> The company already runs a corporate identity provider supporting SAML.

What should the company implement?

A. IAM Identity Center with the corporate IdP as identity source, and permission sets assigned to groups

B. A single IAM user per engineer in the management account, assuming roles into the others

C. An SCP denying iam:CreateUser in all member accounts

D. Rotate all access keys automatically every 30 days

◆ PAUSE AND DECIDE

What should the company implement?

A Identity Center with the corporate IdP

Removing someone from a group in the IdP removes their access everywhere at once, and there are no long-lived keys to share.

B One user in the management account

Better than 30 users, and it still relies on long-lived keys and puts human identities in the management account.

C Deny CreateUser

Stops new users appearing and does nothing about the 30 accounts' worth that already exist, or about the shared keys.

D Rotate keys every 30 days

A key shared in a document is compromised the moment it is shared. Rotating it later does not un-share the previous one.

THE SIGNAL

Two failures are described: deprovisioning missed, and keys shared. Central identity with temporary credentials fixes both; nothing else fixes either properly.

The five things to carry forward

- **SCPs cap principals; RCPs cap resources.** Ask who is acting and what is being reached.
- **SCPs skip the management account and service-linked roles.** They do not skip infrastructure roles.
- **Declarative policies enforce a setting, not an action**, and survive new APIs and new accounts.
- **Delegated administration is per service.** Account creation stays in the management account.
- **Identity Center permission sets become real IAM roles**, so module 24's evaluation order still applies to them.

> ON THE EXAM
>
> Next: encryption and secrets - KMS keys, key policies, grants, ACM and Secrets Manager.

MODULE 26 · DOMAIN 4 - SECURITY AND COMPLIANCE

Encryption and Secrets

KMS keys, key policies, grants and rotation, plus ACM certificates and Secrets Manager.

DOMAIN 4 of 5 EXAM WEIGHT 16% MODULE 26 of 35

admin@sthithapragna.com

Encryption on AWS is two questions: **who holds the key**, and **who may use it**. The second is answered by a resource policy that behaves unlike any other.

Three kinds of key

KEY TYPE	WHAT YOU CONTROL
AWS owned	Nothing. Shared across accounts, invisible to you, free
AWS managed (aws/service)	Nothing much. Visible in your account, rotates yearly, free to store
Customer managed	Everything: key policy, grants, rotation, deletion. Charged monthly

ON THE EXAM

Only a customer managed key gives you a policy you can write, rotation you can set, and the ability to deny access. That is why compliance answers always name it.

Envelope encryption

- KMS does not encrypt your data. It encrypts a **data key**, which encrypts your data.
- **GenerateDataKey** returns a plaintext key and an encrypted copy. You use the plaintext, store the encrypted one, and discard the plaintext.
- To read the data later you call **Decrypt** on the stored encrypted key, then decrypt locally with the result.
- KMS has a **4 KB limit** on direct encryption. Anything larger must use envelope encryption, which is why every AWS service does.

> ON THE EXAM
>
> This is why reading an encrypted object requires kms:Decrypt. The object's data key has to be unwrapped before anything can be read.

The key policy, and why it is different

- **Every KMS key has a key policy, and it is mandatory.** There is no key without one.
- **An identity policy alone cannot grant access to a key.** The key policy must first delegate to IAM.
- The default policy includes a statement giving the **account root full access**, and that statement is what enables IAM policies to work.
- Remove it and the key can only be used by principals the key policy names directly, which is a legitimate and very strict design.

> ON THE EXAM
>
> This is the single most common KMS surprise. Granting kms:Decrypt in an identity policy achieves nothing unless the key policy allows IAM to grant it.

Key policy or grant?

KEY POLICY

Durable and declarative

- Written once, reviewed, version controlled
- Names principals and conditions
- The primary access control on a key
- Changing it is a deliberate act

GRANT

Temporary and programmatic

- Created by an API call, often by an AWS service
- Granular: specific operations, specific conditions
- Can be retired or revoked when finished
- How services get short-lived access on your behalf

THE TIEBREAKER

Grants exist because AWS services need scoped, temporary key access without rewriting your key policy every time you create a resource.

Key rotation, updated

- **Automatic rotation** replaces the key material on a schedule. Since **April 2024** the period is configurable from **90 to 2,560 days**, default 365.
- **On-demand rotation** also arrived in 2024. It rotates immediately, does not disturb the automatic schedule, and is capped at **10 times per key**.
- **Old key material is retained**, so data encrypted before a rotation still decrypts. The key ID and ARN never change.
- **Symmetric encryption keys only.** Not asymmetric, not HMAC, not custom key stores. **AWS managed keys rotate yearly and cannot be changed.**

> ON THE EXAM
>
> "Rotate every 90 days" was impossible before April 2024 and is now a setting. Older study material still says rotation is annual and fixed.

Disabling and deleting keys

- **Disabling** is immediate and reversible. Everything encrypted with the key becomes unreadable until you re-enable it.
- **Deletion is not immediate.** A mandatory waiting period of **7 to 30 days**, defaulting to 30, during which the key is in PendingDeletion.
- **Deleting a key destroys every ciphertext encrypted under it, permanently.** There is no recovery of any kind.
- Disable first and watch for errors. CloudWatch and CloudTrail will show anything that was still using it.

> ON THE EXAM
>
> The waiting period exists because key deletion is one of very few genuinely irreversible actions on AWS. Alarm on ScheduleKeyDeletion.

Multi-Region keys and custom key stores

- **Multi-Region keys** share key material and key ID across Regions, so ciphertext encrypted in one Region decrypts in another with no cross-Region call.
- They are **not global**. Each replica is a distinct key resource with **its own key policy, grants and tags**.
- **CloudHSM key store**: key material lives in your own CloudHSM cluster, under your control.
- **External key store**: key material lives entirely **outside AWS**, in a key manager you operate. For the strictest sovereignty requirements.

> ON THE EXAM
>
> Multi-Region keys are the answer for cross-Region replication of encrypted data. Ordinary keys are Regional, so a replica in another Region cannot decrypt.

Constraining how a key may be used

- **kms:ViaService** restricts key use to requests arriving through a named service, such as s3.eu-west-1.amazonaws.com.
- That stops a principal calling KMS directly to decrypt data they should only reach through S3.
- **Encryption context** is additional authenticated data. It must match exactly on decrypt, and it appears in CloudTrail.
- **kms:CallerAccount** and **aws:PrincipalOrgID** restrict which accounts may use the key at all.

> ON THE EXAM
>
> Encryption context in CloudTrail is what turns key usage logs from "someone decrypted something" into "this bucket, this object, this request".

S3 encryption options

OPTION	NOTES
SSE-S3	AES-256, keys managed entirely by S3. The default on every new object
SSE-KMS	A KMS key you choose. Auditable in CloudTrail, and you control the policy
DSSE-KMS	Dual-layer: two independent layers of KMS encryption. For the strictest requirements
SSE-C	You supply the key with every request. Disabled by default on new buckets since April 2026
Client-side	Encrypted before it reaches AWS. S3 never sees plaintext

ON THE EXAM

SSE-KMS is the usual answer whenever a question mentions auditing key usage, controlling who can decrypt, or a compliance requirement.

S3 Bucket Keys

- Without them, S3 calls KMS **once per object operation**. At millions of objects that is a very large KMS bill.
- A **bucket-level key** is generated from KMS and held briefly by S3, then used to create data keys for many objects.
- This reduces KMS request costs by **up to 99 percent**, with no application change at all.
- **Not supported with DSSE-KMS.** Applies to new objects; existing ones need a copy, which S3 Batch Operations can do.

> ON THE EXAM
>
> "Our KMS bill is enormous and it is all S3 requests" is a bucket key. It is a checkbox, and it is the highest-leverage encryption cost answer there is.

EBS and RDS encryption rules

- **EBS encryption is set at creation.** You cannot encrypt an existing volume in place.
- The route is **snapshot, copy the snapshot with encryption enabled, create a volume from the copy**.
- **Default encryption** is an account and Region setting, so every new volume is encrypted without anyone remembering.
- **RDS encryption is also set at creation.** Encrypting an existing instance means snapshot, copy with encryption, then restore.

> ON THE EXAM
>
> Neither can be encrypted in place. Both follow the same snapshot-copy-restore pattern, and both mean downtime or a migration.

AWS Certificate Manager

- **Public certificates are free** when used with integrated services such as ALB, CloudFront and API Gateway.
- **DNS validation renews automatically** as long as the record stays in place. **Email validation requires a human every time.**
- **Certificates are Regional.** A certificate for **CloudFront must be in us-east-1**, whatever Region your origin is in.
- An ACM certificate attached to a load balancer **cannot expire unnoticed**, which removes an entire class of outage.

> ON THE EXAM
>
> DNS validation over email validation, every time. Email validation is why certificates still expire in organisations that thought they had automated renewal.

New: exportable public certificates

- **Announced June 2025.** ACM public certificates can now be marked **exportable**, giving you the certificate and its **private key**.
- That means ACM can issue certificates for **EC2 instances, containers and on-premises hosts**, not only integrated AWS services.
- Exportable certificates are **charged**, unlike ordinary public certificates, and you must be explicit at request time.
- **You take over renewal and redeployment.** The automatic renewal that makes ACM valuable does not extend to an exported copy.

> ON THE EXAM
>
> Every course written before mid-2025 says ACM public certificates cannot be exported. That was true, and it is now a request-time option.

Private certificates

- **AWS Private CA** issues certificates for internal names that no public authority would sign.
- For internal load balancers, service-to-service TLS, and mutual TLS between microservices.
- It carries a **monthly charge per CA** plus a charge per certificate. It is not a free alternative to public certificates.
- Clients must **trust your CA**, which means distributing the root, and that distribution is the real work.

> ON THE EXAM
>
> Public CA for anything a browser will see. Private CA for internal names and machine-to-machine trust you control end to end.

Secrets Manager rotation

- Rotation runs a **Lambda function** on a schedule. AWS provides **managed rotation** for RDS, Aurora, Redshift and DocumentDB.
- **Single user** strategy changes the one password in place. **Alternating users** keeps two, rotating one while the other serves traffic.
- Alternating users gives **zero downtime rotation**, because there is always a valid credential in use.
- Rotation changes the credential **in the database and in the secret together**. That atomicity is the whole point.

> ON THE EXAM
>
> Module 7's tiebreaker restated: expiry deletes a value, rotation replaces it in two places at once. Only Secrets Manager does the second.

Secrets across accounts and Regions

- **Replication** copies a secret to other Regions, keeping replicas in sync when the source rotates.
- That is what makes a secret available in a disaster recovery Region, which module 17 listed as a common gap.
- **Cross-account access** needs a **resource policy on the secret** and permission on the **KMS key**, because a secret is always encrypted.
- A secret encrypted with the **default aws/secretsmanager key cannot be shared cross-account**. Use a customer managed key.

> ON THE EXAM
>
> The last point is a real design constraint. If a secret will ever be read from another account, it must use a customer managed key from the start.

> An application role has an identity policy allowing kms:Decrypt on a specific customer managed key, and s3:GetObject on the bucket. Downloads still fail with AccessDenied. Both the role and the key are in the same account.
>
> A security engineer previously removed the default statement from the key policy to tighten access.

What is the cause?

A The key policy no longer delegates to IAM, so identity policies cannot grant access to the key

B The role needs kms:Encrypt as well as kms:Decrypt

C The key must be a multi-Region key

D kms:Decrypt cannot be granted in an identity policy

◆ PAUSE AND DECIDE

What is the cause?

A Key policy no longer delegates to IAM

The default statement giving the account root full access is what allows identity policies to grant key access. Removing it makes the key policy the only authority.

B Needs kms:Encrypt too

Downloading decrypts. Encrypt is needed for writing, not reading, and adding it would not help.

C Needs a multi-Region key

Multi-Region keys matter when ciphertext crosses Regions. Everything here is in one account and one Region.

D Decrypt cannot be in an identity policy

It certainly can, provided the key policy delegates to IAM. That delegation is exactly what was removed.

THE SIGNAL

The setup tells you what changed. A KMS key policy is not like a bucket policy: without delegation, IAM grants are simply ignored for that key.

> A data platform stores 400 million small objects in S3 with SSE-KMS. The monthly bill shows a very large AWS KMS charge, dominated by request costs rather than key storage. Applications read objects continuously.
>
> The team must reduce cost without weakening encryption or changing application code.

What should the team do?

A Enable S3 Bucket Keys on the bucket

B Switch the bucket to SSE-S3

C Switch to DSSE-KMS with a bucket key

D Reduce the key's rotation frequency

◆ PAUSE AND DECIDE

What should the team do?

A Enable S3 Bucket Keys

Cuts KMS request traffic by up to 99 percent, keeps SSE-KMS and the customer managed key, and needs no application change.

B Switch to SSE-S3

Removes the KMS charge by removing KMS, so you lose the auditable key, the key policy and the control. That is weakening encryption.

C DSSE-KMS with a bucket key

Bucket keys are not supported with DSSE-KMS, and dual-layer doubles the work. It would increase cost, not reduce it.

D Rotate less often

Rotation is not billed per rotation, and the charge is per request. Rotation frequency has no bearing on it.

THE SIGNAL

"Dominated by request costs" is the phrase. The bill is per KMS API call, and a bucket key removes almost all of those calls.

> A compliance requirement states that the database encryption key must be rotated every 90 days. An engineer reports that AWS KMS only rotates keys annually and proposes writing a Lambda function to create a new key quarterly and re-encrypt all data.
>
> The database uses a customer managed symmetric key.

What should the team do?

A Build the Lambda function as proposed

B Enable automatic rotation with a 90-day rotation period

C Switch to an AWS managed key, which rotates more frequently

D Use a multi-Region key, which supports custom rotation

◆ PAUSE AND DECIDE

What should the team do?

A. Build the Lambda function

Solving a problem that no longer exists, with a function that re-encrypts a whole database quarterly. Considerable risk for nothing.

B. Automatic rotation, 90-day period

Since April 2024 the rotation period is configurable from 90 to 2,560 days on customer managed symmetric keys. This is a single setting.

C. AWS managed key

Rotates yearly and cannot be changed, so it is further from the requirement, not closer. It also removes your control of the policy.

D. Multi-Region key

Concerns where ciphertext can be decrypted, not how often material rotates. Irrelevant to the requirement.

THE SIGNAL

The engineer's premise was true until April 2024. The whole scenario turns on a fact that changed, which is why the currency matters.

> An application on EC2 in a private subnet needs a TLS certificate for an internal hostname. The team wants automatic renewal and does not want to manage a certificate authority. They have used ACM before, for load balancers.
>
> The certificate must be installed directly on the instances, which terminate TLS themselves.

What are the realistic options?

A. An ACM exportable public certificate, if the hostname is publicly resolvable, or AWS Private CA for an internal-only name

B. An ordinary ACM public certificate, exported to the instances

C. Terminate TLS at an ALB instead, using an ordinary ACM certificate

D. A self-signed certificate, since the subnet is private

◆ PAUSE AND DECIDE

What are the realistic options?

A Exportable public cert, or Private CA

Both put a certificate on the instance. Which applies depends on whether the name is publicly resolvable, since a public CA will not sign an internal-only name.

B Export an ordinary ACM certificate

The trap. Ordinary ACM public certificates cannot be exported; exportability must be chosen when the certificate is requested.

C Terminate at an ALB

A good design in general, and the scenario states the instances terminate TLS themselves. It answers a different question.

D Self-signed

No automatic renewal, and every client must be configured to trust it. That is running a CA badly rather than not running one.

THE SIGNAL

The exportable option must be selected at request time. An existing ACM certificate cannot be made exportable afterwards.

> An application in account A must read a database credential stored in Secrets Manager in account B. The secret is encrypted with the default aws/secretsmanager key. A resource policy has been added to the secret allowing the role in account A.
>
> Requests still fail with AccessDenied.

What is the cause?

A. A secret encrypted with the default AWS managed key cannot be shared across accounts. It must use a customer managed key

B. The secret must be replicated into account A

C. Cross-account access to Secrets Manager is not supported

D. The role in account A needs secretsmanager:CreateSecret

◆ PAUSE AND DECIDE

What is the cause?

A Default managed key blocks cross-account

A secret is always encrypted, so reading it requires decrypt on the key. AWS managed key policies cannot be edited to permit another account.

B Replicate the secret

Replication puts a copy in another Region, not another account. It does not address cross-account access at all.

C Not supported

It is fully supported, via a resource policy on the secret plus permission on a customer managed key.

D Needs CreateSecret

Reading a secret needs GetSecretValue. CreateSecret is for making new ones and would not help.

THE SIGNAL

Module 24's fourth rung again: the resource is only half of it. A secret is encrypted, so the key policy is always the second thing to check.

The five things to carry forward

- **An identity policy alone cannot grant key access.** The key policy must delegate to IAM first.
- **KMS rotation is configurable from 90 to 2,560 days** since 2024, plus on-demand. It is no longer annual and fixed.
- **S3 Bucket Keys cut KMS request costs by up to 99 percent**, with no application change.
- **ACM public certificates can be exportable** since June 2025, chosen at request time and charged.
- **Anything encrypted needs the key checked too.** Cross-account secrets require a customer managed key.

> ON THE EXAM
>
> Next: compliance and detection - Config, conformance packs, Security Hub, GuardDuty, Inspector and Macie.

MODULE 27 · DOMAIN 4 - SECURITY AND COMPLIANCE

Compliance and Detection

Config and conformance packs, GuardDuty, Inspector, Macie, Security Hub and Trusted Advisor.

DOMAIN 4 of 5 EXAM WEIGHT 16% MODULE 27 of 35

admin@sthithapragna.com

Each detective service answers **one** question. They all emit findings in **one format**, so a single rule can automate a response to any of them.

Which service answers which question

QUESTION	SERVICE
Is this resource configured the way we require?	AWS Config
Is something behaving maliciously right now?	Amazon GuardDuty
Does this software have known vulnerabilities?	Amazon Inspector
Is there sensitive data in this bucket?	Amazon Macie
How do we stand against a security standard overall?	Security Hub CSPM
Are we wasting money or approaching a limit?	AWS Trusted Advisor

ON THE EXAM

Read the question a scenario is really asking. Configuration, behaviour, vulnerability, data content, posture, or waste. Six questions, six services.

AWS Config: the recorder

- The **configuration recorder** captures a **configuration item** every time a supported resource changes, plus relationships between resources.
- That builds a **configuration history**, which answers "what did this security group look like last Tuesday?"
- **One recorder per account per Region**, and nothing is recorded until it is switched on. Config is not retrospective.
- A **delivery channel** writes configuration snapshots and history to S3, and can notify an SNS topic.

> ON THE EXAM
>
> Module 5's triangle again: CloudTrail records the API call, Config records the resulting state. Both are needed to answer "who changed it, and to what?"

Config rules

- **AWS managed rules** cover hundreds of common checks and need no code. Start here.
- **Custom rules** are a Lambda function, or a **Guard** policy written in AWS's policy-as-code language.
- Rules are **change-triggered**, **periodic**, or both. Change-triggered evaluates when the resource changes; periodic on a schedule.
- **Remediation** attaches an SSM Automation runbook, automatic or manual, as module 8 covered.

> ON THE EXAM
>
> Config evaluates state, so it finds resources that were already wrong before the rule existed. That is what an event-based control cannot do.

Conformance packs

- A **collection of Config rules and remediation actions**, packaged as a single deployable unit. Added to the exam guide in v1.1.
- AWS publishes **sample packs** for CIS, PCI DSS, HIPAA, NIST 800-53 and others, so a standard is one deployment rather than fifty rules.
- Deploy to **an account and Region, or across an entire organisation** from a delegated administrator.
- The pack is **immutable as a unit**. You change the template and redeploy, rather than editing rules individually.

> ON THE EXAM
>
> "Demonstrate compliance with a named standard across every account" is a conformance pack deployed organisation-wide. Not fifty individually managed rules.

Config at organisation scale

- An **aggregator** collects configuration and compliance data from many accounts and Regions into one view.
- **Advanced queries** run SQL over that aggregated state: every unencrypted volume across the organisation, in one query.
- **Cost is per configuration item recorded and per rule evaluation.** Recording every resource type in every Region adds up quickly.
- The **recording strategy** lets you record all types, all types except an exclusion list, or only specific types.

> ON THE EXAM
>
> Config cost is the one most teams meet by surprise. Noisy resource types with frequent changes generate configuration items continuously.

Amazon GuardDuty

- Analyses **CloudTrail management events, VPC Flow Logs and Route 53 DNS query logs** as foundational data sources.
- **You do not need to enable or pay for those logs.** GuardDuty consumes them independently of anything you have configured.
- **Protection plans** are separate and separately charged: S3, EKS, Malware, RDS, Lambda and Runtime Monitoring.
- Findings carry a severity and an affected resource, and flow to **EventBridge and Security Hub** automatically.

> ON THE EXAM
>
> GuardDuty reads flow logs even if you have never enabled VPC Flow Logs. That independence surprises people and it appears in questions.

GuardDuty Extended Threat Detection

- Generally available **December 2024**. Correlates signals over time into a single **attack sequence** finding.
- Example: credential compromise followed by reconnaissance followed by data exfiltration, presented as **one critical-severity finding** rather than a dozen.
- Attack sequences carry **MITRE ATT&CK tactics and techniques** as indicators.
- **May 2026** added indicators sourced from other services: misconfiguration, reachability, sensitive data and vulnerability context.

> ON THE EXAM
>
> This is why enabling Inspector, Macie and Config improves GuardDuty. The exposure context comes from those services, not from GuardDuty itself.

Amazon Inspector

- Continuously scans **EC2 instances, ECR container images, Lambda functions and Lambda code** for known vulnerabilities.
- **Scans on deploy and rescans automatically when a new CVE is published**, so a clean result does not go stale.
- Produces a **risk score** combining CVE severity with network reachability and exploitability, so findings are prioritised rather than listed.
- **Inspector Classic reached end of support on 20 May 2026.** The modern Inspector is agentless via SSM where possible.

> ON THE EXAM
>
> Rescanning on new CVE publication is the differentiator. A point-in-time scan tells you an image was clean when you built it, not that it is clean now.

Inspector or GuardDuty?

INSPECTOR

What could be exploited

- Known CVEs in software and dependencies
- Network reachability of a vulnerable port
- Proactive: finds weaknesses before anyone uses them
- Scans artefacts and instances

GUARDDUTY

What is being exploited

- Anomalous API calls, credential misuse, C2 traffic
- Cryptomining, data exfiltration patterns
- Reactive: something is happening now
- Analyses logs and runtime behaviour

THE TIEBREAKER

Vulnerability versus activity. Inspector says you have an unlocked door; GuardDuty says somebody just walked through one.

Amazon Macie

- Discovers and classifies **sensitive data inside S3 objects**: personal data, financial data, credentials, health information.
- **Managed data identifiers** cover common types out of the box. **Custom identifiers** use your own patterns and keywords.
- **Automated sensitive data discovery** samples buckets continuously and builds a picture without you defining jobs.
- Also reports the **bucket inventory**: which buckets are public, unencrypted, or shared outside the account.

> ON THE EXAM
>
> Macie reads the contents of objects. That is what separates it from every other service here, and it is what makes it charged by data volume.

Macie or GuardDuty S3 Protection?

MACIE

What is in the objects

- Sensitive data classification
- Managed and custom data identifiers
- Answers: do we hold customer PII here?
- Charged by data volume inspected

GUARDDUTY S3 PROTECTION

How the objects are accessed

- Anomalous access patterns and API calls
- Access from unusual locations or principals
- Answers: is somebody exfiltrating this?
- Charged by S3 data event volume

THE TIEBREAKER

Macie inspects the contents; GuardDuty watches the behaviour. A question about classification is Macie; a question about unusual access is GuardDuty.

Security Hub, and Security Hub CSPM

- **What used to be called Security Hub is now Security Hub CSPM:** standards, controls, a security score, and finding aggregation.
- **Security Hub** is now the broader product that correlates signals across Inspector, GuardDuty, Macie and CSPM.
- **Enabling Security Hub automatically enables Security Hub CSPM.** Inspector and GuardDuty analytics need enabling separately, and **Macie is not enabled automatically**.
- **Security Hub CSPM controls depend on AWS Config being enabled** in each account and Region. Without Config, controls cannot evaluate.

> ON THE EXAM
>
> That last point is a real dependency chain, and it is per account and per Region. A CSPM security score means nothing where Config is switched off.

One finding format, one automation

- Findings from GuardDuty, Inspector, Macie, Config, IAM Access Analyzer and partners are normalised into the **AWS Security Finding Format**.
- That means **one EventBridge rule** can match findings from any source and route them to a runbook, a queue or a ticket.
- **Automation rules** in Security Hub can suppress, change severity or update findings automatically as they arrive.
- **CSPM findings are retained for 90 days** after their last update. Longer retention means exporting them.

> ON THE EXAM
>
> Normalisation is the point of an aggregation layer. Without it you would need a different integration for every detective service you run.

AWS Trusted Advisor

- Five categories: **cost optimisation, performance, security, fault tolerance and service quotas**.
- **A limited set of core checks is available to everyone.** The full set requires a **Business, Enterprise On-Ramp or Enterprise** Support plan.
- **Service quota checks** warn as you approach limits, which module 17 showed is what fails a disaster recovery test.
- Checks can be viewed organisation-wide, and findings can be sent to **EventBridge** for automation.

> ON THE EXAM
>
> Trusted Advisor is the only service here that covers cost and performance as well as security. If a question mentions waste or idle resources, that is the signal.

AWS Security Agent

- Added to skill 4.2.5 in **exam guide v1.1**. Generally available **31 March 2026** for on-demand penetration testing.
- Performs **agentic penetration testing**, plus **STRIDE threat modelling** and repository and pull request scanning.
- Integrates with GitHub, GitLab, Bitbucket and Confluence, so findings arrive where the code review happens.
- **Rename in flight:** announced June 2026 as becoming **Continuum pen testing** and **Continuum code scanning**.

> ON THE EXAM
>
> Answer with the exam guide's name, AWS Security Agent, and recognise Continuum in the console. Module 33 covers the full list of renames in flight.

> A security team enables Security Hub across 40 accounts and adopts the AWS Foundational Security Best Practices standard. In twelve accounts the security score shows as unavailable and most controls report no data, although Security Hub itself is clearly enabled there.
>
> The twelve accounts were created recently by a different team.

What is the most likely cause?

A AWS Config is not enabled in those accounts and Regions, so CSPM controls cannot evaluate

B GuardDuty must be enabled before Security Hub can produce a score

C The accounts need to be invited to the Security Hub delegated administrator

D Amazon Macie is not enabled in those accounts

◆ PAUSE AND DECIDE

What is the most likely cause?

A Config is not enabled

Security Hub CSPM controls evaluate using AWS Config. Without a configuration recorder in that account and Region, controls have nothing to assess.

B GuardDuty required first

GuardDuty enriches Security Hub with threat findings. It has no bearing on whether CSPM controls can evaluate configuration.

C Invite to delegated administrator

Would prevent findings appearing centrally. The scenario says Security Hub is enabled and the controls themselves report no data.

D Macie not enabled

Macie is never enabled automatically, and it classifies data. It contributes nothing to a standard's control evaluations.

THE SIGNAL

The dependency chain is per account and per Region. New accounts often have Security Hub switched on centrally and Config never switched on at all.

> An auditor requires evidence that the company complies with the CIS AWS Foundations Benchmark across all 40 accounts, with automatic remediation where possible, and a single report of which resources are non-compliant.
>
> The team does not want to create and maintain the individual rules by hand.

What should the team implement?

A. A Config conformance pack based on the CIS sample template, deployed organisation-wide, with a Config aggregator for reporting

B. Individual Config rules created by a StackSet in every account

C. GuardDuty enabled organisation-wide

D. Trusted Advisor security checks across the organisation

◆ PAUSE AND DECIDE

What should the team implement?

A CIS conformance pack plus aggregator

A sample pack is the standard as one deployable unit, remediation is included, and the aggregator gives the single cross-account report.

B Individual rules via StackSet

Achieves the same outcome and is exactly the hand-maintained rule set the requirement rules out. Conformance packs exist to replace this.

C GuardDuty

Detects malicious behaviour. It evaluates no configuration and maps to no compliance standard.

D Trusted Advisor

A useful fixed set of checks. It does not implement a named benchmark or provide per-resource compliance evidence.

THE SIGNAL

"A named standard, across every account, without maintaining rules by hand" is precisely what conformance packs were built for, and why v1.1 added them.

> A team receives an alert that an EC2 instance is communicating with a known command-and-control server, and separately that credentials from that instance were used to enumerate S3 buckets and then download a large volume of objects.
>
> They want these related events presented as a single prioritised incident rather than as separate findings.

What provides this?

A GuardDuty Extended Threat Detection, which correlates signals into attack sequence findings

B Amazon Inspector, which correlates vulnerabilities across resources

C A Config conformance pack

D CloudWatch composite alarms across the GuardDuty findings

◆ PAUSE AND DECIDE

What provides this?

A Extended Threat Detection

Built exactly for this: correlating signals across services and time into one critical-severity attack sequence, with MITRE tactics attached.

B Inspector

Finds vulnerabilities in software. It observes no behaviour and correlates no activity.

C Conformance pack

Evaluates configuration against rules. Nothing here is a configuration problem.

D Composite alarms

The thoughtful wrong answer. It groups alarms you already defined, so it cannot discover a relationship you did not anticipate.

THE SIGNAL

Option D is worth a moment: composite alarms combine known signals, while attack sequences discover relationships across services you never linked.

> A company must determine whether any of its 900 S3 buckets contain customer personal data. Separately, it must be alerted if anyone downloads unusual volumes of data from those buckets.
>
> The team has GuardDuty enabled but no other security services.

What should they add?

A. Amazon Macie for classification, and GuardDuty S3 Protection for access anomalies

B. Amazon Macie alone, which covers both requirements

C. GuardDuty S3 Protection alone, which covers both requirements

D. Amazon Inspector to scan the buckets

◆ PAUSE AND DECIDE

What should they add?

A Macie plus S3 Protection

Two distinct questions: what is in the objects, and how they are accessed. Neither service answers both.

B Macie alone

Classifies contents and reports bucket posture. It does not monitor access patterns or detect anomalous downloads.

C S3 Protection alone

Detects the unusual download. It has no idea whether the objects contain personal data, because it never reads them.

D Inspector

Scans compute for software vulnerabilities. It does not inspect S3 object contents at all.

THE SIGNAL

Contents versus behaviour, stated as two requirements in one scenario. Options B and C each answer exactly one half, which is what makes them tempting.

> A container image passed its vulnerability scan when it was pushed to ECR three months ago and has been running in production since. A critical CVE affecting one of its base packages was published last week.
>
> The team wants to be told automatically when this happens, without rescanning manually.

What should the team use?

A. Amazon Inspector, which rescans automatically when new CVEs are published

B. ECR basic scanning on push

C. A Config rule checking image age

D. GuardDuty Runtime Monitoring on the cluster

◆ PAUSE AND DECIDE

What should the team use?

A Inspector, continuous rescanning

Enhanced scanning re-evaluates existing images whenever a new CVE is published, so an image clean three months ago is reassessed today.

B Basic scanning on push

The exact failure described. It produced a clean result three months ago and that result never changes.

C Config rule on image age

Flags old images regardless of whether they are vulnerable, and stays silent about a new CVE in a recent one.

D Runtime Monitoring

Detects malicious behaviour in running containers. It says nothing about whether the software has a known vulnerability.

THE SIGNAL

Module 21's tiebreaker made concrete: basic scanning is a moment, enhanced scanning is continuous. The three-month gap is the entire question.

The five things to carry forward

- **Configuration, behaviour, vulnerability, data content, posture, waste.** Six questions, six services.
- **Security Hub CSPM controls require AWS Config**, per account and per Region. No Config, no security score.
- **Conformance packs turn a named standard into one deployment**, with remediation, organisation-wide.
- **GuardDuty reads CloudTrail, flow logs and DNS logs independently**, whether or not you have enabled them.
- **Macie reads contents; GuardDuty watches behaviour.** Inspector finds the unlocked door; GuardDuty sees someone walk through it.

> ON THE EXAM
>
> That completes domain four. Next: VPC fundamentals, and the start of domain five.

MODULE 28 · DOMAIN 5 - NETWORKING AND CONTENT DELIVERY

VPC Fundamentals

CIDR sizing, subnets, route tables, NAT, IPv6, IPAM and Block Public Access.

DOMAIN 5 of 5 EXAM WEIGHT 18% MODULE 28 of 35

admin@sthithapragna.com

A subnet is not public because of a setting. It is public because its **route table** has a route to an internet gateway. Everything else follows from that.

VPC and subnet sizing

- A VPC CIDR is between **/16 and /28**. The **primary CIDR cannot be changed** after creation, though secondary CIDRs can be added.
- A subnet is between **/28 and /16**, must sit inside a VPC CIDR, and **belongs to exactly one Availability Zone**.
- **AWS reserves five addresses in every subnet**: the first four and the last one. A /28 has 16 addresses and **11 usable**.
- The reserved four are network, VPC router, **DNS at base plus two**, and one held for future use.

> ON THE EXAM
>
> Subnets cannot span Availability Zones. Multi-AZ always means multiple subnets, which is why every AWS service asks for a list of them.

Sizing in practice

- **Too small is unfixable.** You cannot enlarge a subnet, only create another, and the primary VPC CIDR is fixed.
- Plan for **three Availability Zones** from the start, even if you deploy into two today. Retrofitting a third is painful.
- Remember what consumes addresses: every ENI, every Fargate task, every Lambda function attached to the VPC, every endpoint.
- A subnet with no free addresses **fails scale-out silently**. Module 12's scenario 5 was exactly this.

> ON THE EXAM
>
> Address exhaustion is the failure that appears months later, during an incident, when the Auto Scaling group cannot launch. Size generously.

Route tables

- Every route table has a **local route** covering the VPC CIDR. It cannot be deleted or modified, and it always wins for internal traffic.
- Every subnet is associated with **exactly one** route table. Without an explicit association it uses the **main** route table.
- **Longest prefix match wins.** A /24 route beats a /16 route for an address inside both.
- Where prefixes tie, **static routes beat propagated ones**. That matters with VPN and Direct Connect propagation.

> ON THE EXAM
>
> The main route table is the default for anything you forget to associate. Leaving it permissive means a new subnet is accidentally public.

Internet gateways

- An **internet gateway** is attached to the VPC, is horizontally scaled and highly available, and costs nothing itself.
- A subnet becomes **public** when its route table sends 0.0.0.0/0 to the internet gateway.
- **The instance also needs a public IPv4 address**, either auto-assigned by the subnet or an Elastic IP. A route alone is not enough.
- The gateway performs **one-to-one NAT** between the private address and the public one. The instance never sees its public address.

> ON THE EXAM
>
> "My instance is in a public subnet and cannot reach the internet" is usually a missing public IP, not a missing route.

NAT gateways

- Lets instances in **private** subnets reach the internet outbound, while nothing on the internet can initiate a connection inward.
- It lives in a **public subnet**, needs an **Elastic IP**, and is a **zonal resource**. Module 14 showed why one per AZ matters.
- Scales from 5 Gbps to 100 Gbps automatically, and supports around **55,000 simultaneous connections per unique destination**.
- Charged **per hour and per gigabyte processed**, which makes it one of the largest line items in most VPC bills.

> ON THE EXAM
>
> A NAT gateway in a private subnet cannot work, because it needs its own route to an internet gateway. That is a common misconfiguration.

The NAT gateway bill

- **Data processing is charged per gigabyte**, in addition to the hourly rate, and it applies to traffic to AWS services too.
- **VPC endpoints remove that traffic entirely.** A gateway endpoint for S3 or DynamoDB is free and bypasses the NAT gateway.
- **One NAT gateway per AZ** avoids paying cross-AZ data transfer on top of the processing charge.
- For a development environment, a single NAT gateway shared across zones is a legitimate cost-availability trade.

> ON THE EXAM
>
> "Our NAT gateway bill is enormous and most of the traffic is S3" is a gateway endpoint. It is free, and it removes the traffic rather than reducing it.

NAT gateway or NAT instance?

NAT GATEWAY

Managed, and the default

- AWS manages availability and patching
- Scales automatically to 100 Gbps
- No security group; it is not an instance
- Charged hourly plus per GB

NAT INSTANCE

Legacy, occasionally justified

- An EC2 instance you patch and scale yourself
- Can be a bastion, or run custom software
- Needs source/destination check disabled
- Cheaper at very low volume

THE TIEBREAKER

A NAT instance needs source/destination check disabled or it silently drops forwarded traffic. That single setting is the classic exam detail.

IPv6 in a VPC

- An Amazon-provided VPC IPv6 block is a **/56**. Every subnet gets a **/64**, and that size is fixed.
- **IPv6 addresses are globally unique and publicly routable.** There is no private IPv6 equivalent of RFC 1918 by default.
- So outbound-only access uses an **egress-only internet gateway**, which is the IPv6 counterpart of a NAT gateway.
- It is **stateful and free**. There is no data processing charge, unlike a NAT gateway.

> ON THE EXAM
>
> Because IPv6 addresses are public, adding IPv6 to a subnet can expose instances that were private over IPv4. Check your security groups.

The public IPv4 charge

- **Since February 2024, every public IPv4 address is charged hourly**, whether it is attached to anything or sitting idle.
- That covers EC2 public IPs, Elastic IPs, load balancers, NAT gateways, RDS and more. Roughly a few pounds per address per month.
- **Public IP Insights**, part of IPAM and free, shows every public IPv4 address in the account and what is using it.
- Reduce it by **releasing idle Elastic IPs**, moving to IPv6 where possible, and not auto-assigning public IPs to instances that do not need them.

> ON THE EXAM
>
> Idle Elastic IPs used to be the only ones charged. Since 2024 every public IPv4 address costs money, attached or not.

VPC IP Address Manager

- **IPAM** plans, tracks and monitors IP address usage across accounts and Regions, replacing the spreadsheet.
- **Pools** are hierarchical, so a top-level range is subdivided per Region, per environment and per account, with automatic allocation.
- The **free tier** covers basic monitoring and Public IP Insights. The **advanced tier** adds cross-account, cross-Region and BYOIP management.
- **Amazon-provided contiguous IPv4 blocks** give sequential Elastic IPs, so a partner can allow-list one range rather than thirty addresses.

> ON THE EXAM
>
> "We cannot tell which CIDR ranges are in use across 60 accounts" is IPAM. It is in the exam's in-scope list precisely because that problem is universal.

VPC Block Public Access

- An **account and Region level** control that blocks internet traffic to and from VPC resources, regardless of route tables and security groups.
- Two modes: **Block Ingress**, where inbound from the internet is blocked but NAT and egress-only gateways still work, and **Block Bidirectional**.
- **Exclusions** allow specific VPCs or subnets to remain reachable, so it is not all-or-nothing.
- Deployable **organisation-wide as a declarative policy**, as module 25 covered, so new accounts inherit it automatically.

> ON THE EXAM
>
> This is a switch above the route table. It overrides an accidentally public subnet without anyone having to find and fix the route.

VPC Encryption Controls

- Enforces that traffic within and between your VPCs is **encrypted in transit**, as a network-level control rather than an application setting.
- Also deployable through a **declarative policy**, so the requirement applies organisation-wide.
- It was **free until 1 March 2026**, and is now charged **per non-empty VPC per hour**, at a rate that varies by Region.
- Useful where a compliance regime demands encryption in transit everywhere, including between instances inside one VPC.

> ON THE EXAM
>
> Compliance frameworks increasingly require encryption in transit internally, not just at the edge. This enforces it without touching applications.

The remaining pieces

- An **elastic network interface** is the thing that actually holds addresses and security groups. Instances have one or more.
- **DHCP option sets** control the DNS servers, domain name and NTP servers handed to instances. Useful with on-premises DNS.
- **enableDnsSupport** and **enableDnsHostnames** on the VPC decide whether the Amazon resolver works and whether instances get DNS names.
- The **default VPC** has public subnets in every AZ and auto-assigns public IPs. Convenient, and not what production should use.

> ON THE EXAM
>
> Interface endpoints and Route 53 private hosted zones both depend on enableDnsSupport. If DNS resolution fails inside a VPC, check those two flags first.

> An EC2 instance in a subnet whose route table sends 0.0.0.0/0 to an internet gateway cannot reach the internet. The security group allows all outbound traffic, and the network ACL is the default allow-all.
>
> The instance has only a private IPv4 address.

What is the cause?

A The instance has no public IPv4 address, so the internet gateway has nothing to translate to

B The subnet needs a NAT gateway as well as an internet gateway

C The route table needs a route to the NAT gateway

D The internet gateway must be attached to the subnet

◆ PAUSE AND DECIDE

What is the cause?

A No public IPv4 address

An internet gateway performs one-to-one NAT between a private and a public address. With no public address there is nothing to translate.

B Needs a NAT gateway too

A NAT gateway is for instances in private subnets. This subnet already routes to an internet gateway, which is the public pattern.

C Route to a NAT gateway

Would give the subnet two default routes to different targets, which is not valid. It also does not address the missing address.

D Attach the IGW to the subnet

Internet gateways attach to a VPC, not a subnet. Subnets connect to one through a route table.

THE SIGNAL

Route plus public address, both required. The scenario eliminates security groups and NACLs deliberately, leaving only the addressing.

A company's NAT gateway charges have grown to a significant monthly figure. Analysis shows that about 80 percent of the processed traffic is private instances reading from and writing to S3 buckets, in the same Region.

The team wants to reduce this without moving the instances to public subnets.

What should the team implement?

A. A gateway VPC endpoint for S3, with routes added to the private subnets' route tables

B. A second NAT gateway to spread the load

C. Move the buckets to another Region

D. Replace the NAT gateway with a NAT instance

◆ PAUSE AND DECIDE

What should the team implement?

A Gateway endpoint for S3

Gateway endpoints are free and route S3 traffic directly, removing 80 percent of the volume from the NAT gateway rather than reducing it.

B A second NAT gateway

Doubles the hourly charge and processes the same total volume. It increases cost, not reduces it.

C Move the buckets

Cross-Region traffic is more expensive, not less, and it adds latency. It makes the problem worse in both dimensions.

D NAT instance

Trades a managed service for one you patch and scale, and still carries all the traffic. The volume is the cost driver, not the appliance.

THE SIGNAL

Gateway endpoints for S3 and DynamoDB are free. That is why this is the single highest-value networking cost answer on the exam.

> An Auto Scaling group has stopped launching instances during peak periods. The scaling activity history reports 'There are not enough free addresses in subnet subnet-0a1b2c'. The subnet is a /27 and also hosts an interface endpoint and several Fargate tasks.
>
> The VPC's primary CIDR is a /24 and is fully allocated to existing subnets.

What is the most appropriate fix?

A Enlarge the subnet from /27 to /25

B Add a secondary CIDR block to the VPC, create larger subnets in it, and move the Auto Scaling group to them

C Change the VPC's primary CIDR to a /16

D Release unused Elastic IP addresses in the account

◆ PAUSE AND DECIDE

What is the most appropriate fix?

A. Enlarge the subnet

Subnets cannot be resized. The only way to get a larger subnet is to create a new one, and the existing /24 has no space.

B. Secondary CIDR, new subnets, migrate

The primary CIDR is immutable and full, so a secondary block is the only route to more address space. Then migrate.

C. Change the primary CIDR

The primary CIDR cannot be changed after the VPC is created. This is not an option that exists.

D. Release Elastic IPs

Elastic IPs are public addresses. The shortage here is private addresses inside a subnet, which is unrelated.

THE SIGNAL

Two immutable facts do the work: subnets cannot be resized, and a primary VPC CIDR cannot be changed. Both A and C describe operations that do not exist.

> A security team must guarantee that no resource in any VPC across the organisation can be reached from the internet. A small number of documented exceptions are allowed. Route tables and security groups are managed by many different application teams.
>
> New accounts are created weekly and must be covered automatically.

What should the team implement?

A. VPC Block Public Access in Block Ingress mode with exclusions, deployed as a declarative policy

B. An SCP denying ec2:CreateRoute for internet gateway destinations

C. A Config rule detecting route tables with an internet gateway route

D. Delete all internet gateways in all accounts

◆ PAUSE AND DECIDE

What should the team implement?

A Block Public Access via declarative policy

Overrides route tables and security groups directly, supports documented exclusions, and a declarative policy covers accounts created later.

B SCP denying CreateRoute

Stops new routes being created and does nothing about routes that already exist. It also blocks legitimate exception cases entirely.

C Config rule

Detective. It reports a publicly reachable resource after it exists, and the requirement is that none can be reached.

D Delete all internet gateways

Breaks NAT gateways and every legitimate outbound path, and the exceptions could not be accommodated at all.

THE SIGNAL

Block Ingress is the mode that matters here: inbound is blocked while NAT and egress-only gateways keep working, so outbound access survives.

> A company with 70 accounts cannot determine which private CIDR ranges are already in use. Two teams recently created overlapping VPCs, which blocked a Transit Gateway attachment. Address planning is currently a shared spreadsheet.
>
> They also want to identify and release unused public IPv4 addresses, which now carry an hourly charge.

What should the company adopt?

A. VPC IPAM with hierarchical pools for allocation, plus Public IP Insights for the IPv4 clean-up

B. A Config rule recording every VPC CIDR into an aggregator

C. Reachability Analyzer across all accounts

D. A tag policy requiring every VPC to be tagged with its CIDR

◆ PAUSE AND DECIDE

What should the company adopt?

A IPAM pools plus Public IP Insights

Pools allocate non-overlapping ranges automatically, which prevents the collision rather than reporting it, and Public IP Insights is free and covers the second requirement.

B Config rule into an aggregator

Gives visibility of what exists. It does not allocate ranges, so two teams could still pick overlapping CIDRs on the same day.

C Reachability Analyzer

Tests whether a path exists between two resources. It is a troubleshooting tool, not an address planning one.

D Tag policy

A spreadsheet in tag form. It records intent and prevents nothing, and it goes stale exactly as the spreadsheet did.

THE SIGNAL

Preventing the overlap beats detecting it. IPAM allocates from a pool, so two teams cannot be handed the same range.

The five things to carry forward

- **A subnet is public because of its route table.** There is no setting, and an instance also needs a public IP.
- **Five reserved addresses per subnet.** A /28 gives 11 usable, and subnets cannot be resized.
- **Gateway endpoints for S3 and DynamoDB are free** and remove that traffic from the NAT gateway entirely.
- **Every public IPv4 address is charged hourly since February 2024**, attached or idle.
- **Block Public Access overrides route tables**, and IPAM prevents CIDR overlap rather than reporting it.

> ON THE EXAM
>
> Next: security groups, NACLs, and a systematic ladder for troubleshooting connectivity.

MODULE 29 · DOMAIN 5 - NETWORKING AND CONTENT DELIVERY

Security Groups, NACLs and Troubleshooting

Stateful versus stateless, ephemeral ports, flow logs, Reachability Analyzer - and a ladder that works every time.

DOMAIN 5 of 5 EXAM WEIGHT 18% MODULE 29 of 35

admin@sthithapragna.com

Security groups are **stateful**; network ACLs are **stateless**. Almost every confusing connectivity failure comes down to **return traffic**.

Security group or network ACL?

SECURITY GROUP

Stateful, at the instance

- Attached to an elastic network interface
- Allow rules only; there is no deny
- Return traffic automatically permitted
- All rules evaluated together

NETWORK ACL

Stateless, at the subnet

- Attached to a subnet, so it covers everything in it
- Allow and deny rules, evaluated by rule number
- Return traffic needs its own rule
- First matching rule wins, then evaluation stops

THE TIEBREAKER

A security group cannot block a specific IP address, because it has no deny. Blocking one bad address is a NACL job, or AWS WAF.

Security groups in detail

- A **new** security group allows **no inbound and all outbound**. The **default** security group also allows inbound from itself.
- Rules can reference an **IP range, a prefix list, or another security group**.
- Multiple security groups on one interface are **additive**. The union of their allow rules applies; nothing subtracts.
- Default limits: **60 inbound and 60 outbound rules** per group per IP version, and **5 groups per interface**, adjustable to 16.

> ON THE EXAM
>
> Groups are additive, so adding one can only widen access. If you need to narrow it, you must edit or remove a rule, not add a group.

Referencing a security group

- Instead of an address range, a rule can name **another security group** as its source. Anything in that group is allowed.
- The rule stays correct as instances are added and removed, because it describes a **role** rather than an address.
- The classic pattern: the database group allows port 3306 **from the application group**, never from a CIDR range.
- References work **within a VPC and across peered VPCs in the same Region**. They do not work across Regions.

> ON THE EXAM
>
> This is the single best practice in VPC security. An address range goes stale; a security group reference describes intent and never does.

Network ACLs in detail

- Rules are **numbered** and evaluated from lowest to highest. The **first match wins** and evaluation stops there.
- So a deny at rule 100 beats an allow at rule 200, even though the allow exists. Rule order is the logic.
- The **default** NACL allows all inbound and outbound. A **custom** NACL **denies everything** until you add rules.
- Number rules in gaps of 100, so you can insert one later without renumbering everything.

> ON THE EXAM
>
> Creating a custom NACL and attaching it before adding rules cuts off the subnet completely. Default allows all; custom denies all.

Ephemeral ports: the classic trap

- A response does not come back on the port you sent to. The client picks a high **ephemeral** source port, and the response goes there.
- So a NACL allowing inbound 443 must also allow **outbound 1024 to 65535** for the response to leave.
- Ranges vary: **Linux 32768-60999**, **Windows 49152-65535**, and **NAT gateways and load balancers use 1024-65535**.
- Security groups are unaffected, because they are stateful and track the connection.

> ON THE EXAM
>
> "It connects and then hangs" or "works one way only" is a NACL missing the ephemeral port range. Nothing else produces that exact symptom.

Where a packet is checked

01

Leaves the source

Source security group outbound rules.

02

Leaves the subnet

Source subnet's NACL outbound rules.

03

Routing

Route table decides the next hop.

04

Enters the subnet

Destination subnet's NACL inbound rules.

05

Reaches the target

Destination security group inbound rules.

ON THE EXAM

Then the response makes the same journey in reverse. Security groups remember it; NACLs do not, which is why the return trip needs its own rules.

The connectivity ladder

- **1. Routing.** Is there a route to the destination, and a route back? Both directions need one.
- **2. Security groups.** Outbound on the source, inbound on the destination. Check both, not just the destination.
- **3. NACLs.** Both subnets, both directions, and **ephemeral ports on the return path**.
- **4. The thing itself.** Is the process listening, on that port, on the right interface? DNS resolving to the right address?

> ON THE EXAM
>
> Work down in order and stop at the first failure. Most people start at step 2, find nothing, and never check that a route exists in both directions.

VPC Flow Logs

- Records accepted and rejected traffic at the **VPC, subnet or network interface** level. Destinations: CloudWatch Logs, S3, or Amazon Data Firehose.
- Each record shows source, destination, ports, protocol, packets, bytes and an **action of ACCEPT or REJECT**.
- A **custom format** adds fields such as **pkt-srcaddr** and **pkt-dstaddr**, which matter behind a NAT gateway or Transit Gateway.
- Aggregation interval is **1 or 10 minutes**, so flow logs are never a real-time view.

> ON THE EXAM
>
> REJECT tells you a security group or NACL blocked it. Silence tells you the packet never arrived, which is a routing or DNS problem.

What flow logs do not capture

- Traffic to and from the **instance metadata service** at 169.254.169.254, and the **Amazon Time Sync** service.
- **DHCP traffic**, and traffic to the **reserved VPC router address**.
- Traffic to the **Amazon-provided DNS server**. Queries to your own DNS servers **are** captured.
- **Windows licence activation** traffic to the AWS-managed activation servers.

> ON THE EXAM
>
> "We have flow logs and see nothing for the metadata service" is expected behaviour, not a fault. For DNS visibility, use Route 53 Resolver query logging.

Reachability Analyzer

- Analyses your **configuration** between two endpoints and reports whether a path exists. It **sends no packets**.
- When a path is blocked it names the **specific component**: this security group, this NACL rule, this missing route.
- It works **before anything is deployed** and on resources that are stopped, because it reads configuration rather than observing traffic.
- Charged **per analysis**, at a small fixed price. It is in the exam's in-scope service list.

> ON THE EXAM
>
> It evaluates the whole path across route tables, security groups, NACLs, gateways, peering and Transit Gateways. That is what makes it faster than reading them yourself.

Flow logs or Reachability Analyzer?

REACHABILITY ANALYZER

Could traffic flow?

- Static configuration analysis
- Names the blocking component precisely
- Works on stopped or undeployed resources
- Start here when something never connects

FLOW LOGS

What traffic did flow?

- Observed records of real packets
- ACCEPT and REJECT for actual attempts
- Shows intermittent and volumetric problems
- Start here when it works sometimes

THE TIEBREAKER

Never connects means configuration, so use the analyzer. Sometimes fails means behaviour, so use flow logs. That split saves a lot of time.

Network Access Analyzer

- Reachability Analyzer answers about **one specific path**. Network Access Analyzer finds **all paths matching a description**.
- You define a **Network Access Scope**: for example, any path from the internet to any resource in a subnet holding regulated data.
- It then reports every route that satisfies it, including ones nobody knew existed through peering or a Transit Gateway.
- It is **configuration analysis**, so it finds paths that are possible, not paths anybody has used.

> ON THE EXAM
>
> "Prove nothing on the internet can reach these subnets" is Network Access Analyzer. A single-path check cannot prove a negative across an estate.

Security group references across a Transit Gateway

- By default, a Transit Gateway **discards security group information** about forwarded traffic.
- So a rule allowing traffic **from another security group** silently fails for anything arriving through the Transit Gateway.
- **Security group referencing support** must be enabled on the Transit Gateway VPC attachment, within a Region.
- Reachability Analyzer reports this specifically, with explanation codes for references not preserved and referencing support.

> ON THE EXAM
>
> This is why a rule that works within a VPC fails across a Transit Gateway. The rule is correct; the group identity did not survive the journey.

Watching the network itself

- Skill 5.3.5 names **CloudWatch network monitoring**, which is three things.
- **Network Flow Monitor**: agent-based, near real-time packet loss and latency between your instances and toward AWS services.
- **Internet Monitor**: the health of the internet paths your users take to reach you, by city and network provider.
- **Network Synthetic Monitor**: probes between chosen endpoints, so you measure a path continuously rather than during an incident.

> ON THE EXAM
>
> Flow logs tell you a connection was rejected. Network Flow Monitor tells you it was accepted and slow, which is a different and harder problem.

Traffic Mirroring

- Copies **actual packets** from an elastic network interface to a monitoring appliance or a Network Load Balancer.
- Flow logs are metadata. Mirroring gives you the **payload**, which is what intrusion detection and packet analysis need.
- **Filters** select which traffic is mirrored, so you copy the flows that matter rather than everything.
- It consumes instance bandwidth and generates a lot of data. It is a targeted tool, not a default.

> ON THE EXAM
>
> "We need to inspect packet contents" is mirroring. Flow logs can never answer that, because they record that a flow happened, not what was in it.

> An engineer creates a custom network ACL for a subnet and adds an inbound rule allowing TCP 443 from 0.0.0.0/0. Instances in the subnet can be reached on 443, but every response times out and connections hang.
>
> The security groups allow all outbound traffic.

What is missing?

A An outbound NACL rule allowing the ephemeral port range, because NACLs are stateless

B An inbound security group rule for port 443

C An outbound NACL rule allowing TCP 443

D A route to the internet gateway

◆ PAUSE AND DECIDE

What is missing?

A Outbound ephemeral range

The response leaves from port 443 to the client's high ephemeral port. A stateless NACL needs an outbound rule covering that range.

B Inbound SG rule for 443

Traffic is arriving, which proves the security group already permits it. And the symptom is the response, not the request.

C Outbound NACL rule for 443

The near miss, and it names the wrong port. The response leaves from 443 but is destined for the ephemeral port, which is what the rule must match.

D Route to the IGW

The request arrived, so routing inbound works. A missing route would prevent the connection entirely rather than hanging it.

THE SIGNAL

Connects then hangs is the stateless signature. Option C is the trap for anyone who knows the rule is needed but matches on the wrong port.

> An application in VPC A cannot reach a database in VPC B through a Transit Gateway. The database's security group allows the database port from the application's security group, and that same rule works correctly for application instances inside VPC B.
>
> Route tables and NACLs have been verified as correct.

What is the most likely cause?

A The Transit Gateway discards security group information unless referencing support is enabled on the attachment

B Security group references never work across VPCs

C The database security group needs the application's CIDR range instead

D The Transit Gateway needs a NAT gateway on the path

◆ PAUSE AND DECIDE

What is the most likely cause?

A Referencing support not enabled

By default a Transit Gateway discards security group information about forwarded traffic, so a group-referencing rule cannot match.

B References never work across VPCs

Too absolute. They work across peered VPCs in the same Region, and across a Transit Gateway once referencing support is enabled.

C Use a CIDR range

A workaround that would work, at the cost of the maintainable rule. The question asks for the cause, not a way around it.

D NAT gateway on the path

NAT is for internet access. Both VPCs are private and routing has already been verified.

THE SIGNAL

The controlled comparison is the clue: the identical rule works inside VPC B and fails across the Transit Gateway. Only the path differs.

> A team must prove to an auditor that no resource in three regulated subnets can be reached from the internet by any path. That includes peering connections and a Transit Gateway other teams manage.
>
> They have VPC Flow Logs enabled on all VPCs.

What should the team use?

A. Network Access Analyzer with a scope matching any path from the internet to those subnets

B. Reachability Analyzer between the internet gateway and each instance

C. Analyse the flow logs for accepted inbound traffic from public addresses

D. A Config rule checking security groups for 0.0.0.0/0 rules

◆ PAUSE AND DECIDE

What should the team use?

A Network Access Analyzer scope

Finds every path matching a description across the whole estate, including routes through peering and Transit Gateways nobody documented.

B Reachability Analyzer per instance

Tests one specified path at a time. Proving no path exists means enumerating every possible source, which is what a scope does for you.

C Flow log analysis

Shows traffic that happened. A path nobody has used yet produces no records, and absence of traffic is not absence of a path.

D Config rule on security groups

Checks one component. A path can be blocked or open for reasons in route tables, NACLs or gateways that a security group rule never reveals.

THE SIGNAL

Proving a negative is the giveaway. A single-path tool cannot do it; only a scope that enumerates all matching paths can.

> Instances in a private subnet intermittently fail to resolve DNS names. VPC Flow Logs for the subnet show no records at all relating to DNS traffic. The team takes that as evidence that queries are blocked before they leave the instance.
>
> The instances use the Amazon-provided DNS server.

What should the team understand and do?

A Flow logs do not capture traffic to the Amazon-provided DNS server. Use Route 53 Resolver query logging instead

B The flow log needs a custom format including pkt-srcaddr

C The NACL is blocking UDP 53 outbound

D enableDnsSupport must be disabled and re-enabled on the VPC

◆ PAUSE AND DECIDE

What should the team understand and do?

A Flow logs never capture it; use Resolver query logging

Documented behaviour. The absence of records is expected and proves nothing, and Resolver query logging is the tool that does show these queries.

B Custom format with pkt-srcaddr

Adds fields to records that exist. It cannot create records for traffic flow logs never capture.

C NACL blocking UDP 53

Would block resolution consistently rather than intermittently, and it is the conclusion the team drew from evidence that does not support it.

D Toggle enableDnsSupport

If DNS support were disabled, resolution would fail completely and permanently, not intermittently.

THE SIGNAL

The team's inference is the error being tested. Silence in flow logs about Amazon DNS is expected, so it is evidence of nothing at all.

> A new application server cannot connect to a database. It has never worked. The environment spans two VPCs joined by peering. There are several security groups, custom NACLs and multiple route tables, maintained by different teams.
>
> An engineer has spent two hours reading configuration without finding the cause.

What is the most efficient next step?

A. Run Reachability Analyzer between the application instance and the database, and read the blocking component it names

B. Enable VPC Flow Logs and look for REJECT records

C. Temporarily open all security groups to 0.0.0.0/0 to isolate the layer

D. Enable Traffic Mirroring on the application instance

◆ PAUSE AND DECIDE

What is the most efficient next step?

A Reachability Analyzer

Has never worked means configuration. The analyzer evaluates the whole path across both VPCs and names the component, in seconds.

B Flow logs for REJECT

Useful, and it only shows the first blocking point that generates a record. A missing route produces no REJECT at all.

C Open everything temporarily

The genuinely dangerous answer. It creates a real exposure, and if the cause is routing it changes nothing while you believe you have tested it.

D Traffic Mirroring

Captures packet contents on a path that is not passing packets. There is nothing to mirror.

THE SIGNAL

"It has never worked" is the phrase. Configuration problems belong to the analyzer; flow logs are for things that used to work or work sometimes.

The five things to carry forward

- **Stateful versus stateless.** Connects then hangs means a NACL missing the ephemeral range on the return path.
- **Reference security groups, not CIDR ranges.** The rule then describes a role and never goes stale.
- **A Transit Gateway discards group references** unless referencing support is enabled on the attachment.
- **Never worked means Reachability Analyzer. Works sometimes means flow logs.**
- **Flow logs never capture Amazon DNS traffic.** Silence there is expected, not evidence.

> ON THE EXAM
>
> Next: private and hybrid connectivity - endpoints, PrivateLink, peering, Transit Gateway and VPN.

MODULE 30 · DOMAIN 5 - NETWORKING AND CONTENT DELIVERY

Private and Hybrid Connectivity

VPC endpoints, PrivateLink, peering, Transit Gateway, Site-to-Site VPN and Direct Connect.

DOMAIN 5 of 5 EXAM WEIGHT 18% MODULE 30 of 35

admin@sthithapragna.com

Four questions: reach an **AWS service** privately, join **two** VPCs, join **many**, or reach **on-premises**. Each has one obvious answer.

The options, mapped

REQUIREMENT	ANSWER
Reach S3 or DynamoDB privately from a VPC	Gateway endpoint. Free
Reach another AWS service privately	Interface endpoint, powered by PrivateLink
Expose your own service privately to other accounts	PrivateLink endpoint service, behind an NLB
Connect two VPCs	VPC peering
Connect many VPCs and on-premises networks	Transit Gateway
Reach a data centre over the internet	Site-to-Site VPN
Reach a data centre over a private circuit	Direct Connect

ON THE EXAM

Gateway endpoints exist for exactly two services. Everything else private within a Region is an interface endpoint, and that is charged.

Gateway or interface endpoint?

GATEWAY ENDPOINT

S3 and DynamoDB only

- A route table entry pointing at a prefix list
- Completely free, with no data processing charge
- Same Region only; no ENI and no security group
- NOT reachable from on-premises over DX or VPN

INTERFACE ENDPOINT

Almost every other service

- An ENI with a private IP in your subnet
- Charged per AZ per hour, plus per GB processed
- Has a security group, so you control access to it
- Reachable from on-premises over DX or VPN

THE TIEBREAKER

The last row of each column is the deciding one. If on-premises systems must reach S3 privately, a gateway endpoint cannot do it; an interface endpoint can.

Endpoint policies and private DNS

- An **endpoint policy** restricts what may be done through that endpoint: only these buckets, only these actions, only this organisation.
- That is a **data perimeter** control. Traffic to a bucket outside your organisation can be blocked at the endpoint.
- **Private DNS** on an interface endpoint makes the service's normal public hostname resolve to the endpoint's private address.
- Private DNS needs **enableDnsSupport and enableDnsHostnames** on the VPC. Module 28 flagged those two attributes.

> ON THE EXAM
>
> Private DNS is what makes an interface endpoint transparent. Without it, applications must be changed to use the endpoint-specific hostname.

PrivateLink for your own services

- Put your service behind a **Network Load Balancer** or Gateway Load Balancer, then create an **endpoint service**.
- Consumers create an interface endpoint to it. Traffic never traverses the internet, and **no peering or route sharing is required**.
- **CIDR ranges may overlap**, because there is no routing between the two VPCs. That is the significant advantage over peering.
- The provider controls **allowed principals** and can require manual acceptance of each connection request.

> ON THE EXAM
>
> PrivateLink is unidirectional: the consumer reaches the provider, never the reverse. That asymmetry is exactly what makes it safe for SaaS.

VPC peering

- A one-to-one connection between two VPCs. Works **across accounts and across Regions**, using the AWS backbone.
- **CIDR ranges must not overlap.** This is the constraint that kills peering at scale, and module 28's IPAM prevents it.
- **Peering is not transitive.** If A peers with B and B peers with C, A cannot reach C.
- **No edge-to-edge routing.** You cannot use a peer's internet gateway, NAT gateway, VPN or Direct Connect connection.

> ON THE EXAM
>
> Both sides need routes. A peering connection that is Active with traffic still failing is almost always a route table nobody updated on one side.

Transit Gateway

- A regional router. Everything **attaches once** to it: VPCs, VPN connections, Direct Connect gateways, and other Transit Gateways.
- Replaces a mesh. Ten VPCs need **45 peering connections** or **10 attachments**.
- **Route tables** on the gateway control who can reach whom. **Association** decides which table an attachment uses; **propagation** decides which routes it advertises.
- That separation is how you build isolation: a shared services VPC reachable by everyone, while spokes cannot reach each other.

> ON THE EXAM
>
> Association and propagation are different things and the exam tests both. One is which routes you see; the other is which routes you publish.

Transit Gateway details that decide questions

- **Appliance mode** keeps both directions of a flow on the same Availability Zone, which stateful firewalls require.
- Without it, asymmetric routing breaks inspection appliances, and the symptom is intermittent connection failures.
- **Inter-Region peering** connects Transit Gateways in different Regions, encrypted, over the AWS backbone.
- **Security group referencing support** must be enabled on an attachment, as module 29 covered, or group references are discarded.

> ON THE EXAM
>
> Appliance mode is the answer whenever a stateful inspection appliance sits behind a Transit Gateway. Without it, the return traffic can arrive at a different appliance.

Peering or Transit Gateway?

PEERING WHEN

A small, fixed number

- Two or three VPCs with a stable relationship
- No data processing charge, only data transfer
- Lowest latency: no intermediate hop
- Becomes unmanageable beyond a handful

TRANSIT GATEWAY WHEN

Many, or hybrid

- Dozens of VPCs, or VPN and Direct Connect too
- Central route tables give real segmentation
- Charged per attachment per hour, plus per GB
- One extra hop of latency

THE TIEBREAKER

Peering has no data processing charge, so a very high volume link between two VPCs can be cheaper peered even in an estate that otherwise uses a Transit Gateway.

Site-to-Site VPN

- IPsec over the internet. Every connection has **two tunnels** to two AWS endpoints, for redundancy.
- **Your device must be configured for both.** A single-tunnel configuration loses connectivity during AWS tunnel maintenance.
- Terminates on a **virtual private gateway** or a **Transit Gateway**. The customer gateway represents your device.
- **BGP** gives dynamic routing and automatic failover. Static routing works and fails over only when you intervene.

> ON THE EXAM
>
> Two tunnels are provided and only one is used unless you configure both. That is the most common cause of an unexpected VPN outage.

New: VPN bandwidth changed twice

- **November 2025: large bandwidth tunnels** support **5 Gbps per tunnel**, four times the standard 1.25 Gbps.
- Available on **Transit Gateway or Cloud WAN only**, not on a virtual private gateway.
- It **reduces the need for ECMP**, which was previously the only way to aggregate bandwidth across bonded tunnels.
- **May 2026:** bandwidth can be **changed on an existing connection**, preserving tunnel IPs, CIDRs and pre-shared keys. Previously this meant delete and recreate.

> ON THE EXAM
>
> The May 2026 change removes the reason teams avoided upgrading: no new tunnel IPs, no on-premises device reconfiguration, no firewall changes.

Other VPN options

- **VPN Concentrator**, from November 2025, connects up to **100 low-bandwidth remote sites** through a **single Transit Gateway attachment**.
- For a retailer with hundreds of branches, that replaces hundreds of individual attachments.
- **Accelerated VPN** routes tunnel traffic through **AWS Global Accelerator**, entering the AWS network at the nearest edge location.
- **ECMP** on a Transit Gateway still aggregates bandwidth across multiple tunnels, up to around 50 Gbps.

> ON THE EXAM
>
> Accelerated VPN shortens the distance travelled over the public internet, which is where jitter and packet loss come from on a long-haul VPN.

Direct Connect

- A private physical circuit into an AWS Direct Connect location. **Dedicated** connections at 1, 10, 100 or 400 Gbps, ordered from AWS.
- **Hosted** connections from a partner run from 50 Mbps to 25 Gbps, and are provisioned far faster.
- Three **virtual interfaces**: **public** for AWS service endpoints, **private** for a VPC via a VGW or DX gateway, and **transit** for a Transit Gateway.
- **Direct Connect is not encrypted by default.** Add **MACsec** on supported 10 and 100 Gbps dedicated connections, or run a VPN over it.

> ON THE EXAM
>
> Private is not the same as encrypted. That distinction appears in compliance questions and the answer is MACsec or an IPsec VPN on top.

Direct Connect at scale

- A **Direct Connect gateway** is global, letting one connection reach VPCs in **multiple Regions**. Up to **20 VGWs or 6 Transit Gateways**.
- A **link aggregation group** bundles connections into one logical link: up to 4 below 100 Gbps, or 2 at 100 Gbps.
- **SiteLink** sends traffic directly between two Direct Connect locations over the AWS backbone, **bypassing Regions entirely**.
- Resiliency: **High Resiliency** is two connections at two locations. **Maximum Resiliency** is four across two locations.

> ON THE EXAM
>
> SiteLink turns Direct Connect into a private global WAN between your own sites, which is a use case that has nothing to do with reaching AWS.

Direct Connect or VPN?

DIRECT CONNECT WHEN

Consistent and high volume

- Predictable latency and dedicated bandwidth
- Lower data egress pricing
- Weeks to provision, and a fixed port cost
- Not encrypted unless you add MACsec or IPsec

VPN WHEN

Fast, encrypted, flexible

- Live in under an hour, over any internet connection
- Encrypted by default with IPsec
- Now up to 5 Gbps per tunnel on a Transit Gateway
- Subject to internet variability

THE TIEBREAKER

The usual production answer is both: Direct Connect as primary and a VPN as automatic backup. When both advertise the same routes, Direct Connect is always preferred.

> On-premises servers connected over Direct Connect must reach an S3 bucket privately, without traversing the internet. The team creates a gateway endpoint for S3 in the VPC and adds it to the route tables, but on-premises traffic still cannot reach S3 privately.
>
> In-VPC instances reach S3 through the endpoint correctly.

What should the team do?

A Create an interface endpoint for S3, which can be reached from on-premises over Direct Connect

B Add the on-premises CIDR range to the gateway endpoint's policy

C Propagate the gateway endpoint's prefix list over BGP

D Create a second gateway endpoint in the Direct Connect gateway

◆ PAUSE AND DECIDE

What should the team do?

A Interface endpoint for S3

Gateway endpoints cannot be reached from on-premises over Direct Connect or VPN. Interface endpoints have a private IP in your subnet, and can.

B Endpoint policy change

An endpoint policy restricts what may be done through an endpoint that is already reachable. It cannot make an unreachable one reachable.

C Propagate the prefix list

Gateway endpoints work through a route table entry inside the VPC. There is no path to advertise to an on-premises router.

D Gateway endpoint on the DX gateway

Gateway endpoints attach to a VPC route table. There is no such construct on a Direct Connect gateway.

THE SIGNAL

The controlled comparison is stated: in-VPC access works, on-premises does not. That is precisely the documented boundary of a gateway endpoint.

> A software vendor must expose an API to 200 customer AWS accounts privately. Many customers use the 10.0.0.0/16 range, which overlaps with the vendor's own VPC. Customers must not be able to reach anything else in the vendor's environment.
>
> The vendor does not want to manage 200 peering connections.

What should the vendor implement?

A. A PrivateLink endpoint service behind a Network Load Balancer, with customers creating interface endpoints

B. VPC peering with each customer account

C. A Transit Gateway shared with customers through RAM

D. A public API endpoint restricted by IP allow-list

◆ PAUSE AND DECIDE

What should the vendor implement?

A PrivateLink endpoint service

No routing between VPCs, so overlapping CIDRs are irrelevant. Exposure is limited to the one service, and it scales to any number of consumers.

B Peering per customer

Fails on overlapping CIDRs alone, and 200 peering connections is exactly the management burden the vendor ruled out.

C Shared Transit Gateway

Creates routing between the vendor and customers, so overlaps break it and customers gain a route into the vendor's network.

D Public endpoint with allow-list

Traffic traverses the internet, which the requirement excludes, and an IP allow-list for 200 customers is unmaintainable.

THE SIGNAL

Overlapping CIDRs is the clause that eliminates everything routing-based. PrivateLink works precisely because it does not route.

> Traffic between two VPCs attached to a Transit Gateway passes through stateful firewall appliances. Those sit in an inspection VPC, spread across three Availability Zones. Connections succeed most of the time and fail intermittently, with no pattern the team can identify.
>
> The appliances log packets arriving without a matching session.

What is the cause?

A Appliance mode is not enabled on the inspection VPC's Transit Gateway attachment

B The Transit Gateway route tables are missing a propagation

C Security group referencing support is not enabled

D The appliances need larger instance types

◆ PAUSE AND DECIDE

What is the cause?

A Appliance mode not enabled

Without it the Transit Gateway may send the return path through a different AZ, so a stateful appliance sees a packet for a session it never opened.

B Missing propagation

Would break connectivity consistently, not intermittently. The scenario says most connections succeed.

C SG referencing support

A real Transit Gateway setting, and it would cause consistent denial for group-referencing rules, not asymmetric flows.

D Bigger appliances

The log message names a missing session, not exhausted resources. Capacity would show as drops under load, not orphaned packets.

THE SIGNAL

"Packets arriving without a matching session" is the asymmetric-routing signature. Intermittent rather than consistent points at path selection, not configuration.

> A company runs a Site-to-Site VPN to a Transit Gateway. Two tunnels use ECMP, achieving about 2.5 Gbps. A migration now needs 5 Gbps sustained. The team is reluctant to change anything, because the last bandwidth change required deleting and recreating the connection.
>
> It is 2026.

What should the team do?

A. Modify the existing connection's tunnel bandwidth to large, which preserves tunnel IPs and pre-shared keys

B. Add two more tunnels and extend ECMP

C. Delete and recreate the connection with large bandwidth tunnels

D. Order a Direct Connect circuit

◆ PAUSE AND DECIDE

What should the team do?

A Modify bandwidth in place

Since May 2026 bandwidth can be changed on an existing connection, preserving tunnel IPs, CIDRs and pre-shared keys. No on-premises change at all.

B More tunnels with ECMP

Works, and it is the workaround that large bandwidth tunnels were introduced to remove. More tunnels means more device configuration to maintain.

C Delete and recreate

The team's stated fear, and it was the only option until May 2026. It is now unnecessary.

D Direct Connect

Takes weeks to provision and a migration is already under way. It is the right long-term answer to a different question.

THE SIGNAL

The team's reluctance is based on a constraint that was removed in May 2026. The phrase "it is 2026" is there to make the currency the point.

> A company has 14 VPCs across three accounts, currently joined by 21 peering connections. Adding a VPC now requires updating route tables in every existing VPC. They also need to connect two on-premises data centres, and want central control over which VPCs can reach each other.
>
> Address ranges do not overlap.

What should the company implement?

A. A Transit Gateway, shared across accounts with RAM, with route tables providing segmentation

B. Continue with peering and automate route table updates

C. PrivateLink endpoint services between each pair of VPCs

D. One large shared VPC replacing all 14

◆ PAUSE AND DECIDE

What should the company implement?

A Transit Gateway shared via RAM

One attachment per VPC, VPN attachments for the data centres, and route tables giving the central segmentation asked for. All three requirements.

B Automate peering routes

Automates the symptom. Peering is non-transitive and cannot attach a VPN, so the on-premises requirement is unmet regardless.

C PrivateLink between pairs

Exposes individual services, not networks. It cannot provide general VPC-to-VPC routing or reach a data centre.

D One shared VPC

A genuine pattern, and it discards the isolation boundaries entirely and is an enormous migration for 14 existing VPCs.

THE SIGNAL

Three requirements, and peering fails two of them structurally: it cannot attach a VPN, and it offers no central place to control who reaches whom.

The five things to carry forward

- **Gateway endpoints cannot be reached from on-premises.** Interface endpoints can, and are charged.
- **PrivateLink does not route**, so overlapping CIDRs do not matter. Peering and Transit Gateway both do.
- **Peering is non-transitive and cannot attach a VPN.** Those are structural limits, not scale ones.
- **Appliance mode** pins both directions of a flow to one AZ. Intermittent failures with stateful appliances mean it is missing.
- **VPN tunnels now reach 5 Gbps**, and since May 2026 bandwidth changes in place with no on-premises reconfiguration.

> ON THE EXAM
>
> Next: Route 53 - hosted zones, alias records, routing policies, Resolver and DNS Firewall.

MODULE 31 · DOMAIN 5 - NETWORKING AND CONTENT DELIVERY

Route 53

Hosted zones, alias records, routing policies, Resolver, Profiles, DNS Firewall and Global Resolver.

DOMAIN 5 of 5 EXAM WEIGHT 18% MODULE 31 of 35

admin@sthithapragna.com

Route 53 is three products: a **registrar**, an **authoritative DNS service** that answers for your domains, and a **resolver** that asks questions on behalf of your VPCs.

Hosted zones

- A **public hosted zone** answers queries from anywhere on the internet. A **private hosted zone** answers only from **associated VPCs**.
- A private zone can be associated with **many VPCs, across accounts and Regions**, which is how a shared internal namespace works.
- Private zones need **enableDnsSupport and enableDnsHostnames** on the VPC. Module 28 flagged these; they are the usual cause of resolution failing.
- Every hosted zone is created with an **NS** and an **SOA** record. Deleting or editing those breaks delegation.

> ON THE EXAM
>
> A private hosted zone is invisible outside its associated VPCs. Queries from anywhere else get no answer at all, not a refusal.

Split-horizon DNS

- The **same domain name** can exist in a public zone and a private zone at once, with different answers.
- Queries from an associated VPC get the **private** answer. Queries from anywhere else get the **public** one.
- So internal traffic reaches an internal load balancer by private address, while external traffic reaches the public one, using one hostname.
- The private zone wins for the whole domain within the VPC, so anything not defined there simply does not resolve.

> ON THE EXAM
>
> That last point is the trap. Creating a private zone for example.com means subdomains you did not define stop resolving inside the VPC, even public ones.

Alias or CNAME?

ALIAS RECORD

Route 53's own extension

- Works at the zone apex: example.com itself
- Queries to AWS targets are free
- Follows the target's IP changes automatically
- Supports evaluate target health

CNAME RECORD

Standard DNS

- Cannot exist at the zone apex. This is a DNS rule, not an AWS limit
- Charged per query
- Points at any DNS name, inside or outside AWS
- Adds an extra resolution step

THE TIEBREAKER

"example.com must point at the load balancer" can only be an alias. The DNS standard forbids a CNAME coexisting with the SOA and NS records at the apex.

The routing policies

POLICY	CHOOSES BY
Simple	Nothing. One record, and any values are returned in random order
Weighted	A weight from 0 to 255. Proportional split for testing or gradual shifts
Latency	Lowest measured network latency to an AWS Region
Failover	Primary while healthy, otherwise secondary. Module 14 covered this
Geolocation	Where the user is: continent, country, or US state
Geoproximity	Distance to a location, adjustable with a bias. Needs Traffic Flow
Multivalue answer	Returns up to 8 healthy records at random
IP-based	The CIDR block the query came from

ON THE EXAM

Latency routes by measured network performance; geolocation routes by where the user is. Those are different, and questions exploit the difference.

Weighted, latency and multivalue in detail

- **Weighted**: weights are relative, not percentages. A weight of **0** means never used, unless every record is 0, in which case all are used.
- **Latency** is measured network latency to a Region, which is **not** the same as geographic closeness.
- **Multivalue answer** returns up to eight **healthy** records. Simple routing returns all values whether they are healthy or not.
- Multivalue answer is **not a load balancer**. There is no session awareness, no connection draining and no capacity awareness.

> ON THE EXAM
>
> Multivalue answer is health-aware simple routing. Its real use is improving availability for something with no load balancer in front of it.

Geolocation or geoproximity?

GEOLOCATION

Where the user is

- Continent, country, or US state
- For compliance, licensing and language
- Always configure a default record
- No concept of distance or adjustment

GEOPROXIMITY

How far from your resource

- Distance between user and resource location
- A bias from -99 to +99 expands or shrinks a region
- Requires Traffic Flow
- For shifting load between sites gradually

THE TIEBREAKER

Geolocation answers "which country is this user in?". Geoproximity answers "which of my sites is nearest, and how much do I want to skew that?"

Records, TTL and Traffic Flow

- **Evaluate target health** on an alias to a load balancer uses the target's own health, with no separate health check to create or pay for.
- **TTL** is how long resolvers cache an answer. Lower means faster change and more queries; higher means cheaper and slower.
- **Alias records to AWS targets have no configurable TTL.** Route 53 manages it.
- **Traffic Flow** is a visual editor producing a versioned **traffic policy**, combining several routing policies into one tree.
- Traffic policies are **versioned and can be rolled back**, which ordinary record edits cannot.

> ON THE EXAM
>
> Lower the TTL days before a planned migration, not on the day. Resolvers are still holding the old value for as long as the old TTL said.

Route 53 Resolver

- Every VPC has a resolver at the **base of the CIDR plus two**, and at the link-local address 169.254.169.253.
- By default it resolves **public names**, **private hosted zones** associated with the VPC, and **EC2 private DNS names**.
- It does **not** know about your on-premises domains, and on-premises systems cannot reach it directly.
- That gap is what **inbound and outbound endpoints** exist to close.

> ON THE EXAM
>
> Module 29's flow log exclusion applies here: queries to the VPC resolver are never recorded in flow logs. Use Resolver query logging.

Inbound or outbound endpoint?

INBOUND ENDPOINT

On-premises asks AWS

- ENIs with private IPs in your subnets
- On-premises DNS forwards AWS domains to them
- Data centre systems resolve private zones
- Queries flow into the VPC

OUTBOUND ENDPOINT

AWS asks on-premises

- ENIs used as a source for outbound queries
- Paired with rules naming the domains
- Instances resolve corp.example.com
- Queries flow out of the VPC

THE TIEBREAKER

Name the direction of the query, not the traffic. Inbound means queries coming in to AWS; outbound means queries going out to your data centre.

Resolver rules

- A **forwarding rule** says which domain names go to which target DNS servers, through an outbound endpoint.
- A **system rule** overrides forwarding for a subdomain, so example.com forwards on-premises while aws.example.com stays with Route 53.
- Rules are **shareable through AWS RAM**, so a networking account defines them once for the whole organisation.
- The most specific matching rule wins, exactly as with route tables.

> ON THE EXAM
>
> The RAM sharing point matters at scale. Without it, every VPC in every account needs its own rules and outbound endpoints, and they drift.

Route 53 Profiles

- A **Profile** bundles **private hosted zones, Resolver rules and DNS Firewall rule groups** into one shareable object.
- Share it through **AWS RAM** and associate it with VPCs across accounts, so a new VPC inherits the whole DNS configuration at once.
- Without it, each element is associated separately with each VPC, which is where multi-account estates drift apart.
- Changing the Profile changes every associated VPC, which is the point and also the blast radius.

> ON THE EXAM
>
> The same pattern as StackSets and organization backup policies: define once centrally, and new resources inherit it without anyone remembering.

Resolver DNS Firewall

- Filters **outbound DNS queries from your VPCs** against domain lists, before the name is resolved.
- Actions are **ALLOW**, **BLOCK** or **ALERT**. A block can return NODATA, NXDOMAIN, or an override to a domain you choose.
- **AWS Managed Domain Lists** cover malware, botnet command and control, phishing and DGA domains, and are **free to use**.
- Rule groups are evaluated in **priority order**, and are associated with VPCs. AWS's guidance is to **test with ALERT before switching to BLOCK**.

> ON THE EXAM
>
> Blocking at the DNS layer stops the connection before it is attempted, so no data leaves. Network Firewall inspects packets after a name has resolved.

Advanced DNS threat detection

- Beyond domain lists, DNS Firewall detects **DNS tunnelling**, where data is exfiltrated inside DNS queries themselves.
- That matters because DNS is often the one protocol allowed out of a restricted network, so it is the exfiltration path attackers reach for.
- It also detects **domain generation algorithm** patterns, where malware computes thousands of candidate domains rather than using a fixed one.
- A static domain list cannot catch either, because neither uses domains anybody has listed.

> ON THE EXAM
>
> This is the DNS equivalent of GuardDuty's shift from signatures to behaviour: detecting the shape of an attack rather than a known name.

New: Route 53 Global Resolver

- Generally available **9 March 2026**, across 30 Regions, for IPv4 and IPv6. An **internet-reachable anycast resolver**.
- Resolves **public domains and your private hosted zones** from anywhere, through one set of anycast addresses.
- Clients are authorised by **Access Source**, matching an IP range, or by revocable **Access Tokens** for clients with changing addresses.
- Supports **Do53, DNS over HTTPS and DNS over TLS**, and carries the same DNS Firewall filtering.

> ON THE EXAM
>
> This removes the need for inbound endpoints plus split-DNS forwarding for branch offices and remote workers. Inbound endpoints remain right for a data centre with its own DNS servers.

The remaining pieces

- **Resolver query logging** records the queries your VPCs make. Flow logs never capture these, as module 29 established.
- **DNSSEC signing** for public hosted zones proves responses have not been tampered with. The key-signing key lives in **KMS in us-east-1**.
- DNSSEC is a **one-way door operationally**: an expired or mismatched key makes the domain unresolvable, not merely unverified.
- **Domain registration** covers 250 or so top-level domains, and creates the hosted zone for you.

> ON THE EXAM
>
> Query logging is the only way to see what your instances are looking up. That is both a security signal and the fastest way to find a hard-coded endpoint.

> A team must point example.com, the bare domain with no subdomain, at an Application Load Balancer. They create a CNAME record for example.com pointing at the load balancer's DNS name, and Route 53 rejects it.
>
> A CNAME for www.example.com pointing at the same load balancer works correctly.

What should they do?

A. Create an alias record for example.com targeting the load balancer

B. Create an A record with the load balancer's IP addresses

C. Delete the SOA record so the CNAME can be created

D. Use a redirect from example.com to www.example.com in the application

◆ PAUSE AND DECIDE

What should they do?

A Alias record at the apex

Alias is Route 53's extension that works at the zone apex, follows the load balancer's changing addresses, and is free for AWS targets.

B A record with the IPs

A load balancer's addresses change without notice. This works until AWS replaces a node, then fails silently.

C Delete the SOA record

Would break the zone entirely. The DNS standard forbids a CNAME coexisting with other records at the apex, and SOA is mandatory.

D Application redirect

Requires something already answering at the apex to issue the redirect, which is the problem being solved.

THE SIGNAL

The comparison is supplied: www works, the apex does not. That is the CNAME-at-apex rule, and only an alias solves it.

> A team creates a private hosted zone for example.com and associates it with a VPC. Instances can resolve app.example.com internally, as intended. However, they can no longer resolve mail.example.com, a public record not defined in the private zone.
>
> External systems resolve mail.example.com normally.

What is the cause and the fix?

A The private hosted zone is authoritative for the whole domain inside the VPC. Add the missing records to it

B enableDnsHostnames is disabled on the VPC

C The private hosted zone needs a forwarding rule to the public zone

D The VPC needs an outbound Resolver endpoint

◆ PAUSE AND DECIDE

What is the cause and the fix?

A The private zone is authoritative for the whole domain

Inside an associated VPC the private zone answers for example.com entirely. Names not defined in it do not resolve, even if they exist publicly.

B enableDnsHostnames disabled

Would prevent the private zone working at all. app.example.com resolves correctly, so the attribute is enabled.

C Forward to the public zone

Resolver forwarding rules send queries to DNS servers you specify. There is no mechanism to fall through from a private zone to a public one.

D Outbound endpoint

Sends queries to on-premises DNS servers. The missing record is on the public internet, which the resolver already reaches.

THE SIGNAL

Overlaying a private zone on a public domain is a decision to own every name in it. There is no fall-through, and that surprises people.

> A hybrid environment needs two things. Instances in AWS must resolve names in corp.internal, which is served by DNS servers in the data centre. Servers in the data centre must resolve names in a Route 53 private hosted zone used by AWS workloads.
>
> The team has a Direct Connect connection in place.

What should the team configure?

A. An outbound endpoint with a forwarding rule for corp.internal, and an inbound endpoint for the data centre's DNS to forward to

B. An inbound endpoint only, with a forwarding rule for corp.internal

C. An outbound endpoint only, associated with both networks

D. Associate the private hosted zone with the on-premises network

◆ PAUSE AND DECIDE

What should the team configure?

A Both endpoints

Two directions of query means two endpoints. Outbound with a rule sends AWS queries to the data centre; inbound receives queries coming the other way.

B Inbound only

Handles queries arriving from the data centre. AWS instances would still have no way to reach corp.internal.

C Outbound only

Handles AWS querying on-premises. The data centre still has no AWS address to send its queries to.

D Associate the PHZ on-premises

Private hosted zones associate with VPCs only. There is no way to associate one with a network outside AWS.

THE SIGNAL

Two requirements in opposite directions means two endpoints. Options B and C each solve exactly half, which is what makes them plausible.

> A security team must stop workloads in 45 VPCs from resolving known malware and command-and-control domains, and must detect data exfiltration hidden inside DNS queries. They want the same policy applied automatically to VPCs created later.
>
> They do not want to maintain domain lists by hand.

What should they implement?

A DNS Firewall rule groups using AWS Managed Domain Lists and advanced threat detection, bundled into a Route 53 Profile shared through RAM

B A custom domain list of known bad domains, associated with each VPC

C AWS Network Firewall in each VPC

D Security group rules denying outbound port 53

◆ PAUSE AND DECIDE

What should they implement?

A Managed lists plus advanced detection, in a Profile

Managed lists remove the maintenance, advanced detection catches tunnelling that no list contains, and a shared Profile covers new VPCs.

B Custom lists per VPC

Exactly the hand-maintained lists ruled out, associated 45 times, and a list can never catch tunnelling or generated domains.

C Network Firewall

Inspects packets after a name has resolved. Useful alongside, and it does not stop the lookup or see inside DNS queries the same way.

D Block outbound port 53

Breaks all DNS resolution, since instances query the VPC resolver. It would take every workload offline.

THE SIGNAL

Three requirements: no manual lists, detect tunnelling, cover future VPCs. Managed lists, advanced detection, and a Profile map onto one each.

A company has 90 branch offices and a large remote workforce. All of them need to resolve names in Route 53 private hosted zones. The current design forwards from a DNS server at each site to Resolver inbound endpoints in two Regions, and the team maintains failover configuration at every site.

The current design forwards from a DNS server at each site to Resolver inbound endpoints in two Regions. The team maintains failover configuration at every site. Remote workers have changing IP addresses and cannot be covered by source-IP rules.

What should the company consider?

A Route 53 Global Resolver, using Access Sources for the offices and Access Tokens for remote workers

B Inbound Resolver endpoints in more Regions

C A Route 53 Profile shared to each branch office

D Make the private hosted zones public

◆ PAUSE AND DECIDE

What should the company consider?

A Global Resolver with both authorisation methods

Anycast addresses remove per-site failover configuration, Access Sources cover fixed-IP offices, and Access Tokens cover clients whose addresses change.

B More inbound endpoints

More of the thing causing the burden. Every site still needs forwarding and failover configuration maintained by hand.

C A Profile per office

Profiles associate with VPCs. There is no way to associate one with a branch office network.

D Make the zones public

Publishes internal DNS records to the entire internet, which is a serious disclosure of internal architecture.

THE SIGNAL

The remote-worker clause is decisive: changing IPs cannot be authorised by source range, and Access Tokens exist precisely for that case.

The five things to carry forward

- **A CNAME cannot exist at the zone apex.** That is a DNS rule, and an alias record is the answer.
- **A private hosted zone is authoritative for the whole domain** inside associated VPCs. There is no fall-through.
- **Inbound means queries coming in to AWS; outbound means queries going out.** Most hybrid designs need both.
- **DNS Firewall blocks before resolution**, and detects tunnelling and generated domains that no list contains.
- **Global Resolver (March 2026)** gives anycast resolution of private zones from anywhere, without inbound endpoints.

> ON THE EXAM
>
> Next: CloudFront and the edge - OAC, cache behaviours, invalidation, WAF, Shield and Global Accelerator.

MODULE 32 · DOMAIN 5 - NETWORKING AND CONTENT DELIVERY

CloudFront and the Edge

Cache behaviours, OAC, VPC origins, edge functions, WAF, Shield and Global Accelerator.

DOMAIN 5 of 5 EXAM WEIGHT 18% MODULE 32 of 35

admin@sthithapragna.com

The edge does three things: **cache** so the origin is not asked, **filter** so bad requests never arrive, and **shorten the path** so traffic joins the AWS network sooner.

Distributions, origins and behaviours

- A **distribution** has one or more **origins** and a set of **cache behaviours** that decide which origin serves which path.
- Behaviours are matched by **path pattern in order**, and the **default behaviour, matching everything, is evaluated last**.
- That is how one distribution serves static files from S3 and **/api** from a load balancer, under one domain name.
- Each behaviour has its own **cache policy, allowed methods, TTLs and function associations**. They are not shared.

> ON THE EXAM
>
> Behaviour ordering is the same first-match logic as ALB listener rules and NACLs. A broad pattern placed too early shadows everything beneath it.

The cache key

- By default the cache key is **only the URL path**. Headers, cookies and query strings are **excluded unless you add them**.
- Adding something to the cache key **multiplies the number of cached copies**. Including a cookie that varies per user destroys the cache entirely.
- So the rule is: include the minimum that genuinely changes the response, and nothing else.
- **Cache-Control headers from the origin** are respected, bounded by the behaviour's minimum and maximum TTL.

> ON THE EXAM
>
> A near-zero cache hit ratio is almost always a cache key that includes something highly variable. Check the key before blaming the TTL.

The three policy types

POLICY	CONTROLS
Cache policy	What is in the cache key, and the TTL settings. Also forwarded to the origin
Origin request policy	What is forwarded to the origin but NOT part of the cache key
Response headers policy	Headers CloudFront adds to responses: CORS, security headers, custom

ON THE EXAM

Origin request policy is the one people miss. It is how the origin sees a header for logging or geolocation without that header fragmenting the cache.

Invalidation, and why to avoid it

- **Invalidation** removes objects from every edge cache. The first 1,000 paths a month are free, and it takes minutes to propagate.
- **Versioned file names** are the better answer: publish app.v27.js rather than invalidating app.js.
- A new name is a **new object**, so it is never stale, needs no invalidation, and old versions expire naturally.
- Invalidation remains right for an **emergency**: wrong content published, or a security issue in a cached response.

> ON THE EXAM
>
> A deployment pipeline that invalidates /* on every release is a design smell. Versioned assets make the cache correct by construction.

Origin groups and origin protection

- An **origin group** holds a primary and a secondary origin, failing over on status codes you nominate, such as 500, 502, 503 and 504.
- That gives origin failover at the edge, without any DNS change and without waiting for a TTL to expire.
- **Origin Shield** adds a caching layer in one Region between the edges and your origin, raising the cache hit ratio.
- It matters most when many edge locations would otherwise each fetch the same object from your origin independently.

> ON THE EXAM
>
> Origin Shield collapses many edge misses into one origin request. For an expensive origin, that is a bigger saving than it first appears.

New: VPC origins

- Since **November 2024**, CloudFront can serve directly from an ALB, NLB or EC2 instance in a **private subnet**.
- The origin needs **no public IP address and no internet-facing load balancer**. It is unreachable except through your distribution.
- That replaces the old pattern of a public ALB protected by a **secret custom header**, which is one leaked header from being reachable.
- Extended since: **cross-account VPC origins via RAM** (November 2025), and **WebSocket support** (May 2026).

> ON THE EXAM
>
> The old pattern relied on a secret staying secret and on someone rotating it. A VPC origin removes the public endpoint entirely.

Protecting an S3 origin

- **Origin Access Control** lets CloudFront sign requests to S3, so the bucket policy can allow only that distribution.
- **Origin Access Identity is the legacy predecessor.** If an option offers OAI for new work, that is the dated answer.
- OAC supports **SSE-KMS**, all Regions, and **POST and PUT** requests, none of which OAI handled.
- Pair it with **Block Public Access** on the bucket, so the only path to the objects is through the distribution.

> ON THE EXAM
>
> OAC plus Block Public Access is the standard static site pattern: the bucket is private, and CloudFront is the only thing that can read it.

Restricting who can view

- **Signed URLs** grant time-limited access to **one file**. **Signed cookies** grant access to **many files** without changing any URL.
- So a single download link is a signed URL, while an entire subscriber video library is signed cookies.
- **Geo restriction** allows or blocks whole countries at the CloudFront level, using its own geolocation database.
- For anything more nuanced than a country list, use **AWS WAF**, which can combine geography with other conditions.

> ON THE EXAM
>
> Signed cookies exist because rewriting every URL in an application to sign it is impractical. The choice is about how many objects, not how secret they are.

CloudFront Functions or Lambda@Edge?

CLOUDFRONT FUNCTIONS

Tiny, fast, everywhere

- JavaScript, sub-millisecond, at every edge location
- Viewer request and viewer response only
- No network access and no request body access
- Header manipulation, redirects, URL rewrites, token checks

LAMBDA@EDGE

Fuller, slower, regional

- Node.js or Python, runs at Regional edge caches
- All four triggers, including origin request and response
- Network access, so it can call other services
- Up to 5 seconds at viewer, 30 at origin

THE TIEBREAKER

If it needs to call something, it is Lambda@Edge. If it only inspects and rewrites the request, it is a CloudFront Function, and far cheaper.

Cost, addresses and logs

- **Price classes** limit which edge locations are used. Fewer locations costs less and serves distant users more slowly.
- **Anycast static IPs** give a distribution a dedicated set of addresses, for partners who must allow-list them.
- **Standard logs** go to S3 and arrive with a delay. **Real-time logs** go to Kinesis Data Streams within seconds, with configurable fields and sampling.
- Real-time logs are charged per line, so **sample** rather than logging everything on a high-volume distribution.

> ON THE EXAM
>
> CloudFront addresses normally change, which is why partner allow-listing used to force a Global Accelerator or NLB. Anycast static IPs removed that constraint.

AWS WAF

- A **web ACL** holds rules evaluated in **priority order**. Actions are **Allow, Block, Count, CAPTCHA** or **Challenge**.
- **Count** is the safe way to introduce a rule: it records what would have matched without blocking anything.
- **Managed rule groups** from AWS and partners cover common threats, so you write very few rules yourself.
- Attaches to **CloudFront, ALB, API Gateway, AppSync, Cognito user pools** and more.

> ON THE EXAM
>
> Count mode is the same measure-before-enforcing pattern as Hooks warn mode, Allowed AMIs audit mode and DNS Firewall alert. Fifth appearance in this course.

Rate limiting and bots

- **Rate-based rules** block a source exceeding a request threshold in a window. The classic defence against credential stuffing and scraping.
- They can be scoped down, so the limit applies only to **/login** rather than the whole site, and aggregated by more than source IP.
- **Bot Control** distinguishes verified good bots, common bots and targeted automation, rather than blocking all automation.
- **CAPTCHA and Challenge** sit between allow and block: Challenge is silent to a real browser, while CAPTCHA asks the user to act.

> ON THE EXAM
>
> Challenge is the underused action. It stops most automation with no user-visible friction at all, which CAPTCHA cannot claim.

Shield Standard or Shield Advanced?

SHIELD STANDARD

Free and automatic

- Enabled for every AWS customer, nothing to configure
- Network and transport layer DDoS mitigation
- Covers CloudFront, Route 53 and load balancers
- No support engagement, no cost protection

SHIELD ADVANCED

Paid, with people

- Application-layer protection and richer detection
- Shield Response Team access during an event
- Cost protection: credits for attack-driven scaling
- Includes Firewall Manager. Monthly commitment

THE TIEBREAKER

Two clauses signal Advanced: access to AWS specialists during an attack, and refunds for the scaling an attack caused. Standard offers neither.

CloudFront or Global Accelerator?

CLOUDFRONT WHEN

HTTP, and cacheable

- Content can be cached at the edge
- HTTP and HTTPS only
- WAF, signed URLs, edge functions
- Caching removes origin load entirely

GLOBAL ACCELERATOR WHEN

Any protocol, no cache

- TCP or UDP, any port. Gaming, VoIP, IoT, MQTT
- Two static anycast IPs for allow-listing
- Fast regional failover, in around 30 seconds
- Traffic dials and endpoint weights for gradual shifts

THE TIEBREAKER

Global Accelerator is not a cache. It shortens the network path and fails over between Regions. If content is cacheable HTTP, CloudFront does more.

Global Accelerator in detail

- Two **static anycast IP addresses** that never change, fronting endpoints in multiple Regions.
- **Endpoint groups** are per Region, and a **traffic dial** sets what percentage of traffic each receives.
- Continuous health checks give **failover in roughly 30 seconds**, with no DNS involved and therefore no TTL to wait for.
- **Custom routing accelerators** map deterministically to a specific instance and port, for gaming sessions and virtual desktops.

> ON THE EXAM
>
> The absence of DNS is the point. Module 14's TTL and resolver-caching arithmetic simply does not apply, because the address never changes.

A CloudFront distribution in front of a dynamic application has a cache hit ratio of about 2 percent. The origin is under heavy load. The cache behaviour forwards all cookies and all query strings to the origin, and includes them in the cache key. Most responses are identical for all users.

The application needs the CloudFront-Viewer-Country header for analytics.

What should the team do?

A. Reduce the cache key to what actually varies the response, and use an origin request policy to forward the country header without caching on it

B. Increase the maximum TTL on the behaviour

C. Enable Origin Shield

D. Add more origins to an origin group

◆ PAUSE AND DECIDE

What should the team do?

A Shrink the cache key; forward via origin request policy

Cookies in the cache key give every user their own copy. An origin request policy forwards the header without fragmenting the cache.

B Raise the maximum TTL

Objects are not expiring; they are never being reused, because each request produces a distinct cache key. A longer TTL on a unique object achieves nothing.

C Origin Shield

Collapses duplicate origin fetches for the same object. With a near-unique key per request there are no duplicates to collapse.

D More origins

Spreads the same load across more servers. It treats the symptom while the cache continues to do nothing.

THE SIGNAL

A 2 percent hit ratio with identical responses is a cache key problem, always. Option B is the reflex answer and addresses expiry, not uniqueness.

> An application load balancer sits behind CloudFront. It is internet-facing, and a WAF rule on the ALB blocks any request that does not carry a secret custom header set by CloudFront. A security review objects that the ALB remains publicly reachable and that the header is a shared secret nobody has rotated in two years.
>
> The application must stay behind CloudFront.

What should the team implement?

A. Convert the ALB to internal and configure it as a CloudFront VPC origin

B. Rotate the custom header automatically with a Lambda function

C. Add an Origin Access Control to the ALB

D. Restrict the ALB's security group to CloudFront's published IP ranges

◆ PAUSE AND DECIDE

What should the team implement?

A Internal ALB as a VPC origin

Removes the public endpoint entirely. The ALB has no public address, so there is nothing to reach and no secret to protect.

B Rotate the header

Genuinely improves the existing design, and the ALB stays publicly reachable. It fixes the stale secret, not the exposure.

C OAC on the ALB

Origin Access Control signs requests to S3 origins. It does not apply to a load balancer.

D Security group to CloudFront ranges

The strongest alternative: it does restrict access. The ranges change and must be maintained, and any CloudFront distribution is inside them, including someone else's.

THE SIGNAL

Option D is the subtle one: CloudFront's IP ranges admit every CloudFront customer, not only your distribution. That is why the custom header existed in the first place.

> A multiplayer game server uses UDP on a custom port and runs in three Regions. Players report high latency and slow recovery when a Region becomes unhealthy. The team currently uses Route 53 latency-based routing with health checks.
>
> Some corporate players need to allow-list fixed IP addresses.

What should the team implement?

A AWS Global Accelerator with endpoint groups in each Region

B A CloudFront distribution in front of the game servers

C Route 53 geoproximity routing with a bias

D A Network Load Balancer with cross-Region targets

◆ PAUSE AND DECIDE

What should the team implement?

A Global Accelerator

UDP on any port, two static anycast IPs for allow-listing, traffic onto the AWS backbone at the nearest edge, and failover in about 30 seconds with no DNS.

B CloudFront

HTTP and HTTPS only, and game traffic is not cacheable. It cannot carry UDP at all.

C Geoproximity routing

Still DNS. It changes which endpoint is chosen, and failover still waits for health checks plus TTL plus resolver caching.

D NLB with cross-Region targets

An NLB is Regional. It does not provide global anycast entry or Regional failover.

THE SIGNAL

Three clauses each point the same way: UDP rules out CloudFront, static IPs rule out DNS-based answers, and slow recovery rules out anything using TTLs.

> A login endpoint is being attacked with credential stuffing from thousands of distributed addresses. Legitimate users must not be blocked, and the team's own monitoring bots must continue to work. Blocking whole countries is not acceptable.
>
> The site is behind CloudFront with AWS WAF attached.

Which combination should the team apply?

A. A rate-based rule scoped to /login, plus Bot Control, with new rules introduced in Count mode first

B. A single rate-based rule applied to the whole distribution

C. Geo restriction on CloudFront for the top attacking countries

D. Shield Advanced, which blocks credential stuffing automatically

◆ PAUSE AND DECIDE

Which combination should the team apply?

A Scoped rate limit, Bot Control, Count first

The scope-down keeps the limit off ordinary browsing, Bot Control distinguishes the team's own bots from attackers, and Count proves the effect before blocking.

B One rate rule for everything

A threshold low enough to stop login abuse will block normal browsing, since a page load makes many requests.

C Geo restriction

Explicitly ruled out, and attacks from distributed addresses are rarely confined to a few countries anyway.

D Shield Advanced

Focused on DDoS, with expert support and cost protection. Credential stuffing is a low-volume application attack, which is WAF's job.

THE SIGNAL

Three constraints, three features. Scope-down, bot classification, and Count mode each answer one of them exactly.

> A static website is served from an S3 bucket through CloudFront. The bucket is currently public so CloudFront can read it, and a security audit requires that it must not be. Objects are encrypted with SSE-KMS.
>
> An engineer proposes using an Origin Access Identity, which they have used before.

What should the team do?

A. Use Origin Access Control, and enable Block Public Access on the bucket

B. Use an Origin Access Identity as proposed

C. Keep the bucket public and restrict access with a bucket policy on CloudFront's IP ranges

D. Move the objects behind a VPC origin

◆ PAUSE AND DECIDE

What should the team do?

A OAC plus Block Public Access

OAC is the current mechanism and, unlike OAI, it supports SSE-KMS. Block Public Access then makes the distribution the only path.

B Origin Access Identity

Legacy, and it does not support SSE-KMS, which the scenario states is in use. It would fail on this bucket specifically.

C Public bucket, IP-range policy

Leaves the bucket public, which the audit forbids, and CloudFront's ranges admit every CloudFront customer.

D VPC origin

VPC origins serve from ALBs, NLBs and EC2 in private subnets. S3 is not a VPC resource, so this does not apply.

THE SIGNAL

The SSE-KMS detail is deliberate: it makes OAI not merely dated but actually non-functional here. That is why it is in the setup.

The five things to carry forward

- **A poor cache hit ratio is a cache key problem**, not a TTL problem. Include only what genuinely varies the response.
- **An origin request policy forwards without caching on it.** That is how the origin sees a header without fragmenting the cache.
- **VPC origins remove the public endpoint entirely**, replacing the secret custom header pattern.
- **OAC, not OAI.** OAC supports SSE-KMS, all Regions, and POST and PUT.
- **Global Accelerator is not a cache.** Any protocol, static IPs, and failover with no DNS involved.

> ON THE EXAM
>
> That completes the teaching modules. Next: what changed for SOA-C03, and what AWS has renamed since.

MODULE 33 · EXAM STRATEGY - ALL DOMAINS

What Changed, and What AWS Renamed

The C02 to C03 changes, exam guide v1.1, and everything AWS has moved since the guide was written.

DOMAIN Cross-cutting EXAM WEIGHT All MODULE 33 of 35

admin@sthithapragna.com

Two kinds of change. The **exam guide** changed, twice. And **AWS** kept changing after the guide was written, which the guide cannot reflect.

The exam is not called what you think

- **SOA-C03 is the AWS Certified CloudOps Engineer - Associate.** AWS renamed the certification with this version.
- The new name applies **only to people who pass SOA-C03**. It is not applied retroactively to existing SysOps Administrator holders.
- Existing holders **need not retake anything**. Their credential remains valid for its full three years.
- Almost every search result, forum post and study guide still calls it SysOps Administrator. Both names describe this exam.

> ON THE EXAM
>
> SOA-C02 ran until 29 September 2025. SOA-C03 began 30 September 2025. Anything written before that date describes a different exam.

Exam mechanics, confirmed

FACT	VALUE
Duration	130 minutes
Questions	65 total: 50 scored, 15 unscored
Question types	Multiple choice and multiple response only
Exam labs	NONE. SOA-C03 has no hands-on lab section
Cost	150 USD
Passing score	720 of 100 to 1000, compensatory scoring
Validity	3 years

ON THE EXAM

A high-ranking third-party site states "$300, 65 questions plus labs, 180 minutes". All three figures are wrong. The labs belonged to C02 and were suspended in March 2023.

The domains changed shape

SOA-C02	SOA-C03
D1 Monitoring, Logging, Remediation, 20%	D1 adds Analysis and Performance Optimization, 22%
D2 Reliability and Business Continuity, 16%	D2 same name, 22%
D3 Deployment, Provisioning, Automation, 18%	D3 same name, 22%
D4 Security and Compliance, 16%	D4 unchanged, 16%
D5 Networking and Content Delivery, 18%	D5 unchanged, 18%
D6 Cost and Performance Optimization, 12%	GONE. Folded into Task 1.3

ON THE EXAM

Domain 6 did not disappear, it moved. Cost and performance questions now arrive inside Domain 1, which is why module 9 and module 10 sat there.

What AWS explicitly added and removed

- **Added:** the CloudWatch agent on **ECS and EKS clusters**, CloudFormation **and AWS CDK**, Region and service selection enforcement, and **CloudWatch network monitoring services**.
- **Moved: VPNs** from the security domain to networking. The old cost and performance tasks into Task 1.3.
- **Removed:** configuring S3 static website hosting.
- **Containers are new scope.** ECR, ECS and EKS were out of scope in C02 and are in scope now. That is the largest single gap in C02-era material.

> ON THE EXAM
>
> The container change matters most. If you are revising from SOA-C02 material, module 21 has no equivalent anywhere in it.

Exam guide v1.1, published 1 June 2026

- **Most courses on the market predate this revision.** AWS publishes revisions about a month before they affect the exam, so 1.1 is live.
- **Services added to the in-scope list:** Amazon Bedrock, **AWS DevOps Agent**, **AWS Health Dashboard**, **Kiro**, and **AWS Security Agent**.
- **Removed from the out-of-scope list**, so no longer explicitly excluded: AppStream 2.0, Augmented AI, AppSync, Cloud Directory, Kendra, and Amazon Q Developer.
- Three of the five additions are **agentic services that went GA in 2026**. That is a deliberate signal about where AWS operations is heading.

> ON THE EXAM
>
> Nothing in v1.1 removes content. It adds, which means material written against version 1.0 is incomplete rather than wrong.

The v1.1 skill rewordings that matter

- **1.3.4** added **Amazon S3 Files** to the shared storage list. **4.1.5** added **Config conformance packs**.
- **2.3.4** now names the four DR strategies explicitly: backup and restore, pilot light, warm standby, active/active.
- **1.2.1** dropped User Notifications and auto scaling, and **added Kiro and AWS DevOps Agent**. **3.2.2** added EventBridge and DevOps Agent.
- **1.1.1** now says monitoring for "serverless, compute, **AI**" workloads. **4.2.5** added AWS Security Agent.

> ON THE EXAM
>
> Naming the four DR strategies explicitly is the clearest signal in the whole revision. Expect a question that describes a requirement and wants the strategy name.

Still examinable, no longer buildable

FEATURE	CLOSED TO NEW CUSTOMERS
Systems Manager Incident Manager	7 November 2025
Systems Manager Change Manager	7 November 2025
CloudTrail Lake	31 May 2026
ARC readiness check	30 April 2026

ON THE EXAM

Existing customers continue. These remain in the exam guide, so learn what they do, and never propose them for new work.

Removed entirely, not merely closed

FEATURE	GONE
CloudWatch Evidently	End of life 17 October 2025
RDS Performance Insights	End of life 2026. Console redirects to Database Insights
SSM CloudWatch Dashboard	Removed 30 April 2026
SSM Advanced Instances Tier	Removed 30 June 2026. Hybrid nodes now register free
Amazon Inspector Classic	End of support 20 May 2026
Elastic Beanstalk AL2 platform branches	Retired 30 June 2026. Migrate to AL2023

ON THE EXAM

These differ from the closed features: there is no existing-customer carve-out. If older material recommends one, that recommendation is simply dead.

Renames in flight

OLDER NAME	CURRENT NAME
RDS Performance Insights	CloudWatch Database Insights. Console redirects; API persists
Aurora Serverless v2	Aurora serverless, renamed April 2026
Route 53 Application Recovery Controller	Amazon Application Recovery Controller
Security Hub	Security Hub CSPM. "Security Hub" is now the broader product
AWS Security Agent	Becoming Continuum pen testing and Continuum code scanning
AWS Fault Injection Simulator	AWS Fault Injection Service

ON THE EXAM

Answer with the exam guide's name and recognise the current one in the console. The guide still says "Aurora Serverless v2" and "AWS Security Agent".

Numbers that changed

LIMIT	OLD VALUE STILL PUBLISHED
gp3: 64 TiB, 80,000 IOPS, 2,000 MiB/s	16 TiB, 16,000 IOPS, 1,000 MiB/s
Logs Insights: 100 concurrent, 100,000 results	30 concurrent, 10,000 results
KMS rotation: 90 to 2,560 days, plus on-demand	Fixed annual, not configurable
VPN tunnels: 5 Gbps each	1.25 Gbps each
Aurora serverless: 256 ACUs, scales to zero	128 ACUs, minimum 0.5
Public IPv4: charged always, since Feb 2024	Free while attached

ON THE EXAM

Each of these changes the correct answer to a real question. gp3 reaching 80,000 IOPS removes the reason to choose io2 in many designs.

Facts that were true, and are now wrong

WHAT OLDER MATERIAL SAYS	WHAT IS TRUE NOW
ECS blue/green requires CodeDeploy	Native since July 2025. AWS recommends native for new work
ACM public certificates cannot be exported	Exportable since June 2025, chosen at request time
Terraform state locking needs a DynamoDB table	Deprecated. Use S3 native locking, use_lockfile
Logs Insights QL cannot do JOINs	JOIN and sub-query arrived April 2026
Instrument tracing with the X-Ray SDK	SDKs in maintenance mode. Use ADOT. The service is fine
Launch configurations are an option	Cannot be created at all in accounts made after 1 Oct 2024

ON THE EXAM

These are the dangerous ones. A stale limit makes you cautious; a stale fact makes you confidently choose a wrong answer.

The new services, in one place

- **AWS DevOps Agent**, GA 31 March 2026. Investigates incidents and produces a **mitigation plan for human approval**. It does not execute changes autonomously.
- **AWS Security Agent**, GA 31 March 2026. Agentic penetration testing, STRIDE threat modelling, repository and pull request scanning.
- **Kiro**, GA November 2025. Spec-driven agentic IDE. For operations it **authors automation rather than running it**. The Kiro autonomous agent is still preview.
- **Amazon S3 Files**, GA 7 April 2026. Mounts an S3 bucket as NFS v4.2, with the S3 API still working against the same data.

> ON THE EXAM
>
> The DevOps Agent boundary is the exam-relevant detail: it investigates and proposes, and a human approves. Do not pick it as an answer that acts alone.

Amazon Q Developer and Kiro: get the nuance right

- **Amazon Q Developer is retiring.** New sign-ups blocked 15 May 2026; IDE plugins and paid subscriptions end 30 April 2027.
- **Kiro is the successor** for the agentic IDE, and joined the exam guide's in-scope list in version 1.1.
- **Q Developer inside the AWS console and other first-party experiences is NOT affected.** Only the standalone product is retiring.
- Q Developer was also **removed from the out-of-scope list** in v1.1, so it is no longer explicitly excluded from the exam.

> ON THE EXAM
>
> Two things share a name and have opposite futures. Saying "Amazon Q Developer is going away" without qualification is wrong.

New capabilities that changed the standard answer

CAPABILITY	WHAT IT REPLACED
CloudFront VPC origins	A public ALB guarded by a secret custom header
ECS native blue/green	Wiring in CodeDeploy for every deployment
Drift-aware change sets	Detecting drift, then correcting it by hand
AutoScalingInstanceRefresh policy	Rigid rolling updates, or drift from refreshing outside the stack
Route 53 Global Resolver	Inbound endpoints plus per-site forwarding configuration
Resource control policies	Reviewing every bucket policy in every member account
Declarative policies	SCPs enumerating API actions, which new APIs bypass
Logically air-gapped vaults	Copying isolated backups somewhere usable before restoring

ON THE EXAM

Each of these makes an older, more laborious pattern the wrong answer. Recognising the older pattern in a distractor is worth as much as knowing the new one.

When the guide and reality disagree

- **Answer with the exam guide's terminology.** If it says Aurora Serverless v2, that is the name in the answer options.
- **Answer with current behaviour for limits.** Exams are updated for capability changes more readily than for naming.
- **Never choose a closed feature for new work.** Incident Manager and CloudTrail Lake are the ones most likely to appear as plausible distractors.
- **If two options differ only by name**, and one is the guide's name, take the guide's name.

> ON THE EXAM
>
> You are unlikely to be penalised for knowing something is newer than the question assumes. You can be penalised for not recognising the name in the options.

The patterns worth more than the facts

- **Measure before enforcing** appeared five times: Hooks warn mode, Allowed AMIs audit mode, predictive scaling forecast-only, DNS Firewall alert, WAF count.
- **Preventive, detective, corrective**: a Hook blocks it, Config finds it, Automation fixes it. Control Tower presents all three as one vocabulary.
- **An experienced colleague's advice has aged** appeared repeatedly, because AWS closes and replaces things faster than runbooks are rewritten.
- **Over-engineering is a wrong answer**, not a safe one. Meeting an agreed target beats exceeding it expensively.

> ON THE EXAM
>
> AWS designs these patterns deliberately across services. Recognising the pattern often gets you to the answer faster than recalling the service.

> A question describes a team needing a queryable, immutable audit store for CloudTrail events across an organisation, and lists CloudTrail Lake among the options. The team is building this in 2026 and has never used CloudTrail Lake.
>
> The other options include an organisation trail delivering to S3 with Athena for queries.

How should you approach this?

A Choose the organisation trail with Athena, because CloudTrail Lake closed to new customers on 31 May 2026

B Choose CloudTrail Lake, because it is purpose-built and appears in the exam guide

C Choose CloudTrail Lake, because closures do not affect exam answers

D Assume CloudTrail is also closed and choose neither

◆ PAUSE AND DECIDE

How should you approach this?

A Organisation trail plus Athena

A team that has never used CloudTrail Lake cannot onboard after 31 May 2026. The alternative genuinely meets the requirement.

B CloudTrail Lake

Purpose-built and unavailable to this team. The scenario says they have never used it, which is the clause that closes the door.

C Closures do not matter

They do. A question describing new work in 2026 has a correct answer the team can actually implement.

D Assume CloudTrail is closed

Overcorrecting. CloudTrail itself is fully supported; only Lake closed. Precision about scope matters in both directions.

THE SIGNAL

Option D is the mirror-image error: knowing about a closure and applying it too broadly. Lake closed; CloudTrail did not.

> A question asks how to give a database team the ability to see database load broken down by wait event and SQL statement. The answer options include both 'RDS Performance Insights' and 'CloudWatch Database Insights'.
>
> You know Performance Insights reached end of life and the console now redirects.

Which do you choose?

A Whichever appears without the other; if both appear, the one matching the capability described

B Always CloudWatch Database Insights, because Performance Insights no longer exists

C Always RDS Performance Insights, because the exam guide predates the change

D Neither, because the capability was removed

◆ PAUSE AND DECIDE

Which do you choose?

A Match the capability described

Both names describe the same capability. Read what the question actually asks for, and pick the option describing it, rather than deciding on the name alone.

B Always Database Insights

Reasonable, and it fails if the question was written earlier and only offers the old name. The capability is what is being tested.

C Always Performance Insights

The mirror error. If the question offers only the new name, insisting on the old one leaves you with no answer.

D The capability was removed

It was renamed and extended, not removed. Advanced mode added lock diagnostics and execution plans that Performance Insights never had.

THE SIGNAL

Renames are the one case where a rigid rule fails. Learn the capability, recognise both names, and let the question's wording decide.

> A question describes needing 30,000 IOPS and asks which EBS volume type to choose. It offers gp3 and io1 among the options. There is no requirement for sub-millisecond latency or five-nines durability.
>
> You recall older material stating gp3 caps at 16,000 IOPS.

What should you choose?

A. gp3, because it now supports up to 80,000 IOPS and no requirement points at io1

B. io1, because gp3 cannot exceed 16,000 IOPS

C. io2 Block Express, as the safest high-performance choice

D. gp2 with a very large volume

◆ PAUSE AND DECIDE

What should you choose?

A gp3

Since September 2025 gp3 reaches 80,000 IOPS, and nothing in the requirement points at provisioned IOPS volumes. It is also substantially cheaper.

B io1

Based on a limit that changed in September 2025. It would work, at higher cost, for a reason that is no longer true.

C io2 Block Express

Over-engineering, which this course has repeatedly shown is a wrong answer rather than a safe one. No stated requirement justifies it.

D gp2 with a large volume

Would need over 10 TiB to reach 30,000 IOPS, and gp2 caps at 16,000 anyway. Expensive and insufficient.

THE SIGNAL

Unlike a rename, a raised limit is unambiguous. Answer with current capability, and remember that gp3's ceiling moved.

> A colleague reviewing your architecture says: "Amazon Q Developer is being retired, so remove any dependency on it. Also, our runbook says to use Systems Manager Incident Manager for on-call escalation, which is fine because we already have it configured."
>
> Both statements need checking.

Which assessment is correct?

A. The first is overstated: only standalone Q Developer is retiring, not Q Developer in the console. The second is correct: existing Incident Manager customers keep it

B. Both statements are correct as given

C. Both statements are wrong

D. The first is correct and the second is wrong, because Incident Manager was removed entirely

◆ PAUSE AND DECIDE

Which assessment is correct?

A First overstated, second correct

Q Developer in the console is unaffected, so the blanket claim is wrong. Incident Manager closed to NEW customers only, so an existing configuration continues.

B Both correct

The Q Developer claim is too broad. Console and first-party Q Developer experiences continue unchanged.

C Both wrong

Overcorrecting. The Incident Manager statement is accurate: closed to new customers is not the same as withdrawn.

D Incident Manager removed entirely

It closed to new customers on 7 November 2025. Existing customers keep it, which is precisely what the colleague described.

THE SIGNAL

Both halves test precision about scope. Retiring is not the same as removed, and closed to new customers is not the same as gone.

The five things to carry forward

- **65 questions, 130 minutes, 150 dollars, no labs.** Widely misreported, and worth being certain about.
- **Containers, CDK, Terraform and Git are new scope.** C02-era material has no equivalent content.
- **Four features are closed to new customers** and still in the guide. Never propose them for new work.
- **Answer with the guide's name and current behaviour** for limits. Recognise both names for renamed services.
- **Over-engineering is a wrong answer**, and "measure before enforcing" is a design instinct AWS rewards.

> ON THE EXAM
>
> Next: confusion pairs - the services that look like each other, and the single question that separates each pair.

MODULE 34 · EXAM STRATEGY - ALL DOMAINS

Confusion Pairs

Sixty services that look like each other, and the one question that separates each pair.

DOMAIN Cross-cutting EXAM WEIGHT All MODULE 34 of 35

admin@sthithapragna.com

Every confusing pair reduces to **one question**. Find the question and you have the answer, without recalling the full comparison.

Monitoring and logging

PAIR	THE ONE QUESTION
Basic or detailed monitoring	Do you need one-minute EC2 metrics?
Standard or high resolution	Is the metric published more often than once a minute?
Average or percentile	Are you hiding a slow minority behind a healthy mean?
EMF or PutMetricData	Is the metric derived from something you are already logging?
Metric filter or Logs Insights	Forward-looking alarm, or backward-looking question?
Subscription filter or export to S3	Streaming continuously, or a bulk copy?

ON THE EXAM

The metric filter versus Logs Insights split is the most useful here. A filter creates a metric going forward; Logs Insights queries what is already stored.

Alarms, events and remediation

PAIR	THE ONE QUESTION
Missing as breaching or not breaching	Is silence a symptom, or is the resource simply idle?
Static threshold or anomaly detection	Do you know the right number, or only the normal shape?
Composite alarm or mute rule	Suppress by logic, or suppress by calendar?
Scheduled rule or EventBridge Scheduler	Do you need time zones, DST or a one-time schedule?
EventBridge or SNS	Route on event content, or fan out to subscribers?
Config remediation or EventBridge remediation	Drifted existing state, or a fresh event?

ON THE EXAM

Config finds things that were already wrong before the rule existed. EventBridge only ever sees what happens next. That is the whole distinction.

Systems Manager and operations

PAIR	THE ONE QUESTION
Run Command or State Manager	Once now, or continuously enforced?
Session Manager or EC2 Instance Connect	Do you need a fully logged, port-free session?
Parameter Store or Secrets Manager	Does it need automatic rotation?
Automation or Run Command	Acting on the AWS resource, or inside the operating system?
Patch policies or maintenance windows	Are you building patching new, or maintaining what exists?
Runbook or DevOps Agent	Is the cause known, or does it need investigating?

ON THE EXAM

Run Command versus State Manager is the same question as EventBridge versus Config: one acts once, the other keeps a state true.

Compute and storage performance

PAIR	THE ONE QUESTION
Standard or unlimited credit mode	Predictable bill, or predictable performance?
gp2 or gp3	Almost always gp3. Is there any reason not to?
gp3 or io2 Block Express	Above 80,000 IOPS, sub-millisecond, or five-nines durability?
Volume limit or instance limit	Did throughput halve about 30 minutes in?
Transfer Acceleration or DataSync	One distant client, or a file server's worth of data?
DAX or ElastiCache	Is the database DynamoDB, and must code changes be minimal?

ON THE EXAM

The volume-versus-instance row is not a service pair at all, but it is where storage performance questions are actually decided.

Databases and scaling

PAIR	THE ONE QUESTION
Multi-AZ or read replica	Availability, or read scale?
Multi-AZ instance or Multi-AZ cluster	Do you need the standbys to serve reads?
Provisioned Aurora or Aurora serverless	Is the load steady, or spiky and unpredictable?
DynamoDB on-demand or provisioned	Can you predict the load?
Node-based or serverless ElastiCache	Do you want control, or do you want it to just work?
Scale the database or add a cache	Do a few items dominate reads, and is staleness tolerable?

ON THE EXAM

Multi-AZ versus read replica is the single most confused pair in the RDS syllabus: availability versus scale, synchronous versus asynchronous, automatic versus manual.

Load balancing and traffic

PAIR	THE ONE QUESTION
ALB or NLB	Do you need HTTP routing, or static IPs and any protocol?
Target tracking or step scaling	Do different severities need different responses?
Evaluate target health or a health check	Is the record an alias to a load balancer?
502 or 503	Did a target answer badly, or was there no target?
503 or 504	Was there no target, or did it not answer in time?
Cross-zone on or off	ALB is always on and free. NLB is off and charged

ON THE EXAM

The error-code rows are the highest-value entries in this whole module. 502 answered badly, 503 nobody answered, 504 nobody answered in time.

Reliability and recovery

PAIR	THE ONE QUESTION
Pilot light or warm standby	Is anything running and serving in the second Region?
Automated backups or manual snapshots	Must it survive the instance being deleted?
Vault Lock governance or compliance	Does the requirement say "including the root user"?
Zonal shift or routing controls	One impaired Availability Zone, or a whole Region?
Cross-Region copy or cross-account copy	Defending against a Regional event, or a compromised account?
Warm pool or a better AMI	Is the boot time spent installing, or loading current data?

ON THE EXAM

"Including the root user" or "including administrators" is the discriminator for compliance mode, and it appears in Object Lock, Vault Lock and CloudTrail questions alike.

Deployment and provisioning

PAIR	THE ONE QUESTION
DeletionPolicy or UpdateReplacePolicy	Is the resource leaving the stack, or being replaced?
Ref or GetAtt	Do you want the default identifier, or a named attribute?
Nested stacks or cross-stack exports	Who owns the lifecycle: one team, or several?
Self-managed or service-managed StackSets	Must accounts created later be covered automatically?
CDK or plain CloudFormation	Does the infrastructure have real logic, or is the template the artefact?
Terraform or CloudFormation	Does it span providers, or is there an existing Terraform estate?

ON THE EXAM

DeletionPolicy and UpdateReplacePolicy is the most expensive pair in this table. Both default to Delete, and setting only one leaves a database unprotected.

Containers and deployment strategy

PAIR	THE ONE QUESTION
Task role or task execution role	Did it fail before your code ran?
ECS on EC2 or Fargate	Do you need specific instance types, or no hosts at all?
ECR basic or enhanced scanning	Must a clean result stay true as new CVEs appear?
IRSA or EKS Pod Identity	Both give a pod its own role. Is a per-cluster OIDC provider acceptable?
Immutable or blue/green	Does the old environment survive the switch?
Rolling or canary	Do you need a bake period before everyone is exposed?

ON THE EXAM

Task role versus execution role is decided by timing, not by memorising a list. Anything happening before your code runs belongs to the execution role.

Serverless and orchestration

PAIR	THE ONE QUESTION
Reserved or provisioned concurrency	Is the complaint throttling, or slow first requests?
Pool limit or scaling rate	Were you throttled with capacity still free?
Destinations or a DLQ	Do you need the request and response context?
Step Functions Standard or Express	Long and auditable, or short and high volume?
Step Functions or EventBridge Pipes	Orchestrating many steps, or connecting one source to one target?
S3 notifications or EventBridge	Do several consumers need overlapping filters?

ON THE EXAM

The second row is not a service pair. It is the Lambda behaviour almost nobody teaches: two independent limits, and only one of them is on the dashboard.

Identity and governance

PAIR	THE ONE QUESTION
Permissions boundary or SCP	Capping one identity, or every principal in an account?
SCP or RCP	Is the risk your people acting, or someone reaching your data?
Declarative policy or SCP	Enforcing a setting, or denying an action?
Identity Center or IAM users	Must leavers be deprovisioned everywhere at once?
RAM or a cross-account role	Sharing a thing, or sharing an identity?
Key policy or grant	Durable and declared, or temporary and programmatic?

ON THE EXAM

SCP versus RCP is the newest pair here and the most likely to appear. Ask who is acting: your engineers, or somebody outside reaching in.

Detection and encryption

PAIR	THE ONE QUESTION
Inspector or GuardDuty	A vulnerability that could be exploited, or activity happening now?
Macie or GuardDuty S3 Protection	What is inside the objects, or how they are accessed?
Config or CloudTrail	The resulting state, or the API call that caused it?
Hooks or Config rules	Block it before provisioning, or find it afterwards?
Parameter Store or Secrets Manager	Does it need automatic rotation?
SSE-S3 or SSE-KMS	Must key usage be auditable and the policy yours?

ON THE EXAM

Inspector finds the unlocked door; GuardDuty sees somebody walk through one. Macie reads the contents; GuardDuty watches the behaviour.

Networking

PAIR	THE ONE QUESTION
Security group or network ACL	Stateful or stateless. Is return traffic the problem?
Gateway or interface endpoint	Must on-premises reach it?
Peering or Transit Gateway	Two VPCs, or many plus hybrid?
PrivateLink or peering	Do the CIDR ranges overlap?
Direct Connect or VPN	Consistent and high volume, or fast to stand up?
Alias or CNAME	Is it the zone apex?

ON THE EXAM

PrivateLink versus peering is decided by one clause: overlapping CIDRs. PrivateLink does not route, so overlaps are irrelevant to it.

DNS and the edge

PAIR	THE ONE QUESTION
Geolocation or geoproximity	Where the user is, or how far from your sites?
Inbound or outbound Resolver endpoint	Which direction does the DNS query travel?
Latency or geolocation routing	Measured network performance, or the user's country?
CloudFront or Global Accelerator	Is the content cacheable HTTP?
CloudFront Functions or Lambda@Edge	Does it need to call something?
Shield Standard or Advanced	Do you need AWS specialists during an attack, and cost protection?

ON THE EXAM

CloudFront versus Global Accelerator is the most reliably examined pair in Domain 5. Global Accelerator is not a cache, and it handles any protocol.

Three-way confusions

TRIO	HOW TO SPLIT THEM
CloudTrail, Config, CloudWatch	Who did it. What it looks like now. How it is performing
SQS, SNS, EventBridge	Decouple in time. Decouple in number. Decouple in content
Reachability Analyzer, Network Access Analyzer, flow logs	This path? All paths? What actually flowed?
Preventive, detective, corrective	A Hook blocks it. Config finds it. Automation fixes it
Inspector, GuardDuty, Macie	Vulnerability. Behaviour. Data contents
ASG, target group, Route 53 health checks	Replace it. Stop sending to it. Stop resolving to it

ON THE EXAM

The last row catches more people than any pair in this module. Three services use the phrase health check for three different verbs.

One word, different meanings

WORD	WHAT IT MEANS WHERE
Health check	Replace an instance, stop routing to a target, or change a DNS answer
Endpoint	A VPC endpoint, a Resolver endpoint, a service URL, or a PrivateLink service
Policy	IAM policy, key policy, stack policy, scaling policy, backup policy, RCP
Grant	A KMS grant, or an IAM Allow. Only one is temporary and programmatic
Warm	Warm pool, warm standby, warm throughput. Three unrelated ideas
Rotation	KMS key material, a Secrets Manager credential, or log rotation

ON THE EXAM

When a question uses one of these words, read the surrounding sentence for which meaning applies. The word alone tells you nothing.

Pairs where the answer is both

- **Multi-AZ and read replicas.** Availability and read scale are different requirements, and most production databases need both.
- **Predictive and target tracking scaling.** Predictive only scales out, so target tracking handles scale-in and surprises.
- **Direct Connect and VPN.** The standard design is Direct Connect primary with a VPN as automatic backup.
- **Inspector and GuardDuty.** One finds weaknesses, the other finds activity, and GuardDuty's newer findings use Inspector's context.

> ON THE EXAM
>
> A question forcing a choice between these usually adds a constraint that rules one out. Without such a constraint, treat "both" as the honest answer.

Pairs where the newer option is now the default

- **OAC over OAI. Launch templates over launch configurations. ADOT over the X-Ray SDK.**
- **gp3 over gp2. Instance refresh over AutoScalingRollingUpdate. ECS-native blue/green over CodeDeploy.**
- **Identity Center over IAM users. Destinations over Lambda DLQs. Valkey over Redis OSS** for new ElastiCache deployments.
- In each case the older option still works and still appears in answer options. It is the dated answer, not an incorrect one.

> ON THE EXAM
>
> These are the pairs where an option can be technically workable and still wrong. The question is usually which is recommended, not which is possible.

> A question describes an application where server-side metrics are healthy, the load balancer reports normal latency, and a small group of users in one country report slowness. It asks how to determine what those users experienced.
>
> The options include CloudWatch Synthetics, CloudWatch RUM, X-Ray, and detailed monitoring.

Which pair is being tested, and what decides it?

A Synthetics or RUM: does the answer need real users, or robots on a schedule?

B X-Ray or Application Signals: one request, or one service over time?

C Basic or detailed monitoring: is one-minute granularity needed?

D Static threshold or anomaly detection

◆ PAUSE AND DECIDE

Which pair is being tested, and what decides it?

A Synthetics or RUM

The question asks what real users experienced. Synthetics runs robots from AWS; only RUM reports actual browsers, by geography and device.

B X-Ray or Application Signals

Both stop at the server, and every server-side measurement is stated as healthy. Neither can see the client side.

C Basic or detailed monitoring

Changes how often EC2 metrics are collected. More frequent healthy metrics are still healthy metrics.

D Threshold or anomaly detection

About how an alarm decides to fire. Nothing here concerns alarm configuration.

THE SIGNAL

Healthy server, unhappy users is the gap only RUM measures. Recognising which pair a question is testing is often faster than evaluating four services.

> A question requires that seven years of records must not be deletable by anyone in the company, for the full retention period. That explicitly includes administrators and the root user.
>
> Options include Object Lock governance mode, Object Lock compliance mode, MFA delete, and a restrictive bucket policy.

What decides this?

A The phrase "including the root user" eliminates every control a privileged user can reverse

B The seven-year duration, which only compliance mode supports

C Whether versioning is already enabled on the bucket

D Whether the records are encrypted

◆ PAUSE AND DECIDE

What decides this?

A "Including the root user"

Governance mode, MFA delete and a bucket policy can all be reversed by someone with sufficient privilege. Compliance mode cannot, by anyone.

B The seven-year duration

Governance mode supports any retention period too. Duration is not what separates the two modes.

C Versioning enabled

A prerequisite for Object Lock in either mode, so it cannot discriminate between them.

D Encryption

Unrelated. Encryption controls who can read the data, not who can delete it.

THE SIGNAL

That phrase is the discriminator in Object Lock, Vault Lock and CloudTrail questions alike. It always eliminates the reversible option.

> A question describes an Auto Scaling group behind a load balancer where instances launch, are marked unhealthy, are terminated and replaced, repeatedly. The application takes several minutes to start.
>
> Options mention health check grace period, instance warm-up, cooldown, and deregistration delay.

Which timer is being tested?

A The health check grace period, because it governs when health checks may judge a new instance

B The instance warm-up, because it governs when a new instance counts

C The cooldown, because it governs the gap between scaling activities

D The deregistration delay, because it governs draining

◆ PAUSE AND DECIDE

Which timer is being tested?

A Health check grace period

It is the only timer that decides when health checks may terminate a new instance. Set below start-up time, it creates a permanent replacement loop.

B Instance warm-up

The closest distractor. Warm-up excludes a booting instance from scaling metrics; it never causes or prevents a termination.

C Cooldown

Pauses further scaling activity after one completes. It has no bearing on health evaluation.

D Deregistration delay

Governs how long a removed target keeps draining. It applies on the way out, not on the way in.

THE SIGNAL

Four timers, and only one can terminate an instance. Warm-up hides metrics, cooldown blocks scaling, deregistration delay drains connections.

> A question describes two VPCs in different accounts that must exchange traffic for one specific API. Both use the 10.0.0.0/16 range. The provider must expose only that API and nothing else.
>
> Options include VPC peering, Transit Gateway, PrivateLink, and a shared VPC via RAM.

What single clause decides this?

A The overlapping CIDR ranges, which eliminate every routing-based option

B The different accounts, since peering does not work across accounts

C The number of VPCs, since two VPCs always means peering

D The requirement to expose one API, since only Transit Gateway can scope traffic

◆ PAUSE AND DECIDE

What single clause decides this?

A Overlapping CIDRs

Peering, Transit Gateway and shared VPCs all build routes, and routes cannot exist between two networks using the same addresses. PrivateLink does not route.

B Different accounts

Peering works across accounts perfectly well. That clause eliminates nothing.

C Two VPCs means peering

A reasonable default that the overlapping ranges override completely. Never apply the default before checking the constraints.

D Exposing one API

A genuine reason to prefer PrivateLink, and it is the second reason here. The overlap eliminates the alternatives outright.

THE SIGNAL

One clause can eliminate three options at once. Scanning for the disqualifying constraint is faster than evaluating each option in turn.

> A question describes needing to know both which resources are shared outside the organisation, and which IAM roles have gone unused for 90 days. Both answers must cover all accounts.
>
> Options offer one organisation-level analyzer, two separate analyzers, credential reports, and Config rules.

What is being tested?

A That IAM Access Analyzer is three separate analyzer types, each created explicitly

B That credential reports cover roles as well as users

C That Config rules can compute unused access

D That external access findings require Security Hub

◆ PAUSE AND DECIDE

What is being tested?

A Three separate analyzers

External access, unused access and internal access are distinct analyzers. Creating one produces none of the others' findings.

B Credential reports cover roles

They cover users and their credentials, per account. Roles and organisation-wide coverage are both outside their scope.

C Config computes unused access

Config evaluates resource configuration against rules. It does not analyse access patterns or compute what went unused.

D Security Hub required

Invented dependency. Access Analyzer produces findings independently, and external access analysis carries no additional charge.

THE SIGNAL

One service name covering several distinct products is its own confusion category, alongside Security Hub CSPM and the three CloudWatch network monitors.

> A question describes an application that must be updated with no capacity reduction. It must pause for review partway through, and reverse automatically if error rates rise. It runs on an Auto Scaling group defined in CloudFormation.
>
> Options mention rolling updates, instance refresh, blue/green, and canary.

What should you recognise here?

A That instance refresh becomes rolling, immutable or canary depending purely on configuration

B That blue/green is always the safest deployment strategy

C That rolling updates cannot maintain capacity under any configuration

D That canary deployments require a load balancer

◆ PAUSE AND DECIDE

What should you recognise here?

A One feature, three strategies by configuration

MinHealthyPercentage 100 keeps capacity, checkpoints give the review pause, and an alarm specification gives automatic reversal. Three requirements, one feature.

B Blue/green is always safest

Over-engineering, which this course has repeatedly shown is a wrong answer rather than a safe one. It also costs a second full environment.

C Rolling can never maintain capacity

Too absolute. Rolling with an additional batch maintains capacity, and instance refresh at 100 percent launches before terminating.

D Canary needs a load balancer

True for traffic-weighted canaries. Instance refresh checkpoints give a canary at the instance level with no traffic splitting.

THE SIGNAL

Not every question is a choice between services. Sometimes one feature answers all the requirements, and the skill is recognising that.

> A question describes a fleet where a configuration file must be present and correct on every instance, including instances launched next month. It must be corrected automatically if someone edits it.
>
> Options include Run Command, State Manager, an Automation runbook, and a Config rule with remediation.

Which discriminator applies?

A. Once now versus continuously enforced, which is Run Command versus State Manager

B. Inside the OS versus on the AWS resource, which is Run Command versus Automation

C. Preventive versus detective, which is Hooks versus Config

D. Known cause versus unknown cause, which is runbook versus DevOps Agent

◆ PAUSE AND DECIDE

Which discriminator applies?

A Once now versus continuously enforced

Two clauses demand continuous enforcement: instances launched later must be covered, and drift must be corrected. That is State Manager, not Run Command.

B Inside the OS versus AWS resource

A real discriminator, and it separates Run Command from Automation. Both act once, so it does not address the continuous requirement.

C Preventive versus detective

Applies to Hooks and Config rules. A Config rule with remediation could work, and it evaluates state rather than enforcing a file's contents.

D Known versus unknown cause

Separates a runbook from an investigation. Nothing here is being investigated; the desired state is already known.

THE SIGNAL

Two clauses point the same way: future instances, and automatic correction. Either alone would suggest continuous enforcement; together they settle it.

> A question describes a Lambda function behind API Gateway that returns throttling errors during a traffic spike. CloudWatch shows concurrency peaked at 280 against an account limit of 1,000, with no other function busy.
>
> Options include raising the account quota, reserved concurrency, provisioned concurrency, and accepting the scaling rate.

Which discriminator applies?

A. Pool limit versus scaling rate: were you throttled with capacity still free?

B. Reserved versus provisioned concurrency: throttling or slow first requests?

C. Synchronous versus asynchronous invocation

D. Destinations versus a dead-letter queue

◆ PAUSE AND DECIDE

Which discriminator applies?

A Pool limit versus scaling rate

280 of 1,000 with nothing else running means the pool was 72 percent free. Only the scaling rate explains throttling with capacity available.

B Reserved versus provisioned

The right discriminator for a different question. Neither raises the rate at which new execution environments are created.

C Sync versus async

Decides retry behaviour on failure. The failure here is throttling at admission, not an error after invocation.

D Destinations versus DLQ

Both handle failed asynchronous events. This function is invoked synchronously through API Gateway.

THE SIGNAL

The numbers are the whole question. Two limits exist, only one appears on the dashboard, and the gap between them is where this failure lives.

> A question describes users behind a load balancer who connect successfully and then see the connection hang. A custom network ACL was recently applied to the subnet. Security groups permit all outbound traffic.
>
> Options include the security group, the NACL's ephemeral range, the idle timeout, and the deregistration delay.

Which discriminator applies?

A Stateful versus stateless: is return traffic the problem?

B 502 versus 504: did a target answer badly, or not in time?

C Cross-zone on or off

D Evaluate target health versus a separate health check

◆ PAUSE AND DECIDE

Which discriminator applies?

A Stateful versus stateless

Connects then hangs is the stateless signature. A NACL evaluates the response separately, and it leaves on the client's ephemeral port.

B 502 versus 504

Useful when a status code is quoted. None is here, and the symptom described is a hang rather than a returned error.

C Cross-zone

Produces uneven load across zones, not a hang. It also does not interact with NACLs.

D Evaluate target health

Concerns Route 53 alias records. Nothing in the scenario involves DNS.

THE SIGNAL

"A custom NACL was recently applied" plus "connects then hangs" is the pairing. Either detail alone is suggestive; together they are conclusive.

The five things to carry forward

- **Find the one question.** Every pair reduces to a single discriminating property, and the question gets you there faster than the comparison.
- **Trios are harder than pairs.** Health check means replace it, stop sending to it, or stop resolving to it.
- **One word, several meanings.** Endpoint, policy, grant, warm and rotation all mean different things in different places.
- **Scan for the disqualifying clause first.** One constraint often eliminates three options at once.
- **Sometimes the answer is both, and sometimes it is one feature.** Not every question is a choice between services.

> ON THE EXAM
>
> Next, and last: exam mechanics - reading the question, the qualifier words, and managing 130 minutes.

MODULE 35 · EXAM STRATEGY - ALL DOMAINS

Exam Mechanics

Reading the question, the qualifier words, the eight distractor patterns, and 130 minutes.

DOMAIN Cross-cutting EXAM WEIGHT All MODULE 35 of 35

admin@sthithapragna.com

The question tells you which answer it wants. The **qualifier** is an instruction, not decoration, and several options are usually technically correct.

The anatomy of a question

- **The scenario** sets the situation and, crucially, contains the **constraints** that eliminate options.
- **The stem** asks the question, and carries the **qualifier**: most cost-effective, least operational overhead, fastest.
- **The options** are usually four, of which one or two are wrong outright and the rest are plausible.
- Read the **stem before the options**. Reading options first makes you evaluate each against the scenario rather than against the requirement.

> ON THE EXAM
>
> Read the last sentence of the scenario twice. The constraint that decides the question is very often the final clause before the stem.

The qualifier words

QUALIFIER	WHAT IT ELIMINATES
MOST cost-effective	Options that work but cost more. All of them may be correct
LEAST operational overhead	Anything you build, run or maintain yourself
MOST secure	Anything a privileged user can reverse, or that widens access
FASTEST to implement	Anything requiring procurement, provisioning or a migration
MINIMUM changes to the application	Anything requiring a rewrite. Favours transparent mechanisms
Without downtime	Anything replacing a resource, or requiring a restart
MOST resilient	Single-AZ, single-Region, and single-instance answers

ON THE EXAM

Least operational overhead is the most common qualifier on this exam, and it consistently favours managed services over anything custom.

Multiple response questions

- **Choose TWO** or **Choose THREE** tells you exactly how many. Selecting a different number is marked wrong.
- **There is no partial credit.** Two of three correct scores the same as none.
- They frequently pair an **immediate mitigation** with a **structural fix**, or address **two stated stakeholders**.
- If you are confident about one answer, use it to narrow the rest: the second answer usually addresses a **different** part of the requirement.

> ON THE EXAM
>
> Module 13's scenario 2 is the shape: the business wants it working today, engineering wants no long-lived HTTP requests. Two needs, two answers.

The eight distractor patterns

PATTERN	HOW IT LOOKS
The failed experiment	The scenario says they already tried it, and it did not work
Over-engineering	More robust than required, and more expensive. Correct, and wrong
The dated recommendation	Was best practice, and AWS changed something
The overcorrection	Applies a real fact too broadly
Works, but costs more	Technically achieves it, with extra components or charges
Solves half	Answers one of two stated requirements
Invented behaviour	States a limitation or requirement that does not exist
The absolute	Contains never, always, cannot, or only. Usually too strong

ON THE EXAM

This course used all eight deliberately, roughly 150 times. Recognising the pattern is often faster than evaluating the technical claim.

The failed experiment, and over-engineering

- **The failed experiment:** when a scenario states they already tried something, that thing is not the answer, and it is usually a strong hint about the real cause.
- "They increased capacity to 30,000 and it did not help" tells you the constraint is not capacity. That is evidence, not background.
- **Over-engineering:** exceeding an agreed target is not a safer answer, it is a more expensive one.
- If the scenario states an RTO of 24 hours, an answer delivering 5 minutes at ten times the cost is wrong.

> ON THE EXAM
>
> Both patterns exploit the same instinct: doing more feels safer. On this exam, doing exactly what was asked is the correct answer.

The dated recommendation, and the overcorrection

- **The dated recommendation** is often voiced by a character: a colleague, an architect, or a runbook. That framing is the signal.
- This course used it five times: Incident Manager, ARC readiness check, Terraform's DynamoDB lock, CodeDeploy for ECS, and Origin Access Identity.
- **The overcorrection** is the mirror error: knowing CloudTrail Lake closed and concluding CloudTrail closed.
- Closed to new customers is not withdrawn. Retiring a product is not retiring every feature bearing its name.

> ON THE EXAM
>
> When a scenario quotes somebody's recommendation, treat the quote as a hypothesis to test, not as context to accept.

Works but costs more, and solves half

- **Works but costs more:** the option achieves the outcome by adding a component that something already present does natively.
- An ALB in front of a Lambda that API Gateway already fronts. A second NAT gateway when a free endpoint removes the traffic.
- **Solves half:** the scenario states two requirements, and each of two options answers exactly one.
- The word **separately**, or a sentence beginning **they also need**, is usually announcing the second requirement.

> ON THE EXAM
>
> Count the requirements before you read the options. If there are two, an option answering one of them is a distractor by construction.

Invented behaviour, and absolutes

- **Invented behaviour** states a limitation or dependency that does not exist: "failover routing requires a calculated health check".
- These are usually the easiest to eliminate, because the claim sounds oddly specific and you have never met it.
- **Absolutes** contain never, always, cannot or only. Sometimes an absolute is true, so check rather than eliminating reflexively.
- True absolutes on this exam: a CNAME cannot exist at the zone apex; an explicit Deny always wins; a subnet cannot span AZs.

> ON THE EXAM
>
> "Security group references never work across VPCs" is too strong and is wrong. "An explicit Deny always wins" is absolute and is true. Read each one.

Working an option list

- **1. Count the requirements** in the scenario, and note the qualifier in the stem.
- **2. Scan for the disqualifying clause**: overlapping CIDRs, no public IP, must survive deletion. One clause often removes three options.
- **3. Eliminate what does not work at all**, which is usually one or two options.
- **4. Apply the qualifier** to what remains. This is the step people skip, and it is where the mark is.

> ON THE EXAM
>
> If two options survive and both work, you have not applied the qualifier. Go back to the stem rather than choosing between them on instinct.

The arithmetic of 130 minutes

- **65 questions in 130 minutes is exactly two minutes each.** Most take under one, and a few take four.
- A useful checkpoint: you should be at **question 33 by the 65-minute mark**. If you are behind, start flagging sooner.
- **Never spend more than three minutes** on a question on the first pass. Flag it, choose something, and move.
- Always **record an answer before flagging**. An unanswered flagged question you run out of time on scores zero; a guess does not.

> ON THE EXAM
>
> There is no negative marking. An unanswered question is a guaranteed zero, and a guess between two survivors is a coin flip you are ahead on.

Flagging, and the review pass

- Flag anything where you eliminated to two and guessed, or where a term was unfamiliar.
- **Do not flag questions you answered confidently.** A review pass of thirty flags is not a review pass.
- Later questions sometimes **remind you of something** that unlocks an earlier one. That is the main value of reviewing.
- **Change an answer only with a reason.** A remembered fact is a reason. A feeling that the other one looks better is not.

> ON THE EXAM
>
> Most changed answers on a review pass are changed from right to wrong. Change when you can name what you now know that you did not before.

Scoring, and what it means for strategy

- **15 of the 65 questions are unscored** and are not marked as such. A bizarre question may simply be one of them.
- **Scoring is compensatory.** You need 720 overall, and there is **no minimum per domain**.
- So a weak area does not fail you. Strength elsewhere genuinely compensates, which is why breadth beats depth here.
- The scaled score runs 100 to 1000, so **720 is not 72 per cent**. Do not try to convert it while sitting there.

> ON THE EXAM
>
> Two questions in a row that feel unreasonably obscure is not a signal about your preparation. Roughly one question in four is unscored.

When you genuinely do not know

- **Eliminate on principle rather than fact.** Over-engineered, invented behaviour, or an absolute you doubt: those go first.
- **Prefer the managed service** over the thing you build, unless the question rewards control.
- **Prefer the answer that changes least.** AWS questions rarely reward rebuilding when a setting exists.
- **Prefer the newer mechanism** where you recognise both, since the exam tracks AWS's own recommendations.

> ON THE EXAM
>
> These heuristics are not guesses. They encode how AWS writes questions, and they will beat a coin flip reliably.

The week before

- **Re-watch module 33.** It is the highest density of things other material will have taught you wrongly.
- **Drill module 34.** The discriminating questions are what you want available instantly, not the full comparisons.
- Take the practice exams **timed**, and review every question you got right for the wrong reason as carefully as the ones you missed.
- Do not learn new services in the final week. Consolidate what you have; a half-known service is a distractor you will fall for.

> ON THE EXAM
>
> The most valuable revision is the questions you answered correctly by luck. They are the ones that will not repeat.

The day itself

- **130 minutes is enough** if you keep moving. Nobody fails this exam for lack of time; people fail it by over-thinking twelve questions.
- Read the **last sentence of every scenario twice**. The deciding constraint is very often there.
- When two options survive, **go back to the qualifier** rather than choosing between them on feel.
- You get a **pass or fail indication at the end**, with the detailed score report following within a few working days.

> ON THE EXAM
>
> The single highest-value habit in this module: read the stem before the options, and read the last sentence of the scenario twice.

A question describes a team needing to reduce EC2 costs. Four options are given: buy Reserved Instances, move to Graviton, right-size using Compute Optimizer, and migrate to Spot. The stem asks for the approach with the LEAST operational overhead.

All four options would genuinely reduce cost.

How should the qualifier be used?

A It selects between four working options by which requires the least ongoing management, not by which saves most

B It means choose the cheapest option regardless of effort

C It is decoration; pick the largest saving

D It means eliminate any option that is not managed by AWS

◆ PAUSE AND DECIDE

How should the qualifier be used?

A Selects by ongoing management

The scenario states all four reduce cost. The qualifier is therefore the only thing distinguishing them, and it asks about effort, not savings.

B Means cheapest

Conflates two different qualifiers. Most cost-effective and least operational overhead frequently point at different answers.

C Decoration

The premise of this whole module. When several options work, the qualifier is the entire question.

D Eliminate anything unmanaged

Close, and too crude. Spot is fully managed and carries high operational overhead because of interruption handling.

THE SIGNAL

Option D is the instructive near miss: managed and low-overhead are not the same thing. Spot is managed and demands constant handling.

> A question describes a database that is throttling. It notes that the team already doubled the provisioned capacity last month with no improvement. Two of the four options propose increasing capacity further, by different means.
>
> The stem asks for the root cause and the fix.

What does the second sentence tell you?

A. It is evidence that the constraint is not total capacity, which eliminates both capacity-increasing options

B. It is background detail explaining the team's frustration

C. It suggests the previous increase was too small

D. It means the answer must be a different service entirely

◆ PAUSE AND DECIDE

What does the second sentence tell you?

A Evidence that eliminates two options

A stated failed experiment is data. It removes both options that repeat it, halving the list before you evaluate anything technical.

B Background detail

AWS questions rarely include a sentence with no function. Detail about something already attempted is almost always there to eliminate options.

C The increase was too small

Doubling and seeing no change at all points at a different kind of limit, not an insufficient one.

D Must be a different service

Over-reads it. The fix is usually a different setting or design in the same service, such as a partition key or an index.

THE SIGNAL

Two options can be eliminated before any AWS knowledge is applied. That is what the failed-experiment pattern gives you.

> A question presents four options. One says a feature 'cannot be used across accounts'. Another says a service 'always encrypts data in transit by default'. You are unsure about both claims.
>
> The other two options describe mechanisms you recognise.

How should you treat the two absolute statements?

A. Treat each as a claim to test. Some absolutes are true, so check rather than eliminating both reflexively

B. Eliminate both, because absolutes are always distractors

C. Prefer both, because specific claims signal the correct answer

D. Ignore them and choose between the other two

◆ PAUSE AND DECIDE

How should you treat the two absolute statements?

A Test each claim

Most absolutes are too strong, and several on this exam are true: a CNAME cannot exist at the apex, an explicit Deny always wins, Direct Connect is not encrypted by default.

B Eliminate both

The rule of thumb, applied without judgement. It would have you eliminate several correct answers this course has taught.

C Prefer both

Inverts the heuristic. Specificity is not evidence of correctness; invented behaviour is often very specific.

D Ignore them

Discards two of four options without evaluation, which is guessing with extra steps.

THE SIGNAL

Note that option B is itself an absolute. Rules of thumb are useful and are not laws, and this exam rewards judgement over reflex.

> With 20 minutes remaining you have 8 questions unanswered and 11 flagged for review. Three of the unanswered ones are long scenarios you skipped.
>
> You are unsure how to spend the remaining time.

What is the best use of the last 20 minutes?

A Answer all 8 unanswered questions first, even by elimination, then review flags with whatever remains

B Work carefully through the three long scenarios, since they carry the most detail

C Review all 11 flagged questions, since you have partial knowledge of those

D Divide the time evenly between unanswered and flagged questions

◆ PAUSE AND DECIDE

What is the best use of the last 20 minutes?

A Answer the unanswered first

An unanswered question is a guaranteed zero. A flagged one already has an answer, so reviewing it can gain a mark or lose one.

B The three long scenarios

Spends most of the remaining time on three questions while five others stay at zero. Length does not correlate with marks.

C Review the flags

Reviewing an answered question has an uncertain payoff in both directions. Answering an unanswered one has a strictly positive expected value.

D Split evenly

Feels balanced and ignores that the two activities have very different expected returns.

THE SIGNAL

There is no negative marking, so an unanswered question is the only thing on the paper with a guaranteed value of zero. Fix those first.

> A question asks for the MOST cost-effective way to reduce a large NAT gateway bill. Most traffic goes to S3 in the same Region. Two options work: a gateway endpoint for S3, and moving the workload to a public subnet with public IPs.
>
> Both would remove the NAT gateway data processing charge.

Which wins, and why?

A The gateway endpoint: it is free, requires no architectural change, and does not expose instances

B The public subnet, since removing the NAT gateway entirely saves the hourly charge too

C Either, since the qualifier only concerns cost

D Neither, since the qualifier requires the cheapest possible answer regardless of security

◆ PAUSE AND DECIDE

Which wins, and why?

A The gateway endpoint

Free, no architectural change, and instances stay private. Cost-effective means good value, not lowest possible cost at any other price.

B Public subnet

The trap. It does remove the hourly charge, and public IPv4 addresses are charged per hour each, and every instance becomes internet-reachable.

C Either

Two options are rarely equally correct on this exam. The qualifier exists to separate them.

D Neither

Misreads cost-effective as cheapest at any cost. AWS never rewards an answer that trades security for a saving.

THE SIGNAL

Cost-effective is not the same as cheapest. An option that saves money by weakening security is a wrong answer on this exam, every time.

The five things to carry forward

- **The qualifier is the instruction.** If two options both work, you have not applied it yet.
- **Count the requirements, then scan for the disqualifying clause.** One constraint often removes three options.
- **A stated failed experiment is evidence**, and it eliminates every option that repeats it.
- **Answer everything.** No negative marking means an unanswered question is the only guaranteed zero.
- **Cost-effective is not cheapest**, and over-engineering is not safe. Do exactly what was asked.

> ON THE EXAM
>
> That completes the teaching. Next: four practice exams, worked the same way, so you can drill everything in this module.

MODULE 36 · EXAM STRATEGY - ALL DOMAINS

Practice Exam 1

Twenty questions, weighted by domain, worked in full. Take it under time.

QUESTIONS 20 SUGGESTED TIME 40 minutes PASS GUIDE 14 of 20

admin@sthithapragna.com

Before you start

- **Set a timer for 40 minutes.** Twenty questions at two minutes each is the real exam's pace, and pace is a skill worth practising.
- **Write your answers down** before watching the workings. Deciding is worth several times more than recognising.
- Each question pauses for nine seconds. **Pause it properly** if you need longer, and note anything you guessed.
- **14 of 20 is a reasonable pass indication.** It is not the real scaled score, which is compensatory and calculated differently.

> ON THE EXAM
>
> Mark the questions you guessed even when you got them right. Those are the ones to revisit, because luck does not repeat on the day.

An operations team must alarm when available memory on a fleet of EC2 instances falls below 10 percent. CloudWatch shows CPU, network and disk metrics for the instances but no memory metric of any kind.

The instances have an instance profile and are managed by Systems Manager.

What must the team do first?

A Enable detailed monitoring on the instances

B Install and configure the CloudWatch agent to publish memory metrics

C Create a metric filter on the instances' system logs

D Enable high-resolution metrics on the default EC2 namespace

◆ PAUSE AND DECIDE

What must the team do first?

A **Detailed monitoring**

Changes the interval from five minutes to one for metrics that already exist. It cannot create a metric the hypervisor cannot observe.

B **Install the CloudWatch agent**

EC2 metrics come from the hypervisor, which cannot see inside the guest. Memory and disk space usage require the agent.

C **Metric filter on system logs**

Would work only if something were already writing memory figures to a log group. Nothing here suggests that.

D **High-resolution EC2 metrics**

Resolution and existence are different axes. A metric that is not published cannot be published more often.

THE SIGNAL

Resolution, interval and existence are three different things. If a metric does not exist, no setting will summon it.

> An alarm on a batch processing queue is configured to fire when a custom metric exceeds a threshold. The metric is published only while the batch job runs, roughly twice a day. The alarm spends most of its time in INSUFFICIENT_DATA and occasionally fires spuriously overnight.
>
> The team wants the alarm to reflect only the periods when the job is actually running.

What should the team configure?

A Treat missing data as breaching

B Reduce the evaluation period to one minute

C Switch the alarm to anomaly detection

D Treat missing data as missing, so gaps neither trigger nor clear the alarm

◆ PAUSE AND DECIDE

What should the team configure?

A Missing as breaching

Would make the alarm fire whenever the job is not running, which is most of the day. That is the opposite of the requirement.

B Shorter period

Evaluates the same absent data more often. A shorter period on a metric that is not being published changes nothing.

C Anomaly detection

Learns a normal band from history. A metric absent for twenty-two hours a day gives it almost nothing to learn from.

D Missing as missing

Gaps are ignored entirely: they neither trigger nor clear the alarm, so its state reflects only the periods when data exists.

THE SIGNAL

Four missing-data treatments exist because silence means different things. Here silence means idle, so it should mean nothing at all.

> A security team must be alerted within minutes whenever anyone calls DeleteTrail in any account. They also need to answer, on demand, how many times a particular API was called by a specific role over the last month.
>
> CloudTrail delivers to a CloudWatch log group and to S3.

Which combination meets both requirements?

A. A metric filter with an alarm for the alerting, and Logs Insights or Athena for the on-demand question

B. Logs Insights queries on a schedule for both

C. A subscription filter to Lambda for both

D. CloudTrail Insights for both

◆ PAUSE AND DECIDE

Which combination meets both requirements?

A Metric filter plus a query tool

Two requirements with opposite shapes: forward-looking alerting is a metric filter and alarm; a backward-looking question is a query over stored data.

B Scheduled queries for both

Queries answer the second requirement well. Polling on a schedule is a poor alerting mechanism and adds latency and cost.

C Subscription filter for both

Streams matching events to a consumer, which could alert. It does not answer historical questions about data already stored.

D CloudTrail Insights

Detects unusual rates of API activity. It is not a targeted alert on a specific call, nor an ad hoc query tool.

THE SIGNAL

A metric filter is forward-looking and creates a metric from events as they arrive. Logs Insights is backward-looking and queries what is already stored.

> An engineer cannot connect to an EC2 instance in a private subnet using Session Manager. The instance appears in the EC2 console as running, has the SSM agent installed and a suitable instance profile attached, but does not appear as a managed node in Systems Manager.
>
> The subnet has no route to a NAT gateway or internet gateway.

What is the most likely cause?

A The instance profile lacks ssm:StartSession

B Session Manager requires inbound port 22 to be open

C The instance has no network path to the Systems Manager endpoints, and needs interface endpoints for ssm, ssmmessages and ec2messages

D The SSM agent version is too old to support Session Manager

◆ PAUSE AND DECIDE

What is the most likely cause?

A Missing ssm:StartSession

That permission belongs to the human starting the session, not to the instance profile. It also would not stop the node registering.

B Needs inbound 22

Confidently wrong, and the opposite of the point. Session Manager requires no inbound ports at all, which is why it replaces bastions.

C No network path to the SSM endpoints

Registration requires three prerequisites: agent, permissions, and a network path. Two are stated as present and the third is explicitly absent.

D Agent too old

Possible in principle, and the scenario supplies a much more specific cause. A stated absent route beats a speculative version problem.

THE SIGNAL

Three prerequisites: agent, permissions, network path. The scenario confirms two and then rules out the third in its final sentence.

> A data processing job on an m6i.4xlarge reads from a 6 TiB gp3 volume, provisioned at 50,000 IOPS and 1,000 MiB/s. For the first half hour of each run it achieves close to 1,000 MiB/s. It then settles at roughly half that, for the remaining hours.
>
> The volume's BurstBalance metric reports no data.

What is the cause?

A The gp3 volume's burst credits are exhausted

B The provisioned throughput exceeds what a 6 TiB volume supports

C The file system needs a larger block size

D The instance's EBS bandwidth burst has expired, dropping it to its sustained baseline

◆ PAUSE AND DECIDE

What is the cause?

A gp3 burst credits

gp3 has no burst mechanism at all, which is exactly why BurstBalance reports no data. That absence disproves this option.

B Throughput exceeds the volume

A 6 TiB gp3 volume comfortably supports 1,000 MiB/s, and the run achieves it for the first half hour, which proves the volume can deliver it.

C Block size

Might improve efficiency generally. It would not produce a clean halving exactly half an hour into every run.

D Instance EBS burst expired

Smaller instance sizes hold their maximum EBS bandwidth for around 30 minutes in 24 hours, then drop to roughly half. Both the timing and the ratio match.

THE SIGNAL

Two numbers point at the instance: about 30 minutes, and about half. The missing BurstBalance metric independently rules out the volume.

A newly deployed Auto Scaling group behind an ALB never reaches its desired capacity. Instances launch, are marked unhealthy after about two minutes, are terminated, and are replaced. The application takes around five minutes to start and pass its health check.

The group uses ELB health checks.

What should be changed?

A Increase the health check grace period beyond the application's start-up time

B Increase the instance warm-up to 300 seconds

C Switch the group to EC2 health checks

D Increase the target group's unhealthy threshold

◆ PAUSE AND DECIDE

What should be changed?

A Increase the grace period

The grace period is precisely how long after launch before health checks may terminate an instance. Set below start-up time, it condemns every instance.

B Instance warm-up

Warm-up excludes a booting instance from the group's scaling metrics. It never prevents a termination, which is what is happening here.

C EC2 health checks

Stops the loop by no longer checking whether the application serves traffic. It fixes the symptom by removing the monitoring.

D Unhealthy threshold

Delays the verdict by a few checks. Against a three-minute gap between judgement and readiness, that is not enough.

THE SIGNAL

Launch, terminate, repeat, forever, has exactly one cause. Only one of the four timers offered can terminate an instance at all.

> Users of an application behind an Application Load Balancer intermittently receive HTTP 504 responses. The targets are registered and healthy, and the application logs show the affected requests completing successfully after about 75 seconds.
>
> The business confirms these requests legitimately take that long.

What is the immediate cause?

A. No healthy targets are registered in the target group

B. The targets are returning malformed responses

C. The ALB's idle timeout, which defaults to 60 seconds, is shorter than the request duration

D. The deregistration delay is too short

◆ PAUSE AND DECIDE

What is the immediate cause?

A **No healthy targets**

That produces 503, not 504, and the scenario states the targets are registered and healthy.

B **Malformed responses**

That produces 502. The logs show requests completing successfully, so the response is well formed, merely late.

C **Idle timeout shorter than the request**

504 means the target did not respond in time. The default 60-second idle timeout against a 75-second request produces exactly this.

D **Deregistration delay**

Governs how long a removed target keeps draining connections. It has no bearing on the timeout of a live request.

THE SIGNAL

502 means someone answered badly. 503 means nobody answered. 504 means nobody answered in time. That sentence separates all three.

> An Aurora PostgreSQL cluster runs a single writer instance with no reader instances. During an Availability Zone failure the database was unavailable for several minutes. The team is confused, because Aurora stores six copies of the data across three Availability Zones.
>
> They require recovery within one minute.

What should the team do?

A Enable Multi-AZ on the Aurora cluster

B Add at least one reader instance in another Availability Zone, so there is something to promote

C Convert the cluster to Aurora serverless

D Reduce the cluster endpoint's TTL

◆ PAUSE AND DECIDE

What should the team do?

A **Enable Multi-AZ**

The team's premise is correct: the storage already spans three AZs. Durability was never the problem.

B **Add a reader instance**

Aurora's fast failover works by promoting an existing replica. With none, AWS must create a new instance, which takes minutes rather than seconds.

C **Aurora serverless**

Changes how capacity scales, not how failover works. A serverless cluster with a single instance has the same problem.

D **Lower the endpoint TTL**

The cluster endpoint follows failover automatically. The delay was creating a writer, not resolving to one.

THE SIGNAL

Durable is not the same as available. The data was safe throughout; there was simply no compute able to serve it.

A company must be able to recover a customer-facing application in a second Region. The agreed RPO is 15 minutes and the agreed RTO is 45 minutes. Cost must be kept as low as those targets allow. A scaled-down copy of the environment is not currently running in the second Region.

Data is replicated continuously; the compute layer exists only as AMIs and an Auto Scaling group set to zero.

Which DR strategy does this describe?

A Backup and restore

B Warm standby

C Active/active

D Pilot light

◆ PAUSE AND DECIDE

Which DR strategy does this describe?

A Backup and restore

Nothing runs in the DR Region and data is not continuously replicated. Here the data layer is live, which is a stronger position.

B Warm standby

Requires a scaled-down but running environment. The scenario states explicitly that no such copy is running.

C Active/active

Both Regions serve production traffic. Nothing in the second Region is serving anything.

D Pilot light

The data layer is live and replicating while compute exists but is switched off. That is the definition, and it fits the 45-minute RTO.

THE SIGNAL

The tiebreaker: is anything running and serving in the second Region? No means pilot light. Yes means warm standby.

> A CloudFormation stack manages a production RDS database with DeletionPolicy set to Retain. An engineer changes a property that requires replacement of the DB instance. After the update completes, the original database no longer exists.
>
> The team believed Retain protected it.

What should have been set as well?

A A stack policy denying all updates to the database

B DeletionPolicy: Snapshot instead of Retain

C UpdateReplacePolicy: Retain, which governs the old resource when an update replaces it

D Termination protection on the stack

◆ PAUSE AND DECIDE

What should have been set as well?

A **Stack policy**

Genuinely would have blocked the update, which is a different control. The question asks what governs the old resource once the update proceeds.

B **DeletionPolicy: Snapshot**

Still DeletionPolicy, so it fires on the wrong event. A snapshot is also not the same as retaining the database.

C **UpdateReplacePolicy: Retain**

DeletionPolicy fires when a resource leaves the stack. UpdateReplacePolicy fires when an update replaces it, and it defaults to Delete.

D **Termination protection**

Prevents the stack being deleted. The stack was not deleted; a resource within it was replaced.

THE SIGNAL

Two attributes, two different events, both defaulting to Delete. Set both on anything holding data. This is the most expensive gap in CloudFormation.

> An organisation must deploy a baseline set of IAM roles and a Config recorder to every account. New accounts are created most weeks and must be covered without anyone remembering. The organisation uses AWS Organizations with all features enabled.
>
> Deployment must halt if more than three accounts fail.

What should be implemented?

A. A service-managed StackSet targeting the organisation's OUs, with automatic deployment and a failure tolerance of 3

B. A self-managed StackSet listing every account ID

C. A pipeline that deploys a CloudFormation stack into each account

D. An SCP requiring the roles to exist

◆ PAUSE AND DECIDE

What should be implemented?

A Service-managed StackSet on OUs

Automatic deployment covers accounts joining a targeted OU later, and failure tolerance implements the stated halting condition exactly.

B Self-managed with account IDs

Works on the day it is built, and requires someone to add every new account each week. That is the manual step the requirement forbids.

C A pipeline per account

Rebuilds StackSets by hand, with no failure tolerance mechanism and a growing list of deployments to maintain.

D An SCP

SCPs restrict what principals may do. They never create resources, so nothing would be deployed at all.

THE SIGNAL

"Covered without anyone remembering" is automatic deployment, which exists only in the service-managed permission model.

> An ECS service on Fargate fails to start. Tasks move from PROVISIONING to STOPPED with the message 'ResourceInitializationError: unable to pull secrets or registry auth'. The application code is unchanged and the container image exists in ECR.
>
> The task definition specifies a task role and a task execution role.

Which role should be investigated?

A The task role, which the application uses to call AWS APIs

B The task execution role, which ECS uses to pull the image and fetch secrets before the container runs

C The cluster's EC2 instance profile

D The ECS service-linked role

◆ PAUSE AND DECIDE

Which role should be investigated?

A The task role

The application's own identity, used only once the container is running. This failure occurs before any application code executes.

B The task execution role

Pulling the image, fetching secrets and writing logs all happen under the execution role, before the container starts. The error names exactly those actions.

C Instance profile

Fargate has no instances, so there is no instance profile to hold permissions.

D Service-linked role

Lets ECS manage load balancers and scaling on your behalf. It is not used to pull images or retrieve secrets.

THE SIGNAL

The stage of failure identifies the role. Anything happening before your code runs belongs to the execution role.

During a promotional campaign a Lambda function behind API Gateway returns throttling errors for about two minutes. CloudWatch shows ConcurrentExecutions peaking at roughly 350 against an account limit of 1,000, with a matching spike in Throttles. The concurrency graph rises in distinct steps.

No other function in the account was active.

What is the cause?

A The account concurrency limit was reached

B Reserved concurrency on the function is set too low

C The function's timeout is too short

D The function hit Lambda's scaling rate, which limits how fast new execution environments are created

◆ PAUSE AND DECIDE

What is the cause?

A Account limit reached

350 against a limit of 1,000, with nothing else running, means the pool was around 65 percent free.

B Reserved concurrency too low

Would produce a flat ceiling at a fixed number, not a rising staircase. Nothing indicates a reservation was set.

C Timeout too short

Produces timeout errors in the function's own logs, not throttling at admission. A different failure entirely.

D The scaling rate

Lambda creates new execution environments at a fixed rate. A sharp spike hits that ceiling regardless of unused pool capacity, producing the stair-step shape.

THE SIGNAL

Two independent limits exist and only one is on the dashboard people watch. Throttled with capacity free is always the scaling rate.

> An application role has an identity policy allowing s3:GetObject on a bucket and kms:Decrypt on the customer managed key that encrypts it. Downloads fail with AccessDenied. The role and the key are in the same account, and there are no SCPs.
>
> A security engineer recently removed the default statement from the key policy.

What is the cause?

A The key policy no longer delegates authority to IAM, so identity policies cannot grant access to the key

B The role also needs kms:Encrypt

C The bucket needs a bucket policy allowing the role

D The key must be a multi-Region key

◆ PAUSE AND DECIDE

What is the cause?

A Key policy no longer delegates to IAM

A KMS key policy is mandatory and is the ultimate authority. The default statement granting the account root full access is what lets identity policies grant key access.

B Needs kms:Encrypt

Downloading decrypts. Encrypt is needed for writing, and adding it changes nothing here.

C Needs a bucket policy

Same-account access works from the identity policy alone. A bucket policy is not required.

D Multi-Region key

Matters when ciphertext must be decrypted in another Region. Everything here is in one account and one Region.

THE SIGNAL

A KMS key policy is unlike other resource policies: without delegation, IAM grants for that key are simply ignored.

A security team attaches an SCP at the organisation root denying all actions outside three approved Regions. Testing in member accounts confirms it works. A month later an audit finds EC2 instances running in an unapproved Region.

Those instances are in the organisation's management account.

What explains this?

A The SCP must also be attached to each OU

B The root user is exempt from SCPs

C SCPs do not apply to the management account

D SCPs take effect only after the next account refresh

◆ PAUSE AND DECIDE

What explains this?

A Attach to each OU

A policy at the root is inherited by every OU and account beneath it. Re-attaching changes nothing.

B Root user is exempt

Precisely backwards, and the most attractive distractor. SCPs apply to every principal in a member account including its root user.

C SCPs do not apply to the management account

Documented behaviour, and the main reason AWS advises keeping workloads out of the management account entirely.

D Account refresh

Invented behaviour. The scenario also states the policy was confirmed working in member accounts.

THE SIGNAL

The last line of the scenario is the whole answer. Option B is the same fact inverted, which makes it the hardest distractor here.

A compliance team must report across 50 accounts: which resources are shared with accounts outside the organisation, and which IAM roles have been unused for 90 days. They have already enabled an organisation-level external access analyzer.

No unused access findings are appearing.

What is required?

A Enable Security Hub, which aggregates all Access Analyzer finding types

B Create a separate organisation-level unused access analyzer, because each finding type requires its own analyzer

C Wait, because unused access findings require 90 days of history to accumulate

D Enable AWS Config in all accounts, which computes unused access

◆ PAUSE AND DECIDE

What is required?

A Security Hub aggregates them

Security Hub aggregates findings that exist. It cannot produce findings from an analyzer that was never created.

B A separate unused access analyzer

IAM Access Analyzer is three distinct analyzer types: external access, unused access and internal access. Each must be created explicitly.

C Wait for history

The tracking period is configurable and analysis uses existing CloudTrail history. It does not require a fresh 90 days.

D AWS Config

Evaluates resource configuration against rules. It does not analyse access patterns or compute unused permissions.

THE SIGNAL

One service name covering several distinct products. Having one analyzer produces none of the others' findings, and the pricing differs too.

Servers in an on-premises data centre, connected over Direct Connect, must reach an S3 bucket without traversing the public internet. A gateway endpoint for S3 has been created and added to the VPC's route tables. Instances inside the VPC reach S3 through it correctly.

On-premises traffic still cannot reach S3 privately.

What should the team do?

A Create an interface endpoint for S3, which has a private IP reachable from on-premises

B Add the on-premises CIDR to the gateway endpoint policy

C Advertise the S3 prefix list to on-premises over BGP

D Attach the gateway endpoint to the Direct Connect gateway

◆ PAUSE AND DECIDE

What should the team do?

A Interface endpoint

Gateway endpoints cannot be reached from on-premises over Direct Connect or VPN. An interface endpoint has a private IP in your subnet, and can be.

B Endpoint policy

An endpoint policy restricts what may be done through an endpoint that is already reachable. It cannot make an unreachable one reachable.

C Advertise the prefix list

A gateway endpoint works through a VPC route table entry. There is no path to advertise to an on-premises router.

D Attach to the DX gateway

Gateway endpoints attach to VPC route tables. No such construct exists on a Direct Connect gateway.

THE SIGNAL

The scenario supplies a controlled comparison: in-VPC access works, on-premises does not. That is the documented boundary of a gateway endpoint.

> A custom network ACL is applied to a subnet. Clients can establish connections to a web server on port 443, and every response times out. The security groups allow all outbound traffic, and the NACL has an inbound rule allowing TCP 443 from 0.0.0.0/0.
>
> No other rules have been added.

What is missing?

A An inbound security group rule for port 443

B An outbound NACL rule allowing the ephemeral port range, because NACLs are stateless

C An outbound NACL rule allowing TCP 443

D A route to the internet gateway

◆ PAUSE AND DECIDE

What is missing?

A Inbound SG rule for 443

Connections are being established, which proves the security group already permits the traffic.

B Outbound ephemeral range

The response leaves from port 443 addressed to the client's high ephemeral port. A stateless NACL needs an outbound rule covering that range.

C Outbound rule for 443

The near miss. The rule matches on destination port, and the response is destined for the ephemeral port, not for 443.

D Route to the IGW

The request arrived, so inbound routing works. A missing route would prevent connection entirely rather than hanging the response.

THE SIGNAL

Connects then hangs is the stateless signature. Option C is the trap for anyone who knows a rule is needed but matches on the wrong port.

A multiplayer game backend uses UDP on a custom port across three Regions. Players report high latency, and recovery is slow when a Region becomes unhealthy. Some corporate customers require fixed IP addresses to add to their firewalls.

The team currently uses Route 53 latency-based routing with health checks.

What should the team implement?

A. A CloudFront distribution in front of the game servers

B. Route 53 geoproximity routing with a bias

C. AWS Global Accelerator with endpoint groups in each Region

D. A Network Load Balancer with targets in all three Regions

◆ PAUSE AND DECIDE

What should the team implement?

A CloudFront

HTTP and HTTPS only, and game traffic is not cacheable. It cannot carry UDP at all.

B Geoproximity routing

Still DNS. Failover waits for health checks, then the TTL, then resolver caching, which is the slow recovery being complained about.

C Global Accelerator

UDP on any port, two static anycast IPs for allow-listing, traffic onto the AWS backbone at the nearest edge, and failover in about 30 seconds with no DNS.

D NLB across Regions

An NLB is a Regional resource. It provides neither global anycast entry nor Regional failover.

THE SIGNAL

Three clauses point the same way: UDP eliminates CloudFront, fixed IPs eliminate DNS-based answers, and slow recovery eliminates anything with a TTL.

> A software vendor must expose a single API privately to 150 customer AWS accounts. Many customers use the 10.0.0.0/16 range, which is identical to the vendor's own VPC CIDR. Customers must not be able to reach anything else in the vendor's environment.
>
> The vendor does not want to manage per-customer network connections.

What should the vendor implement?

A VPC peering with each customer account

B A Transit Gateway shared with customers through AWS RAM

C A public API endpoint restricted by an IP allow-list

D A PrivateLink endpoint service behind a Network Load Balancer, with customers creating interface endpoints

◆ PAUSE AND DECIDE

What should the vendor implement?

A Peering per customer

Fails on overlapping CIDRs alone, and 150 peering connections is exactly the per-customer management the vendor ruled out.

B Shared Transit Gateway

Creates routing between vendor and customers, so overlaps break it, and customers gain a route into the vendor's network.

C Public endpoint with allow-list

Traffic traverses the internet, which the requirement excludes, and an allow-list for 150 customers is unmaintainable.

D PrivateLink endpoint service

PrivateLink establishes no routing, so identical CIDRs are irrelevant. It exposes exactly one service, and scales to any number of consumers.

THE SIGNAL

Overlapping CIDRs eliminates every routing-based option at once. One clause removes three of the four answers before any other consideration.

How to use your score

- **14 or more** suggests you are on track. **11 to 13** means revisit the weaker domains before the next practice exam.
- **Note which domain each miss came from.** Five questions were Domain 1, four Domain 2, four Domain 3, three Domain 4, four Domain 5.
- **Review anything you guessed correctly** with the same care as a miss. That is the single highest-value revision you can do.
- **Do not memorise these questions.** The exam will not repeat them; the reasoning patterns are what transfer.

> ON THE EXAM
>
> Several questions here shared a shape: a stated fact that eliminates an option, and a final sentence carrying the deciding constraint. Look for both.

MODULE 37 · EXAM STRATEGY - ALL DOMAINS

Practice Exam 2

Twenty fresh questions, same weighting, worked in full. Leans harder on recent changes.

QUESTIONS 20 SUGGESTED TIME 40 minutes PASS GUIDE 14 of 20

admin@sthithapragna.com

> An API's average response time sits comfortably at 180 milliseconds and the team's alarm never fires. Support tickets nevertheless report the application being unusably slow, and the affected users are consistently the same accounts.
>
> The alarm uses the Average statistic on the latency metric.

What should the team change?

A Reduce the alarm threshold below 180 milliseconds

B Alarm on a high percentile such as p99, which reveals the slow minority the mean conceals

C Switch the metric to high resolution

D Increase the evaluation periods so the alarm is less sensitive

◆ PAUSE AND DECIDE

What should the team change?

A Lower the threshold

Alarms on the same mean, which is healthy. It would fire constantly on normal traffic while still missing the slow tail.

B Alarm on p99

A mean hides a minority. If 2 percent of requests take 9 seconds, the average barely moves while those users have an unusable experience.

C High resolution

Changes how often the metric is published, not which statistic is evaluated. More frequent averages are still averages.

D More evaluation periods

Makes the alarm less sensitive, which is the opposite of the requirement. It already never fires.

THE SIGNAL

"Healthy average, unhappy minority" is the percentile signature. Resolution and statistic are different axes, and only one is the problem here.

> A team moves a high-volume log group to the Infrequent Access log class to reduce cost. Afterwards, an existing metric filter on that log group stops producing data and its alarm goes to INSUFFICIENT_DATA.
>
> Logs Insights queries against the log group still return results.

What is the cause?

A The metric filter must be recreated after a log class change

B Infrequent Access retains logs for a shorter period

C The Infrequent Access log class does not support metric filters

D The alarm needs its missing data treatment changed

◆ PAUSE AND DECIDE

What is the cause?

A **Recreate the filter**

Would imply the capability exists and merely needs re-establishing. The capability is absent in this log class.

B **Shorter retention**

Retention is configured independently of log class, and the scenario confirms queries still return data.

C **IA does not support metric filters**

The Infrequent Access class trades features for cost: no metric filters, no subscription filters, no Live Tail, no anomaly detection.

D **Missing data treatment**

Changes how the alarm interprets gaps. It cannot make a metric exist that is no longer produced.

THE SIGNAL

The log class is chosen at creation and trades capability for cost. Logs Insights still working is the clue that the data is fine and the feature is not.

> An EventBridge rule invokes a Lambda function. During a two-hour outage of a downstream API the function failed every invocation, and those events are now lost. The team wants both to capture failures for reprocessing and to replay a range of past events after a code fix.
>
> No dead-letter queue is configured on the rule's target.

What should the team configure?

A. A dead-letter queue only, which also allows replay

B. An EventBridge archive only, which also captures failures

C. Increase the retry attempts on the rule

D. A dead-letter queue for failed deliveries, and an event archive for replay

◆ PAUSE AND DECIDE

What should the team configure?

A DLQ only

Captures events EventBridge could not deliver. It holds nothing about events delivered successfully, so there is nothing to replay.

B Archive only

Stores matched events for replay. It does not capture delivery failures, which is the other half of the requirement.

C More retries

EventBridge already retries for up to 24 hours. It captures nothing and replays nothing.

D Both, for different jobs

A DLQ captures what could not be delivered; an archive stores what matched, so a range can be replayed later. Two requirements, two mechanisms.

THE SIGNAL

Two stated requirements, and each of A and B answers exactly one. Counting the requirements before reading the options settles this immediately.

> A database password must change every 30 days, in the database and in the configuration the application reads, without downtime and without human involvement. The value is currently a SecureString in Parameter Store with a policy that expires it after 30 days.
>
> Applications fail when the parameter expires.

What should the team do?

A. Move the credential to Secrets Manager and enable rotation, which changes it in the database and the secret together

B. Change the Parameter Store policy from expire to notify

C. Use an Advanced tier parameter, which supports rotation

D. Increase the expiry period to 90 days

◆ PAUSE AND DECIDE

What should the team do?

A Secrets Manager with rotation

Rotation changes the credential in the database and in the secret atomically. The alternating-user strategy gives rotation with no downtime.

B Expire to notify

Stops the outage by no longer deleting the value, and nothing then changes the password. The requirement is rotation.

C Advanced tier parameter

Advanced tier adds size, count and parameter policies. It does not add rotation; that is the distinction being tested.

D Longer expiry

Delays the same failure by 60 days, and still deletes the value rather than replacing it.

THE SIGNAL

A parameter policy expires or notifies. Only Secrets Manager rotates, meaning it changes the credential in two places at once.

A security group rule permitting inbound 0.0.0.0/0 on port 22 is discovered on a production instance. The team needs to know who made the change and when, and separately needs to see what the security group's configuration looked like before and after.

Both CloudTrail and AWS Config are enabled.

Which service answers which question?

A CloudTrail answers both, since it records the API call and its parameters

B Config answers both, since it records configuration over time

C CloudTrail identifies who and when; Config shows the before and after configuration

D Neither; VPC Flow Logs are required

◆ PAUSE AND DECIDE

Which service answers which question?

A CloudTrail answers both

It records the call and its parameters, so it shows the change requested. It does not maintain the resource's state over time.

B Config answers both

Config records configuration items and relationships. It does not record the identity that made a call.

C CloudTrail for who; Config for what

Complementary by design: CloudTrail records the API call and the caller, Config records the resulting resource state and its history.

D Flow logs needed

Flow logs record traffic that flowed, not configuration changes. The wrong category of evidence entirely.

THE SIGNAL

Who did it, what it looks like now, how it is performing: CloudTrail, Config, CloudWatch. The trio that appears in some form on almost every attempt.

A retail site sees traffic rise from a quiet overnight baseline to five times that level, between 08:00 and 08:20 every weekday. The pattern is unchanged for eighteen months. Instances take about seven minutes to become useful, and target tracking on CPU is configured.

The Auto Scaling group is nowhere near its maximum capacity.

What should be added?

A Predictive scaling in ForecastAndScale mode, retaining target tracking

B A lower target tracking threshold

C A step scaling policy with larger steps

D A higher maximum capacity

◆ PAUSE AND DECIDE

What should be added?

A Predictive plus target tracking

Eighteen months of consistent history is exactly what a forecast needs, and capacity arrives before 08:00 rather than seven minutes after demand.

B Lower threshold

Reacts sooner and still only after load arrives, then runs excess capacity for the other twenty-two hours.

C Larger steps

Still reactive. However aggressive the steps, instances take seven minutes against a twenty-minute ramp.

D Higher maximum

The scenario states the group is nowhere near its maximum, so the ceiling is explicitly not the constraint.

THE SIGNAL

Every reactive answer loses the same race: seven minutes to boot against a twenty-minute ramp. Only scaling before 08:00 wins it.

> An RDS for MySQL database is deployed as Multi-AZ. Reporting queries are slowing the application, and a developer proposes directing the reporting tool at the standby instance to spread the load.
>
> Availability requirements are already met.

What is wrong with the proposal, and what should be done?

A. Nothing is wrong; the standby can serve read traffic

B. The standby is in another Region, so latency would be too high

C. Multi-AZ must be disabled before a read replica can be added

D. The Multi-AZ standby serves no traffic and has no endpoint. Add a read replica for the reporting workload

◆ PAUSE AND DECIDE

What is wrong with the proposal, and what should be done?

A The standby can serve reads

It cannot. A classic Multi-AZ standby is invisible: no endpoint, no reads, and no backups taken from it.

B Another Region

Multi-AZ is within one Region by definition. Cross-Region means a read replica or a global database.

C Disable Multi-AZ first

Invented requirement. Read replicas and Multi-AZ coexist, and most production designs use both.

D Standby serves nothing; add a replica

Multi-AZ is availability, replicas are scale. Different mechanisms answering different requirements.

THE SIGNAL

Availability versus scale, synchronous versus asynchronous, automatic versus manual. The most confused pair in the RDS syllabus.

> An engineer deletes a production RDS instance in error. Automated backups were enabled with 14-day retention. The 'retain automated backups' option was not selected during deletion, and no manual snapshots exist.
>
> The team asks how to restore to a point five minutes before the deletion.

What is the situation?

A Restore to the required point in time from the retained automated backups

B The automated backups were deleted with the instance, so no restore is possible

C Restore from the final snapshot that RDS always takes automatically

D Recover the instance from the RDS recycle bin within 14 days

◆ PAUSE AND DECIDE

What is the situation?

A Restore from automated backups

There are none. Automated backups are a property of the instance and are removed with it unless retention was explicitly requested.

B Nothing to restore from

Uncomfortable and correct. This is precisely why manual snapshots or AWS Backup vault copies exist as a separate control.

C The automatic final snapshot

The most tempting option. A final snapshot is offered at deletion, not taken automatically, and the scenario says it was not selected.

D RDS recycle bin

Recycle Bin covers EBS snapshots and AMIs, not RDS instances. Invented behaviour for this service.

THE SIGNAL

Some questions have an unpleasant correct answer. Recognising that a recovery is impossible is a real skill, and the exam does test it.

A team configures Route 53 failover routing between two Regions. The primary record's health check targets an internal Application Load Balancer in a private subnet. The health check has never once reported healthy, so all traffic goes to the secondary Region.

The load balancer and its targets are confirmed healthy.

What is the cause and the fix?

A The failure threshold is set too low; raise it

B Failover routing requires a calculated health check

C Endpoint health checkers run on the public internet and cannot reach a private endpoint. Use a CloudWatch alarm health check instead

D The record's TTL is too high

◆ PAUSE AND DECIDE

What is the cause and the fix?

A Threshold too low

Would cause flapping on intermittent problems, not a check that has never once succeeded since creation.

B Calculated check required

Invented requirement. Failover routing works with any health check type, including none at all.

C Public checkers cannot reach a private endpoint

Endpoint health checks originate on the public internet. An internal load balancer has no public address, so every probe fails.

D TTL too high

TTL governs how long clients cache an answer. It has no bearing on whether a health check succeeds.

THE SIGNAL

"Never once healthy" is the signal. Intermittent problems flap; a structural impossibility fails from the very first probe.

A CloudFormation stack creates an Auto Scaling group of application servers. The stack reports CREATE_COMPLETE about three minutes after launch, but the application takes roughly nine minutes to install and start on each instance. A pipeline runs smoke tests as soon as the stack completes, and they fail unpredictably.

The team wants CREATE_COMPLETE to mean the application is genuinely serving.

What should be added?

A. A DependsOn attribute between the Auto Scaling group and the load balancer

B. A CreationPolicy with a ResourceSignal, and cfn-signal at the end of user data

C. An UpdatePolicy with AutoScalingRollingUpdate

D. A fixed 10-minute wait step in the pipeline

◆ PAUSE AND DECIDE

What should be added?

A DependsOn

Changes ordering between resources. The problem is not order; it is that an instance counts as created before it is ready.

B CreationPolicy plus cfn-signal

The stack waits for each instance to signal success from its own user data, so CREATE_COMPLETE means the application is actually running.

C UpdatePolicy

Governs how updates replace instances. The scenario describes the initial creation reporting success too early.

D A fixed wait

The tempting shortcut. It waits whether or not anything worked, so a failed installation still reports success ten minutes later.

THE SIGNAL

Launched is not ready. CreationPolicy is the only mechanism that makes CloudFormation's definition of complete match the application's.

A team is designing blue/green deployments for an ECS service in 2026. They need a bake period, automated validation against the new version before customers reach it, and automatic rollback on a CloudWatch alarm. They have no existing CodeDeploy configuration.

The service runs on Fargate behind an Application Load Balancer.

What should they implement?

A ECS native blue/green, setting the deployment controller to ECS, with a test listener, bake time and alarm rollback

B ECS blue/green through CodeDeploy, with an appspec file and a deployment group

C An ECS rolling update with minimum healthy percent set to 100

D Two ECS clusters with Route 53 weighted records between them

◆ PAUSE AND DECIDE

What should they implement?

A ECS native blue/green

Built into ECS since July 2025, with bake time, a test listener for pre-customer validation, and alarm rollback. AWS names it the default choice for new deployments.

B CodeDeploy

Works, and since July 2025 it is extra machinery: an application, deployment group, appspec and role. The scenario removes the one good reason to choose it.

C Rolling at 100 percent

Avoids the capacity dip and discards old tasks as it goes, so rollback means another full deployment. It offers no test listener.

D Two clusters plus DNS

Achieves blue/green at the DNS layer, where TTLs and resolver caching make rollback slow and imprecise.

THE SIGNAL

Every course written before mid-2025 says ECS blue/green requires CodeDeploy. It does not, and AWS no longer recommends that path for new work.

A team is configuring Terraform remote state for a new AWS project. A colleague provides a runbook from an earlier project. It specifies an S3 bucket for state, plus a DynamoDB table with a LockID partition key for locking.

The team wants the configuration currently recommended.

What should the team do?

A Follow the runbook exactly, since it is a proven pattern

B Store state locally and commit it to the repository

C Use the DynamoDB table but drop the S3 bucket

D Use an S3 bucket with use_lockfile enabled, and no DynamoDB table

◆ PAUSE AND DECIDE

What should the team do?

A Follow the runbook

Works, and DynamoDB locking is deprecated in HashiCorp's own documentation and slated for removal. A runbook that has aged.

B Local state in Git

State contains resource identifiers and often secrets, and committing it provides no locking. Two people applying at once corrupt it.

C DynamoDB without S3

DynamoDB was only ever the lock, never the state store. Removing the bucket removes the state itself.

D S3 with use_lockfile

S3 native locking is the current mechanism: a .tflock object beside the state file, one fewer resource, and no deprecated arguments.

THE SIGNAL

The same shape as Incident Manager and ARC readiness check: an experienced colleague's advice that has quietly gone out of date.

A Lambda function is triggered asynchronously by S3 events. About 3 percent of objects cause the function to fail permanently because of a malformed file. The team discovers this weeks later and has no record of which objects failed.

The function has no destination and no dead-letter queue configured.

What explains the missing record, and what should be configured?

A S3 event notifications do not retry, so the events were never delivered

B The function timeout is too short; increase it

C Asynchronous invocation retries twice and then discards the event silently. Configure an on-failure destination

D Enable S3 versioning to preserve the failed objects

◆ PAUSE AND DECIDE

What explains the missing record, and what should be configured?

A S3 does not retry

Asynchronous Lambda invocation does retry, twice. The problem is what happens after the retries are exhausted.

B Timeout too short

The failures are permanent and caused by malformed input. A longer timeout produces the same failure more slowly.

C Silent discard; add a destination

With no destination and no DLQ, a permanently failing async event is dropped and the only trace is a metric. A destination captures request and response context.

D Versioning

Protects objects that were never at risk. It says nothing about which invocations failed.

THE SIGNAL

Destinations superseded the DLQ for asynchronous invocation: they capture request and response context and support on-success as well.

> A platform team must let application teams create IAM roles for their own workloads. Those roles must never modify IAM, delete CloudTrail trails, or act outside approved Regions. The platform team will not review each role by hand.
>
> Application teams must retain the ability to create roles.

What should the platform team implement?

A. A permissions boundary attached to the application teams' own roles

B. An SCP denying iam:CreateRole in the application accounts

C. An AWS Config rule detecting over-permissive roles after creation

D. A permissions boundary, plus a condition on the teams' policies requiring that boundary on any role they create

◆ PAUSE AND DECIDE

What should the platform team implement?

A Boundary on their own roles

The near miss: right feature, wrong attachment point. It caps what the teams themselves can do, not the roles they create.

B Deny CreateRole

Removes the delegation entirely. The requirement is that teams should be able to create roles, safely.

C Config rule

Detective, so an over-permissive role exists until someone acts. The requirement is that it never can.

D Boundary plus the required-boundary condition

The condition forces every role they create to carry the boundary, and the boundary caps what those roles can ever do. Delegation with a guarantee.

THE SIGNAL

The boundary is not the control. The condition requiring the boundary is. Without it, teams simply create a role with no boundary at all.

A regulator requires that seven years of transaction records held in S3 cannot be deleted or altered by anyone in the organisation for the full retention period. The requirement explicitly names administrators and the account root user.

The bucket already has versioning enabled.

What should be implemented?

A S3 Object Lock in compliance mode with a seven-year retention period

B S3 Object Lock in governance mode with a seven-year retention period

C MFA delete on the bucket

D A bucket policy denying s3:DeleteObject to all principals

◆ PAUSE AND DECIDE

What should be implemented?

A Compliance mode

The only control here that the root user cannot override. Retention cannot be shortened and objects cannot be deleted until it expires.

B Governance mode

Designed to be overridable by a user holding s3:BypassGovernanceRetention. The requirement says nobody, which rules it out.

C MFA delete

Raises the bar without removing the capability. An administrator holding the MFA device can still delete.

D Bucket policy

Whoever can write bucket policies can rewrite this one. A policy cannot bind the people who control policies.

THE SIGNAL

"Including the root user" eliminates every control a privileged person can reverse. The same discriminator applies to Vault Lock and CloudTrail.

An audit finds several S3 buckets across member accounts whose bucket policies grant read access to named external AWS accounts. Application teams own their own buckets and the security team cannot review every policy. They need a central control preventing any principal outside the organisation from accessing any S3 bucket.

S3 Block Public Access is already enabled account-wide everywhere.

What should the security team implement?

A An SCP denying s3:PutBucketPolicy in all member accounts

B A resource control policy denying S3 access to principals outside the organisation

C Rely on Block Public Access, which already covers this

D An IAM Access Analyzer external access analyzer at organisation level

◆ PAUSE AND DECIDE

What should the security team implement?

A Deny PutBucketPolicy

Stops new bucket policies being written and leaves every existing grant intact. It also blocks legitimate use entirely.

B RCP denying external principals

An RCP caps what may be done to your resources, overriding any bucket policy, for every bucket at once. Exactly the data perimeter use case.

C Block Public Access

The sharp one. Access granted to a named external AWS account is not public access, so BPA permits it, and it is already enabled here.

D External access analyzer

Detective. It reports the sharing the audit has already found, and prevents nothing.

THE SIGNAL

Cross-account is not the same as public. Block Public Access is already enabled in this scenario and has done nothing about these grants.

An architecture spans three Availability Zones with EC2 instances in private subnets in each, an Auto Scaling group and an ALB across all three, and an RDS Multi-AZ database. A single NAT gateway sits in the first Availability Zone and all three private subnets route to it.

During a simulated failure of the first AZ, instances in the other two lose outbound internet access.

What should be changed?

A Add a second ALB in another Availability Zone

B Deploy a NAT gateway in each Availability Zone, with each private subnet routing to its local one

C Convert the database to a Multi-AZ DB cluster

D Enable cross-zone load balancing on the ALB

◆ PAUSE AND DECIDE

What should be changed?

A — A second ALB

An ALB already spans the zones you enable. The load balancer was never the failing component.

B — A NAT gateway per AZ

A NAT gateway is a zonal resource. Routing every private subnet through one makes that zone a single point of failure for all outbound traffic.

C — Multi-AZ DB cluster

Improves database failover time. The database was already Multi-AZ and is not what broke.

D — Cross-zone load balancing

Always on for an ALB, and it concerns inbound distribution rather than outbound internet access.

THE SIGNAL

The scenario lists four components correctly spread across zones, then names one that is not. That asymmetry is the whole question.

A CloudFront distribution in front of a dynamic web application reports a cache hit ratio of about 3 percent, and the origin is heavily loaded. The cache behaviour forwards all cookies and all query strings and includes them in the cache key. Most responses are identical for all users.

The application requires the CloudFront-Viewer-Country header for analytics.

What should the team do?

A Increase the maximum TTL on the behaviour

B Enable Origin Shield

C Add more origins to an origin group

D Reduce the cache key to what genuinely varies the response, and use an origin request policy to forward the country header

◆ PAUSE AND DECIDE

What should the team do?

A. Raise the maximum TTL

Objects are not expiring; they are never reused, because each request produces a distinct cache key. A longer TTL on a unique object achieves nothing.

B. Origin Shield

Collapses duplicate origin fetches for the same object. With a near-unique key per request, there are no duplicates to collapse.

C. More origins

Spreads the same load across more servers while the cache continues to do nothing.

D. Shrink the key; forward via origin request policy

Cookies in the cache key give every user their own copy. An origin request policy forwards the header without fragmenting the cache.

THE SIGNAL

A poor cache hit ratio is a cache key problem, not a TTL problem. Option A is the reflex answer and addresses expiry rather than uniqueness.

> A team must point example.com, the bare domain with no subdomain, at an Application Load Balancer. Route 53 rejects a CNAME record created for example.com. The identical CNAME created for www.example.com works correctly.
>
> The load balancer's IP addresses are managed by AWS and change over time.

What should the team create?

A. An alias record for example.com targeting the load balancer

B. An A record containing the load balancer's current IP addresses

C. A CNAME, after deleting the zone's SOA record

D. An NS record delegating example.com to the load balancer

◆ PAUSE AND DECIDE

What should the team create?

A An alias record

Alias is Route 53's extension that works at the zone apex, follows the load balancer's changing addresses, and is free for AWS targets.

B A record with IPs

The scenario states the addresses change. This works until AWS replaces a node, then fails silently for everyone.

C Delete the SOA record

Would break the zone entirely. SOA is mandatory, and the DNS standard forbids a CNAME coexisting with other records at the apex.

D NS delegation

Delegates authority for the zone to other name servers. A load balancer is not a name server.

THE SIGNAL

The comparison is supplied: www works, the apex does not. That is the CNAME-at-apex rule, and only an alias record solves it.

> An application in VPC A cannot reach a database in VPC B across a Transit Gateway. The database's security group permits the database port from the application's security group. That identical rule works correctly for application instances inside VPC B.
>
> Route tables and network ACLs have been verified as correct.

What is the most likely cause?

A Security group references never work across VPCs

B The Transit Gateway needs a NAT gateway on the path

C The Transit Gateway discards security group information unless referencing support is enabled on the attachment

D The database security group must use the application's CIDR range instead

◆ PAUSE AND DECIDE

What is the most likely cause?

A References never work across VPCs

Too absolute. They work across peered VPCs in the same Region, and across a Transit Gateway once referencing support is enabled.

B NAT gateway on the path

NAT is for internet access. Both VPCs are private and routing has already been verified.

C Referencing support not enabled

By default a Transit Gateway discards security group information about forwarded traffic, so a group-referencing rule has nothing to match against.

D Use a CIDR range

A workaround that would work, at the cost of the maintainable rule. The question asks for the cause, not a way around it.

THE SIGNAL

The controlled comparison is the clue: the identical rule works inside VPC B and fails across the Transit Gateway. Only the path differs.

How this set was weighted

- **Five Domain 1, four Domain 2, four Domain 3, three Domain 4, four Domain 5**, matching the real exam's proportions.
- **Four questions turned on recent changes**: the IA log class, ECS native blue/green, Terraform state locking, and resource control policies.
- **Three questions contained a controlled comparison**: something that works in one place and fails in another. That is always the clue.
- **One question had an unpleasant correct answer**: no restore was possible. The exam does ask you to recognise that.

> ON THE EXAM
>
> Compare your Domain 1 to 5 breakdown with practice exam 1. A domain weak in both is where your remaining revision belongs.

MODULE 38 · EXAM STRATEGY - ALL DOMAINS

Practice Exam 3

Twenty questions. Heavier on operations detail and the services added in exam guide v1.1.

QUESTIONS 20 SUGGESTED TIME 40 minutes PASS GUIDE 14 of 20

admin@sthithapragna.com

> An application already writes structured JSON to CloudWatch Logs, including a field for the duration of each order. The team wants a CloudWatch metric for order duration without adding a metrics library or making extra API calls from the application.
>
> Log volume is high and cost matters.

What should the team use?

A PutMetricData called from the application for each order

B A CloudWatch alarm reading the log group directly

C Embedded Metric Format, so CloudWatch extracts metrics from the logs already being written

D A Lambda function polling Logs Insights every minute

◆ PAUSE AND DECIDE

What should the team use?

A PutMetricData per order

Adds a synchronous API call to every order, which is exactly the extra call the requirement excludes, and it is charged per request.

B Alarm on the log group

Alarms evaluate metrics, not log groups. Something must turn log data into a metric first.

C Embedded Metric Format

EMF lets you emit metrics inside log events you are already writing. CloudWatch extracts them, with no separate API call.

D Poll Logs Insights

Builds a metric pipeline by hand, adds latency, and pays for a query every minute.

THE SIGNAL

"Already logging the value" is the EMF signal. PutMetricData is for values you are not otherwise recording.

A platform team must view CloudWatch metrics, logs and traces from 40 member accounts in a single account, without granting engineers access to each member account. Engineers should see cross-account dashboards natively in the CloudWatch console.

All accounts are in one AWS Organization.

What should the team configure?

A CloudWatch cross-account observability: a monitoring account sink, with source account links

B A metric stream from each account to a central Firehose

C A cross-account IAM role in each member account for engineers to assume

D Amazon Managed Grafana with 40 CloudWatch data sources

◆ PAUSE AND DECIDE

What should the team configure?

A Sink and links

Purpose-built: a sink in the monitoring account, links from each source account, and metrics, logs and traces appear natively in one console.

B Metric streams to Firehose

Streams metrics to a destination for storage or third-party tools. It does not carry logs or traces, nor produce native cross-account views.

C Cross-account roles

Requires engineers to switch accounts one at a time, which is the access model the requirement rules out.

D Managed Grafana

Genuinely works and adds a service and per-user cost for something CloudWatch does natively across accounts.

THE SIGNAL

Sink in the monitoring account, links in the sources. Grafana is the answer when the data is heterogeneous, not merely cross-account.

> An investigator needs to determine who deleted a specific S3 object 100 days ago. The account has never configured a CloudTrail trail, and the team is relying on CloudTrail Event history in the console.
>
> Event history shows nothing relevant.

Why, and what should have been in place?

A Event history covers 180 days, so the record has only just expired

B Object deletions are management events and should be visible

C CloudTrail Lake should have been enabled instead

D Event history covers 90 days and management events only. A trail logging S3 data events was required

◆ PAUSE AND DECIDE

Why, and what should have been in place?

A 180 days

Event history covers 90 days, not 180. Even at 180 the object-level event would still be absent for the second reason.

B Deletions are management events

The core error. Object-level operations are data events, which are off by default and charged from the first copy.

C CloudTrail Lake

Would provide longer retention, and it closed to new customers on 31 May 2026. It also would still need data events enabled.

D 90 days, management only; needed a data event trail

Two independent reasons: the retention window and the event category. Both had to be addressed in advance.

THE SIGNAL

Two failures, not one. Event history is 90 days AND management events only, so object-level activity was never captured at all.

A team currently patches 900 EC2 instances using maintenance windows, patch groups and a hand-maintained set of tags. Onboarding a new account takes a day of configuration, and drift between accounts is common.

They want the approach AWS currently recommends for a new multi-account patching design.

What should they adopt?

A More maintenance windows, one per account, driven by StackSets

B Patch policies configured through Systems Manager Quick Setup, with separate scan and install schedules

C A Lambda function invoking Run Command with the patch baseline document

D State Manager associations applying patches on a schedule

◆ PAUSE AND DECIDE

What should they adopt?

A More maintenance windows

Automates the existing complexity rather than removing it. Patch groups and per-account windows are what the new design is meant to replace.

B Patch policies via Quick Setup

AWS's recommended path: organisation-wide configuration, separate scan and install schedules, and no patch groups to maintain.

C Lambda plus Run Command

Rebuilds patching by hand, with a function to maintain and no reporting or compliance view.

D State Manager associations

Enforces state continuously and is a reasonable mechanism. It is not the managed patching path, and it lacks patch policy's reporting.

THE SIGNAL

Patch policies are the current recommended path. Maintenance windows and patch groups are the older design they replace.

> A team is adding distributed tracing to new microservices on EKS in 2026. They want traces in X-Ray today, and the freedom to send telemetry to a different backend later without re-instrumenting the code.
>
> An engineer proposes adding the AWS X-Ray SDK to each service.

What should the team do?

A Proceed with the X-Ray SDK, since X-Ray is the AWS-native tracing service

B Use CloudWatch Container Insights, which provides tracing

C Instrument with OpenTelemetry and deploy the ADOT Collector, exporting traces to X-Ray

D Send traces to Amazon Managed Service for Prometheus

◆ PAUSE AND DECIDE

What should the team do?

A X-Ray SDK

The SDKs and daemon entered maintenance mode in 2026: security fixes only. Building new instrumentation on a frozen library, and it locks the backend in.

B Container Insights

Provides cluster, node and pod metrics. It does not produce distributed traces.

C OpenTelemetry with ADOT

Vendor-neutral instrumentation with X-Ray as today's exporter. Changing backend later becomes a configuration change.

D Prometheus for traces

Prometheus is a metrics system and PromQL is a metrics language. Neither handles traces.

THE SIGNAL

Be precise: the X-Ray SDKs are frozen, and the X-Ray service is fully supported. The answer still sends traces to X-Ray.

> Instances in an Auto Scaling group take six minutes to become useful. Four of those minutes are spent installing packages, runtimes and the application itself; the remaining two load the current day's reference data into a local cache.
>
> The team wants to reduce scale-out time as far as practical.

What should the team do?

A Use a warm pool only, since it addresses all six minutes

B Increase the instance size so installation completes faster

C Use a golden AMI only, since it addresses all six minutes

D Bake the installation into a golden AMI, and use a warm pool for the data loading

◆ PAUSE AND DECIDE

What should the team do?

A Warm pool only

Would work, and it pays to keep stopped instances holding software that could simply have been baked into the image.

B Bigger instances

Speeds installation somewhat and pays for larger instances permanently to fix a one-off cost at launch.

C Golden AMI only

Removes the four minutes of installation. The two minutes of loading current data cannot be baked, because it depends on today's data.

D Both, for different halves

Installation belongs in the image; loading current data cannot. The scenario splits the six minutes deliberately.

THE SIGNAL

Ask what the boot time is spent on. Installing software belongs in the image. Loading today's data does not, and that is the warm pool case.

A 60-instance Auto Scaling group must receive a new AMI during business hours. Capacity must never fall below current levels, the rollout must pause after the first quarter for review, and it must reverse automatically if error rates rise.

The group is defined in CloudFormation and the stack must stay consistent with reality.

What should the team use?

A The AutoScalingInstanceRefresh update policy with MinHealthyPercentage 100, checkpoints and an alarm specification

B The AutoScalingRollingUpdate policy with MaxBatchSize 15

C Run an instance refresh manually from the console after updating the stack

D Create a second Auto Scaling group and shift ALB target group weights

◆ PAUSE AND DECIDE

What should the team use?

A AutoScalingInstanceRefresh policy

MinHealthyPercentage 100 gives launch-before-terminate, checkpoints give the review pause, and the alarm specification gives automatic reversal, all inside the stack.

B AutoScalingRollingUpdate

Terminates before launching, so capacity dips, and it offers neither checkpoints nor alarm rollback. It also suspends scaling policies.

C Manual refresh

Gets the deployment right and breaks the requirement that the stack stays consistent. This is the drift the newer policy exists to remove.

D Second group plus weights

A valid blue/green pattern that doubles the fleet and duplicates the stack, which is far more machinery than the requirements ask for.

THE SIGNAL

Four requirements, and only the July 2026 update policy meets all four without leaving CloudFormation.

A DynamoDB table in on-demand capacity mode normally serves about 900 reads per second. During a product launch, traffic rises to roughly 50,000 reads per second within twenty seconds. Customers see errors and CloudWatch shows ReadThrottleEvents for several minutes.

The team believed on-demand mode could not throttle.

What explains this, and what should they have done?

A On-demand tables have a hard 40,000 read limit that cannot be raised

B The table's warm throughput was too low for the spike. Pre-warm the table before a known event

C Switch to provisioned mode with auto scaling and a low target utilisation

D Add a global secondary index to spread the read load

◆ PAUSE AND DECIDE

What explains this, and what should they have done?

A Hard 40,000 limit

There is a default account-level limit near that figure and it is raisable on request, so "cannot be raised" makes this wrong.

B Warm throughput too low; pre-warm

On-demand scales, but not instantly. Warm throughput is what a table serves immediately, and pre-warming raises it ahead of a known event.

C Provisioned with auto scaling

Worse for this shape. Provisioned auto scaling reacts after about two minutes, which is slower than on-demand rather than faster.

D Add a GSI

An index serves different query patterns. It does not add capacity for the same reads, and it adds write cost.

THE SIGNAL

"On-demand cannot throttle" is the misconception being tested. It means it always eventually scales, not that it never throttles.

A team is designing a multi-Region recovery plan in 2026 and wants continuous confirmation that the secondary Region remains capable of taking over: correct service quotas, sufficient capacity and matching routing configuration.

An architect recommends ARC readiness checks, which they used successfully at a previous employer.

What should the team do?

A Implement ARC readiness checks as recommended

B Use Route 53 health checks against the secondary Region's endpoint

C Onboard to ARC Region switch and use its plan evaluation capability

D Use AWS Config conformance packs in the secondary Region

◆ PAUSE AND DECIDE

What should the team do?

A ARC readiness checks

Closed to new customers on 30 April 2026. A team designing a new plan cannot onboard, whatever the architect used previously.

B Route 53 health checks

Confirms an endpoint responds. It says nothing about quotas, capacity or configuration parity.

C Region switch plan evaluation

AWS's own recommended replacement. Plan evaluation continually monitors that the recovery plan remains executable.

D Conformance packs

Checks resource configuration against rules, which helps. It does not evaluate quotas, capacity or readiness to fail over.

THE SIGNAL

The architect's recommendation is voiced by a character, which is the signal to test it rather than accept it. ARC itself is fully supported; only readiness check closed.

A developer creates a new CloudFormation stack. It fails because an S3 bucket name is already taken, and CloudFormation rolls back. The stack now shows ROLLBACK_COMPLETE. The developer corrects the bucket name and attempts a stack update, which is rejected immediately.

No resources from the stack remain.

What should the developer do?

A Call ContinueUpdateRollback to clear the state

B Create a change set against the existing stack and execute it

C Enable disable-rollback and retry the update

D Delete the stack and create it again with the corrected template

◆ PAUSE AND DECIDE

What should the developer do?

A ContinueUpdateRollback

Applies to UPDATE_ROLLBACK_FAILED, a different state. There is no update rollback in progress to continue.

B Change set and execute

A change set is still an update, and updates are not permitted from this state. It is rejected identically.

C Disable rollback and retry

Useful on the next attempt to preserve resources for debugging. It does not make an update legal from ROLLBACK_COMPLETE.

D Delete and recreate

ROLLBACK_COMPLETE permits deletion only. There is no repair path, and the stack contains nothing worth preserving.

THE SIGNAL

ROLLBACK_COMPLETE and UPDATE_ROLLBACK_FAILED sound almost identical and are completely different. One is a dead end; the other has a documented way out.

> Development teams need to create RDS databases on demand. The security team will not grant rds:CreateDBInstance to developers. Every database must use approved instance classes, be encrypted, and carry a cost centre tag.
>
> The platform team already has a CloudFormation template that satisfies all of this.

What should the platform team implement?

A. A Service Catalog portfolio with the template as a product, a launch constraint, and a template constraint on instance classes

B. Grant rds:CreateDBInstance with an IAM condition restricting instance classes

C. A StackSet deploying the template into every development account

D. A CDK construct published to an internal package repository

◆ PAUSE AND DECIDE

What should the platform team implement?

A Service Catalog with both constraints

The launch constraint means developers never hold the permission, and the template constraint limits instance classes. Self-service without privilege.

B Grant with conditions

Directly contradicts the stated constraint. The security team will not grant it, conditioned or otherwise.

C A StackSet

Pushes the same resources to every account on the platform team's schedule. It is not on-demand self-service.

D A CDK construct

Standardises the code and still requires whoever deploys it to hold the underlying permissions. It solves consistency, not privilege.

THE SIGNAL

The stated refusal to grant the permission is the whole question. Only a launch constraint provisions with a role the requesting user does not have.

A security team enables an SCP permitting only AMIs owned by the company's own accounts. Shortly afterwards, an EKS Auto Mode cluster stops provisioning nodes and an ECS Managed Instances capacity provider stops scaling.

No other change was made.

What is the cause, and what is the fix?

A Those services require the SCP to be removed entirely

B SCPs apply to the infrastructure roles those services use. Permit the AWS-owned AMI accounts as well

C The clusters need a Kubernetes version upgrade

D Service-linked roles are exempt from SCPs, so this cannot be the cause

◆ PAUSE AND DECIDE

What is the cause, and what is the fix?

A Remove the SCP

Weakens a legitimate control to accommodate a service. The AMI accounts can simply be permitted instead.

B SCPs govern infrastructure roles; permit the AMI accounts

Managed compute launches instances using a role in your account, and SCPs apply to that role. The AWS-owned AMI accounts must be permitted.

C Version upgrade

Nothing about a version changed. The timing points at the policy, which is the only change described.

D Roles are exempt from SCPs

Confuses two similar things. SCPs skip service-linked roles, but do apply fully to infrastructure roles, which is why this breaks.

THE SIGNAL

Service-linked roles are exempt from SCPs. Infrastructure roles are not. Two similar-sounding things behaving oppositely.

A team wants to expose a redesigned checkout flow to 10 percent of users, monitor conversion for a week, then expand or withdraw it. Both the old and new flows are already deployed and passing tests. Withdrawing the feature must not require a deployment.

The application runs on ECS behind an ALB.

What should the team use?

A. A canary deployment shifting 10 percent of traffic to a new task set

B. Blue/green with the green environment serving 10 percent

C. Weighted target groups on the ALB

D. AWS AppConfig feature flags, with a deployment strategy and CloudWatch alarm rollback

◆ PAUSE AND DECIDE

What should the team use?

A Canary deployment

The closest competitor, and it splits traffic between versions. Both flows are already in the same deployed version, so there is nothing to split.

B Blue/green at 10 percent

Runs two full environments for a week, and withdrawing still means a traffic switch rather than a configuration change.

C Weighted target groups

The mechanism underneath a canary. Same objection: both flows live in the same tasks already.

D AppConfig feature flags

The code is already deployed. A flag turns the feature on for a subset and off again instantly, with no deployment either way.

THE SIGNAL

"Both flows are already deployed" is the clause. Nothing needs deploying, so no deployment strategy is the answer.

A compliance regime requires the KMS key protecting a database to have its key material rotated every 90 days. An engineer states that KMS only rotates annually, and proposes a Lambda function to create a new key each quarter and re-encrypt all data.

The key is a customer managed symmetric encryption key.

What should the team do?

A Enable automatic rotation with a 90-day rotation period

B Build the Lambda function as proposed

C Switch to an AWS managed key, which rotates more frequently

D Use an external key store, which supports custom rotation

◆ PAUSE AND DECIDE

What should the team do?

A Automatic rotation, 90-day period

Since April 2024 the rotation period is configurable from 90 to 2,560 days on customer managed symmetric keys. This is a single setting.

B Build the Lambda

Solves a problem that no longer exists, with a function that re-encrypts an entire database quarterly. Considerable risk for nothing.

C AWS managed key

Rotates yearly and cannot be changed, so it is further from the requirement, and it removes your control of the key policy.

D External key store

Places key material outside AWS for sovereignty requirements. It does not provide a shorter automatic rotation period.

THE SIGNAL

The engineer's premise was true until April 2024. A requirement that once needed custom tooling is now a single setting.

> A secret in Secrets Manager in account B must be read by an application role in account A. A resource policy has been added to the secret permitting the role. Requests still fail with AccessDenied.
>
> The secret is encrypted with the default aws/secretsmanager key.

What is the cause?

A The role in account A needs secretsmanager:CreateSecret

B A secret encrypted with the default AWS managed key cannot be shared cross-account. Use a customer managed key

C The secret must be replicated into account A

D Cross-account access to Secrets Manager is not supported

◆ PAUSE AND DECIDE

What is the cause?

A Needs CreateSecret

Reading a secret needs GetSecretValue. CreateSecret makes new ones and would not help.

B Default managed key blocks cross-account

A secret is always encrypted, so reading it requires decrypt on the key. AWS managed key policies cannot be edited to permit another account.

C Replicate the secret

Replication puts a copy in another Region, not another account. It does not address cross-account access at all.

D Not supported

Fully supported, via a resource policy on the secret plus permission on a customer managed key.

THE SIGNAL

Anything encrypted needs the key checked too. A secret that might ever be read cross-account must use a customer managed key from the start.

> An organisation must guarantee that IMDSv2 is required on every EC2 instance in every account, now and in future. A previous attempt used an SCP denying RunInstances without the correct metadata options, and new launch paths and new APIs repeatedly bypassed the wording.
>
> New accounts join the organisation most weeks.

What should the organisation use?

A. A more comprehensive SCP covering every launch API

B. An AWS Config rule with automatic remediation

C. A declarative policy setting instance metadata defaults across the organisation

D. A CloudFormation Hook rejecting non-compliant templates

◆ PAUSE AND DECIDE

What should the organisation use?

A A better SCP

The approach that already failed, written more carefully. It still enumerates calls, so a future API needs another policy update.

B Config rule with remediation

Detective then corrective. Non-compliant instances exist before being fixed, which the requirement does not accept.

C Declarative policy

Declares the setting's value rather than denying calls, and is maintained as the service adds new APIs and as accounts join.

D CloudFormation Hook

Preventive, and only for resources created through CloudFormation. Console and CLI launches bypass it entirely.

THE SIGNAL

The scenario states the failure mode of enumeration: new APIs slip past. That is exactly the gap declarative policies were built to close.

A security team must guarantee that no resource in any VPC across the organisation can be reached from the internet. A small number of documented exceptions are allowed. Route tables and security groups are managed by many application teams, and new accounts are created weekly.

Outbound internet access through NAT gateways must continue to work.

What should the team implement?

A An SCP denying ec2:CreateRoute for internet gateway destinations

B A Config rule detecting route tables with an internet gateway route

C Delete all internet gateways in all accounts

D VPC Block Public Access in Block Ingress mode with exclusions, deployed as a declarative policy

◆ PAUSE AND DECIDE

What should the team implement?

A Deny CreateRoute

Stops new routes and does nothing about routes that already exist. It also blocks the documented exceptions entirely.

B Config rule

Detective. It reports a publicly reachable resource after it exists, and the requirement is that none can be reached.

C Delete internet gateways

Breaks every NAT gateway and every legitimate outbound path, which the final sentence explicitly forbids.

D Block Public Access, Block Ingress, declarative

Overrides route tables and security groups directly, exclusions cover the documented cases, and a declarative policy covers accounts created later.

THE SIGNAL

Block Ingress is the mode that matters: inbound is blocked while NAT and egress-only gateways keep working, which the last sentence requires.

A new application server cannot connect to a database. It has never worked once. The environment spans two VPCs joined by peering, with several security groups, custom network ACLs and route tables owned by different teams. An engineer has spent two hours reading configuration.

VPC Flow Logs are not currently enabled.

What is the most efficient next step?

A Enable VPC Flow Logs and look for REJECT records

B Temporarily open all security groups to 0.0.0.0/0 to isolate the layer

C Run Reachability Analyzer between the application instance and the database, and read the blocking component it names

D Enable Traffic Mirroring on the application instance

◆ PAUSE AND DECIDE

What is the most efficient next step?

A Flow logs for REJECT

Useful, and it shows only the first blocking point that generates a record. A missing route produces no REJECT at all.

B Open everything temporarily

The genuinely dangerous answer. It creates a real exposure, and if the cause is routing it changes nothing while you believe you tested it.

C Reachability Analyzer

Never worked means configuration. The analyzer evaluates the whole path across both VPCs and names the blocking component in seconds.

D Traffic Mirroring

Captures packet contents on a path that is not passing packets. There is nothing to mirror.

THE SIGNAL

"It has never worked" means configuration. Flow logs are for things that used to work, or work sometimes.

> An internet-facing Application Load Balancer sits behind CloudFront. A WAF rule on the ALB blocks any request lacking a secret custom header that CloudFront adds. A security review objects that the ALB remains publicly reachable and that the header has not been rotated in two years.
>
> The application must remain behind CloudFront.

What should the team implement?

A Rotate the custom header automatically with a Lambda function

B Make the ALB internal and configure it as a CloudFront VPC origin

C Attach an Origin Access Control to the ALB

D Restrict the ALB's security group to CloudFront's published IP ranges

◆ PAUSE AND DECIDE

What should the team implement?

A Rotate the header

Genuinely improves the existing design, and the ALB stays publicly reachable. It fixes the stale secret, not the exposure.

B Internal ALB as a VPC origin

Removes the public endpoint entirely. The ALB has no public address, so there is nothing to reach and no secret to protect.

C OAC on the ALB

Origin Access Control signs requests to S3 origins. It does not apply to a load balancer.

D CloudFront IP ranges

The subtle one. Those ranges admit every CloudFront distribution in the world, including someone else's pointed at your ALB.

THE SIGNAL

Option D is why the secret header pattern existed in the first place. VPC origins remove the public endpoint rather than guarding it.

> A team creates a private hosted zone for example.com and associates it with a VPC. Instances resolve app.example.com internally, as intended. They can no longer resolve mail.example.com, a public record the team does not manage in the private zone.
>
> External systems resolve mail.example.com normally.

What is the cause and the fix?

A. The private hosted zone is authoritative for the whole domain inside the VPC. Add the missing records to it

B. enableDnsHostnames is disabled on the VPC

C. Add a Resolver forwarding rule pointing at the public zone

D. The VPC needs an outbound Resolver endpoint

◆ PAUSE AND DECIDE

What is the cause and the fix?

A The private zone is authoritative for the whole domain

Inside an associated VPC the private zone answers for example.com entirely. Names not defined in it do not resolve, even if they exist publicly.

B enableDnsHostnames disabled

Would prevent the private zone working at all. app.example.com resolves correctly, so the attribute is enabled.

C Forward to the public zone

Resolver forwarding rules send queries to DNS servers you specify. There is no mechanism to fall through from a private zone to a public one.

D Outbound endpoint

Sends queries to on-premises DNS servers. The missing record is on the public internet, which the resolver already reaches.

THE SIGNAL

Overlaying a private zone on a public domain is a decision to own every name in it. There is no fall-through, and that surprises people.

What this set was testing

- **Five questions turned on a stated belief being wrong**: the X-Ray SDK, ARC readiness check, on-demand throttling, KMS annual rotation, and CloudTrail Event history.
- **Three questions had an answer voiced by a character** - an engineer or architect recommending something. Treat a quoted recommendation as a hypothesis to test.
- **Two questions split a requirement in half** deliberately, so the answer needed two mechanisms rather than one.
- **One question offered a genuinely dangerous option**: opening every security group to isolate a fault. It creates real exposure and proves nothing.

> ON THE EXAM
>
> If you missed several of the first group, module 33 is your revision. If you missed the character-voiced ones, re-read module 35 on distractor patterns.

MODULE 39 · EXAM STRATEGY - ALL DOMAINS

Practice Exam 4

The last twenty. Mixed difficulty, weighted as before, with the trickiest distractors of the four sets.

QUESTIONS 20 SUGGESTED TIME 40 minutes PASS GUIDE 14 of 20

admin@sthithapragna.com

A security team must forward a filtered subset of CloudWatch log events to a third-party SIEM in near real time, and separately must place a complete daily copy of the same log group into S3 for long-term archive.

The SIEM ingests from Amazon Data Firehose.

What should the team configure?

A Two export tasks to S3, one of which the SIEM reads

B A subscription filter to Firehose for the SIEM, and a scheduled export task to S3 for the archive

C A subscription filter to S3, and Logs Insights queries for the SIEM

D A metric filter for the SIEM and a subscription filter for the archive

◆ PAUSE AND DECIDE

What should the team configure?

A. Two export tasks

Export tasks are bulk and batch, taking up to twelve hours to complete. Nothing about them is near real time.

B. Subscription filter plus export task

Two requirements with opposite shapes: continuous filtered streaming is a subscription filter; a complete periodic copy is an export task.

C. Subscription to S3, Insights for SIEM

Inverts both halves. Logs Insights is an interactive query tool and cannot push to a SIEM continuously.

D. Metric filter for the SIEM

A metric filter produces a numeric metric, not log events. The SIEM needs the events themselves.

THE SIGNAL

Streaming versus bulk copy. A subscription filter is continuous and filtered; an export task is periodic and complete.

> An operations team receives roughly forty alarm notifications during any single database failover, because dozens of dependent service alarms fire at once. They want one notification describing the underlying problem, while keeping the individual alarms visible on dashboards.
>
> They do not want to delete or disable any existing alarm.

What should the team implement?

A Increase the evaluation periods on all dependent alarms

B An alarm mute rule covering the failover window

C Delete the dependent alarms and keep only the database alarm

D A composite alarm whose rule suppresses child alarms when the database alarm is in ALARM, notifying only on the composite

◆ PAUSE AND DECIDE

What should the team implement?

A Longer evaluation periods

Delays every alarm equally, so you still get forty notifications, merely later. It also slows genuine detection.

B A mute rule

Suppresses by calendar, for known windows such as maintenance. A failover is unplanned, so there is no window to schedule.

C Delete the dependents

Explicitly ruled out, and it destroys the per-service visibility the team wants on dashboards.

D Composite alarm with suppression

Suppresses by logic rather than by calendar: children stay defined and visible, and only the composite notifies.

THE SIGNAL

Composite alarms suppress by logic; mute rules suppress by calendar. A failover is unplanned, so only one of those applies.

> An investigator must run ad hoc queries across three years of CloudTrail logs stored in S3. Those must be joined against a separate S3 dataset of employee identifiers. Queries will run a few times a month, with no infrastructure to manage.
>
> CloudTrail Lake is not in use.

What should the team use?

A Amazon Athena over the CloudTrail S3 data, partitioned by date

B CloudWatch Logs Insights over a log group containing the trail

C Onboard to CloudTrail Lake for its query engine

D Load the logs into an Amazon Redshift cluster

◆ PAUSE AND DECIDE

What should the team use?

A Athena over S3

Serverless, charged per terabyte scanned, and it joins across separate S3 datasets natively. Partitioning by date limits what each query scans.

B Logs Insights

Queries CloudWatch log groups, not S3. Retaining three years in a log group would also be far more expensive than S3.

C CloudTrail Lake

Closed to new customers on 31 May 2026, and the scenario confirms it is not in use. The team cannot onboard.

D Redshift

A cluster to manage and pay for continuously, for queries running a few times a month. The opposite of the stated requirement.

THE SIGNAL

Three years, in S3, joined against another dataset, a few times a month. Every clause points at Athena, and one clause closes the door on Lake.

> An operations team must automate a recovery runbook that stops an EC2 instance, detaches an EBS volume, snapshots it, attaches a replacement volume, and starts the instance again. Some steps must wait for the previous one to reach a given state, and the whole thing must be auditable.
>
> The instance may be unresponsive when the runbook runs.

What should the team use?

A Run Command with a shell script performing the sequence

B A State Manager association applying the steps on a schedule

C An SSM Automation runbook, which acts on AWS resources through APIs and supports waits between steps

D A Session Manager session with the commands typed manually

◆ PAUSE AND DECIDE

What should the team use?

A Run Command

Runs commands inside the operating system, which requires a responsive instance and cannot stop or start the instance it runs on.

B State Manager

Maintains a desired state continuously on a schedule. This is a one-off ordered sequence, not a state to enforce.

C Automation runbook

Automation acts on AWS resources through APIs, so it works on a stopped or unresponsive instance, and it supports waits and branching between steps.

D Manual session

Not automation at all, and it requires the instance to be responsive, which the scenario says it may not be.

THE SIGNAL

Automation acts on the AWS resource; Run Command acts inside the operating system. An unresponsive instance settles it immediately.

An ECS service on Fargate must send application logs to both CloudWatch Logs and a third-party observability platform. Some log lines must be filtered out before leaving the container, configured in the task definition rather than in application code.

The application writes to stdout.

What should the team use?

A The awslogs driver, configured with a filter pattern

B FireLens with a Fluent Bit sidecar, routing to both destinations with filtering

C A CloudWatch subscription filter on the log group

D The CloudWatch agent as a sidecar container

◆ PAUSE AND DECIDE

What should the team use?

A awslogs driver

Sends stdout to one CloudWatch log group. It supports no filtering and no second destination.

B FireLens with Fluent Bit

Configured in the task definition, routes to multiple destinations simultaneously, and filters or transforms before the logs leave the task.

C Subscription filter

Would fan out after the logs reach CloudWatch, so you still pay to ingest everything and nothing is filtered before leaving the container.

D CloudWatch agent sidecar

Collects metrics and logs from a host or files. It is not the ECS log routing mechanism, and FireLens exists for this.

THE SIGNAL

awslogs is one destination, no filtering. FireLens is many destinations, with filtering, configured in the task definition.

> An Auto Scaling group must respond differently depending on severity: a modest queue backlog should add two instances, while a severe backlog should add ten immediately. The team currently uses target tracking on queue depth per instance and finds it too slow to react to the severe case.
>
> Both thresholds are well understood from historical data.

What should the team configure?

A. A second target tracking policy with a lower target value

B. Predictive scaling in ForecastAndScale mode

C. Step scaling with two steps, adding 2 instances at the modest threshold and 10 at the severe one

D. A scheduled scaling action sized for the severe case

◆ PAUSE AND DECIDE

What should the team configure?

A Second target tracking policy

Target tracking aims at one value and works out the adjustment itself. Two policies compete; neither expresses different responses to different severities.

B Predictive scaling

Forecasts recurring patterns. A backlog spike driven by severity is not a time-of-day pattern, and predictive only scales out.

C Step scaling with two steps

Step scaling exists precisely to give different adjustments at different breach magnitudes. Two known thresholds map onto two steps.

D Scheduled action

Scales at a fixed time regardless of load. The trigger here is severity, not the clock.

THE SIGNAL

Target tracking answers "keep this number here". Step scaling answers "if it is this bad do this, if it is much worse do more".

> Users of an application behind an Application Load Balancer intermittently receive HTTP 502 responses. The target group shows all targets healthy, and the application logs show the affected requests being processed and returning a response.
>
> The application recently began returning a very large custom header on some responses.

What is the most likely cause?

A The target returned a malformed or oversized response the load balancer could not parse

B No healthy targets were registered at that moment

C The target did not respond within the idle timeout

D The deregistration delay is too short

◆ PAUSE AND DECIDE

What is the most likely cause?

A Malformed or oversized response

502 means the load balancer received something it could not parse. An oversized header exceeding the ALB's limit produces exactly this.

B No healthy targets

That produces 503, and the scenario states all targets are healthy.

C Idle timeout exceeded

That produces 504. The logs show the requests completing and returning a response, so nothing timed out.

D Deregistration delay

Governs draining for removed targets. It does not cause a parse failure on a live response.

THE SIGNAL

502 answered badly, 503 nobody answered, 504 not in time. The oversized header is the clue that something was answered, and answered wrongly.

> A global application must survive the loss of an entire Region. The recovery point objective is about one second, and the recovery time objective is under one minute. The database is Aurora PostgreSQL and reads must be served locally in three Regions.
>
> Cost is secondary to the targets.

What should the team implement?

A. A cross-Region Aurora read replica promoted manually on failure

B. Automated snapshots copied cross-Region every 15 minutes

C. Aurora Multi-AZ in three Availability Zones

D. An Aurora global database with secondary Regions, using managed failover

◆ PAUSE AND DECIDE

What should the team implement?

A Cross-Region replica, manual promotion

Closer, and manual promotion cannot reliably meet a one-minute RTO, and it does not provide the managed multi-Region model described.

B Snapshots every 15 minutes

An RPO of fifteen minutes at best, against a requirement of about one second. Off by three orders of magnitude.

C Multi-AZ

Protects against the loss of an Availability Zone, not a Region. The requirement is explicitly Regional.

D Aurora global database

Built for this: typical sub-second replication lag, secondary Regions serving local reads, and managed failover measured in well under a minute.

THE SIGNAL

Multi-AZ is zone-level and a global database is Region-level. The one-second RPO alone eliminates anything snapshot-based.

> A regulator requires that backup copies of financial systems cannot be deleted early for seven years. That explicitly includes the account root user and anyone at AWS. The team uses AWS Backup.
>
> A 72-hour cooling-off period before the lock takes effect is acceptable.

What should the team configure?

A. A backup vault with an IAM policy denying delete operations

B. AWS Backup Vault Lock in compliance mode

C. AWS Backup Vault Lock in governance mode

D. Cross-Region copies of every recovery point

◆ PAUSE AND DECIDE

What should the team configure?

A IAM policy denying deletes

Whoever can write IAM policies can rewrite this one. A policy cannot bind the people who control policies.

B Vault Lock compliance mode

Once the cooling-off period elapses the lock is immutable: not the root user, not AWS, nobody can shorten retention or delete early.

C Governance mode

Designed to be removable by a principal with sufficient permissions. The requirement says nobody, which rules it out.

D Cross-Region copies

Protects against a Regional event. It does nothing to prevent early deletion, and a deletion could apply to copies too.

THE SIGNAL

"Including the root user" appears again, and here it extends to AWS itself. The 72-hour cooling-off period is the tell for compliance mode.

> A networking team owns a stack exporting a VPC ID and subnet IDs. Six application stacks, owned by different teams, import those values. The networking team now needs to replace the VPC, and CloudFormation refuses to delete or modify the exported outputs.
>
> Application teams deploy on their own schedules.

What explains this, and what is the better long-term pattern?

A Exports can be changed at any time; the error is unrelated

B Convert the six application stacks into nested stacks of the networking stack

C An export cannot be modified or deleted while another stack imports it. Consider SSM Parameter Store for values crossing ownership boundaries

D Delete all six application stacks first, then recreate them

◆ PAUSE AND DECIDE

What explains this, and what is the better long-term pattern?

A Exports are freely changeable

They are not. That rigidity is the entire point of the mechanism and the cause of the error.

B Nested stacks

Nested stacks share one lifecycle under one owner. Here six teams deploy independently, which is exactly when nesting is wrong.

C Locked while imported; use Parameter Store

An export is deliberately immutable while imported. A Parameter Store parameter is read at deploy time and creates no such lock.

D Delete all six stacks

Would work and requires coordinated downtime across six teams. It also does nothing to prevent a repeat.

THE SIGNAL

Exports are a hard dependency by design. That is a feature when you want protection and a problem when ownership boundaries differ.

A platform team maintains infrastructure that differs per environment: production has three Availability Zones and read replicas, staging has two AZs and none, and development has one. The team currently maintains three near-identical CloudFormation templates that drift apart.

They want the environment differences expressed as logic, with type checking and unit tests.

What should the team adopt?

A The AWS CDK, synthesising CloudFormation from code with per-environment logic

B One CloudFormation template with many Conditions and nested Fn::If expressions

C Three separate StackSets, one per environment

D Terraform with three workspaces

◆ PAUSE AND DECIDE

What should the team adopt?

A The AWS CDK

Loops, conditionals, type checking and unit tests in a real language, synthesising to CloudFormation. Named in exam guide skill 3.1 alongside CloudFormation.

B Conditions and Fn::If

Possible and rapidly unreadable. Conditions express choices, not logic, and there is no type checking or unit testing.

C Three StackSets

StackSets deploy one template to many targets. They do not express per-environment structural differences.

D Terraform workspaces

A reasonable alternative, and it adds a second toolchain and state management for a team already invested in CloudFormation.

THE SIGNAL

"Expressed as logic, with type checking and unit tests" is the CDK clause. Conditions are choices; the CDK gives you a programming language.

A company must be able to run its containerised platform from a second Region within 30 minutes. EKS cluster definitions are in code and the data layer replicates continuously. During a recovery test the cluster came up correctly but every pod failed with ImagePullBackOff.

All container images are stored in ECR in the primary Region only.

What should the company implement?

A ECR pull through cache in the recovery Region, configured against the primary Region's registry

B Enhanced scanning on the ECR repositories

C An ECR lifecycle policy retaining more image versions

D ECR cross-Region replication rules, so images exist in the recovery Region

◆ PAUSE AND DECIDE

What should the company implement?

A Pull through cache from the primary

The tempting one. A cache populates on first pull from an upstream source, and in a Regional failure that source is the Region that has failed.

B Enhanced scanning

Improves vulnerability detection. It does not place an image in another Region.

C Longer retention

Keeps more versions in the primary Region, which is the Region that is unavailable.

D Cross-Region replication

Images are copied to the recovery Region automatically and continuously, so they are already there when the primary Region is not.

THE SIGNAL

DR tests fail on the things that are not data. The cluster was fine, the data replicated, and there were no images.

> A nightly job must process about 500,000 records held in S3. Each record takes roughly two seconds and records are independent. The current implementation is a single Lambda function that loops and repeatedly hits the 15-minute timeout. The team needs per-record error handling and a report of which records failed.
>
> No servers are to be introduced.

What should the team use?

A Increase the Lambda timeout beyond 15 minutes

B An EC2 instance running the job as a script

C A Step Functions Distributed Map reading from S3, with Retry and Catch on the child workflow

D An SQS queue with one message per record and a Lambda consumer

◆ PAUSE AND DECIDE

What should the team use?

A Longer timeout

Fifteen minutes is Lambda's hard maximum and cannot be raised. 500,000 records at two seconds each is over eleven days serially anyway.

B An EC2 instance

Introduces a server, which the requirement forbids, and it runs serially unless you write the concurrency yourself.

C Distributed Map with Retry and Catch

Reads the dataset from S3, fans out across thousands of parallel child executions, and gives declarative per-record retry, catch and reporting.

D SQS with one message per record

A reasonable design that does parallelise the work. Per-record failure reporting means building it yourself from the DLQ.

THE SIGNAL

The arithmetic settles it before any service knowledge: 500,000 records at two seconds is over eleven days of serial work.

A role in account A must read objects from a bucket in account B. The bucket policy in account B allows s3:GetObject for that role's ARN. The role in account A has no S3 permissions at all in its identity policy. Requests fail with AccessDenied.

Both accounts are in the same organisation and there are no SCPs.

What must change?

A Nothing; a resource policy naming the principal is sufficient

B Add s3:GetObject on that bucket to the role's identity policy in account A

C Add account B to the role's trust policy

D Enable Block Public Access on the bucket

◆ PAUSE AND DECIDE

What must change?

A **Nothing needed**

True within a single account, and false across two. That single-account exception is exactly what makes this trip people up.

B **Grant it in the identity policy too**

Cross-account access is an AND. The bucket policy permits it, and the calling identity must independently be permitted to attempt it.

C **Change the trust policy**

Trust policies govern who may assume the role. Nobody is assuming anything; the role is calling S3 directly.

D **Block Public Access**

Governs public access. Nothing here is public, and enabling it would not grant anything.

THE SIGNAL

Cross-account is an AND, not an OR. Being in the same organisation changes nothing about that rule.

> An auditor requires evidence that 60 accounts comply with the CIS AWS Foundations Benchmark. That means automatic remediation where possible, and a single report of non-compliant resources. The team will not maintain the individual rules by hand.
>
> AWS Config is enabled everywhere and a delegated administrator is in place.

What should the team implement?

A. A Config conformance pack based on the CIS sample template, deployed organisation-wide, with a Config aggregator for reporting

B. Individual Config rules deployed to every account by a StackSet

C. GuardDuty enabled organisation-wide

D. Trusted Advisor security checks across the organisation

◆ PAUSE AND DECIDE

What should the team implement?

A CIS conformance pack plus aggregator

A sample pack is the standard as one deployable unit, remediation is included, and the aggregator gives the single cross-account report.

B Individual rules via StackSet

Achieves the same outcome and is exactly the hand-maintained rule set the requirement rules out. Conformance packs exist to replace this.

C GuardDuty

Detects malicious behaviour. It evaluates no configuration and maps to no compliance benchmark.

D Trusted Advisor

A useful fixed set of checks. It does not implement a named benchmark or give per-resource compliance evidence.

THE SIGNAL

A named standard, across every account, without maintaining rules by hand, is precisely what conformance packs were built for.

A security team wants GuardDuty enabled across the organisation. A network engineer objects that the cost will be prohibitive. He believes GuardDuty requires VPC Flow Logs and DNS query logging enabled and retained in every VPC, which the company does not do.

The team wants to understand the actual dependency.

What is correct?

A The engineer is right; flow logs must be enabled and retained first

B GuardDuty replaces the need for flow logs entirely for all purposes

C GuardDuty needs only CloudTrail; it does not use flow logs or DNS logs

D GuardDuty consumes CloudTrail, VPC Flow Logs and Route 53 DNS logs independently. You need not enable or pay for those logs yourself

◆ PAUSE AND DECIDE

What is correct?

A The engineer is right

A very common belief and wrong. GuardDuty's access to these sources is independent of any flow log configuration you create.

B GuardDuty replaces flow logs

Overstates it in the other direction. You may still want your own flow logs for troubleshooting and traffic analysis.

C CloudTrail only

Understates the foundational sources. Flow logs and DNS query logs are both used, alongside CloudTrail management events.

D Consumed independently

GuardDuty reads these sources directly, whether or not you have enabled them, and you are not charged for that consumption.

THE SIGNAL

GuardDuty reads flow logs even if you have never enabled VPC Flow Logs. That independence surprises people, and it is a cost argument in questions.

A company's NAT gateway charges have grown substantially. Analysis shows about 85 percent of the processed traffic is instances in private subnets reading from and writing to S3 and DynamoDB in the same Region. Instances must remain in private subnets.

The team wants the cheapest correct fix.

What should the team implement?

A Gateway VPC endpoints for S3 and DynamoDB, with routes added to the private subnets' route tables

B Interface endpoints for S3 and DynamoDB

C A second NAT gateway to spread the load

D Move the instances to public subnets with public IPs

◆ PAUSE AND DECIDE

What should the team implement?

A Gateway endpoints

Gateway endpoints exist for exactly these two services, are completely free, and remove 85 percent of the volume from the NAT gateway.

B Interface endpoints

Would work and costs per AZ per hour plus per GB. For S3 and DynamoDB specifically, the free gateway endpoint is the better answer.

C A second NAT gateway

Doubles the hourly charge and processes the same total volume. It increases cost.

D Public subnets

Violates the stated constraint, exposes the instances, and incurs per-hour public IPv4 charges for every one of them.

THE SIGNAL

Gateway endpoints exist for S3 and DynamoDB only, and they are free. That makes this the highest-value networking cost answer on the exam.

> Traffic between two VPCs attached to a Transit Gateway is inspected by stateful firewall appliances. Those sit in an inspection VPC, spread across three Availability Zones. Connections succeed most of the time and fail intermittently.
>
> The appliances log packets arriving for sessions they never opened.

What is the cause?

A. A missing route propagation in a Transit Gateway route table

B. Appliance mode is not enabled on the inspection VPC's Transit Gateway attachment

C. Security group referencing support is not enabled on the attachment

D. The appliances are undersized and dropping packets under load

◆ PAUSE AND DECIDE

What is the cause?

A Missing propagation

Would break connectivity consistently, not intermittently. The scenario says most connections succeed.

B Appliance mode not enabled

Without it the Transit Gateway may send the return path through a different AZ, so a stateful appliance receives a packet for a session it never opened.

C SG referencing support

A real Transit Gateway setting, and it would cause consistent denial for group-referencing rules, not asymmetric flows.

D Undersized appliances

The log message names sessions never opened, not exhausted resources. Capacity shows as drops under load, not orphaned packets.

THE SIGNAL

"Packets for sessions they never opened" is the asymmetric-routing signature. Intermittent rather than consistent points at path selection.

> A security team must stop workloads in 50 VPCs resolving known malware and command-and-control domains. They must also detect data exfiltration hidden inside DNS queries. The same policy must apply automatically to VPCs created later.
>
> Route 53 Resolver is in use throughout.

What should they implement?

A. A custom DNS Firewall domain list associated with each VPC

B. AWS Network Firewall in each VPC

C. Security group rules denying outbound port 53

D. DNS Firewall rule groups using AWS Managed Domain Lists and advanced threat detection, bundled into a Route 53 Profile shared through RAM

◆ PAUSE AND DECIDE

What should they implement?

A. Custom lists per VPC

Exactly the hand-maintained lists ruled out, associated 50 times, and a list can never catch tunnelling or generated domains.

B. Network Firewall

Inspects packets after a name has resolved. Useful alongside, and it does not stop the lookup or apply automatically to new VPCs.

C. Block outbound 53

Breaks all DNS resolution, since instances query the VPC resolver. It would take every workload offline.

D. Managed lists plus advanced detection, in a Profile

Managed lists remove the maintenance, advanced detection catches tunnelling no list contains, and a shared Profile covers VPCs created later.

THE SIGNAL

Three requirements: no manual lists, detect tunnelling, cover future VPCs. Managed lists, advanced detection and a Profile map onto one each.

A company has 90 branch offices and a large remote workforce, all of which must resolve names in Route 53 private hosted zones. Today each site runs a DNS server forwarding to Resolver inbound endpoints in two Regions, and the team maintains failover configuration at every site.

Remote workers have changing IP addresses and cannot be covered by source-IP rules.

What should the company consider?

A Inbound Resolver endpoints in more Regions

B Making the private hosted zones public

C Route 53 Global Resolver, using Access Sources for the offices and Access Tokens for remote workers

D A Route 53 Profile shared to each branch office

◆ PAUSE AND DECIDE

What should the company consider?

A More inbound endpoints

More of the thing causing the burden. Every site still needs forwarding and failover configuration maintained by hand.

B Make the zones public

Publishes internal DNS records to the entire internet, which is a serious disclosure of internal architecture.

C Global Resolver with both authorisation methods

Anycast addresses remove per-site failover configuration, Access Sources cover fixed-IP offices, and Access Tokens cover clients whose addresses change.

D A Profile per office

Profiles associate with VPCs. There is no way to associate one with a branch office network.

THE SIGNAL

The remote-worker clause is decisive: changing IPs cannot be authorised by source range, and Access Tokens exist precisely for that case.

You have finished the course

- **Four practice exams, 80 questions**, on top of 172 worked scenarios in the modules. Compare your domain breakdown across all four.
- **A domain weak in two or more sets** is where your remaining time belongs. A single bad set is noise.
- **Re-watch module 33 and drill module 34** in the final week. Those two carry the highest value per minute at that stage.
- **Review what you got right by luck** as carefully as what you missed. Luck does not repeat on the day.

> ON THE EXAM
>
> 130 minutes, 65 questions, no labs. Read the stem before the options, and the last sentence of every scenario twice. Good luck.